

Cirque ISMS Manual

Master Manual — ISO/IEC 27001:2022 and SOC 2:2017 (Security and Confidentiality)

Cirque Corporation — IT/Security

2026-05-08

Table of Contents

About This Manual

This is the master Information Security Management System (ISMS) manual for Cirque Corporation. It is the **single source of truth** for all ISMS documents — policies, procedures, registers, and forms. All future edits are made to this master document; the previously separate per-document files have been archived.

Standards alignment. This manual implements the requirements of **ISO/IEC 27001:2022** (Information Security Management Systems) and the **AICPA Trust Services Criteria for SOC 2:2017**, Security and Confidentiality categories. Availability, Processing Integrity, and Privacy categories are out of scope for the current SOC 2 Type 1 audit cycle.

Document control. Maintenance of this manual follows IS-AMR04-CIRQ01-A00 (Documented Information Control Policy) and IS-AMR04-CIRQ02-A00 (Document Control Procedure). Each section retains its original document ID (IS-CIRQ-...) and version metadata. The master manual itself is versioned independently:

Master version

Effective date

Summary of change

1.0

2026-05-08

Initial consolidated manual. Combines all per-document IS-CIRQ-*.md sources, applies SOC 2 mapping, geographic-scope corrections, and the Lenovo CAR-2026-001 remediation.

Owner: Chris Wren, IT Manager / ISMS Owner **Approver:** Executive Committee **Audit window:** SOC 2 Type 1 — April 1 to June 30, 2026

Part I — Governance and Framework

IS-APM01-CIRQ01-A00: Information Security Policy (Master Policy)

IS-APM01-CIRQ01-A00: Information Security Policy (Master Policy)

Document ID: IS-APM01-CIRQ01-A00 **Document Title:** Information Security Policy (Master Policy) **Category:** Base Policy & ISMS Manual **Division:** Policy **Document Type:** Global **Version:** 2.0 **Effective Date:** 2026-05-08 **Review Date:** 2027-05-08 **Owner:** IT Manager (Chris Wren) **Approved By:** CEO and IT Manager (see signature block at Section 10)

Change history (v1.0 → v2.0): Added explicit alignment with the AICPA Trust Services Criteria for SOC 2:2017 (Security and Confidentiality); corrected geographic scope (removed Japan reference); added SOC 2 mapping table (Section 7); added policy exception process (Section 8); added document change-history table; added named approver signature block.

1. Introduction

Cirque Corporation is an innovative engineering design and technology manufacturing company committed to protecting its information assets to ensure business continuity, minimize business damage, and maximize return on investments and business opportunities. Information, in all its forms, is a critical asset for Cirque's manufacturing operations, intellectual property, customer relations, and regulatory compliance.

This Information Security Policy establishes the overarching principles and commitment of Cirque's management to information security. It forms the foundation for the Information Security Management System (ISMS) and aligns the ISMS with both:

ISO/IEC 27001:2022 (Information Security Management Systems — Requirements), and

AICPA Trust Services Criteria for SOC 2:2017 — Security (CC1.1 through CC9.2) and Confidentiality (C1.1 and C1.2) categories.

By upholding this policy, Cirque aims to **enable innovative manufacturing, ensure product quality, and maintain customer trust.**

2. Purpose

The purpose of this policy is to:

State Cirque's commitment to information security and to the AICPA Trust Services Criteria for Security and Confidentiality.

Define the objectives of information security within Cirque.

Provide a framework for establishing and achieving information security objectives.

Ensure compliance with relevant legal, regulatory, and contractual obligations.

Protect information assets from all threats, whether internal or external, deliberate or accidental.

3. Scope

This policy applies to all information, information processing facilities, information systems, networks, applications, services, and personnel within Cirque, including employees, contractors, and approved third parties who access Cirque's information assets at the physical and remote locations defined in IS-APM02-CIRQ01-A01A (ISMS Scope Document):

Sandy, Utah, USA (HQ and production)

Taipei, Taiwan (Sales and operations office)

Cirque has no operations or workforce in Japan; previous references to Japan have been corrected.

4. Information Security Objectives

Cirque is committed to:

Maintaining the confidentiality, integrity, and availability of all information assets.

Protecting intellectual property, including manufacturing designs, processes, and customer data.

Ensuring the security of operational technology (OT) systems used in manufacturing processes.

Complying with all applicable legal, regulatory, and contractual requirements related to information security, including data protection laws in regions where Cirque operates (e.g., the United States — including the Utah Consumer Privacy Act — and Taiwan PDPA, and applicable laws covering remote workers in China).

Implementing a robust risk management framework to identify, assess, and treat information security risks.

Promoting information security awareness and competence among all personnel, including required annual training and acknowledgment of this policy.

Detecting, responding to, and recovering from information security incidents in line with the Incident Response Procedure (IS-AMG01-CIRQ02-A00), with the goal of preventing material data breaches.

Enhancing supply cha

IS-APM02-CIRQ01-A01A: ISMS Scope Document

IS-APM02-CIRQ01-A01A: ISMS Scope Document

Document ID: IS-APM02-CIRQ01-A01A **Document Title:** ISMS Scope Document **Category:** Base Policy & ISMS Manual **Division:** Document **Document Type:** Global **Version:** 2.0 **Effective Date:** 2026-05-08 **Review Date:** 2027-05-08 **Approved By:** Executive Committee **Owner:** IT Manager (Chris Wren)

Change history (v1.1 → v2.0): SOC 2:2017 Trust Services Criteria added to scope framing; geographic scope corrected (Sandy, UT HQ + Taipei, Taiwan + remote workers in China and other approved locations); explicit confirmation that no operations exist in Japan; SOC 2 Type 1 audit context added.

1. Introduction

This document defines the scope of Cirque Corporation's Information Security Management System (ISMS) in accordance with **ISO/IEC 27001:2022** and the **AICPA Trust Services Criteria (TSC) for SOC 2:2017** (Security and Confidentiality categories). It details the organizational units, physical locations, information assets, technologies, and processes that are included within the ISMS, along with any justified exclusions.

This scope statement is the authoritative basis for the SOC 2 Type 1 audit covering the period **April 1, 2026 through June 30, 2026**.

2. Context of the Organization

This ISMS scope has been determined considering:

Internal Issues: Cirque Corporation's organizational structure, strategic direction, existing IT infrastructure, manufacturing processes, critical intellectual property assets (e.g., designs, formulas, production methods, **Hardware Engineering designs, Firmware Engineering code, Software Engineering code, and ASIC development specifications**), customer data, and current operational technology (OT) environment.

External Issues: Applicable laws and regulations (e.g., data privacy regulations like CCPA, UCPA, PIPL, Cybersecurity Law, Taiwan PDPA), industry standards, contractual obligations, technological landscape, and market demands.

3. Frameworks Addressed by This ISMS

The Cirque ISMS is designed to satisfy the requirements of the following frameworks:

Framework

Standard / Source

In-Scope Categories

ISO/IEC 27001:2022

ISO/IEC 27001:2022 with Annex A controls

All clauses 4–10 and applicable Annex A controls

SOC 2:2017

AICPA Trust Services Criteria (TSP section 100)

Security (CC1.1–CC9.2) and Confidentiality (C1.1–C1.2)

SOC 2 categories explicitly out of scope for the current audit: Availability (A1.x), Processing Integrity (PI1.x), and Privacy (P1.x–P8.x). These categories may be added in a future audit cycle.

4. Interested Parties and Their Requirements

The requirements of relevant interested parties, as documented in IS-AMR06-CIRQ01-F01A: Interested Parties and Their Requirements Register, have been considered in defining this ISMS scope. These include, but are not limited to, customers in the United States and Taiwan, regulatory bodies, supply chain partners, employees, and the SOC 2 audit firm.

5. ISMS Boundaries and Applicability

The ISMS at Cirque Corporation covers the information security aspects of the following:

5.1 Organizational Units / Functions

All departments and functions directly involved in or supporting the processing, storage, or transmission of Cirque Corporation's information assets, including:

Executive Management

Information Technology (IT) Department

Sales & Marketing

Hardware Engineering

Firmware Engineering

Software Engineering

ASIC Development

Confidential — Cirque Corporation Internal

Manufacturing Operations (information related to production planning, quality control, inventory, and intellectual property)

Finance & Accounting

Human Resources (HR)

Customer Service

Research & Development (R&D)

5.2 Physical Locations

Main Headquarters and Production Facility: 9883 S 500 W, Sandy, Utah, USA

Includes: office spaces, server rooms, manufacturing floors (information systems and data on these floors).

Sales and Operations Office: 8 F., No. 87, Songjiang Rd., Zhongshan Dist., Taipei City 104495, Taiwan

Includes: office spaces, local IT infrastructure.

Authorized Remote Work Locations: Home offices and temporary remote work sites for Cirque Corporation employees and approved contractors located in the United States, Taiwan, China (no physical office; remote workers only), and other locations approved under IS-AHR01-CIRQ03-A00 (Remote Work Policy). Remote workers access Cirque information assets through company-managed devices and approved network paths.

Note on Japan: Cirque Corporation has no offices, employees, or remote workers in Japan. Earlier document revisions referenced Japan in error; all such references have been corrected.

5.3 Information Assets

All information, in both physical and digital forms, owned by or in the custody of Cirque Corporation. This includes, but is not limited to:

Customer Data (e.g., contact information, order history, payment details)

Employee Data (e.g., personal details, payroll information, HR records)

Financial Data (e.g., accounting records, budgets, invoices)

Intellectual Property (e.g., product designs, manufacturing processes, R&D data, patents, trade secrets, **CAD files, schematics, source code for firmware and software, ASIC design specifications, test data, and intellectual property related to innovative manufacturing techniques**)

Proprietary Business Information (e.g., strategic plans, marketing materials, sales data)

Operational Data (e.g., production schedules, quality control data, inventory records, supply chain information, **machine calibration data, production efficiency metrics**)

System Configuration and Log Data

5.4 Technologies and Systems

All information technology infrastructure, including:

Servers (physical and virtual)

Network devices (routers, switches, firewalls, wireless access points)

Workstations, laptops, mobile devices

Business applications (e.g., ERP, CRM, HRIS, CAD/CAM systems, **design software, simulation tools, code repositories**)

Email systems and collaboration platforms

Data storage systems (on-premise and cloud)

Note: While no specific Operational Technology (OT) assets are currently identified as requiring direct inclusion within the ISO 27001 / SOC 2 ISMS scope, information systems that interact with or manage data from OT environments (e.g., production planning systems, quality control databases) are included. The ISMS is structured to allow for the future integration of specific OT controls as deemed necessary by risk assessment.

5.5 Processes

All business processes that involve the creation, processing, storage, transmission, or disposal of Cirque Corporation's information assets. This includes, but is not limited to:

Product Design and Development (including **Hardware, Firmware, Software, and ASIC design lifecycles**)

Manufacturing Planning and Execution

Sales and Order Fulfillment

Customer Relationship Management

Human Resources Management

Financial Operations

Information Technology Management and Support

Supplier Management (**including sharing design specificatio

IS-APM02-CIRQ02-A00: ISMS Scope Definition Procedure

IS-APM02-CIRQ02-A00: ISMS Scope Definition Procedure

Document: IS-APM02-CIRQ02-A00

Standards Name: ISMS Scope Definition Procedure

Category: Base Policy & ISMS Manual

Division: Procedure

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.1 **Effective Date:** July 2025 **Review Date:** July 2026 **Approved By:** [IT Department Head / Information Security Manager]

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC1.3

CC2.1

Information used to support functioning of internal control

The purpose of this procedure is to define the process for establishing and maintaining the scope of Cirque's Information Security Management System (ISMS) in accordance with ISO/IEC 27001:2022 Clause 4.3. A clearly defined scope ensures that all relevant information assets, processes, and locations are included, and that the ISMS effectively supports Cirque's business objectives.

2. Scope

This procedure applies to all activities involved in defining, documenting, and reviewing the ISMS scope, including relevant internal and external issues, interested parties' requirements, and interfaces with Cirque's manufacturing and business functions.

3. Responsibilities

- **Executive Committee:** Provides ultimate approval for the ISMS scope.
- **IT Department / Information Security Manager (ISM):** Responsible for leading the scope definition process, documenting the scope, and ensuring its review and communication. Also responsible for maintaining the ISMS Scope Document.
- **Department Heads/Process Owners:** Provide input regarding their respective areas, information assets, and processes that fall within or interface with the ISMS scope.

4. Procedure

4.1. Identify Internal and External Issues (ISO 27001 Clause 4.1) a. The IT Department / ISM will identify and analyze internal and external issues relevant to Cirque's purpose and its ability to achieve the intended outcomes of the ISMS. This includes: * **Internal Issues:** Organizational culture, capabilities (e.g., resources, knowledge), governance structure, information technology infrastructure, manufacturing processes, operational technology (OT) systems (even if not currently in scope, their potential future inclusion is considered), and proprietary information like designs and customer data. * **External Issues:** Legal and regulatory requirements (e.g., data privacy laws like CCPA, APPI, PIPL, state data breach notification laws), technological advancements, competitive landscape, market conditions, and societal expectations. b. The analysis of these issues will inform the boundaries and applicability of the ISMS.

4.2. Identify Interested Parties and Their Requirements (ISO 27001 Clause 4.2) a. The IT Department / ISM will identify internal and external interested parties relevant to the ISMS. This includes, but is not limited to: * **Internal:** Employees, management, the Executive Committee, internal audit. * **External:** Customers (including those in Taiwan and China (remote workers)), suppliers, regulators, investors, partners, local communities, law enforcement, and auditors. b. The IT Department / ISM will determine the information security requirements of these interested parties that are relevant to the ISMS. This may involve reviewing contracts, regulations, and industry best practices. c. Document identified interested parties and their requirements in IS-AMR06-CIRQ01-F01A: Interested Parties and Their Requirements Register.

4.3. Determine ISMS Boundaries and Applicability (ISO 27001 Clause 4.3) a. Based on the analysis from sections 4.1 and 4.2, the IT Department / ISM, in consultation with relevant department heads, will define the physical and logical boundaries of the ISMS. This includes: * **Organizational Units:** Which departments, teams, or business functions are included (e.g., specific manufacturing functions, R&D, Sales, IT, Finance, HR). * **Physical Locations:** Which buildings, sites, or geographic regions are covered. Initially, this includes: * Main Headquarters and Production Facility, Sandy, Utah, USA. * Sales and Operations Office, Taipei, Taiwan. * Business operations and relationships with entities in China (remote workers). * **Information Assets:** Which types of information (e.g., customer data, intellectual property, financial data, employee data, manufacturing designs, raw material specifications) and associated IT assets (e.g., servers, workstations, network devices, business applications, cloud services) are within scope. * **Technologies:** Which IT systems, networks, and applications are included. While no specific OT assets are currently integrated into the ISMS scope, the ISMS is designed to be extensible to include them should they become information-security-critical. * **Processes:** Which business and manufacturing processes

Confidential — Cirque Corporation Internal
generating, processing, or storing information are covered by the ISMS (e.g., customer order processing, product design, financial reporting, employee onboarding, IT support). b. Any exclusions from the scope must be justified and documented, ensuring they do not compromise the confidentiality, integrity, or availability of information critical to Cirque's core business functions. c. The ISMS scope must be clearly documented in the IS-APM02-CIRQ01-A01A: ISMS Scope Document.

4.4. ISMS Scope Review and Approval a. The proposed ISMS scope documented in IS-APM02-CIRQ01-A01A will be reviewed by the IT Department / ISM and relevant stakeholders. b. The ISMS scope must be formally approved by the **Executive Committee**. c. Any changes to the ISMS scope must follow this procedure and be formally re-approved by the Executive Committee.

5. Related Documents

- IS-APM02-CIRQ01-A01A: ISMS Scope Document
- IS-AMR06-CIRQ01-F01A: Interested Parties and Their Requirements Register
- IS-AMR01-CIRQ01-F01A: Legal, Regulatory, and Contractual Requirements Register

IS-AMR06-CIRQ01-F01A: Interested Parties and Their Requirements Register

IS-AMR06-CIRQ01-F01A: Interested Parties and Their Requirements Register

Document: IS-AMR06-CIRQ01-F01A

Standards Name: Interested Parties and Their Requirements Register

Category: Base Policy & ISMS Manual

Division: Document

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.2 **Effective Date:** 2026-05-08 **Review Date:** 2027-05-08 **Approved By:** Executive Committee
(sponsored by IT Manager / ISMS Owner)

Change history (v1.1 → v1.2): Added entry 2.11 for Lenovo as a named Trusted Supplier Program customer with annual security questionnaire requirements (per CAR-2026-001). Replaced "APPI" with "Taiwan PDPA, China PIPL" in 2.1 to reflect actual customer geographies (Cirque has no Japan operations).

1. Purpose

This register identifies the internal and external interested parties relevant to Cirque Corporation's Information Security Management System (ISMS) and documents their information security requirements. Understanding these requirements is crucial for defining the ISMS scope, establishing objectives, and ensuring the ISMS effectively meets stakeholder expectations in accordance with ISO/IEC 27001:2022 Clause 4.2.

2. Scope

This document applies to all identified interested parties whose requirements or expectations may impact, or be impacted by, Cirque Corporation's information security posture.

3. Interested Parties and Their Information Security Requirements

No. Interested Party Type Relevant Information How Requirements

(Internal/External) Security are

Requirements/Expectations Met/Considered in

ISMS

1 Internal

1.1 Executive Internal Strategic direction for ISMS Policy, Committee information security; Objectives, Resource allocation; Management Compliance with Review, Risk legal/regulatory Management, obligations; Protection of Compliance intellectual property; Controls. Business continuity.

1.2 Employees Internal Clear information security Access Control policies and procedures; Policy, AUP, Secure access to necessary Training & information; Protection of Awareness, HR personal data; Awareness Security, Privacy training; Safe and secure Policy. working environment.

1.3 IT Department Internal Secure and reliable IT Operations infrastructure (Local Security, Servers); Effective Incident incident response; Data Management, backup and recovery Backup & (Veeam); Vulnerability Restoration management; Efficient Procedures, security tools. Vulnerability Management.

1.4 Hardware Internal Confidentiality and Secure Engineering integrity of product Development, designs, schematics, and Access Control, test data; Secure IP Protection, development environment; Data Protection of intellectual Classification, property; Secure use of Secure Use of design tools (e.g., Software. Cadence).

1.5 Firmware Internal Confidentiality and Secure Engineering integrity of source code Development, (e.g., in GitLab); Secure Access Control, development environment; IP Protection, Code integrity; Protection Code Review, of intellectual property; Secure Use of Secure use of development Software. tools (e.g., Visual Studio).

1.6 Software Internal Confidentiality and Secure Engineering integrity of source code Development, (e.g., in GitLab); Secure Access Control, development environment; IP Protection, Application security; Application Protection of intellectual Security Testing, property; Secure use of Secure Use of development tools (e.g., Software. Visual Studio).

1.7 ASIC Development Internal Confidentiality and Secure integrity of ASIC designs Development, and specifications; Secure Access Control, development environment; IP Protection, Protection of intellectual Design Review, property; Secure use of Secure Use of ASIC design tools (e.g., Software. Cadence).

1.8 Manufacturing Internal Availability of production Operations Operations systems; Integrity of Security, production data (e.g., Business machine calibration, Continuity, Data quality control); Integrity Protection of manufacturing Controls, processes/recipes; Secure Physical operational technology (OT) Security. interfaces.

1.9 Sales & Internal Confidentiality of customer Customer Data Marketing sales information; Protection, Availability of sales Access Control, systems (e.g., QuickBooks Data data); Integrity of Classification, marketing materials; Financial Data Protection of sales Protection. strategies.

1.10 Finance & Internal Confidentiality and Financial Data Accounting integrity of financial data Protection, (e.g., QuickBooks data); Access Control, Compliance with financial Compliance regulations; Secure Controls. transaction processing.

1.11 Human Resources Internal Confidentiality of employee Employee Data (HR) personal data; Compliance Protection, with labor laws; Secure HR Access Control, systems. HR Security, Privacy Policy.

1.12 Customer Service Internal Confidentiality of customer Customer Data inquiries and data; Protection, Availability of support Access Control, systems; Secure Secure communication channels. Communication.

1.13 Internal Audit Internal Independent verification of Internal Audit ISMS effectiveness; Access Procedure, to ISMS documentation and Management records. Review.

2 External

2.1 Customers External Confidentiality of their Customer Data (Global, data (**including highly Protection, including US, confidential CAD drawings Privacy Policy, Taiwan, and sales information**)); Contractual China) Integrity of Agreements, products/services; Product Security, Availability of services; Compliance Compliance with data Controls, Data protection laws (e.g., Classification. CCPA/CPRA, UCPA, Taiwan PDPA, China PIPL).

2.2 Suppliers / External Confidentiality of Cirque Supplier Security Third Parties Corporation's intellectual Review Procedure, property and business data Contractual shared (e.g., design specs, Agreements, production schedules); Access Control, Secure handling of shared Data information; Compliance Classification. with Cirque

Confidential — Cirque Corporation Internal
Corporation's
security requirements.

2.3 Regulators & External Compliance with applicable Legal, Government laws and regulations (e.g., Regulatory, and Authorities data privacy, Contractual (e.g., FTC, cybersecurity, Requirements State AGs, METI, industry-specific); Register, Cyberspace Reporting of incidents (if Compliance Administration required). Policy, Incident of China, Taiwan Response. authorities)

2.4 Investors / External Protection of company Risk Management, Shareholders value; Transparency in risk Management management; Compliance with Review, governance requirements. Compliance Controls.

2.5 Partners (e.g., External Secure information sharing; Contractual joint venture, Mutual data protection; Agreements, technology Compliance with partnership Information partners) agreements. Sharing Policy (if separate), Access Control.

2.6 Auditors External Access to ISMS Document Control, (Certification documentation and evidence; Internal Audit, Body) Verification of ISO 27001 Management compliance. Review.

2.7 Local External Responsible data handling; Ethical Communities Ethical conduct; Minimizing Guidelines, negative impact from Incident incidents. Response.

2.8 Law Enforcement External Cooperation in Legal Compliance, investigations; Legal Incident requests for data. Response.

2.9 Software Vendors External Timely security patches and Patch Management, (e.g., Cadence, updates; Secure software by Secure SolidWorks, design; Clear licensing Development Visual Studio) terms. Lifecycle (for internal development), Software Acquisition Procedure.

2.10 Service External Data confidentiality, Supplier Security Providers (e.g., integrity, and Review, Veeam, availability; Compliance Contractual QuickBooks with data protection laws; Agreements, Due Online) Service level agreements Diligence for (SLAs) re

IS-AMR01-CIRQ01-F01A: Legal, Regulatory, and Contractual Requirements Register (Global Core)

IS-AMR01-CIRQ01-F01A: Legal, Regulatory, and Contractual Requirements Register (Global Core)

Document: IS-AMR01-CIRQ01-F01A

Standards Name: Legal, Regulatory, and Contractual Requirements Register (Global Core)

Category: Information Management Regulations

Division: Document

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 Effective Date: June 2025 Review Date: June 2026 Approved By: IT Department / Information Security Manager

1. Purpose

This register identifies and documents universally applicable legal, regulatory, and contractual requirements related to information security for Cirque's global operations. Compliance with these requirements is a fundamental aspect of Cirque's Information Security Management System (ISMS) in accordance with ISO/IEC 27001:2022 Clause 4.2. Specific regional requirements are detailed in localized registers (e.g., IS-AMR01-CIRQ01-F02A, IS-CIRQ-D-003-JP, IS-CIRQ-D-003-CN).

2. Scope

This document applies to all Cirque's global operations, processes, and information assets that are subject to international legal and ethical norms concerning information security.

3. Identified Requirements and Compliance Methods

No.

Requirement Type (Legal/Regulatory/Contractual)

Source/Law/Regulation/Contract

Description of Requirement (Info Security relevance)

Affected ISMS Control/Process

Compliance Status

Notes/Compliance Evidence

A

Legal/Regulatory Requirements (Global Norms)

A.1

International Data Protection Principles

Global Norms / ISO 27001 Annex A.18.1.1

Adherence to generally accepted principles of data protection, privacy, and cybersecurity across international borders, including lawful processing, data minimization, purpose limitation, accuracy, storage limitation, integrity and confidentiality, and accountability.

Privacy Policy, Data Classification, Access Control, Risk Assessment, Incident Response, Compliance Controls.

Compliant

Commitment stated in ISMS policies; specific implementation per localized registers.

A.2

Intellectual Property Rights Protection (General)

International IP Law Norms / WIPO

Protection of intellectual property (e.g., designs, patents, trade secrets) from unauthorized access, use, modification, or disclosure globally.

Confidential — Cirque Corporation Internal
IP Protection Policy, Data Classification, Access Control, Secure Development Lifecycle, Confidentiality Agreements.

Compliant

Internal policies and controls; contractual clauses.

B

Contractual Requirements (Global)

B.1

General Confidentiality Agreements (NDAs)

Standard NDAs

Protect confidential information exchanged with international partners, suppliers, and customers.

Contract Review, Information Transfer Policy, Access Control, Employee Training.

Compliant

Standard legal review process for agreements.

4. Review and Update

This register will be reviewed at least annually, or when significant changes occur to relevant international laws, widely adopted industry standards, or new international agreements impacting [Company Name]. Updates will be approved by the IT Department / Information Security Manager. Legal counsel will be consulted as necessary to ensure accuracy and completeness.

IS-AMR01-CIRQ01-F02A: Legal, Regulatory, and Contractual Requirements Register (US Localized)

IS-AMR01-CIRQ01-F02A: Legal, Regulatory, and Contractual Requirements Register (US Localized)

Document: IS-AMR01-CIRQ01-F02A

Standards Name: Legal, Regulatory, and Contractual Requirements Register (US Localized)

Category: Information Management Regulations

Division: Document

Standard Retention: Exist and No Corrections

Standard Type: Localized

Version: 1.0 Effective Date: June 2025 Review Date: June 2026 Approved By: IT Department / Information Security Manager

1. Purpose

This register identifies and documents all applicable legal, regulatory, and contractual requirements related to information security for Cirque's operations within the United States. Compliance with these requirements is a

Confidential — Cirque Corporation Internal
fundamental aspect of Cirque's Information Security Management System (ISMS) in accordance with ISO/IEC 27001:2022 Clause 4.2.

2. Scope

This document applies to all Cirque's operations, processes, and information assets within the United States, including data pertaining to US residents and business conducted in US states.

3. Identified Requirements and Compliance Methods

No.	Requirement Type	Source/Law/Regulation/Contract	Description of Affected ISMS	Compliance Notes/Compliance
-----	------------------	--------------------------------	------------------------------	-----------------------------

	Requirement (Info Control/Process Status Evidence			
--	---	--	--	--

	Security			
--	----------	--	--	--

	relevance)			
--	------------	--	--	--

A Legal/Regulatory Requirements

A.1	California Data	California Law Requires Incident Response Compliant Breach Breach Notification businesses to Procedure, Data notification plan Law (e.g., Civ. Code notify California Classification, in Incident Section 1798.82)	residents of Legal & Response; annual security breaches Compliance review of involving Review. applicable laws. unencrypted personal information "in the most expedient time possible and without unreasonable delay." Also requires notification to the CA Attorney General for breaches affecting over 500 residents.	
-----	-----------------	--	---	--

A.2	Washington Data	Washington Law Requires Incident Response Compliant Breach Breach Notification notification to Procedure, Data notification plan Law (RCW affected Classification, in Incident 19.255.010)	Washington Legal & Response; annual residents within Compliance review of 30 days of Review. applicable laws. discovery of a breach involving personal information (name + specified data elements), and to the WA Attorney General if affecting over 500 residents.	
-----	-----------------	--	--	--

A.3	Texas Identity	Texas Law Requires Incident Response Compliant Breach Theft Enforcement businesses to Procedure, Data notification plan and Protection Act notify affected Classification, in		
-----	----------------	---	--	--

Incident (ITEPA, Bus. & Com. Texas residents Legal & Response; annual Code Section 521.053) and the TX Compliance review of Attorney General Review. applicable laws. (for 250+ residents) of data breaches involving "sensitive personal information" without unreasonable delay, and not later than 30 days after discovery for AG notification.

A.4 Privacy Laws California Law For qualifying Privacy Policy, Compliant Privacy notice; (e.g., California businesses, grants Data Subject internal Consumer Privacy consumers rights Request procedures for Act - CCPA) over their Procedure, Data handling data personal Classification, subject requests. information, Access Control.

including access, deletion, and opt-out rights. Requires reasonable security procedures for PII.

B Contractual Requirements

B.1 Customer Contract: [Customer Name] Contract Requires Cirque to Third-Party SOC 2 In Progress Engagement with SOC 2 Compliance achieve and Project Plan, third-party maintain SOC 2 Risk Management, auditor; compliance for Internal Audit, continuous control relevant Control monitoring. services/systems Implementation.

(specifically for data related to their highly confidential CAD drawings and sales information).

B.2 General Customer / Various Customer/Partner Adherence to Contract Review Compliant Contract review Partner Contracts Agreements specific Procedure, process; security confidentiality Information controls clauses, data Transfer Policy, implemented as per protection terms, Access Control. agreements. and security standards as mutually agreed upon in contracts.

4. Review and Update

This register will be reviewed at least annually, or when significant changes occur to US federal or state laws, regulations, or new contracts are signed. Updates will be approved by the IT Department / Information Security Manager. Legal counsel will be consulted as necessary to ensure accuracy and completeness.

IS-AMR01-CIRQ01-F03A: Legal, Regulatory, and Contractual Requirements Register (Asia Localized)

IS-AMR01-CIRQ01-F03A: Legal, Regulatory, and Contractual Requirements Register (Asia Localized)

Standards Name: Legal, Regulatory, and Contractual Requirements Register (Asia Localized)

Category: Information Management Regulations

Division: Document

Standard Retention: Exist and No Corrections

Standard Type: Localized (Asia)

Version: 1.0 **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** Legal Department, Executive Committee

1. Purpose

The purpose of this register is to document and maintain a comprehensive record of all applicable legal, regulatory, and contractual requirements related to information security and privacy that Cirque Corporation must comply with in its Asia operations, specifically focusing on China. This register serves as a central reference to ensure ongoing compliance, facilitate risk management, and support the Information Security Management System (ISMS). This document combines and supersedes IS-CIRO-D-003-JP and IS-CIRO-D-003-CN.

2. Scope

This register applies to all Cirque Corporation entities, processes, and systems operating within China (remote workers) that handle, process, store, or transmit information. It covers all legal acts, governmental regulations, industry-specific requirements, and contractual obligations that mandate specific information security and privacy controls or practices.

3. Roles and Responsibilities

- **Legal Department:** Responsible for identifying, interpreting, and updating legal and regulatory requirements for Asia.
- **ISMS Owner (e.g., Information Security Officer/IT Manager):** Responsible for ensuring that the ISMS addresses the requirements listed in this register and that controls are implemented to achieve compliance.
- **Relevant Department Heads/Process Owners:** Responsible for understanding and ensuring compliance with requirements applicable to their respective areas.
- **Compliance Team:** (If applicable) Responsible for monitoring and reporting on compliance status.

4. Register of Legal, Regulatory, and Contractual Requirements (Asia Localized - China + Taiwan)

This section details the identified requirements. Each entry includes relevant information to facilitate understanding and compliance.

4.1. Taiwan Requirements (PDPA)

Ref.	ID	Requirement	Source/Regulation	Relevant	Summary of Applicable	Owner for Compliance	Last Review
1	1	1	1	1	1	1	1

Type**	Name**	Clause/Article**	Requirement	Cirque Corporation Compliance**	Status	Date**

(Information ISMS Control(s) / (Y/N/Partial)**

Security/Privacy Process(es)**

Focus)**

Confidential — Cirque Corporation Internal

JP-001 Legal Act on the Protection Art. 20 (Security Obligation to take IS-APM01-CIRQ01-A00 ISMS Owner, IT [Y/N/P] [DD-MM-YYYY] of Personal Measures) necessary and (InfoSec Policy), Dept. Information (APPI) appropriate measures IS-AAR01-CIRQ03-A00 for the secure (Data Protection), management of IS-AIR01-CIRQ09-A00 personal data, (Logging & including prevention Monitoring) of leakage, loss, or damage.

JP-002 Legal APPI Art. 26 (Record of When providing IS-AAR01-CIRQ03-A00 Legal, Data [Y/N/P] [DD-MM-YYYY] Provision) personal data to a (Data Protection), Owner third party, records IS-AFR01-CIRQ01-A00 of provision must be (Info Transfer made. Policy)

JP-003 Regulatory Telecommunications Art. 4 (Secrecy of Obligation to ensure IS-AIR01-CIRQ02-A00 IT Dept., [Y/N/P] [DD-MM-YYYY] Business Act Communications) the secrecy of (Network Legal communications Security), handled by IS-LMR-CIRQ02-A00 telecommunications (Comms Security) carriers.

JP-004 Contractual [Specific Customer Data Protection Requirements for IS-AIR01-CIRQ02-A00 Contract [Y/N/P] [DD-MM-YYYY] Contract Name] Clause data encryption at (Cryptography Owner, IT rest and in transit. Policy), Dept. IS-AAR01-CIRQ03-A00 (Data Protection)

(Add more rows as needed for Taiwan/PRC specific requirements)

4.2. China Requirements

Ref. ID
Requirement Type
Source/Regulation Name
Relevant Clause/Article
Summary of Requirement (Information Security/Privacy Focus)
Applicable Cirque Corporation ISMS Control(s) / Process(es)
Owner for Compliance

Last Review Date

CN-001

Legal

Cybersecurity Law of the People's Republic of China (CSL)

Art. 21 (Network Operator Security Obligations)

Network operators must implement hierarchical protection for networks, take technical measures, ensure data integrity, confidentiality, and availability.

IS-APM01-CIRQ01-A00 (InfoSec Policy), IS-AIR01-CIRQ10-A00 (Network Security Management), IS-AIR01-CIRQ09-A00 (Logging & Monitoring)

IT Dept., I Owner

SMS [Y/N/P]

[DD-MM-YYYY]

CN-002

Legal

Personal Information Protection Law (PIPL)

Art. 4 (Consent)

Personal information handlers must obtain individuals' consent before processing their personal information, with exceptions.

IS-AAR02-CIRQ01-A00 (Privacy Policy - Global), IS-AAR06-CIRQ01-A00 (Privacy Policy - Asia)

Legal, HR, Data Owner

[Y/N/P]

[DD-MM-YYYY]

CN-003

Legal

PIPL

Art. 39 (Cross-Border Transfer)

Strict requirements for cross-border transfer of personal information, including security assessments or certification.

IS-AFR01-CIRQ01-A00 (Information Transfer Policy), Legal review

Legal, IT Dept.

[Y/N/P]

[DD-MM-YYYY]

CN-004

Regulatory

All

Detailed requirements for security assessments, including self-assessment and government assessment, for certain cross-border data transfers.

IS-AFR01-CIRQ01-A00 (Information Transfer Policy), Legal review

Legal, IT Dept.

[Y/N/P]

[DD-MM-YYYY]

(Add more rows as needed for China specific requirements)

5. Compliance Management

5.1. Identification of Requirements: a. The Legal Department, in conjunction with the ISMS Owner, is responsible for continuous monitoring of changes in legal, regulatory, and contractual requirements in China (remote workers). b. Information about new or amended requirements shall be communicated to relevant stakeholders.

5.2. Assessment of Impact: a. Upon identification of new or changed requirements, an assessment shall be conducted to determine their impact on Cirque Corporation's ISMS, operations, and information assets. b. This assessment will identify any gaps between current controls and the new requirements.

5.3. Implementation of Controls: a. Where gaps are identified, the ISMS Owner and relevant process owners shall develop and implement necessary controls or adjustments to existing controls to ensure compliance. b. These actions may result in updates to policies, procedures, or technical configurations.

5.4. Regular Review and Update: a. This register shall be formally reviewed and updated by the Legal Department and ISMS Owner at least **annually**, or whenever significant changes in legal, regulatory, or contractual landscapes occur in China. b. The updated register shall be presented as an input to the management review (IS-LMG-CIRQ04-A00).

5.5. Record Keeping: a. Records of this register, including previous versions and review dates, shall be maintained as documented information.

6. Related Documents

- IS-APM01-CIRQ01-A00: Information Security Policy
- IS-AAR01-CIRQ01-A00: Data Protection Policy
- IS-AAR01-CIRQ03-A00: Data Protection Procedure
- IS-AFR01-CIRQ01-A00: Information Transfer Policy

- IS-AAR02-CIRQ01-A00: Privacy Policy (Global Core)
- IS-AAR06-CIRQ01-A00: Privacy Policy (Asia Localized) (if created)
- IS-LMR-CIRQ03-A00: Management Review Policy
- IS-LMG-CIRQ04-A00: Management Review Procedure

7. Policy Review

This register and its associated management process will be reviewed at least annually, or sooner if there are significant changes to applicable laws, regulations, or contractual obligations in China.

IS-AMR04-CIRQ01-A00: Documented Information Control Policy

IS-AMR04-CIRQ01-A00: Documented Information Control Policy

Document: IS-AMR04-CIRQ01-A00

Standards Name: Documented Information Control Policy

Category: ISMS Support Process

Division: Policy

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** Executive Committee

1. Purpose

SOC 2 Trust Services Criteria Mapping

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC2.1

Information used to support the functioning of internal control is identified, captured, and used

CC5.3

Deploys policies and procedures that put control activities into action

C1.1

Identifies and maintains confidential information

The purpose of this policy is to establish Cirque's requirements for controlling all documented information related to its Information Security Management System (ISMS). This policy addresses ISO/IEC 27001:2022 Clause 7.5, ensuring that ISMS documents are properly created, updated, distributed, stored, and retained to maintain the integrity, availability, and confidentiality of information vital to the ISMS.

2. Scope

This policy applies to all documented information required by the ISMS standard (ISO 27001:2022) or deemed necessary for the effectiveness of the ISMS. This includes, but is not limited to, policies, procedures, work instructions, forms, templates, records, and external documents of relevance (e.g., legal and regulatory requirements, contractual agreements). This policy covers documented information in all formats (e.g., electronic, hard copy).

3. Principles of Document Control

Cirque shall ensure that documented information is:

- **Available and Suitable:** Available where and when it is needed, and suitable for use.
- **Protected:** Adequately protected from loss of confidentiality, improper use, or loss of integrity.
- **Controlled:** Managed through a systematic process covering creation, update, distribution, retention, and disposition.

4. Requirements for Documented Information

Cirque's documented information shall be controlled to ensure:

4.1. Identification and Description: a. Each document shall be clearly identified (e.g., unique ID, title, date, author, version number). b. The document's purpose and content shall be clearly described.

4.2. Format and Media: a. Documented information shall be presented in a suitable format and on appropriate media (e.g., paper, electronic).

4.3. Review and Approval for Suitability and Adequacy: a. All documents shall be reviewed and approved by authorized personnel prior to their issuance or update to ensure their suitability and adequacy.

4.4. Availability: a. Documented information shall be available at points of use, to the relevant persons, when and where it is needed.

4.5. Protection: a. Documented information shall be protected against unintended alterations, unauthorized access, loss, damage, or deterioration. b. Access controls will be applied to electronic documents.

4.6. Distribution, Access, Retrieval, and Use: a. There shall be a defined method for the distribution, access, retrieval, and use of documented information.

4.7. Storage and Preservation: a. Documented information shall be stored in a manner that preserves its legibility and integrity, and protects it from damage or deterioration.

4.8. Control of Changes: a. Changes to documented information shall be controlled. This includes ensuring that changes are identified, the current version status is clear, and relevant personnel are aware of the changes.

4.9. Retention and Disposition: a. Documented information shall be retained for a defined period based on legal, regulatory, contractual, and operational requirements. b. A process for the appropriate disposition (archiving or destruction) of documented information shall be defined once its retention period expires.

4.10. Control of External Documents: a. Documents of external origin (e.g., customer contracts, regulatory guidelines, vendor security reports, ISO 27001 standard itself) deemed necessary for the planning and operation of the ISMS shall be identified and controlled. Their distribution and version control will be managed appropriately.

5. Responsibilities

- **IT Manager (ISMS Manager):** Accountable for the overall implementation and adherence to this policy and the associated procedure. Ensures the Document Control Procedure is maintained and followed.
- **Document Owners:** Responsible for the content, accuracy, review, and timely update of the documents they own. They initiate the review and approval process.
- **All Employees and Contractors:** Responsible for adhering to this policy and using the current versions of documented information as required by their roles.

6. Related Document

7. Policy Review

This policy will be reviewed at least annually, or sooner if significant changes occur to Cirque's ISMS, organizational structure, or legal/regulatory requirements regarding documented information.

8. Operational Implementation

The questions originally listed below this section have been resolved and codified as follows:

1. **Document Storage Location:** All controlled ISMS documents (policies, procedures, forms, registers, and records) are stored in the Cirque OneDrive/SharePoint location at Documents/ISMS-MANUAL. The folder is restricted to the IT Manager, the Executive Committee, and authorized reviewers, with read access for all employees who need to consult policies. Strike Graph is used as the SOC 2 control / evidence system of record and references the same source documents.
2. **Versioning System:** Documents follow the naming convention IS-CIRQ-<Type>-<NNN>-<Locale>-<Title>.md with a Version fi

IS-AMR04-CIRQ02-A00: Document Control Procedure

IS-AMR04-CIRQ02-A00: Document Control Procedure

Document: IS-AMR04-CIRQ02-A00

Standards Name: Document Control Procedure

Category: ISMS Support Process

Division: Procedure

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** IT Manager

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC2.1

Information used to support functioning of internal control

CC5.3

Deploys policies and procedures

The purpose of this procedure is to define the systematic process for managing all documented information within Cirque's Information Security Management System (ISMS). This includes creation, review, approval, distribution, control of changes, retention, and disposition, in accordance with IS-AMR04-CIRQ01-A00: Documented Information Control Policy and ISO/IEC 27001:2022 Clause 7.5.

2. Scope

This procedure applies to all documented information created, used, or maintained as part of Cirque's ISMS. This includes, but is not limited to, policies, procedures, forms, templates, records, and relevant external documents, regardless of their format (electronic or hard copy) or storage location (local drives, file servers, SharePoint).

3. Responsibilities

- **IT Manager (ISMS Manager):** Overall accountability for the implementation and maintenance of this procedure. Assigns Document IDs, manages the master document list, controls master copies, and ensures correct versioning.
- **Document Owners:** Individuals or departments responsible for the content accuracy, relevance, periodic review, and initiation of changes for specific documents.
- **Reviewers/Approvers:** Authorized personnel responsible for reviewing and approving documented information before release or modification.
- **All Employees/Contractors:** Responsible for using the current versions of documented information and adhering to documented procedures.

4. Procedure

4.1. Document Creation and Identification a. **Template Use:** All new ISMS documents (policies, procedures, forms) shall be created using the official Cirque ISMS document templates, which include fields for Document ID, Version, Effective Date, Review Date, and Approval. b. **Document ID Assignment:** The IT Manager shall assign a unique Document ID to each new ISMS document. The ID format shall follow the established convention (e.g., IS-APM01-CIRQ01-A00 for Policy, IS-APM02-CIRQ02-A00 for Procedure, IS-LMR-CIRQ01-F01A for Form, IS-APM02-CIRQ01-A01A for Document). c. **Versioning:** The initial version of any new document shall be **v1.0**. Subsequent minor changes will increment the decimal (e.g., v1.1, v1.2), while major revisions (e.g., significant content overhaul, change in scope) will increment the whole number (e.g., v2.0). The version number will be clearly displayed on the document.

4.2. Document Review and Approval a. **Initial Draft:** The Document Owner prepares the initial draft. b. **Internal Review:** The Document Owner distributes the draft to identified reviewers (e.g., relevant department managers, IT personnel) via **email or shared file link** for comments and feedback. c. **Formal Approval:** Once reviews are incorporated and the Document Owner deems the document ready, it is submitted to the designated Approver(s) (as specified in the document header, e.g., IT Manager, Executive Committee) via **email with the document attached or a secure file share link**. d. **Evidence of Approval:** Approval shall be documented via **email confirmation** from the designated Approver(s) or, if utilizing a system, through the system's audit trail. These email approvals shall be retained as a record. e. **Effective Date:** Upon approval, the IT Manager will set the "Effective Date" on the document.

4.3. Document Distribution and Availability a. **Master Copies:** The IT Manager shall maintain the master, approved versions of all ISMS documented information. b. **Official Storage Locations:** Approved ISMS documents shall be centrally stored on the **SharePoint** site designated for ISMS documentation. Copies may also be maintained on the **Fileserver** for redundancy and accessibility for specific teams. c. **Accessibility:** Access to ISMS documents will be managed through SharePoint and file server permissions, ensuring that relevant personnel have read-only access to current versions. Write access is restricted to Document Owners and the IT Manager. d. **Communication of New/Updated Documents:** The IT Manager will communicate the release of new or significantly updated ISMS documents to relevant personnel via **Teams channels and/or email** as per IS-LMG-CIRQ03-A00: ISMS Communication Procedure.

4.4. Control of Changes (Revisions) a. **Change Request:** Any request for a change to an existing ISMS document should be submitted to the Document Owner, ideally via email. b. **Review and Update:** The Document Owner reviews the change request, updates the document, and ensures necessary internal reviews are conducted. c. **Versioning Update:** The Document Owner, in consultation with the IT Manager, assigns the next logical version number (e.g., v1.1 to v1.2, or v1.9 to v2.0). d. **Re-Approval:** All changes to documents (including minor revisions) must undergo the formal approval process (Section 4.2.c-d) by the designated Approver(s). e. **Obsolete Documents:** When a document is superseded by a new version, the previous version shall be clearly marked as

Confidential — Cirque Corporation Internal
"Obsolete" or "Superseded" and retained for historical purposes in a dedicated archive folder. Obsolete documents shall be removed from active use locations to prevent unintended use.

4.5. Retention and Disposition of Documented Information a. **Retention Periods:** Documented information shall be retained for periods as defined in the "Standard Retention" field of each document's header or as specified by legal, regulatory, or contractual requirements. b. **Archiving:** Upon reaching the end of their active lifecycle but still within their retention period, documents may be moved to an archive location (e.g., a dedicated archive folder on SharePoint or file server) to reduce clutter in active repositories. c. **Disposition:** Once the retention period expires, documented information shall be disposed of in a secure and unrecoverable manner (e.g., digital shredding for electronic files, cross-shredding for hard copies). The IT Manager is responsible for coordinating the secure disposition.

4.6. Control of External Documents a. External documents (e.g., ISO 27001 standard, relevant laws, customer security requirements) shall be identified, their relevance determined, and controlled. b. The IT Manager is responsible for ensuring that the most current versions of critical external documents are available and referenced. These documents will be stored on SharePoint or the file server with clear identification as "External Document."

4.7. Alignment with Parent’s IS-AMR04 ISMS Standard Management Regulation

This procedure operates as Cirque’s local equivalent of the parent’s IS-AMR04 Section 7 Management of Standards workflow. The mapping is:

- a. **Standardization Planning (parent Section 7.1).** Cirque’s standardization plans are formulated by the Cirque ISMS Management Officer (IT Manager) acting as the Information Management Committee Secretariat. Triggers for standard creation or revision follow parent’s Table 4 (Scenarios Requiring Standard Revisions): (1) a referenced ISMS standard such as ISO 27001 or 27002 is revised; (2) major flaws are identified through customer audits, incidents, or internal/external audits; (3) major organizational changes; (4) business activity requires standardization; (5) current standards have content that is unfavorable or needs improvement; (6) gap emerges between standards and reality; (7) outside standard, law, or regulation is established, revised, or abolished. Any Cirque department may submit a standardization request to the IT Manager.
- b. **Standard Creation (parent Section 7.2.1).** Cirque standards are created using the format and composition rules in IS-AMR04 Appendix 1, the numbering rules in IS-AMR04 Appendix 2, and the content rules in IS-AMR04 Appendix 3. Information Security Basic Policy (IS-APM01-CIRQ01-A00) and material intended for external disclosure may deviate from those appendices when warranted, and the deviation is recorded in the document’s revision history.

c.	d.	e.	f.
g.	h.	i.	j.
k.	l.	m.	n.
o.	p.	q.	r.
s.	t.	u.	v.
w.	x.	y.	z. Examination and Approval (parent Section 7.2.2 and Table 5). Cirque applies the following authority chain (parent’s Table 5 mapped to Cirque roles):

Standard

Creation by

Approval by

Information Security Basic Policy (IS-APM01-CIRQ01-A00)

Information Management Committee Secretariat (IT Manager)

ISMS Management Officer (IT Manager)

General Manager of Information Management (CEO)

Cirque ISMS Manual (IS-APM02-CIRQ01-A00)

Information Management Committee Secretariat (IT Manager)

ISMS Management Officer after ISMS Council approval

ISMS Management Officer (IT Manager)

Regulations

Department Manager (or person of similar rank) responsible for the standard

ISMS Promotion Officer of responsible department after ISMS Council approval

Department Manager responsible for the standard

Procedures and guidelines

Relevant personnel of responsible department

ISMS Promotion Officer of responsible department

Department Manager responsible for the standard

Forms / Attachments

Relevant personnel of responsible department

ISMS Promotion Officer of responsible department

Department Manager responsible for the standard

A revision date on or later than the standard's date of approval shall be assigned. Approval evidence is retained per Section 4.2.d.

- d. **Management of Standard Registration (parent Section 7.2.3).** The Information Management Committee Secretariat (Cirque IT Manager) maintains the master standards register (the master ISMS Manual TOC) and ensures registration of new and revised standards in Cirque's SharePoint location at Documents/ISMS-MANUAL. The Secretariat posts notices of registration or revision through Microsoft Teams and email per IS-LMG-CIRQ03-A00 (ISMS Communication Procedure). Cirque does not share a SharePoint with the parent; registrations are internal to Cirque. The Secretariat shares the contents and registration information of partially applicable standards with the parent's Secretariat through annual or ad-hoc reporting.
- e. **Acceptance of Standards (parent Section 7.2.4).** Each Cirque department head shall, on receipt of a board notice of registration or revision: (i) determine whether the issued standard is applicable to the department; (ii) check the content if applicable;

ensure the standard is shared and implemented within the department by the standard's effective date.

- f. **Validity of Standards (parent Section 7.2.5).** Standards take effect from the effective date stated in the document header. For revisions and new versions, applicability of old and new versions follows IS-AMR04

Figure 3. The effective date for Cirque partially-applicable standards is set by the Department Manager responsible for standard establishment. The IT Manager, acting as the Cirque ISMS Council, may change the default effective date by an explicit decision recorded in Council minutes.

- g. **Regular Reviews (parent Section 7.3.1).** Cirque reviews each standard at least every three years, even if no changes are needed, and records the review in the revision history. Cirque's stricter internal practice is to review annually (per IS-AMR04-CIRQ01-A00 Section 7); the parent's three-year rule is the floor.
- h. **Other Reviews (parent Section 7.3.2).** Departments raise issues via the Document Change Request Form (IS-AMR04-CIRQ01-F01A) to the responsible Department Manager. Where standards conflict and no obvious mistake exists, the superior standard takes precedence; the parent's company-wide standards take precedence over Cirque partially-applicable equivalents on matters of intent.
- i. **Annulment (parent Section 7.4).** When a Cirque standard is annulled, the responsible Department Manager records the annulment in the revision history; the Secretariat updates the standards register, removes the standard from active SharePoint locations, and clearly marks any Teams-archived copy as annulled.

4.8. Tracking Future Revisions to Parent's Global Standards

The IT Manager (acting as Information Management Committee Secretariat) maintains a Global Standard Revision Tracker (IS-LMR-CIRQ06-F01A — see separate workbook) listing every parent company-wide standard that Cirque has linked or independent equivalents to, the parent's current version, Cirque's equivalent version, the last-checked date, and any action triggered. The tracker is reviewed monthly by the Secretariat and at every Cirque ISMS Council meeting.

5. Review and Update

This procedure will be reviewed at least annually, or sooner if there are changes to IS-AMR04-CIRQ01-A00: Documented Information Control Policy, Cirque's document management tools (e.g., shift to a formal DMS), the parent's IS-AMR04 ISMS Standard Management Regulation, or legal/regulatory requirements.

6. Related Documents

- IS-AMR04-CIRQ01-A00: Documented Information Control Policy
- IS-AMR04 (parent): ISMS Standard Management Regulation
- IS-AMR04-CIRQ01-F01A: Document Change Request Form
- IS-LMR-CIRQ06-F01A: Global Standard Revision Tracker
- IS-LMG-CIRQ03-A00: ISMS Communication Procedure
- All other ISMS policies, procedures, and forms that are subject to this control.

IS-AMR04-CIRQ01-F01A: Document Change Request Form

IS-AMR04-CIRQ01-F01A: Document Change Request Form

Document: IS-AMR04-CIRQ01-F01A

Standards Name: Document Change Request Form

Category: ISMS Support Process

Division: Form

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** IT Manager

1. Purpose

This form is used to formally request a change, update, or revision to any documented information within Cirque's Information Security Management System (ISMS). It ensures that all proposed changes are documented, reviewed, and approved in accordance with IS-AMR04-CIRQ01-A00: Documented Information Control Policy and IS-AMR04-CIRQ02-A00: Document Control Procedure.

2. Scope

This form applies to all ISMS documented information, including policies, procedures, forms, templates, and records, regardless of their format or storage location.

3. Instructions for Use

- Any employee or authorized party can submit this form to request a change to an ISMS document.
- Complete all sections of the form accurately and thoroughly.
- Submit the completed form to the Document Owner of the affected document.
- The Document Owner is responsible for initiating the review and approval process as per IS-AMR04-CIRQ02-A00.

4. Document Change Request Details

Change Request ID: [Assigned by IT Manager/Document Owner, e.g., DCR-2025-001] **Date of Request:** [DD-MM-YYYY]

4.1. Requester Information

- **Name:**
- **Department:**
- **Email:**
- **Phone:**

4.2. Document Information (of the document to be changed)

- **Document Title:**
- **Document ID:**
- **Current Version:**
- **Document Owner:**

4.3. Nature of Change Request

- **Type of Change:** (Select one or more)
 - ☐ Minor Revision (e.g., grammatical correction, minor wording clarification)
 - ☐ Major Revision (e.g., significant content update, new section, policy change)
 - ☐ New Document Creation (if this form is used to initiate a new document)
 - ☐ Document Retirement/Obsolescence
 - ☐ Other (Please specify): _____
- **Reason for Change:** (Explain why the change is needed – e.g., improved clarity, new requirement, audit finding, operational change, risk mitigation)
- **Proposed Changes:** (Clearly describe the specific changes proposed, referencing section numbers, paragraphs, or words to be added/deleted. Attach redlined document or specific examples if possible.)

4.4. Document Owner Review & Action (To be completed by Document Owner)

- **Date Received:** _____
- **Accept/Reject Request:** ☐ Accept ☐ Reject

If Rejected, Reason for Rejection: _____

- **Planned Action (if Accepted):** _____
- **Estimated Completion Date:** _____
- **Document Owner Signature:** _____ **Date:** _____

4.5. Approval of Change (To be completed by designated Approver(s))

- **Approver Name(s):** [e.g., IT Manager, Executive Committee]
- **Review Comments (if any):**

- **Approval Status:** ☐ Approved ☐ Approved with Conditions ☐ Rejected
 - **If Approved with Conditions, Conditions:** _____
 - **If Rejected, Reason for Rejection:** _____
- **Date of Approval/Rejection:** _____
- **Approved New Version (if applicable):** v _____
- **Approved New Effective Date (if applicable):** _____

4.6. Implementation Tracking (To be completed by IT Manager/Document Owner)

- **Date of Implementation:** _____
- **Communication of Change (method & date):** _____
- **Document Archived (Yes/No):** _____
- **Notes:** _____

Part II — Roles, Responsibilities, Competence, and Awareness

IS-AHR01-CIRQ01-A00: Roles, Responsibilities, and Authorities Policy

IS-AHR01-CIRQ01-A00: Roles, Responsibilities, and Authorities Policy

Document: IS-AHR01-CIRQ01-A00

Standards Name: Roles, Responsibilities, and Authorities Policy

Category: Base Policy & ISMS Manual

Division: Policy

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.1 Effective Date: July 2025 Review Date: July 2026 Approved By: Executive Committee

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC1.2

Board / executive oversight of the ISMS

CC1.3

Organizational structure and reporting lines

CC1.4

Competence of personnel assigned to security roles

CC1.5

Accountability for security responsibilities

The purpose of this policy is to define the roles, responsibilities, and authorities for information security management within Cirque, in accordance with ISO/IEC 27001:2022 Clause 5.3. Clearly assigning these responsibilities ensures accountability and effective operation of the Information Security Management System (ISMS).

2. Scope

This policy applies to all personnel within Cirque, including employees, contractors, and relevant external parties, insofar as their roles relate to information security and the operation of the ISMS.

3. Information Security Roles and Responsibilities

Information security is a shared responsibility across Cirque. While the IT Department maintains the ISMS, overall security relies on the active participation of all personnel. Specific roles with defined responsibilities are established as follows:

3.1. Executive Committee / Top Management

- **Responsibility:** Ultimate accountability for the ISMS and information security performance.
- **Authority:**
 - Approve the Information Security Policy and ISMS Scope.
 - Ensure the availability of necessary resources for the ISMS.
 - Communicate the importance of effective information security management.
 - Conduct management reviews of the ISMS.

- Ensure information security objectives are consistent with the strategic direction of Cirque.

3.2. IT Manager (also acts as Information Security Manager)

- **Responsibility:** Overall leadership and management of the ISMS; overseeing its establishment, implementation, maintenance, and continual improvement. **Additionally, serves as the primary "Information Asset Manager," responsible for the overall risk posture and security requirements of Cirque's information assets.**
- **Authority:**
 - Develop, implement, and maintain ISMS policies and procedures.
 - Identify and assess information security risks and recommend treatment options.
 - Manage information security incidents.
 - Coordinate information security awareness and training programs.
 - Report on the performance of the ISMS to the Executive Committee.
 - Act as the primary point of contact for ISMS-related matters (e.g., audits).
 - Ensure compliance with legal, regulatory, and contractual information security requirements.
 - Authorize access to information assets based on documented procedures.

3.3. IT Department Personnel

- **Responsibility:** Implementing and maintaining technical security controls, managing IT infrastructure, and providing technical support for information security.
- **Authority:**
 - Implement and manage network security devices (firewalls, IDS/IPS).
 - Manage user access rights and authentication systems.
 - Perform system hardening and vulnerability management.
 - Conduct data backups and ensure recovery capabilities.
 - Respond to technical security incidents under the direction of the IT Manager.

3.4. Department Managers (e.g., Engineering, Sales, Operations)

- **Responsibility:** Ensuring information security within their respective departments and processes; identifying and protecting information assets under their custody.
- **Authority:**
 - **Decide on and approve the selection and use of software tools and systems within their respective departments.**
 - Support the IT Manager in identifying and assessing information security risks relevant to their operations.
 - Ensure their teams comply with ISMS policies and procedures.
 - Report information security incidents or weaknesses promptly.
 - Provide input on the classification and handling of information assets unique to their department (e.g., CAD drawings in Hardware Engineering, sales data in Sales).

3.5. All Employees and Contractors

- **Responsibility:** Adhering to Cirque's Information Security Policy and all related policies and procedures.
- **Authority:**
 - Protecting information assets they handle from unauthorized access, use, modification, or disclosure.
 - Reporting any actual, suspected, or potential information security incidents or weaknesses.
 - Participating in information security awareness training.
 - Maintaining confidentiality of Cirque's information and customer data.

4. Parent-Aligned Governance Roles (per IS-AMR04 ISMS Standard Management Regulation)

As a group company subject to the parent's IS-AMR04 ISMS Standard Management Regulation, Cirque establishes a management system equivalent to the parent's roles described in Section 6 of that regulation. The parent-aligned roles below are mapped onto Cirque's existing organizational structure. Each Cirque role-holder has the responsibilities and authority of the corresponding parent role for matters within Cirque's scope of application.

4.1. General Manager of Information Management (Cirque)

Cirque role-holder: CEO (or CEO's delegate, where named in writing)

Responsibility: Appoints the Cirque ISMS Management Officer; maintains the Cirque ISMS structure to achieve efficient and effective ISMS operation; equivalent to parent's role (1) in IS-AMR04 Section 6 Table 3.

Authority: Final approval of the Cirque-wide Information Security Basic Policy (IS-APM01-CIRQ01-A00) and the Cirque ISMS Manual (IS-APM02-CIRQ01-A00).

4.2. ISMS Management Officer (Cirque)

Cirque role-holder: IT Manager (Chris Wren)

Responsibility: Holds responsibility and authority relating to Cirque ISMS standard management processes overall; ensures the Cirque ISMS is maintained and operated in an appropriate manner; equivalent to parent's role (2) in IS-AMR04 Section 6 Table 3.

Authority: Approves the Cirque ISMS Manual after Cirque ISMS Council review; convenes and chairs the Cirque Information Management Committee and ISMS Council.

4.3. Information Management Committee Secretariat (Cirque)

Cirque role-holder: IT Manager (acting in this capacity), with administrative support from the Independent Reviewer designated by the Executive Committee.

Responsibility: Equivalent to parent's role (4) in IS-AMR04 Section 6 Table 3. Formulates Cirque-wide standardization plans, coordinates with relevant departments through the ISMS Council, creates and maintains the Cirque master ISMS Manual and the Information Security Basic Policy, administers the ISMS Council, establishes and maintains a framework for utilization of suitable versions of standards, and shares information on the establishment and revision of standards.

4.4. ISMS Promotion Officers (Cirque, per department)

Cirque role-holders: Department Managers (Engineering, Sales, Operations, Manufacturing, Finance, HR, Customer Service)

Responsibility: Equivalent to parent's role (3) in IS-AMR04 Section 6 Table 3. Each Department Manager creates, maintains, and continually improves Cirque standards under their supervision and manages the originals; has authority to examine and approve standards under their supervision; participates in the Cirque ISMS Council as the representative of their functional department.

4.5. ISMS Council (Cirque)

Cirque role-holders: The Executive Committee acts as the Cirque ISMS Council, comprising the Information Management Committee Secretariat and the ISMS Promotion Officers.

Responsibility: Equivalent to parent's role (5) in IS-AMR04 Section 6 Table 3. (a) Checks content validity prior to approval of standards (secondary examination); (b) determines suitable departments responsible for standard establishment based on the standardization plan formulated by the Secretariat.

Cadence: At least quarterly. Standards approval may also be handled in ad-hoc Council meetings.

4.6. Information Management Responsible Person (per Cirque department)

Cirque role-holders: Each Department Manager, or a designated deputy.

Responsibility: Equivalent to parent's role (6) in IS-AMR04 Section 6 Table 3. (a) Creates, maintains, and continually improves partially applicable standards (regulations, procedures, guidelines) supervised by the organizational unit and manages the originals; (b) informs members of the unit about applicable standards and conducts training as required; (c) carries out business affairs in accordance with applicable standards.

4.7. Independent Reviewer

Cirque role-holder: Designated Executive Committee member or contracted external compliance lead, named in writing by the Executive Committee.

Responsibility: Performs independent review of IT-owned controls (access reviews, risk-treatment effectiveness, internal audit) so the IT Manager does not audit IT-owned work; supports SOC 2 CC1.3 segregation of duties.

Authority: Approves residual risk acceptances above the Cirque-wide threshold; signs off on internal audit reports prior to closure of corrective actions.

5. Related Documents

IS-AHR01-CIRQ01-F01A: Information Security Roles Matrix

IS-AMR04 (parent): ISMS Standard Management Regulation

IS-APM01-CIRQ01-A00: Information Security Policy (Master Policy)

IS-APM02-CIRQ01-A00: Cirque ISMS Manual

6. Policy Review

This policy will be reviewed at least annually, or sooner if significant changes occur to Cirque's organizational structure or ISMS responsibilities, or when the parent's IS-AMR04 ISMS Standard Management Regulation is revised.

IS-AHR01-CIRQ01-F01A: Information Security Roles Matrix

IS-AHR01-CIRQ01-F01A: Information Security Roles Matrix

Document: IS-AHR01-CIRQ01-F01A

Standards Name: Information Security Roles Matrix

Category: Base Policy & ISMS Manual

Division: Document

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 **Effective Date:** June 2025 **Review Date:** June 2026 **Approved By:** IT Manager

1. Purpose

This document provides a matrix that outlines the key roles, responsibilities, and authorities related to information security within Cirque's Information Security Management System (ISMS). It serves as a quick reference complementing the IS-AHR01-CIRQ01-A00: Roles, Responsibilities, and Authorities Policy.

2. Scope

This matrix summarizes information security responsibilities across Cirque for all personnel.

3. Roles and Responsibilities Matrix

This matrix uses the following legend for responsibilities:

- **A (Accountable):** The individual or role ultimately answerable for the correct and thorough completion of the deliverable or task. Only one A per task.
- **R (Responsible):** The individual or role who performs the task.
- **C (Consulted):** Those whose opinions are sought, typically subject matter experts. Two-way communication.
-
-
-
-
-
-
- **I (Informed):** Those who are kept up-to-date on progress, but not necessarily involved in decision-making. One-way communication.

ISMS Activity / Area

Executive Committee

IT Manager (ISM/Asset Mgr)

IT Department Personnel

Department Managers (e.g., Eng, Sales, Ops)

All Employees & Contractors

ISMS Governance & Strategy

Approve ISMS Policy

A

C

Confidential — Cirque Corporation Internal
I

I

I

Approve ISMS Scope

A

R

I

C

I

Resource Allocation for ISMS

A

R

I

C

I

Conduct Management Review

A

R

I

C

I

Define ISMS Objectives

A

R

C

C

I

Risk Management

Oversee Risk Management

C
A
R
C
I

Identify & Assess Risks

C
A
R
R
I

Recommend Risk Treatment

I
A
R
C
I

Policy & Procedure Management

Develop & Maintain Policies/Procedures

I
A
R
C
I

Adhere to Policies/Procedures

Confidential — Cirque Corporation Internal

I

I

R

R

A

Information Asset Management

Overall Asset Risk/Security

I

A

R

C

I

Classify & Handle Assets

I

R

R

A

R

Protect Information Assets

I

R

R

R

A

Access Control

Manage User Access

- I
- A
- R
- C
- I

Operational Security

Implement Security Controls

- I
- A
- R
- I
- I

Manage IT Infrastructure Security

- I
- A
- R
- I
- I

Software/Tool Selection & Use

- I
- C
- C
- A

Incident Management

Oversee Incident Response

- C
- A
- R
- I
- I

Report Security Incidents

- I
- R
- R
- R
- A

Compliance & Audit

Ensure Legal/Regulatory Compliance

- A
- R
- C
- C
- I

Support Internal/External Audits

Confidential — Cirque Corporation Internal

I

A

R

C

I

Awareness & Training

Plan & Deliver Training

I

A

R

C

I

Participate in Training

I

I

R

R

A

4. Review and Update

This matrix will be reviewed annually as part of the management review process, or sooner if significant changes occur to organizational roles, ISMS responsibilities, or processes. Updates will be approved by the IT Manager.

IS-AHR02-CIRQ01-A00: Competence, Awareness, and Training Policy

IS-AHR02-CIRQ01-A00: Competence, Awareness, and Training Policy

Document: IS-AHR02-CIRQ01-A00

Standards Name: Competence, Awareness, and Training Policy

Category: Base Policy & ISMS Manual

Division: Policy

Standard Retention: Exist and No Corrections

Standard Type: Global

1. Purpose

SOC 2 Trust Services Criteria Mapping

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC1.4

Demonstrates commitment to attract, develop, and retain competent individuals

CC1.5

Holds individuals accountable for their internal-control responsibilities

CC2.2

Internally communicates information needed to support functioning of internal control

The purpose of this policy is to define Cirque's commitment and methodology for ensuring that all personnel performing work under its control are competent, aware of the Information Security Management System (ISMS) and its objectives, and properly trained. This policy addresses the requirements of ISO/IEC 27001:2022 Clauses 7.2 (Competence) and 7.3 (Awareness).

2. Scope

This policy applies to all Cirque personnel, including permanent employees, temporary staff, contractors, and relevant external parties working within or impacting the ISMS scope, across all locations (US HQ, Taipei office, and authorized remote work locations). The same information security rules and training apply globally.

3. Competence

Cirque shall determine the necessary competence for persons performing work affecting information security performance and ensure that these persons are competent on the basis of appropriate education, training, or experience.

3.1. Determining Necessary Competence a. Job descriptions for all roles will clearly identify the required information security competencies, particularly for roles with significant information security responsibilities (e.g., IT personnel, engineering teams, finance). b. The IT Manager, in conjunction with Department Managers, will assess the information security competence required for each role based on the information assets handled, systems accessed, and security controls managed.

3.2. Ensuring Competence a. Cirque will ensure that personnel are competent through a combination of: * **Education:** Relevant academic qualifications. * **Training:** Formal or informal training programs specific to information security. * **Experience:** Practical work experience in information security or related fields. b. Where necessary competence gaps are identified, Cirque will take action to acquire the necessary competence (e.g., provide training, assign experienced personnel, or hire new staff) and evaluate the effectiveness of the actions taken. c. Records of education, training, skills, and experience will be maintained by the HR Department.

4. Awareness

Cirque shall ensure that all persons performing work under its control are aware of:

4.1. The Information Security Policy and Objectives: a. All personnel will be made aware of Cirque's overall Information Security Policy (IS-APM01-CIRQ01-A00) and the general objectives of the ISMS upon hiring and periodically thereafter.

4.2. Their Contribution to the Effectiveness of the ISMS: a. Personnel will understand how their individual actions contribute to the effectiveness of the ISMS, including the benefits of improved information security performance. b. Emphasis will be placed on the protection of highly confidential assets such as **CAD drawings and sales information**, and the secure handling of intellectual property, firmware, software, and ASIC designs.

4.3. The Implications of Non-Conformity: a. Personnel will be aware of the consequences of non-compliance with the ISMS requirements, including security policy violations, procedures, and legal/contractual obligations. This includes potential disciplinary actions, which may be administered in consultation with HR for severe breaches, and the impact on business operations, reputation, and customer trust.

5. Training Program

A structured information security training program will be implemented to support competence and awareness requirements.

5.1. Training Content a. Training content will be tailored to different audiences and roles, covering topics such as: * General information security best practices. * Phishing and social engineering awareness. * Password management. * Clean desk and clear screen policy. * Incident reporting procedures. * Specific policy requirements (e.g., Acceptable Use, Access Control). * Data classification and handling procedures (especially for confidential customer data and intellectual property). * Secure use of internal tools (e.g., GitLab, QuickBooks) and security tools (e.g., Windows Defender for Business, Intune). * Legal and regulatory requirements relevant to Cirque's global operations. b. **Specialized training content for specific departments (e.g., Secure Development Practices for Engineering teams) will be developed and maintained by the respective Department Managers.**

5.2. Training Delivery a. Training may be delivered through various methods, including: * Indoctrination/New Hire training. * Online modules (e.g., quizzes, interactive lessons). * Classroom sessions or workshops. * Phishing simulation exercises. * Regular security awareness communications (e.g., emails, posters). * **Department-specific training sessions conducted by managers.**

5.3. Training Frequency a. Initial awareness training will be provided to all new personnel upon joining Cirque. b. Refresher training will be conducted at least annually for all personnel. c. Role-specific and specialized training will be conducted as needed, particularly when new systems, technologies, or significant changes to processes are introduced.

5.4. Training Records a. Records of all information security awareness and training activities, including attendance and completion, will be maintained by the HR Department and/or the IT Manager.

6. Related Documents

- IS-AHR02-CIRQ02-A00: Information Security Awareness and Training Procedure
- IS-AHR02-CIRQ01-F01A: Training Records Log

7. Policy Review

This policy will be reviewed at least annually, or sooner if significant changes occur to Cirque's business objectives, ISMS scope, or legal/regulatory environment.

IS-AHR02-CIRQ02-A00: Information Security Awareness and Training Procedure

IS-AHR02-CIRQ02-A00: Information Security Awareness and Training Procedure

Document: IS-AHR02-CIRQ02-A00

Standards Name: Information Security Awareness and Training Procedure

Category: Base Policy & ISMS Manual

Division: Procedure

Standard Type: Global

Version: 1.0 Effective Date: July 2025 Review Date: July 2026 Approved By: IT Manager

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC1.4

Personnel competence

CC1.5

Accountability

CC2.2

Internal communication / training

The purpose of this procedure is to outline the process for planning, developing, delivering, and evaluating information security awareness and training programs at Cirque, in accordance with IS-AHR02-CIRQ01-A00: Competence, Awareness, and Training Policy. This ensures that all personnel possess the necessary competence and awareness to protect Cirque's information assets.

2. Scope

This procedure applies to all Cirque personnel, including permanent employees, temporary staff, and contractors, across all operational locations.

3. Responsibilities

- **IT Manager:** Overall coordination and oversight of the information security awareness and training program. Develops and delivers general security awareness content. Ensures training records are maintained.
- **Department Managers:** Responsible for identifying specific training needs within their departments, developing specialized training content relevant to their teams' tools and processes, and delivering or arranging for such training.
- **HR Department:** Supports the IT Manager in scheduling and coordinating general training sessions, and maintains records of all employee training and competence.
- **All Employees and Contractors:** Required to participate in all mandatory information security awareness and training activities.

4. Procedure

4.1. Annual Training Needs Assessment and Planning a. (Q4 Annually): The IT Manager will collaborate with Department Managers to conduct an annual assessment of information security training needs based on: * Results

of risk assessments (IS-LMR-CIRQ01-F01A). * Feedback from incident reports (IS-AMR04-CIRQ01-F01A). * Changes in technology, systems (e.g., new tools like Windows Defender/Intune features, GitLab updates), or business processes. * New or updated legal, regulatory, or contractual requirements. * Performance evaluation feedback (if security aspects are included). b. Based on the assessment, the IT Manager will develop an annual Information Security Awareness and Training Plan. This plan will identify: * Target audiences. * Core awareness topics (general). * Specialized training topics (department-specific). * Delivery methods. * Schedule and frequency. * Required resources.

4.2. Content Development a. **General Awareness Content:** The IT Manager is responsible for developing and/or procuring general information security awareness content (e.g., phishing awareness, password hygiene, clean desk). b. **Specialized Departmental Content:** Department Managers are responsible for developing or arranging for specialized training content relevant to their teams' specific tools, processes, and highly confidential data (e.g., secure design principles for engineering, secure handling of sales data). This includes training on the secure use of tools like Cadence, SolidWorks, Visual Studio, and internal platforms like GitLab and QuickBooks.

4.3. Training Delivery a. **New Hire Orientation:** All new employees and contractors receive initial information security awareness training as part of their onboarding process, covering IS-APM01-CIRQ01-A00: Information Security Policy and other foundational topics. b. **Annual Refresher Training:** All personnel will complete mandatory information security awareness training at least annually. c. **Role-Specific Training:** Delivered to relevant personnel as identified in the annual plan or as needed due to changes in roles or systems. d. **Ad-hoc Training/Communications:** The IT Manager may issue ad-hoc communications (e.g., emails, posters, quick tips) or brief training sessions in response to emerging threats (e.g., new phishing campaigns) or specific incidents. e. **Delivery Methods:** Training will utilize appropriate methods such as online modules, interactive sessions, webinars, or in-person workshops, as determined by the IT Manager and Department Managers.

4.4. Training Records Management a. The IT Manager is responsible for collecting training completion data. b. The HR Department will maintain comprehensive records of all information security training completed by employees and contractors in the IS-AHR02-CIRQ01-F01A: Training Records Log. Records will include: * Employee/Contractor Name. * Date of Training. * Training Topic/Course Name. * Training Provider/Method. * Duration. * Completion Status (e.g., Passed, Completed).

4.5. Evaluation of Effectiveness a. The effectiveness of awareness and training programs will be evaluated through various means, which may include: * Quizzes or assessments following training modules. * Phishing simulation click-through rates. * Analysis of incident reports (e.g., decrease in user-reported incidents, fewer policy violations). * Feedback from participants and managers. b. The results of the evaluation will be used to improve future training programs.

5. Review and Update

This procedure will be reviewed at least annually, or sooner if there are changes to relevant policies, technologies, organizational structure, or significant findings from training effectiveness evaluations or audits.

6. Related Documents

- IS-AHR02-CIRQ01-A00: Competence, Awareness, and Training Policy
- IS-LMR-CIRQ01-F01A: Risk Assessment Register
- IS-AMR04-CIRQ01-F01A: Information Security Incident Report Form
- IS-AHR02-CIRQ01-F01A: Training Records Log

IS-AHR02-CIRQ01-F01A: Training Records Log

IS-AHR02-CIRQ01-F01A: Training Records Log

Document: IS-AHR02-CIRQ01-F01A

Standards Name: Training Records Log

Category: Information Management Forms

Division: Form

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 **Effective Date:** July 2025 **Review Date:** July 2026 **Approved By:** IT Manager

1. Purpose

This log serves as the central record for documenting all information security awareness and training activities undertaken by Cirque personnel. It provides evidence of compliance with the IS-AHR02-CIRQ01-A00: Competence, Awareness, and Training Policy and IS-AHR02-CIRQ02-A00: Information Security Awareness and Training Procedure.

2. Scope

This log covers all personnel (employees and contractors) across all Cirque locations who undergo information security awareness or competence training.

3. Instructions for Use

- This log is maintained by the HR Department, with input from the IT Manager and Department Managers.
- A new entry should be made for each training session attended by personnel.
- Ensure all fields are completed accurately.

4. Information Security Training Records Log

Record ID

Employee/Contractor Name

Department

Role

Training Date

Training Topic/Course Name

Training Provider/Method (e.g., Internal, Online Module, Workshop)

Duration (e.g., 1 hr, Full Day)

Completion Status (e.g., Completed, Passed, Attended)

Notes (e.g., effectiveness score, feedback)

TRL-001

Jane Doe

(example only)

IT

IT Specialist

YYYY-MM-DD

Phishing Awareness 2024

External Online Module

45 min

Passed (90%)

TRL-002

John Smith

(example only)

Engineering

Confidential — Cirque Corporation Internal
Lead Engineer

YYYY-MM-DD

Secure Coding for Firmware

Internal Workshop (Eng. Dept.)

3 hrs

Attended

Good engagement from team.

TRL-003

...

Part III — Risk Management

IS-LMR-CIRQ01-A00: Risk Management Policy

IS-LMR-CIRQ01-A00: Risk Management Policy

Document: IS-LMR-CIRQ01-A00

Standards Name: Risk Management Policy

Category: Base Policy & ISMS Manual

Division: Policy

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.1 Effective Date: June 2025 Review Date: June 2026 Approved By: Executive Committee

1. Purpose

SOC 2 Trust Services Criteria Mapping

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC3.1

Specifies suitable objectives to enable risk assessment

CC3.2

CC3.3

Considers the potential for fraud in risk assessment

CC3.4

Identifies and assesses changes that could significantly impact the ISMS

CC9.1

Identifies, selects, and develops risk-mitigation activities

The purpose of this policy is to establish Cirque's commitment and methodology for identifying, assessing, and treating information security risks in alignment with ISO/IEC 27001:2022 Clause 6.1. This systematic approach ensures that information security risks are managed to an acceptable level, supporting Cirque's business objectives and compliance obligations.

2. Scope

This policy applies to all information security risk management activities undertaken within Cirque's Information Security Management System (ISMS) scope, as defined in IS-APM02-CIRQ01-A01A: ISMS Scope Document. It covers all information assets, processes, technologies, and personnel relevant to information security across all Cirque locations and operations.

3. Principles of Risk Management

Cirque's approach to information security risk management is based on the following principles:

- **Systematic and Consistent:** Risks will be identified, analyzed, evaluated, and treated using a consistent and repeatable methodology, employing **Low, Medium, and High** classifications.
- **Proactive:** Information security risks will be identified and addressed proactively, rather than reactively, where possible.
- **Risk-Based Decision Making:** Decisions regarding information security controls and investments will be based on a clear understanding of identified risks and their potential impact.
- **Continual Improvement:** The risk management process will be regularly reviewed and improved.
- **Transparency:** Risk management activities and decisions will be documented and communicated to relevant stakeholders.
- **Top Management Support:** Top management is committed to providing adequate resources for risk management.

4. Risk Management Framework

Cirque adopts a structured approach to risk management, encompassing the following phases:

4.1. Risk Identification a. Identify all information assets within the ISMS scope, considering their value to Cirque (e.g., intellectual property, customer data, financial data, manufacturing designs, source code). b. Identify potential threats to these assets (e.g., cyber-attacks, human error, natural disasters, hardware failure, unauthorized access). c. Identify existing vulnerabilities that could be exploited by threats. d. Identify existing controls and their effectiveness.

4.2. Risk Analysis a. Assess the likelihood of a threat exploiting a vulnerability to cause an information security incident using **Low, Medium, or High** qualitative ratings. b. Assess the potential impact (e.g., financial, reputational, legal, operational) of such an incident on Cirque's business objectives using **Low, Medium, or High** qualitative ratings. c. Combine likelihood and impact to determine the level of inherent risk (e.g., High, Medium, Low).

4.3. Risk Evaluation a. Compare the assessed risk levels against Cirque's established risk acceptance criteria. b. Prioritize risks based on their severity and alignment with risk acceptance levels.

4.4. Risk Treatment a. Select appropriate risk treatment options based on the risk evaluation: * **Modify:** Implement controls to reduce the risk (e.g., encryption, access controls, training). * **Retain:** Accept the risk as it falls within acceptable levels or treatment is not cost-effective. * **Avoid:** Cease the activity that generates the risk. * **Share/Transfer:** Transfer the risk to another party (e.g., insurance, outsourcing with robust contracts). b. Develop and implement a Risk Treatment Plan (IS-LMR-CIRQ01-F01A) detailing the selected controls, responsibilities, and timelines. c. Implement controls from ISO 27001 Annex A as appropriate.

4.5. Risk Monitoring and Review a. Identified risks and the effectiveness of implemented controls will be regularly monitored. b. **A formal review of high risks will be conducted quarterly.** c. The entire risk assessment and treatment processes will be reviewed periodically to ensure their ongoing suitability and effectiveness. d. Risks will be re-evaluated when significant changes occur (e.g., new systems, new business processes, new threats).

5. Risk Acceptance Criteria

The Executive Committee will define and approve the criteria for accepting information security risks. Cirque maintains a **low risk appetite**, aiming to mitigate almost all identified risks, even those initially assessed as minor, where feasible and cost-effective. Risks exceeding the defined acceptance criteria must be treated.

6. Roles and Responsibilities

- **Executive Committee:** Approves the Risk Management Policy and Risk Acceptance Criteria.
- **IT Manager:** Accountable for the overall risk management process, including facilitating risk assessments, maintaining the Risk Assessment Register, and reporting on risk status.
- **Department Managers/Process Owners:** Responsible for identifying and assessing risks within their operational areas and contributing to risk treatment plans.
- **All Employees:** Responsible for reporting identified vulnerabilities or threats.

7. Related Documents

- IS-LMG-CIRQ01-A00: Information Security Risk Assessment Procedure
- IS-LMG-CIRQ02-A00: Information Security Risk Treatment Procedure
- IS-LMR-CIRQ01-F01A: Risk Assessment Register
- IS-LMR-CIRQ01-F01A: Risk Treatment Plan (RTP)
- IS-APM02-CIRQ01-A02A: Statement of Applicability (SoA)

8. Policy Review

This policy will be reviewed at least annually, or sooner if significant changes occur to Cirque's risk appetite, business environment, or legal/regulatory landscape.

IS-LMG-CIRQ01-A00: Information Security Risk Assessment Procedure

IS-LMG-CIRQ01-A00: Information Security Risk Assessment Procedure

Document: IS-LMG-CIRQ01-A00

Standards Name: Information Security Risk Assessment Procedure

Category: Base Policy & ISMS Manual

Division: Procedure

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.1 **Effective Date:** June 2025 **Review Date:** June 2026 **Approved By:** IT Manager

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC3.1

Specifies suitable objectives

CC3.2

Identifies and analyzes risks

CC3.3

Considers fraud in risk assessment

CC3.4

Identifies and assesses changes

The purpose of this procedure is to describe the systematic process for identifying, analyzing, and evaluating information security risks within Cirque's Information Security Management System (ISMS) scope, in accordance with ISO/IEC 27001:2022 Clause 6.1. This procedure implements the principles outlined in the IS-LMR-CIRQ01-A00: Risk Management Policy.

2. Scope

This procedure applies to all information assets, processes, and systems within the defined ISMS scope of Cirque. It covers both initial and periodic risk assessments, as well as ad-hoc assessments triggered by significant changes.

3. Responsibilities

- **IT Manager:** Overall responsible for coordinating and facilitating risk assessment activities, maintaining the Risk Assessment Register (IS-LMR-CIRQ01-F01A), and ensuring adherence to this procedure.
- **Department Managers/Process Owners:** Provide input for asset identification, threat and vulnerability identification specific to their areas, and contribute to impact assessment.
- **IT Department Personnel:** Provide technical input on vulnerabilities, existing controls, and technical impacts, leveraging insights from security tools.

4. Procedure

4.1. Planning the Risk Assessment a. The IT Manager will schedule and plan risk assessment sessions. This includes defining the scope of the specific assessment (e.g., an annual full assessment, or a targeted assessment for a new system). b. Identify and gather relevant documentation, including the ISMS Scope Document (IS-APM02-

CIRQ01-A01A), previous risk assessments, and the current information asset inventory. c. Assemble a cross-functional risk assessment team, including representatives from IT, relevant department managers, and subject matter experts as needed.

4.2. Information Asset Identification and Valuation a. For the defined assessment scope, identify all relevant information assets by leveraging the **Asset Inventory maintained via RMM and associated spreadsheet**. This includes, but is not limited to, data (e.g., customer data, IP, financial), software (e.g., ERP, CAD, GitLab), hardware (e.g., servers, workstations, network devices), services (e.g., cloud services, internet access), and people. b. For each identified asset, determine its business value and importance to Cirque's operations, especially concerning its Confidentiality, Integrity, and Availability (CIA).

4.3. Threat Identification a. For each asset or group of assets, identify potential threats that could exploit vulnerabilities and cause harm. Threat identification will leverage insights from **Windows Defender for Business** (for common cyber threats and malware) as well as broader categories, including: * **Natural Disasters**: Fire, flood, earthquake. * **Environmental**: Power failure, HVAC failure. * **Human (Accidental)**: Error, negligence, unintentional disclosure. * **Human (Deliberate)**: Unauthorized access, theft, fraud, sabotage, sophisticated cyber-attacks (phishing, ransomware, zero-day exploits). * **Technical Failure**: Hardware failure, software bugs, network outage. b. Record identified threats in the IS-LMR-CIRQ01-F01A: Risk Assessment Register.

4.4. Vulnerability Identification a. For each asset, identify existing vulnerabilities that could be exploited by identified threats. Vulnerability identification will heavily utilize **Windows Defender for Business** for endpoint and server vulnerabilities, alongside other sources such as: * Results from any network scans or penetration tests (if conducted). * Software and system configuration reviews. * Identified weaknesses in processes or human factors (e.g., lack of awareness). * Physical security weaknesses. b. Record identified vulnerabilities in the IS-LMR-CIRQ01-F01A: Risk Assessment Register.

4.5. Existing Control Identification a. For each identified threat-vulnerability pair, identify any existing information security controls currently in place that mitigate the risk. This includes both technical (e.g., firewalls, encryption, Windows Defender for Business configurations) and non-technical (e.g., policies, training, physical security measures) controls. b. Record existing controls in the IS-LMR-CIRQ01-F01A: Risk Assessment Register.

4.6. Risk Analysis (Likelihood and Impact Assessment) a. **Likelihood Assessment**: For each threat-vulnerability pair, assess the likelihood of the threat exploiting the vulnerability, considering the effectiveness of existing controls. Use the following qualitative scale: * **Low**: Unlikely to occur in the foreseeable future (e.g., once every 5+ years). * **Medium**: Could occur occasionally (e.g., once every 1-5 years). * **High**: Likely to occur frequently (e.g., multiple times per year). b. **Impact Assessment**: For each threat-vulnerability pair, assess the potential business impact if the incident were to occur, considering the CIA of the affected assets. Use the following qualitative scale: * **Low**: Minor disruption, limited financial loss, no significant legal/reputational damage. * **Medium**: Moderate disruption, measurable financial loss, some reputational/legal impact, non-critical data breach. * **High**: Severe disruption, significant financial loss, major reputational/legal damage, critical data breach (e.g., IP loss, severe privacy violation). c. Record both likelihood and impact in the IS-LMR-CIRQ01-F01A: Risk Assessment Register.

4.7. Risk Evaluation a. Combine the likelihood and impact ratings to determine the inherent risk level (before additional treatment) using the following matrix:

Impact	**Low Likelihood**	**Medium Likelihood**	**High Likelihood**
:-----	:-----	:-----	:-----
High	Medium	High	High
Medium	Low	Medium	High
Low	Low	Low	Medium

b. Compare the calculated risk level against `Cirque`s **low risk appetite** as defined in `IS-LMR-CIRQ01-A00`. Risks assessed as Medium or High will typically require treatment.

c. Record the resulting risk level in the `IS-LMR-CIRQ01-F01A: Risk Assessment Register`.

4.8. Documentation a. All identified risks, their analysis (likelihood, impact, risk level), and existing controls will be documented in the IS-LMR-CIRQ01-F01A: Risk Assessment Register.

5. Review and Update a. Risk assessments will be conducted periodically, and **high risks will be formally reviewed quarterly** by the IT Manager and relevant stakeholders. b. The risk assessment process will be reviewed annually as part of the ISMS management review or whenever significant changes in Cirque's context occur.

6. Related Documents

- IS-LMR-CIRQ01-A00: Risk Management Policy
- IS-LMG-CIRQ02-A00: Information Security Risk Treatment Procedure
- IS-LMR-CIRQ01-F01A: Risk Assessment Register
- IS-APM02-CIRQ01-A01A: ISMS Scope Document

IS-LMG-CIRQ02-A00: Information Security Risk Treatment Procedure

IS-LMG-CIRQ02-A00: Information Security Risk Treatment Procedure

Document: IS-LMG-CIRQ02-A00

Standards Name: Information Security Risk Treatment Procedure

Category: Base Policy & ISMS Manual

Division: Procedure

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.1 **Effective Date:** July 2025 **Review Date:** July 2026 **Approved By:** IT Manager

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC3.2

Risk treatment as part of risk-analysis response

CC9.1

Develops risk-mitigation activities

CC5.1

Selects and develops control activities to mitigate risks

The purpose of this procedure is to define the systematic process for selecting and implementing appropriate risk treatment options for information security risks identified by Cirque, in accordance with ISO/IEC 27001:2022 Clause 6.1.3. This ensures that risks are reduced to an acceptable level as defined by Cirque's risk appetite.

2. Scope

This procedure applies to all risks identified and evaluated as requiring treatment within Cirque's ISMS scope.

3. Responsibilities

- **IT Manager:** Accountable for leading the risk treatment process, ensuring Risk Treatment Plans (IS-LMR-CIRQ01-F01A) are developed, implemented, and monitored, and reporting on their status. Also approves the acceptance of residual risks that are not classified as "High."
- **Department Managers/Process Owners:** Responsible for implementing risk treatment controls within their respective areas, providing updates on progress, and accepting residual risk.
- **IT Department Personnel:** Responsible for implementing technical controls and providing support for risk treatment activities, leveraging tools such as Windows Defender for Business and Intune.
- **Executive Committee:** Approves significant risk treatment plans and any accepted residual "High" risks.
- **Internal Audit Function (independent of the controls being audited):** Verifies the implementation and effectiveness of risk treatment controls through an annual internal audit covering all in-scope SOC 2 controls, supplemented by quarterly evidence sampling. The IT Manager may not audit IT-owned controls; the Executive Committee designates an independent reviewer for that purpose.

4. Procedure

4.1. Identify Risks Requiring Treatment a. Review the IS-LMR-CIRQ01-F01A: Risk Assessment Register. b. Identify all risks evaluated as "Medium" or "High," or any "Low" risks that are deemed unacceptable due to Cirque's **low risk appetite**. These risks require a formal treatment plan.

4.2. Select Risk Treatment Options a. For each risk requiring treatment, the IT Manager, in consultation with relevant Department Managers and IT Department Personnel, will evaluate and select the most appropriate risk treatment option(s). Options include: * **Modify the risk (Reduce):** Implement controls to reduce the likelihood or impact of the risk. This is the primary focus for Cirque given its low risk appetite. Examples include: * Implementing new security software (e.g., enhanced EDR, SIEM). * Applying patches and updates (e.g., via Intune). * Strengthening access controls. * Conducting targeted security awareness training. * Improving backup and recovery procedures. * Implementing encryption for sensitive data. * **Retain the risk (Accept):** Accept the risk without further action if it falls within the defined risk acceptance criteria (e.g., a "Low" risk that is impractical or excessively costly to reduce further, and where the IT Manager agrees to accept it). * **Avoid the risk:** Stop the activity or remove the asset that is generating the risk. * **Share or Transfer the risk:** Transfer the risk to another party, e.g., through insurance, or by contractually obliging a third-party service provider to manage specific risks. b. The selected treatment option(s) must align with the IS-LMR-CIRQ01-A00: Risk Management Policy and Cirque's overall risk appetite.

4.3. Develop Risk Treatment Plan (RTP) a. For each risk (or group of related risks) selected for modification, a detailed Risk Treatment Plan (IS-LMR-CIRQ01-F01A) will be developed. b. The RTP will include: * Identification of the risk. * Selected risk treatment option(s). * Specific controls to be implemented (referencing ISO 27001 Annex A controls where applicable). * Responsible parties for implementation. * Target completion dates. * Required resources. * Metrics for measuring effectiveness (if applicable). c. The IT Manager is responsible for developing the RTP in collaboration with relevant stakeholders.

4.4. Implement Risk Treatment Plan a. Responsible parties identified in the RTP will implement the agreed-upon controls and actions within the specified timelines. b. Progress will be regularly monitored by the IT Manager, leveraging monitoring data from **Windows Defender for Business and Intune** where applicable for security control status and risk posture. c. Any deviations from the plan or delays must be communicated to the IT Manager for review and adjustment.

4.5. Assess Residual Risk a. Once risk treatment actions have been implemented, the IT Manager will reassess the risk to determine the **residual risk** level (the risk remaining after controls have been applied). b. The reassessment process will follow the methodology outlined in IS-LMG-CIRQ01-A00: Information Security Risk Assessment Procedure. c. Record the residual risk in the IS-LMR-CIRQ01-F01A: Risk Assessment Register.

4.6. Residual Risk Acceptance a. If the residual risk is within Cirque's defined risk acceptance criteria (i.e., "Low" as per IS-LMR-CIRQ01-A00), the risk is accepted. The **IT Manager is authorized to approve the acceptance of these "Low" and acceptable "Medium" residual risks**. b. If the residual risk remains "High," further treatment

options must be identified, and the process (from 4.2 onwards) must be repeated until the risk is reduced to an acceptable level or formally accepted by the Executive Committee with documented justification. c. Any residual risk assessed as "High" must be formally accepted by the Executive Committee.

4.7. Statement of Applicability (SoA) a. Upon completion of risk treatment and the determination of residual risks, the IT Manager will prepare the IS-APM02-CIRQ01-A02A: Statement of Applicability (SoA). b. The SoA will identify the ISO 27001 Annex A controls selected for implementation, provide justification for their inclusion, and justify any exclusions.

4.8. Internal Audit Verification a. The effectiveness of implemented risk treatment controls and the adherence to this procedure will be **verified through an annual internal audit covering all in-scope SOC 2 controls, supplemented by quarterly evidence sampling**, conducted by the designated independent internal audit function (per IS-AMR02-CIRQ03-A00). b. Findings from these audits inform corrective actions (IS-AMR03-CIRQ02-A00) and continual improvement (IS-LMR-CIRQ04-A00). c. The IT Manager does not audit IT-owned controls; the Executive Committee designates an independent reviewer for those areas.

5. Review and Update a. The effectiveness of implemented risk treatments will be monitored continuously. b. The Risk Treatment Plans and the residual

IS-LMR-CIRQ01-F01A: Risk Assessment Register (Template)

IS-LMR-CIRQ01-F01A: Risk Assessment Register (Template)

This will be the central log for all identified risks.

Document: IS-LMR-CIRQ01-F01A

Standards Name: Risk Assessment Register

Category: Information Management Forms

Division: Form

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 Effective Date: July 2025 Review Date: July 2026 Approved By: IT Manager

1. Purpose

This register serves as the central repository for documenting all identified information security risks within Cirque's ISMS scope. It records the details of risk identification, analysis, evaluation, and current status, as defined in IS-LMG-CIRQ01-A00: Information Security Risk Assessment Procedure.

2. Scope

This register covers all information security risks identified as part of Cirque's risk management process.

3. Instructions for Use

- This register is maintained by the IT Manager.
- Entries should be made for each identified risk during risk assessment sessions.
- The "Risk ID" should be a unique identifier.
-
-
-
-
-
-

RA-002

...

IS-LMR-CIRQ01-F01A: Risk Treatment Plan (RTP) (Template)

IS-LMR-CIRQ01-F01A: Risk Treatment Plan (RTP) (Template)

This document specifies the plan to mitigate identified risks.

Document: IS-LMR-CIRQ01-F01A

Standards Name: Risk Treatment Plan (RTP)

Category: Information Management Documents

Division: Document

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 Effective Date: June 2025 Review Date: June 2026 Approved By: IT Manager

1. Purpose

This document details the specific actions and controls implemented by Cirque to treat identified information security risks, reducing them to an acceptable level as defined in IS-LMR-CIRQ01-A00: Risk Management Policy. It serves as the output of the IS-LMG-CIRQ02-A00: Information Security Risk Treatment Procedure.

2. Scope

This RTP addresses all risks identified in the IS-LMR-CIRQ01-F01A: Risk Assessment Register that require treatment.

3. Instructions for Use

- Each Risk Treatment Plan should correspond to one or more identified risks.
- Maintain updates on implementation status and effectiveness.

4. Risk Treatment Plan Details

RTP ID: [Unique Identifier, e.g., RTP-001] Creation Date: [Date] Last Reviewed Date: [Date] Approved By: IT Manager (for Low/Medium Residual), Executive Committee (for High Residual)

		4.1. Risk(s) Being Treated
Risk ID (from F-001-G)		
Description of Risk		
Inherent Risk Level		
[e.g., RA-003]		

Confidential — Cirque Corporation Internal
[e.g., Unauthorized access to customer CAD files due to weak access controls]

High

[e.g., RA-007]

[e.g., Data loss from critical server due to inadequate backup frequency]

Medium

4.2. Selected Risk Treatment Option(s)

[Select one or more: Modify / Retain / Avoid / Share]

4.3. Specific Controls and Actions to be Implemented

Control/Action Description (linking to Annex A if applicable)

Responsible Party

Target Completion Date

Status (Not Started/In Progress/Completed/Delayed)

Verification Method

Notes (e.g., resources needed, dependencies)

[e.g., Implement MFA for all remote access]

IT Department

[Date]

Not Started

System Logs, Access Review

[e.g., A.5.15 Access Control Policy]

IT Manager

[Date]

In Progress

[e.g., Conduct user awareness training on phishing]

IT Manager

[Date]

Not Started

Training Records

4.4. Post-Treatment Risk Assessment

Residual Likelihood (Low/Med/High)

Residual Impact (Low/Med/High)

Residual Risk (Low/Med/High)

Justification for Residual Risk Acceptance (if applicable)

[e.g., Low]

[e.g., Low]

[e.g., Low]

Controls effectively reduce risk to an acceptable level.

4.5. Acceptance of Residual Risk

- **Residual Risk Level:** [Low/Medium/High]
- **Accepted By:**
 - IT Manager: [Name, Signature, Date] (for Low/Medium residual risks)
 - Executive Committee: [Name/Committee, Date] (for High residual risks)

IS-LMR-CIRQ05-A00: Information Security Objectives

IS-LMR-CIRQ05-A00: Information Security Objectives

Document: IS-LMR-CIRQ05-A00

Standards Name: Information Security Objectives

Category: Base Policy & ISMS Manual

Division: Document

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.1 **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** Executive Committee

1. Purpose

Confidential — Cirque Corporation Internal

The purpose of this document is to define the Information Security Objectives of Cirque's Information Security Management System (ISMS), in accordance with ISO/IEC 27001:2022 Clause 6.2. These objectives are consistent with the IS-APM01-CIRQ01-A00: Information Security Policy and the results of the risk assessment process. They are established to ensure the continual improvement of information security performance and to support Cirque's strategic goals.

2. Scope

These objectives apply to all information, information processing facilities, and information security processes within the defined ISMS scope of Cirque.

3. Principles for Information Security Objectives

Cirque's Information Security Objectives are designed to be:

- **Consistent** with Cirque's Information Security Policy.
- **Measurable** (or capable of being evaluated).
- **Monitored** and communicated throughout the organization via **Teams channels, emails, and Company meetings**.
- **Updated** as appropriate.
- **Consider** applicable information security requirements, and the results from risk assessment and risk treatment.

4. Information Security Objectives

The following information security objectives have been established by Cirque's Executive Committee to guide the ISMS activities and improve

Objective ID

Objective Description

Aligns with Policy/Context

Measurement (Key Performance Indicator - KPI)

Target / Acceptance Criteria

Responsibility

Reporting Frequency

ISO-001

Reduce the risk of unauthorized access to sensitive data (e.g., CAD drawings, customer sales data) in key systems.

Confidentiality, Low Risk Appetite

Number of critical/high-risk access control findings from internal audits or vulnerability assessments. Number of unauthorized access incidents involving **Omnify, Cadence, GitLab, Asana**.

Maintain < 2 Critical/High findings per quarter. 0 unauthorized access incidents.

IT Manager

Quarterly

ISO-002

Maintain the integrity and availability of critical IT systems and manufacturing data.

Integrity, Availability, Operational Resilience

Uptime percentage for critical systems (e.g., manufacturing control systems, ERP, **Omnify, Cadence, GitLab**).
Data backup success rate.

>99.9% uptime for critical systems. >98% backup success rate.

IT Manager

Monthly

ISO-003

Enhance employee information security awareness and compliance.

People Controls, Risk Reduction

Average score on annual security awareness training assessments. Phishing simulation click-through rate.
Percentage of employees completing annual training.

>85% average score. <5% click-through rate. 100% completion rate.

IT Manager / HR

Quarterly / Annually

ISO-004

Ensure timely patching and vulnerability management for all endpoints and servers.

Technological Controls, Proactive Security

Percentage of critical/high vulnerabilities patched within defined SLAs (e.g., 7 days for critical, 30 days for high) as identified by tools like Windows Defender for Business.

>95% adherence to patching SLAs.

IT Manager

Monthly

ISO-005

Ensure compliance with applicable legal, regulatory, and contractual requirements.

Compliance

Number of non-compliance findings from internal/external audits or legal reviews.

0 critical non-compliance findings.

IT Manager

Annually

ISO-006

Improve incident response capability and recovery time.

Incident Management

Mean Time To Detect (MTTD) and Mean Time To Respond (MTTR) for critical security incidents.

MTTD < 4 hours. MTTR < 24 hours.

IT Manager

Quarterly

ISO-007

Protect intellectual property related to hardware, firmware, software, and ASIC designs.

Confidentiality, IP Protection

Number of unauthorized disclosures or breaches of IP. Success rate of secure development lifecycle (SDL) reviews for projects involving **Cadence, GitLab**.

0 unauthorized IP disclosures. 100% SDL review completion.

IT Manager / Engineering Managers

Quarterly

5. Planning to Achieve Objectives

The achievement of these objectives will be driven through the ongoing implementation and maintenance of Cirque's ISMS, including:

- Regular information security risk assessments and treatment plans (IS-LMR-CIRQ01-F01A, IS-LMR-CIRQ01-F01A).

- Implementation of controls from the Statement of Applicability (IS-APM02-CIRQ01-A02A).
- Development and delivery of competence, awareness, and training programs (IS-AHR02-CIRQ02-A00).
- Performance monitoring and measurement.
- Management reviews.

6. Review and Update

These Information Security Objectives will be reviewed at least annually as part of the Management Review process, or sooner if significant changes occur to Cirque's strategic direction, risk landscape, or ISMS performance. The Executive Committee will approve any updates to these objectives.

IS-APM02-CIRQ01-A02A: Statement of Applicability (SoA)

IS-APM02-CIRQ01-A02A: Statement of Applicability (SoA)

Document ID: IS-APM02-CIRQ01-A02A **Document Title:** Statement of Applicability (SoA) **Category:** Information Management Documents **Division:** Document **Document Type:** Global **Version:** 2.0 **Effective Date:** 2026-05-08 **Review Date:** 2027-05-08 **Owner:** IT Manager (Chris Wren) **Approved By:** Executive Committee

Change history (v1.0 → v2.0): Replaced template with fully populated SoA covering all 93 ISO/IEC 27001:2022 Annex A controls, with Cirque-specific applicability, justification, document references, and parallel SOC 2 Trust Services Criteria mapping. Aligns with the SOC 2:2017 Type 1 audit covering Security and Confidentiality categories.

1. Purpose

The Statement of Applicability (SoA) documents the information security controls selected by Cirque Corporation for implementation within its Information Security Management System (ISMS) based on the results of the risk assessment and treatment process. It justifies the inclusion or exclusion of controls from ISO/IEC 27001:2022 Annex A in accordance with Clauses 6.1.3(d) and 6.1.3(e), and maps each control to the AICPA Trust Services Criteria for SOC 2:2017 (Security and Confidentiality categories).

2. Scope

This SoA covers all controls within the Cirque ISMS scope as defined in IS-APM02-CIRQ01-A01A: ISMS Scope Document.

3. Applicability Decision Rationale

Cirque's posture is to apply the full ISO/IEC 27001:2022 Annex A control set unless there is a documented business reason for exclusion. As a manufacturer that handles customer IP (touchpads, ASIC, firmware) and operates regulated cloud services on behalf of internal users, Cirque does not currently exclude any Annex A controls. Where a control is not yet fully operational, that is tracked as an open SOC 2 readiness item rather than an exclusion.

4. Maintenance

Owner: IT Manager (Chris Wren)

Review cadence: At least annually, and whenever significant changes occur to the ISMS scope, risk assessment results, or business context.

Approval: Executive Committee approves new versions.

Linkage: Each row references the controlling Cirque policy/procedure and the SOC 2 TSC criteria. Strike Graph control IDs (CC-001 through CC-058) are maintained in a parallel matrix at IS-APM02-CIRQ01-A02A-SOC2-Mapping (forthcoming) and reconcile with this SoA.

5. Statement of Applicability — All ISO/IEC 27001:2022 Annex A Controls

Total controls: 93. **Applicable:** 93. **Excluded:** 0.

Legend: **Y** = Applicable; **X** = Excluded with documented justification.

A.5
Organizational
Controls

Control

Title

Applicable

Justification

Cirque Reference

SOC 2 TSC

A.5.1

Policies for information security

Y

Foundational requirement of the ISMS; establishes the entire policy framework.

IS-APM01-CIRQ01-A00 (Master); all P-series policies

CC1.1, CC1.2, CC2.2, CC5.3

A.5.2

Information security roles and responsibilities

Y

Required to define ISMS governance and accountability.

IS-AHR01-CIRQ01-A00; IS-AHR01-CIRQ01-F01A

CC1.2, CC1.3, CC1.4, CC1.5

A.5.3

Segregation of duties

Y

Reduces fraud and error risk; explicitly required for SOC 2 (e.g., change management, access reviews).

IS-AHR01-CIRQ01-A00; IS-AIR01-CIRQ07-A00; IS-AIR01-CIRQ04-A00

CC1.3, CC5.1, CC6.1, CC8.1

A.5.4

Management responsibilities

Y

Top-management commitment is mandatory under ISO 27001 Clause 5 and SOC 2 CC1.2.

IS-APM01-CIRQ01-A00 Section 5; IS-LMG-CIRQ04-A00

CC1.1, CC1.2

A.5.5

Contact with authorities

Y

Required for incident notification (state AGs, FTC, China CAC, Taiwan authorities).

IS-AMG01-CIRQ01-A00; IS-AMG01-CIRQ02-A00/US/ASIA

CC2.3, CC7.4

A.5.6

Contact with special interest groups

Y

Cirque maintains contacts with industry security groups (e.g., MS-ISAC, vendor advisories) for threat intelligence.

IS-LMG-CIRQ01-A00; IS-AIR01-CIRQ09-A00

CC4.1, CC7.1

A.5.7

Threat intelligence

Y

Continuous threat awareness is required to maintain risk-based control selection.

IS-LMG-CIRQ01-A00; IS-AIR01-CIRQ09-A00; IS-AAR05-CIRQ02-A00 Section 4.2.c

CC3.2, CC3.4, CC4.1, CC7.1

A.5.8

Information security in project management

Y

Security requirements integrated into all engineering projects (firmware, ASIC, software, touchpads).

IS-AAR05-CIRQ01-A00; IS-AAR05-CIRQ02-A00

CC3.4, CC8.1

A.5.9

Inventory of information and other associated assets

Y

Asset inventory is the foundation for protective control selection.

IS-AAR01-CIRQ01-A00; IS-AAR01-CIRQ01-F01A; IS-AAR01-CIRQ03-A00

CC2.1, CC6.1

A.5.10

Acceptable use of information and other associated assets

Y

All employees must be governed by an Acceptable Use Policy.

IS-AHR01-CIRQ02-A00

CC1.4, CC2.2, CC6.1, CC6.7

A.5.11

Return of assets

Y

Required as part of the leaver workflow.

IS-AIR01-CIRQ04-A00; IS-AFR01-CIRQ04-A00; IS-AAR01-CIRQ01-A00

CC6.3, CC6.5

A.5.12

Classification of information

Y

Four-tier classification (Confidential / Restricted / Internal / Public) drives encryption, access, and disposal rules.

IS-AAR01-CIRQ02-A00; IS-AAR01-CIRQ03-A00

CC6.1, CC6.5, C1.1

A.5.13

Labelling of information

Y

Document headers and file naming convention used to indicate classification.

IS-AAR01-CIRQ02-A00; IS-AAR01-CIRQ03-A00

CC6.1, C1.1

A.5.14

Information transfer

Y

Cirque transfers IP (CAD, schematics, firmware) to/from customers and contract manufacturers; rules required.

CC6.7, C1.1, C1.2

A.5.15

Access control

Y

Logical access control is the central security control set for SOC 2.

IS-AIR01-CIRQ01-A00; IS-AIR01-CIRQ04-A00

CC6.1, CC6.2, CC6.3

A.5.16

Identity management

Y

Unique identification of users required; managed via Microsoft 365 / Entra ID.

IS-AIR01-CIRQ01-A00; IS-AIR01-CIRQ04-A00

CC6.1, CC6.2

A.5.17

Authentication information

Y

Password and MFA standards required.

IS-AIR01-CIRQ01-A00; IS-AIR01-CIRQ04-A00; IS-AIR01-CIRQ02-A00

CC6.1, CC6.6

A.5.18

Access rights

Y

Provisioning, modification, revocation, and periodic review of access rights.

IS-AIR01-CIRQ01-A00; IS-AIR01-CIRQ04-A00; IS-AIR01-CIRQ05-A00

CC6.1, CC6.2, CC6.3

A.5.19

Information security in supplier relationships

Y

Supplier security requirements are critical given Cirque's IP-sharing relationships.

IS-ASR01-CIRQ01-A00; IS-ASR01-CIRQ02-A00

CC9.2, C1.1

A.5.20

Addressing information security within supplier agreements

Y

Contracts must include security clauses, NDA, DPA where applicable.

IS-ASR01-CIRQ01-A00; IS-ASR01-CIRQ02-A00

CC9.2

A.5.21

Managing information security in the ICT supply chain

Y

ICT supply chain controls especially relevant for ASIC tooling and firmware components.

IS-ASR01-CIRQ01-A00; IS-ASR01-CIRQ02-A00; IS-AAR05-CIRQ02-A00

CC9.2

A.5.22

Monitoring, review and change management of supplier services

Y

Annual vendor reassessment and change-impact review required.

IS-ASR01-CIRQ02-A00; IS-AIR01-CIRQ07-A00

CC9.2

A.5.23

Information security for use of cloud services

Y

Cirque uses Microsoft 365, Azure, GitLab cloud, NetSuite, Salesforce, Okta, ADP, QuickBooks Online.

IS-ASR01-CIRQ01-A00; IS-ASR01-CIRQ02-A00; IS-AAR05-CIRQ01-A00

CC6.6, CC9.2

A.5.24

Information security incident management planning and preparation

Y

Incident management policy and IR procedure required for SOC 2 CC7.3-CC7.5.

IS-AMG01-CIRQ01-A00; IS-AMG01-CIRQ02-A00/US/ASIA

CC7.3, CC7.4, CC7.5

A.5.25

Assessment and decision on information security events

Y

Severity matrix required to triage events vs. incidents.

IS-AMG01-CIRQ01-A00; IS-AMG01-CIRQ02-A00

CC7.3

A.5.26

Response to information security incidents

Y

Documented IR workflow with containment, eradication, recovery.

IS-AMG01-CIRQ02-A00

CC7.4

A.5.27

Learning from information security incidents

Y

Post-incident review and CAR linkage required.

IS-AMG01-CIRQ02-A00; IS-AMR03-CIRQ02-A00; IS-LMR-CIRQ04-A00

CC4.2, CC9.1

A.5.28

Collection of evidence

Y

Forensic chain of custody for incidents that may lead to legal action.

IS-AMG01-CIRQ02-A00; IS-AIR01-CIRQ09-A00

CC7.4

A.5.29

Information security during disruption

Y

Continuity of confidentiality controls during disruption.

IS-LIR-CIRQ01-A00; IS-LIG-CIRQ01-A00

CC7.5, C1.1

A.5.30

ICT readiness for business continuity

Y

Backup, failover, and DR test cadence required.

CC7.5, CC9.1

A.5.31

Legal, statutory, regulatory and contractual requirements

Y

Tracked in legal/regulatory register.

IS-AMR01-CIRQ01-F01A; IS-AMR01-CIRQ01-F02A; IS-AMR01-CIRQ01-F03A; IS-AMR01-CIRQ01-A00

CC1.1

A.5.32

Intellectual property rights

Y

Cirque protects its own IP (ASIC designs, firmware) and respects third-party IP (Cadence licenses, etc.).

IS-AHR01-CIRQ02-A00; IS-ASR01-CIRQ01-A00

C1.1

A.5.33

Protection of records

Y

Required for retention of audit, compliance, and legal records.

IS-AMR04-CIRQ01-A00; IS-AMR04-CIRQ02-A00

C1.1

A.5.34

Privacy and protection of PII

Y

Privacy policies cover GDPR-style principles even though Privacy TSC is out of SOC 2 scope.

IS-AAR02-CIRQ01-A00/US/ASIA

C1.1, C1.2

A.5.35

Independent review of information security

Y

Independent reviewer (Exec Cmte member or external) audits IT-owned controls.

IS-AMR02-CIRQ03-A00; IS-LMG-CIRQ04-A00; IS-APM01-CIRQ01-A00 Section 6

CC4.1, CC4.2

A.5.36

Compliance with policies, rules and standards for information security

Y

Internal audit and management review verify compliance.

IS-AMR01-CIRQ01-A00; IS-AMR02-CIRQ03-A00

CC4.1, CC4.2

A.5.37

Documented operating procedures

Y

All security-relevant procedures documented (PR-001 through PR-025).

All IS-CIRQ-PR-* procedures

CC2.1, CC5.3

**A.6 People
Controls**

Control

Title

Applicable

Justification

Cirque Reference

SOC 2 TSC

A.6.1

Screening

Y

Pre-employment screening required where legally permitted; HR-owned.

CC1.4

A.6.2

Terms and conditions of employment

Y

Employment contracts must include security and confidentiality clauses.

HR Contracts; IS-AHR01-CIRQ02-A00; NDAs

CC1.4, CC1.5

A.6.3

Information security awareness, education and training

Y

Annual training plus phishing simulation cadence required.

IS-AHR02-CIRQ01-A00; IS-AHR02-CIRQ02-A00; IS-AHR02-CIRQ01-F01A

CC1.4, CC2.2

A.6.4

Disciplinary process

Y

Documented sanctions process required for SOC 2 CC1.5.

HR Disciplinary Policy (referenced from IS-AHR01-CIRQ02-A00); IS-AMR03-CIRQ01-A00

CC1.5

A.6.5

Responsibilities after termination or change of employment

Y

Post-termination obligations (NDA, IP) and access removal required.

IS-AIR01-CIRQ01-A00; IS-AIR01-CIRQ04-A00; HR Offboarding

CC6.3, C1.1

A.6.6

Confidentiality or non-disclosure agreements

Y

NDAs required for employees, contractors, and vendors handling Confidential data.

IS-ASR01-CIRQ01-A00; HR onboarding; vendor contracts

C1.1

Remote working

Y

Cirque has authorized remote workers in the US, Taiwan, and China.

IS-AHR01-CIRQ03-A00

CC6.1, CC6.6, CC6.7, C1.2

A.6.8

Information security event reporting

Y

All employees can report security events; reporting channel documented.

IS-LMR-CIRQ02-A00; IS-AMG01-CIRQ01-A00; IS-AMG01-CIRQ01-F01A

CC2.2, CC7.3

A.7 Physical Controls

Control

Title

Applicable

Justification

SOC 2 TSC

A.7.1

Physical security perimeters

Y

Sandy, UT HQ and Taipei, Taiwan office both have controlled perimeters.

IS-AFR01-CIRQ01-A00; IS-AFR01-CIRQ03-A00

CC6.4

A.7.2

Physical entry

Y

Badge-based access via Unifi Access system.

IS-AFR01-CIRQ03-A00

CC6.4

A.7.3

Securing offices, rooms and facilities

Y

Server rooms and ASIC labs require additional access controls.

IS-AFR01-CIRQ01-A00; IS-AFR01-CIRQ03-A00

CC6.4

A.7.4

Physical security monitoring

Y

CCTV and access logs reviewed; coverage to be confirmed in policy update.

IS-AFR01-CIRQ01-A00; IS-AFR01-CIRQ03-A00

CC6.4, CC7.2

A.7.5

Protecting against physical and environmental threats

Y

Environmental monitoring (temp, humidity, fire suppression) for server rooms.

IS-AFR01-CIRQ01-A00; IS-AFR01-CIRQ04-A00

CC6.4

A.7.6

Working in secure areas

Y

Rules for working in server rooms and ASIC labs.

IS-AFR01-CIRQ01-A00; IS-AFR01-CIRQ02-A00

CC6.4, C1.2

A.7.7

Clear desk and clear screen

Y

Mandatory across all locations including remote workers.

IS-AFR01-CIRQ02-A00

CC6.1, CC6.4, C1.2

A.7.8

Equipment siting and protection

Y

Server placement, UPS, environmental protection.

IS-AFR01-CIRQ01-A00; IS-AFR01-CIRQ04-A00

CC6.4

A.7.9

Security of assets off-premises

Y

Laptops and mobile devices used by remote workers and travelers.

IS-AHR01-CIRQ03-A00; IS-AFR01-CIRQ04-A00; IS-AAR01-CIRQ01-A00

CC6.1, CC6.7

A.7.10

Storage media

Y

Removable media handling rules; removable media generally restricted.

IS-AAR01-CIRQ01-A00; IS-AAR01-CIRQ03-A00; IS-AFR01-CIRQ02-A00

CC6.1, CC6.7, C1.2

A.7.11

Supporting utilities

Y

UPS for critical systems; HVAC for server rooms.

IS-AFR01-CIRQ04-A00

CC6.4

A.7.12

Cabling security

Y

Network cabling protected from interception and damage.

IS-AFR01-CIRQ04-A00; IS-AIR01-CIRQ10-A00

CC6.4, CC6.6

A.7.13

Equipment maintenance

Y

Documented maintenance procedures.

IS-AFR01-CIRQ04-A00

CC6.4

A.7.14

Secure disposal or re-use of equipment

Y

Hardware destruction follows NIST 800-88 with certificate of destruction.

IS-AFR01-CIRQ04-A00; IS-AAR01-CIRQ01-A00

C1.2

A.8 Technological Controls

Control

Title

Applicable

Justification

Cirque Reference

SOC 2 TSC

A.8.1

User endpoint devices

Y

Endpoints managed via Intune; Defender for Endpoint installed.

IS-AIR01-CIRQ01-A00; IS-AHR01-CIRQ03-A00; IS-AFR01-CIRQ04-A00

CC6.1, CC6.8

A.8.2

Privileged access rights

Y

Separate privileged accounts; quarterly review required.

IS-AIR01-CIRQ05-A00

CC6.1, CC6.2, CC6.3

A.8.3

Information access restriction

Y

Need-to-know enforced via RBAC across all systems.

IS-AIR01-CIRQ01-A00; IS-AIR01-CIRQ04-A00; IS-AAR01-CIRQ02-A00

CC6.1, CC6.3

A.8.4

Access to source code

Y

Source code in GitLab; access restricted by repository.

CC6.1, CC6.3

A.8.5

Secure authentication

Y

MFA mandated for all M365 accounts and internet-facing systems.

IS-AIR01-CIRQ01-A00; IS-AIR01-CIRQ04-A00

CC6.1, CC6.6

A.8.6

Capacity management

Y

Capacity is monitored even though Availability TSC is out of scope; relevant to confidentiality continuity.

IS-AIR01-CIRQ03-A00; IS-AIR01-CIRQ09-A00

CC7.1, CC7.5

A.8.7

Protection against malware

Y

Defender for Endpoint deployed; daily monitoring (currently In Place per Strike Graph).

IS-AIR01-CIRQ03-A00; IS-AIR01-CIRQ10-A00

CC6.8

A.8.8

Management of technical vulnerabilities

Y

Vulnerability scanning and patching required; auto-patching In Place per Strike Graph.

IS-AIR01-CIRQ03-A00; IS-AIR01-CIRQ10-A00; IS-AAR05-CIRQ03-A00

CC7.1, CC7.2

A.8.9

Configuration management

Y

Hardening baselines for servers, endpoints, network devices.

IS-AIR01-CIRQ03-A00; IS-AIR01-CIRQ07-A00; IS-AIR01-CIRQ10-A00

CC7.1, CC8.1

A.8.10

Information deletion

Y

Retention/deletion per classification; disposal per NIST 800-88.

IS-AAR01-CIRQ02-A00; IS-AAR01-CIRQ01-A00; IS-AFR01-CIRQ04-A00

C1.2

A.8.11

Data masking

Y

Production data must not be used in dev/test without masking.

IS-AAR05-CIRQ01-A00 Section 4.2; IS-AAR05-CIRQ02-A00 Section 4.1

CC6.1, C1.1

A.8.12

Data leakage prevention

Y

Microsoft Purview DLP and policy controls in M365.

IS-AHR01-CIRQ02-A00; IS-AAR01-CIRQ02-A00; IS-AHR01-CIRQ03-A00

CC6.7, C1.2

A.8.13

Information backup

Y

Veeam-based backup with on-site and off-site retention.

IS-AIR01-CIRQ08-A00

CC7.5, C1.1

A.8.14

Redundancy of information processing facilities

Y

DR site and backup infrastructure for critical systems.

IS-LIG-CIRQ01-A00; IS-LIR-CIRQ04-A00

CC7.5

A.8.15

Logging

Y

Logging procedure with defined retention (1 year minimum for security/auth).

IS-AIR01-CIRQ09-A00

CC4.1, CC7.2

A.8.16

Monitoring activities

Y

Continuous monitoring via Defender, Azure Monitor, Unifi Access.

IS-AIR01-CIRQ09-A00; IS-AMR02-CIRQ01-A00

CC4.1, CC7.2

A.8.17

Clock synchronization

Y

NTP-based time synchronization for all systems.

IS-AIR01-CIRQ09-A00 Section 4.3

CC7.2

A.8.18

Use of privileged utility programs

Y

Privileged utility usage logged and restricted.

IS-AIR01-CIRQ05-A00; IS-AIR01-CIRQ09-A00

CC6.1

A.8.19

Installation of software on operational systems

Y

Software installation controlled via Intune; allowlisting where applicable.

IS-AHR01-CIRQ02-A00; IS-AIR01-CIRQ07-A00

CC6.8, CC8.1

A.8.20

Networks security

Y

Firewall, segmentation, perimeter controls.

CC6.6

A.8.21

Security of network services

Y

VPN, DNS, network service hardening.

IS-AIR01-CIRQ10-A00; IS-AHR01-CIRQ03-A00

CC6.6

A.8.22

Segregation of networks

Y

Production / development / management network segregation.

IS-AIR01-CIRQ10-A00; IS-AAR05-CIRQ01-A00 Section 4.2

CC6.6

A.8.23

Web filtering

Y

Web content filtering at perimeter and endpoint.

IS-AIR01-CIRQ10-A00; IS-AHR01-CIRQ02-A00

CC6.6, CC6.8

A.8.24

Use of cryptography

Y (partial — known gap)

TLS 1.2+ in transit fully deployed; cloud-provider encryption at rest via M365/Azure; **endpoint full-disk encryption and on-premise file-server at-rest encryption are not yet deployed** (documented gap with compensating controls per IS-AIR01-CIRQ02-A00 Section 4.6).

IS-AIR01-CIRQ02-A00; IS-AIR01-CIRQ06-A00

CC6.1, CC6.7, C1.1

A.8.25

Secure development life cycle

Y

SDLC including mandatory threat modeling per CAR-2026-001.

IS-AAR05-CIRQ01-A00; IS-AAR05-CIRQ02-A00 v1.1; IS-AAR05-CIRQ03-A00

A.8.26

Application security requirements

Y

Security requirements gathered at design phase; OWASP and MISRA standards referenced.

IS-AAR05-CIRQ02-A00 Section 4.2; IS-AAR05-CIRQ01-A00 Section 4.1

CC8.1

A.8.27

Secure system architecture and engineering principles

Y

Security-by-design and threat modeling in PR-017 v1.1.

IS-AAR05-CIRQ01-A00; IS-AAR05-CIRQ02-A00

CC8.1

A.8.28

Secure coding

Y

Secure coding standards (OWASP for web, MISRA for firmware) applied; SAST in GitLab CI/CD.

IS-AAR05-CIRQ02-A00 Section 4.3, Section 4.8

CC8.1

A.8.29

Security testing in development and acceptance

Y

SAST plus pre-production security testing.

IS-AAR05-CIRQ02-A00; IS-AAR05-CIRQ03-A00

CC7.1, CC8.1

A.8.30

Outsourced development

Y

Cirque uses contract engineering relationships for some firmware/ASIC work; supplier security controls apply.

IS-ASR01-CIRQ01-A00; IS-ASR01-CIRQ02-A00; IS-AAR05-CIRQ01-A00

CC8.1, CC9.2

A.8.31

Y

Dev/test/prod logically and physically separated.

IS-AAR05-CIRQ01-A00 Section 4.2; IS-AAR05-CIRQ02-A00 Section 4.1

CC8.1

A.8.32

Change management

Y

CAB-approved changes with peer review and segregation of duties.

IS-AIR01-CIRQ07-A00; IS-AIR01-CIRQ03-A00; IS-AAR05-CIRQ01-A00

CC8.1

A.8.33

Test information

Y

Test data must not include unmasked production data.

IS-AAR05-CIRQ02-A00 Section 4.1; IS-AAR01-CIRQ02-A00

CC6.1, C1.1

A.8.34

Protection of information systems during audit testing

Y

Audit testing scheduled to avoid disruption; access requests through ticketing.

IS-AMR02-CIRQ03-A00; IS-AIR01-CIRQ07-A00

CC4.1

6. Excluded Controls

None at this time. All 93 Annex A controls are applicable. If exclusions are determined in a future review, each exclusion will be documented in this section with: control ID, control title, justification for exclusion, business unit affected, date of decision, approver, and re-evaluation date.

Confidential — Cirque Corporation Internal
Name

Signature

Date

IT Manager (ISMS Owner)

Chris Wren

Executive Committee Chair

CEO

8. Document History

Version

Date

Changes

1.0

2025-07-01

Initial template release.

2.0

2026-05-08

Full population of all 93 ISO/IEC 27001:2022 Annex A controls with Cirque-specific applicability, justification, document reference, and SOC 2 TSC mapping. Closes Critical Finding C-01 of the SOC 2 Readiness Findings (May 2026).

Part IV — Communication

IS-LMR-CIRQ02-A00: Communication Policy

IS-LMR-CIRQ02-A00: Communication Policy

Standards Name: Communication Policy

Category: ISMS Support Process

Division: Policy

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.1 Effective Date: 2025-07-01 Review Date: 2026-07-01 Approved By: Executive Committee

1. Purpose

SOC 2 Trust Services Criteria Mapping

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC2.1

Obtains or generates relevant, quality information

CC2.2

Internally communicates information

CC2.3

Communicates with external parties regarding matters affecting internal control

The purpose of this policy is to define Cirque's framework for effective internal and external communication regarding its Information Security Management System (ISMS). This policy addresses ISO/IEC 27001:2022 Clause 7.4, ensuring that relevant information security matters are communicated appropriately, consistently, and in a timely manner to interested parties.

2. Scope

This policy applies to all information security-related communications within Cirque, including communications with employees, contractors, management, external parties (e.g., customers, suppliers, regulators, public), and across all Cirque locations (US HQ, Taipei office, and authorized remote work locations).

3. Principles of Communication

Cirque's information security communication is guided by the following principles:

- **Timeliness:** Communications will be issued promptly, especially concerning incidents or significant changes.
- **Clarity and Accuracy:** Information conveyed will be clear, concise, accurate, and understandable to the intended audience.
- **Relevance:** Only necessary and relevant information will be communicated to specific audiences based on their need-to-know.

- **Consistency:** Information security messages will be consistent across different channels and over time.
- **Confidentiality:** Communications containing sensitive information will be handled with appropriate confidentiality.
- **Accountability:** Responsibilities for communication activities will be clearly defined.

4. Communication Requirements

Cirque shall establish what to communicate, when to communicate, with whom to communicate, how to communicate, and who communicates regarding information security.

4.1. What to Communicate: a. The scope of the ISMS and the Information Security Policy. b. Information security objectives. c. Roles, responsibilities, and authorities for information security. d. Results of risk assessments and treatment plans. e. Information security incidents (actual or potential) and their handling. f. Changes to the ISMS, policies, and procedures. g. Performance of the ISMS. h. Relevant legal, regulatory, and contractual requirements. i. Security awareness and training information. j. Opportunities for improvement within the ISMS.

4.2. When to Communicate: a. Upon hiring (initial awareness). b. Annually (refresher awareness, policy updates, objectives review). c. Immediately for incident notifications or critical vulnerabilities. d. Periodically as part of ongoing ISMS operation (e.g., risk reviews, audit findings). e. When significant changes affecting information security occur (e.g., new systems, major process changes).

4.3. With Whom to Communicate (Interested Parties):

- **Internal:**
 - Executive Committee / Top Management
 - IT Manager
 - Department Managers / Process Owners
 - IT Department Personnel
 - All Employees
 - Contractors
- **External (as required):**
 - Customers (e.g., regarding data breaches, security posture)
 - Suppliers/Vendors (e.g., security requirements, supply chain risks)
 - Regulatory and legal authorities (e.g., data protection agencies, industry bodies)
 - Shareholders/Investors
 - Public/Media

4.4. How to Communicate (Communication Channels):

- **Internal:**
 - Company Intranet
 - **Teams channels**
 - **Emails** (general announcements, targeted updates)
 - **Company meetings** (All-Hands, Departmental, Management Review)
 - Formal documentation (policies, procedures, records)

Confidential — Cirque Corporation Internal
– Direct communication by managers

– Training sessions

- **External:**

- Official correspondence (letters, email)
- Website (for public statements)
- Secured portals for customer/supplier information exchange
- Direct contact through designated points of contact (e.g., Legal, IT Manager)
- **For suppliers, communication of security requirements is primarily managed through contractual agreements and verification of security and SOC 2 compliance.**

4.5. Who Communicates (Responsibilities):

- **Executive Committee:** Approves overall communication strategy, communicates high-level commitment, and provides final approval for highly sensitive external communications.
- **IT Manager:** Responsible for managing and coordinating internal ISMS-related communications, particularly technical security alerts, policy/procedure updates, risk assessment results, and initial incident notifications to internal stakeholders. Serves as primary contact for internal ISMS audits/assessments.
- **Department Managers:** Communicate information security requirements and updates relevant to their teams and processes.
- **HR Department:** Communicates information security requirements during onboarding, manages disciplinary communications related to security, and supports general awareness campaigns.
- **Legal Counsel:** Solely responsible for communications related to external breaches impacting legal or regulatory obligations, and for advising on all legal aspects of information security communications.
- **Designated Public Relations/Communications Lead:** Manages official public/media statements, particularly during crisis situations, in coordination with Legal Counsel and the Executive Committee.

5. Related Document

IS-LMG-CIRQ03-A00: ISMS Communication Procedure

6. Policy Review

This policy will be reviewed at least annually, or sooner if significant changes occur to Cirque's organizational structure, communication channels, or regulatory requirements.

IS-LMG-CIRQ03-A00: ISMS Communication Procedure

IS-LMG-CIRQ03-A00: ISMS Communication Procedure

Document: IS-LMG-CIRQ03-A00

Standards Name: ISMS Communication Procedure

Category: ISMS Support Process

Division: Procedure

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** IT Manager

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC2.1

Generation and use of quality information

CC2.2

Internal communication

CC2.3

External communication

The purpose of this procedure is to establish the methods and responsibilities for effective internal and external communication related to Cirque's Information Security Management System (ISMS), in accordance with IS-LMR-CIRQ02-A00: Communication Policy. This procedure ensures that relevant information is delivered to the right audience, at the right time, and through appropriate channels.

2. Scope

This procedure applies to all communications concerning information security within Cirque's ISMS scope, involving all internal personnel and relevant external parties.

3. Responsibilities

- **IT Manager:** Overall owner of this procedure. Manages and coordinates internal ISMS communications. Initiates incident-related internal communications.
- **Department Managers:** Responsible for cascading ISMS-related communications to their teams and providing feedback upwards.
- **HR Department:** Communicates foundational security policies during onboarding and supports general awareness campaigns.
- **Legal Counsel:** Manages all legally required external communications, especially related to data breaches.
- **All Employees/Contractors:** Responsible for actively seeking and understanding ISMS communications, and for reporting security incidents or concerns.

4. Procedure

4.1. Internal ISMS Communication

4.1.1. General Awareness & Policy Updates (Ongoing) a. **What:** Information Security Policy (IS-APM01-CIRQ01-A00), ISMS Objectives (IS-LMR-CIRQ05-A00), general security awareness topics (e.g., phishing prevention, password hygiene, clean desk). b. **When:** * New hires: During onboarding. * All personnel: Annually (refresher training, policy reviews, objectives communication). * Ad-hoc: As new threats emerge or policies are updated. c. **How:** * New Hire Training (managed by HR and IT Manager). * Annual mandatory security awareness

Confidential — Cirque Corporation Internal

training (online modules, workshops). * **Company meetings (All-Hands):** IT Manager or Executive Committee presents high-level ISMS updates, objectives, and policy highlights. * **Teams channels/Email:** Used for general announcements, quick tips, security alerts, and links to updated policies/procedures. * **Company Intranet:** Repository for all ISMS documentation (policies, procedures, forms). d. **Who:** IT Manager, HR Department, Department Managers.

4.1.2. ISMS Performance and Review Communications (Periodic) a. **What:** Results of risk assessments, audit findings (internal/external), ISMS performance metrics (KPIs from IS-LMR-CIRQ05-A00), opportunities for improvement. b. **When:** * **Quarterly:** Review of high risks and incident summaries by IT Manager with relevant Department Managers. * **Annually:** Formal Management Review (Executive Committee, IT Manager, key Department Managers). * **Ad-hoc:** As needed based on significant findings. c. **How:** Formal management review meetings, dedicated reports, team meetings, email summaries. d. **Who:** IT Manager, Executive Committee, Department Managers.

4.1.3. Incident Communication (As Needed - Internal Escalation) a. **What:** Notification of actual or suspected information security incidents. b. **When:** Immediately upon detection or suspicion of an incident. c. **How:** Defined escalation path: * **Employee/Contractor:** Reports incident to IT Manager (or designated IT contact) via email, Teams message, or ticketing system. * **IT Manager:** * Confirms incident. * Notifies Executive Committee. * Notifies relevant Department Managers if their area is affected. * Initiates incident response procedures (IS-AMR04-CIRQ02-A00). * **Executive Committee:** Notified by IT Manager. * **Legal Counsel:** Notified by Executive Committee/IT Manager if a breach or regulatory impact is suspected. * **Affected Internal Parties:** Notified by IT Manager as needed for awareness or action. d. **Who:** All personnel (reporting), IT Manager (coordination), Executive Committee, Legal Counsel, Department Managers.

4.2. External ISMS Communication

4.2.1. Customer and Partner Communications (As Required) a. **What:** Responses to security questionnaires, information on Cirque's security posture, security requirements for partners. b. **When:** Upon request, during contract negotiation, or as required by incidents. c. **How:** Formal documentation, dedicated security portals, direct communication by designated IT or Sales personnel. d. **Who:** IT Manager, Sales, Legal Counsel (for contractual aspects).

4.2.2. Supplier/Vendor Security Communications (Ongoing) a. **What:** Communication of security requirements, verification of compliance (e.g., SOC 2 reports). b. **When:** During vendor selection, contract renewal, and periodic reviews. c. **How:** Included in **contracts and agreements**. Requests for **security and SOC 2 compliance** documentation. d. **Who:** Procurement, IT Manager, Legal Counsel.

4.2.3. Regulatory and Legal Communications (As Required) a. **What:** Data breach notifications, responses to regulatory inquiries, compliance attestations. b. **When:** As mandated by law or regulation, or upon direct request from authorities. c. **How:** Formal legal channels, official government portals. d. **Who:** **Legal Counsel (primary)**, Executive Committee (oversight), IT Manager (technical input).

4.2.4. Public and Media Communications (Crisis Only) a. **What:** Official statements regarding major security incidents or significant security posture changes. b. **When:** During crisis situations requiring public disclosure. c. **How:** Public statements, press releases, company website updates. d. **Who:** Designated Public Relations/Communications Lead, in strict coordination with Legal Counsel and Executive Committee.

5. Documentation of Communication

All significant communications, particularly those related to incidents, audit findings, policy changes, and external interactions, will be documented and retained as evidence of communication. This may include email archives, meeting minutes, formal reports, and signed acknowledgments.

6. Review and Update

This procedure will be reviewed at least annually, or sooner if there are changes to the IS-LMR-CIRQ02-A00: Communication Policy, communication channels, organizational structure, or significant findings from ISMS audits.

7. Related Documents

- IS-LMR-CIRQ02-A00: Communication Policy
- IS-APM01-CIRQ01-A00: Information Security Policy

- IS-LMR-CIRQ05-A00: Information Security Objectives
- IS-AMR04-CIRQ02-A00: Information Security Incident Management Procedure (Next document to draft)
- IS-AMR04-CIRQ01-F01A: Information Security Incident Report Form

Part V — Asset Management and Data Classification

IS-AAR01-CIRQ01-A00: Asset Management Policy

IS-AAR01-CIRQ01-A00: Asset Management Policy

Document: IS-AAR01-CIRQ01-A00

Standards Name: Asset Management Policy

Category: Information Management Regulations

Division: Policy

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.1 **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** Executive Committee

1. Purpose

SOC 2 Trust Services Criteria Mapping

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC6.1

Implements logical and physical controls based on asset inventories

CC6.5

Discontinues logical and physical protections over assets when no longer needed

CC6.7

Restricts the transmission, movement, and removal of information

C1.1

Identifies and maintains confidential information

C1.2

Disposes of confidential information

The purpose of this policy is to establish a framework for the systematic identification, classification, ownership, and protection of all information assets at Cirque. This policy aligns with ISO/IEC 27001:2022 requirements, ensuring that information assets are managed effectively to reduce risks, maintain their confidentiality, integrity, and availability, and comply with legal, regulatory, and contractual obligations.

2. Scope

This policy applies to all information assets owned by Cirque, leased by Cirque, or under the custody of Cirque, regardless of their format (electronic, physical, intangible) or location (on-premises, cloud, employee devices). This includes, but is not limited to, hardware, software, data, services, networks, and personnel. **Specifically, this policy also covers the physical security aspects of Cirque offices in the US and Taipei, recognizing them as critical physical information assets.**

3. Principles of Asset Management

Cirque is committed to managing its information assets based on the following principles:

- **Identification:** All information assets within the ISMS scope shall be identified.
- **Ownership:** Clear ownership shall be assigned for each information asset.
- **Classification:** Information assets shall be classified according to their value, criticality, and sensitivity.
- **Protection:** Appropriate controls shall be implemented based on the asset's classification, value, and the results of risk assessments.
- **Lifecycle Management:** Assets shall be managed throughout their entire lifecycle, from acquisition to secure disposal.

4. Asset Identification

4.1. Asset Register: Cirque shall maintain an up-to-date **Information Asset Inventory**. The **RMM (Remote Monitoring and Management) system and Intune are considered the authoritative sources for the asset inventory, with assets being automatically added as agents tag them.** A supplementary spreadsheet may be used for planning or summary purposes, but the RMM/Intune data remains primary. The inventory shall include, at a minimum: * Unique asset identifier * Asset type (e.g., hardware, software, data, service) * Asset description * Location * Assigned owner * Classification level * Responsible department

4.2. Asset Types: Assets to be identified include, but are not limited to: * **Data:** Customer data, intellectual property (e.g., CAD drawings, firmware, software code, ASIC designs), financial records, HR data, project data (e.g., in Asana, GitLab), sales information, and email. * **Software:** Operating systems, applications (e.g., Omnify, Cadence, GitLab, Asana, QuickBooks, Microsoft 365 applications), databases, custom-developed software, firmware. * **Hardware:** Servers, workstations, laptops, mobile devices, networking equipment, manufacturing equipment, storage devices. * **Services:** Cloud services, network services, telecommunication services. * **Physical Assets:** Buildings, offices, rooms, and facilities in the **US and Taipei offices**, and cabinets containing sensitive information. * **People:** Employees, contractors (in terms of their skills and knowledge, and their access to information).

5. Asset Ownership

5.1. Asset Owner Assignment: A clear owner shall be assigned for each information asset or group of assets.

The asset owner is an individual (e.g., Department Manager, IT Manager) with authority and responsibility for managing the asset throughout its lifecycle and ensuring its appropriate protection.**5.2. Responsibilities of Asset Owners:** Asset owners are responsible for: * Determining the classification of their assets. * Ensuring appropriate controls are applied to their assets based on classification and risk assessment. * Reviewing asset records periodically. * Approving access to their assets. * Ensuring secure handling and disposal of their assets. * **For IT-managed assets (servers, endpoints, network devices), the IT Manager acts as the operational custodian, responsible for implementing and maintaining technical controls on behalf of the asset owner.**

6. Asset Classification

6.1. Classification Scheme: Information assets shall be classified based on their sensitivity, value, and criticality to Cirque, considering potential impact if their confidentiality, integrity, or availability were compromised. The primary classification scheme will be: * **Confidential:** Information whose unauthorized disclosure, modification, or destruction would have a **severe adverse impact** on Cirque. Access is strictly limited to authorized individuals on a need-to-know basis. Examples: Proprietary ASIC designs, unreleased product firmware, customer CAD files, sensitive financial data. * **Internal Use:** Information whose unauthorized disclosure, modification, or destruction would have a **moderate adverse impact** on Cirque. Access is limited to Cirque employees and authorized contractors. Examples: Internal procedures, general business communications, non-sensitive project plans. * **Public:** Information that is intended for public consumption and whose disclosure would have **little or no adverse impact** on Cirque. Examples: Marketing materials, public website content, press releases.

6.2. Classification Application: All information assets, including data, systems, and devices, shall be assigned a classification level. This classification will dictate the minimum security controls required for handling, storage, transmission, and disposal of the asset.

7. Asset Handling and Protection

7.1. Protection Controls: Appropriate information security controls shall be implemented for assets based on their classification and the results of risk assessments. This includes, but is not limited to: * Access controls (physical, logical) * Encryption for sensitive data * Backup and recovery procedures * Malware protection (e.g., Windows Defender for Business) * Secure configuration management (e.g., via Intune) * Secure disposal procedures * **Physical security measures for the US and Taipei offices (e.g., entry controls, visitor management, securing sensitive areas).**

7.2. Acceptable Use: All users are responsible for handling Cirque's information assets in accordance with their classification, applicable policies (e.g., Acceptable Use Policy), and procedures.

8. Secure Disposal

8.1. Data and Media Sanitization: Information on all media (electronic and physical) shall be properly sanitized or destroyed when it is no longer required or becomes obsolete, according to its classification level, to prevent unauthorized disclosure. **8.2. Equipment Disposal:** Equipment containing information assets shall be securely disposed of, ensuring that all data is permanently removed or rendered unrecoverable before disposal or re-assignment.

9. Related Documents

- IS-AAR01-CIRQ03-A00: Asset Classification and Handling Procedure
- IS-LMR-CIRQ01-F01A: Risk Assessment Register
- Information Asset Inventory (managed via RMM and Intune)
- IS-APM01-CIRQ01-A00: Information Security Policy

10. Policy Review

This policy will be reviewed at least annually, or sooner if significant changes occur to Cirque's business objectives, asset landscape, or legal/regulatory environment.

[IS-AAR01-CIRQ03-A00: Asset Classification and Handling Procedure](#)

IS-AAR01-CIRQ03-A00: Asset Classification and Handling Procedure

Document: IS-AAR01-CIRQ03-A00

Standards Name: Asset Classification and Handling Procedure

Category: Information Management Regulations

Division: Procedure

Standard Retention: Exist and No Corrections

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC6.1

Asset-based protective controls

CC6.5

Discontinues protections when no longer needed

CC6.7

Restrictions on transmission/movement

C1.1

Identifies confidential information

C1.2

Disposes of confidential information

The purpose of this procedure is to describe the systematic process for classifying, handling, and protecting information assets at Cirque, in accordance with IS-AAR01-CIRQ01-A00: Asset Management Policy. This ensures that appropriate security controls are applied throughout the asset's lifecycle, from creation/acquisition to disposal.

2. Scope

This procedure applies to all Cirque personnel (employees, contractors) and to all information assets within the defined ISMS scope, regardless of type, format, or location.

3. Responsibilities

- **IT Manager:** Manages the authoritative asset inventory (RMM/Intune), oversees the classification process, and ensures technical controls are implemented for assets.
- **Asset Owners (e.g., Department Managers):** Responsible for initially classifying their owned assets, ensuring adherence to handling requirements, and reviewing classifications periodically.

- **All Personnel:** Responsible for understanding and adhering to the asset classification and handling requirements relevant to their roles.

4. Procedure

4.1. Asset Identification and Inventory Management

- Initial Identification:** When a new information asset is acquired or created (e.g., new server, software license, significant new data set), it shall be identified and recorded.
- Automated Tagging (for endpoints/servers):** For IT-managed hardware and software, the **RMM system and Intune agents will automatically tag and inventory assets**. The IT Manager will ensure these systems are configured for comprehensive asset discovery.
- Manual Addition:** For assets not automatically detected (e.g., specific data sets, cloud services, physical documents, critical physical office spaces), the Asset Owner or IT Manager shall manually add them to the central asset inventory.
- Asset Inventory Maintenance:** The IT Manager shall ensure the asset inventory, as managed by RMM/Intune, is regularly updated and accurate.
- Minimum Inventory Data:** Each asset record shall include, at minimum: Unique Asset ID, Asset Type, Description, Location, Asset Owner, Date Acquired/Created, and Initial Classification.

4.2. Asset Ownership Assignment

- For each identified asset, a clear **Asset Owner** shall be assigned by the IT Manager in consultation with relevant Department Managers.
- The Asset Owner is responsible for the overall protection and classification of the asset, while the IT Manager acts as the operational custodian for IT-managed assets.

4.3. Asset Classification

- Initial Classification:** The Asset Owner, with guidance from the IT Manager, is responsible for assigning an initial classification level (Confidential, Internal Use, Public) to each owned asset based on its sensitivity, value, and criticality.
- Classification Criteria:** The classification shall be determined by assessing the potential impact of a compromise to the asset's confidentiality, integrity, and availability, as defined in IS-AAR01-CIRQ01-A00: Asset Management Policy.
- Documentation:** The assigned classification level shall be recorded in the asset inventory.
- Review:** Asset classifications shall be reviewed annually by the Asset Owner or when significant changes to the asset's use, value, or sensitivity occur.

4.4. Asset Handling Requirements (Based on Classification)

All personnel handling information assets must adhere to the following controls based on the asset's classification:

4.4.1. Confidential Information (e.g., CAD designs, firmware, ASIC designs, customer sales data):

- Storage:** Must be stored in secured locations with restricted access (e.g., encrypted network drives, secure cloud storage like SharePoint with strict permissions, dedicated secured folders in GitLab for code). Physical confidential documents must be in locked cabinets or secure rooms.
- Access:** Strict Need-to-Know basis. Access granted only after formal approval by Asset Owner. Logical access controls (user authentication, strong passwords, MFA) are mandatory.
- Transmission:** Must be transmitted using secure, encrypted channels (e.g., encrypted email, secure file transfer protocols, VPN for internal access). Avoid public file-sharing services.
- Processing:** Processed only on secured devices (e.g., company-managed workstations with Windows Defender for Business and Intune policies). Do not process on personal devices unless specifically authorized and secured.
- Physical Handling:** Keep out of sight when not in use. Do not leave unattended on desks. Shred or cross-shred physical documents when no longer needed.

f. **Remote Access:** Only via secure VPN and on company-approved devices.

4.4.2. Internal Use Information (e.g., internal procedures, non-sensitive project plans):

a. **Storage:** Stored on company network drives, SharePoint, or approved cloud services. Physical documents in general office areas but not publicly accessible.

b. **Access:** Access is restricted to Cirque employees and authorized contractors on a need-to-know basis for internal business purposes.

c. **Transmission:** Typically via internal email or company messaging platforms (Teams). For external sharing, consider basic encryption if content is not public.

d. **Processing:** Processed on company devices. Exercise caution on personal devices.

e. **Physical Handling:** Keep in secure office areas. Shred physical documents before discarding.

4.4.3. Public Information (e.g., marketing materials, public website content):

a. **Storage:** May be stored in publicly accessible folders or on the company website.

b. **Access:** No restrictions on access.

c. **Transmission:** May be shared via any unencrypted method.

d. **Processing:** Can be processed on any device.

e. **Physical Handling:** No specific handling requirements beyond general office waste.

4.5. Physical Asset Handling and Protection (US and Taipei Offices)

a. **Entry Controls:** All visitors must sign in and be escorted by an employee. Access badges for employees are mandatory.

b. **Securing Areas:** Critical areas (e.g., server rooms, manufacturing floors, design labs where CAD/ASIC work occurs) will have stricter access controls (e.g., keycard access, biometric scanners if applicable).

c. **Clean Desk Policy:** All personnel must maintain a clean desk, especially in areas where sensitive information is handled, ensuring no confidential documents are left unattended.

d. **Equipment Security:** Workstations and equipment will be physically secured to prevent theft where practical.

e. **Environmental Controls:** Monitoring for temperature, humidity, and fire suppression in server rooms and critical manufacturing areas.

4.6. Secure Disposal of Assets

a. **Data Sanitization:** * **Electronic Media (Hard Drives, SSDs, USBs):** Data on media classified as Confidential or Internal Use must be securely wiped using industry-recognized methods (e.g., NIST SP 800-88 guidelines for sanitization) or physically destroyed (e.g., shredding, degaussing) prior to disposal or re-use. * **Cloud Data:** Ensure data is properly deleted from cloud services following service provider's secure deletion processes.

b. **Physical Documents:** Confidential and Internal Use hard copy documents must be cross-shredded or incinerated when no longer required.

c. **Hardware Disposal:** All hardware (laptops, servers, mobile devices) must have their data-bearing components sanitized or destroyed before being recycled, sold, or discarded. The IT Manager will oversee this process.

5. Review and Update

This procedure will be reviewed at least annually, or sooner if there are changes to IS-AAR01-CIRQ01-A00: Asset Management Policy, changes in asset types, new threats, or updates to legal/regulatory requirements.

6. Related Documents

- IS-AAR01-CIRQ01-A00: Asset Management Policy
- Information Asset Inventory (RMM/Intune)
- IS-LMG-CIRQ01-A00: Information Security Risk Assessment Procedure

- ## IS-AAR01-CIRQ01-F01A: Asset Register

Document: IS-AAR01-CIRQ01-F01A

Category: Information Management Regulations

Standard Retention: Exist and No Corrections

Version: 1.0 Effective Date: 2025-07-01 Review Date: 2026-07-01 Approved By: IT Manager

This **Asset Register** serves as a centralized record for identifying, classifying, and tracking all information assets relevant to Cirque's Information Security Management System (ISMS). It supports the requirements of IS-AAR01-CIRQ01-A00: Asset Management Policy and IS-AAR01-CIRQ03-A00: Asset Classification and Handling Procedure, enabling effective risk management and application of security controls.

This register applies to all information assets owned, leased, or under the custody of Cirque, including hardware, software, data, services, and physical locations within the ISMS scope (US HQ, Taipei office, and authorized remote work locations).

- This register is primarily maintained by the **IT Manager**, leveraging data from the **RMM system and Intune** as authoritative sources.
- Manual entries should be made for assets not automatically detected (e.g., specific data sets, cloud services, physical documents, critical physical office spaces).
- Ensure all fields are completed accurately for each asset.

-
- This register will be reviewed and updated periodically as new assets are acquired/created, or existing assets undergo significant changes or are disposed of.

4. Information Asset Register

Asset ID

Asset Type

Description

Location

Manufacturer/Vendor

Model/Version

Serial Number/License Key

Asset Owner (Department/Individual)

Assigned Classification (Confidential/Internal Use/Public)

Date Acquired/Created

Last Review Date

Disposal Date (if applicable)

Notes (e.g., critical system, specific software dependencies)

Example Entries:

HW-SRV-001

Server (Physical)

Production Web Server

Confidential — Cirque Corporation Internal
US Office - Server Room

Dell

PowerEdge R650

ABC123DEF456

IT Department

Confidential

2024-01-15

2025-06-15

Hosts critical customer-facing applications.

SW-DB-001

Database

Customer Database

Azure Cloud

Microsoft

SQL Server 2019

N/A

Sales Department

Confidential

2023-09-01

2025-06-15

Contains sensitive customer PII.

IP-CAD-001

Data (IP)

ASIC Design Files

GitLab / Fileserver

N/A

V1.2

N/A

Engineering Department

Confidential

2025-06-15

Core intellectual property. Integrated with Cadence.

AP-OMN-001

Software (SaaS)

Omnify ERP System

Cloud

Omnify

Latest

Subscription ID:XYZ

Operations Department

Internal Use

2023-01-01

2025-06-15

Critical for manufacturing process and inventory.

PHY-US-001

Physical Site

US Office Building

South Jordan, UT

N/A

N/A

N/A

Operations/Facilities

Confidential

N/A

2025-06-15

Main corporate and engineering office.

New Entries:

IS-AAR01-CIRQ02-A00: Data Classification Policy

IS-AAR01-CIRQ02-A00: Data Classification Policy

Document: IS-AAR01-CIRQ02-A00

Standards Name: Data Classification Policy

Category: Information Management Regulations

Division: Policy

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 **Effective Date:** 2026-03-02 **Review Date:** 2027-03-02 **Approved By:** Executive Committee

1. Purpose

SOC 2 Trust Services Criteria Mapping

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC6.1

Implements protective controls based on data classification

CC6.5

Discontinues protections when no longer needed (handled per classification tier)

CC6.7

Restrictions on transmission and movement based on classification

C1.1

Identifies and maintains confidential information through formal classification

C1.2

Disposes of confidential information per classification-tier handling rules

The purpose of this policy is to establish a standardized data classification framework that enables Cirque to identify, categorize, and protect information assets based on their sensitivity, criticality, and regulatory requirements. This policy ensures that appropriate safeguards are applied to data throughout its lifecycle, in accordance with ISO/IEC 27001:2022 Annex A.8.2, SOC2:2022 criteria, and applicable data protection regulations (GDPR, CCPA, etc.).

2. Scope

This policy applies to all information and data owned, processed, or stored by Cirque, regardless of format (electronic, physical, verbal), location (on-premises, cloud, personal devices), or whether the data is owned by Cirque or belongs to customers, partners, or other third parties. This includes:

Customer data and personal information

Intellectual property (CAD drawings, firmware, software code, ASIC designs)

Financial records and accounting information

Employee and contractor information

Project management data (Asana, GitLab)

Communications (email, chat, documentation)

System configurations and security information

Backup and archive data

All employees, contractors, consultants, and third parties who access Cirque data are required to comply with this policy.

3. Data Classification Levels

Cirque uses a four-tier data classification framework:

3.1. Confidential (Red/High Risk)

Definition: Data that, if disclosed, would cause severe damage to Cirque's business, legal standing, competitive position, or to customers/partners. Unauthorized access is strictly prohibited.

Examples: - Customer proprietary data and trade secrets - Financial data: budgets, financial statements, pricing strategies - Employee personal information (SSN, salary, medical records) - Intellectual property: ASIC designs, firmware source code, CAD drawings, firmware architecture documentation - Active security vulnerabilities, attack vectors, penetration test results - Executive strategic plans and merger/acquisition information - Encryption keys and cryptographic material - Authentication credentials and tokens

Handling Requirements: - Access strictly limited to authorized personnel with explicit business need - Data must be encrypted at rest (AES-256 or stronger) and in transit (TLS 1.2+) - Storage in approved secure repositories only (encrypted cloud storage, on-premises secure database) - No storage on unencrypted personal devices; must use

Confidential — Cirque Corporation Internal

managed endpoints with MDM - Deletion: Upon termination of use or per legal hold requirements (minimum retention specified by business function) - Transfer: Only via secure, encrypted channels (encrypted email, VPN, secure file transfer) - Logging: All access must be logged and monitored; unusual access patterns flagged for review - Approval: IT Manager and data owner approval required before access or sharing - Contractor/third-party access: Explicit data processing agreements (DPA) required with confidentiality obligations

3.2. Restricted (Yellow/Medium Risk)

Definition: Data that is sensitive and requires protection but is less critical than Confidential data. Disclosure could cause moderate harm or regulatory concern.

Examples: - Customer contact information (name, email, phone) - Internal project plans and schedules - Employee directory information - Operational procedures and runbooks (non-security) - Vendor contracts and pricing - Legal correspondence and advice - Internal performance metrics and KPIs - Quality assurance test data (non-customer data) - Log data containing user activity patterns

Handling Requirements: - Access limited to employees with legitimate business need; stored in role-based environments - Data encryption recommended at rest; required in transit - Storage in approved corporate repositories (shared drives, cloud storage with access controls, managed databases) - May be stored on managed corporate devices only (never on personal devices or unmanaged endpoints) - Deletion: Per data retention policy (typically 3-7 years depending on function) - Transfer: Via secure channels (encrypted email, VPN, secure file transfer); internal sharing requires minimal access controls - Logging: Access logging recommended for compliance and audit - Approval: Data owner approval generally required; IT approval for sharing outside immediate team - Contractor/third-party access: Data processing agreements (DPA) required with standard confidentiality terms

3.3. Internal (Green/Low Risk)

Definition: Data intended for internal use only but not particularly sensitive. Disclosure would cause minimal harm.

Examples: - Internal announcements and company news - Organization charts and team structures - Public-facing website content and marketing materials - General meeting minutes and memos (non-confidential) - Internal training materials and documentation - Published corporate policies and procedures - General audit logs and system performance data - Non-sensitive operational information

Handling Requirements: - Access available to all employees; no special access controls required - Encryption: Not required but recommended for data in transit - Storage: Internal repositories, shared drives, corporate websites - May be stored on company devices; personal device storage permitted if encrypted - Deletion: Per business needs; no strict retention requirement - Transfer: Via standard internal communication channels - Logging: Optional - Approval: Not required - Contractor/third-party access: Generally permitted with standard confidentiality terms

3.4. Public (Blue/Minimal Risk)

Definition: Data that is intentionally released for public distribution. Disclosure causes no harm.

Examples: - Published marketing content and brochures - Publicly released press releases and announcements - Job postings and career information - Published research and technical whitepaper abstracts - General company contact information (main phone, corporate address) - Product documentation (non-proprietary) - Social media content

Handling Requirements: - No access restrictions - Encryption: Not required - Storage: Anywhere - Deletion: Not required; can remain in archives - Transfer: Unrestricted - Logging: Not required - Approval: Not required for external sharing - Contractor/third-party access: No restrictions

4. Data Classification Process

4.1. Classification Responsibility

Data owners are responsible for: - Classifying data within their domain of responsibility - Documenting classification rationale - Communicating classification to relevant stakeholders (custodians, users) - Periodically reviewing and updating classification (at least annually) - Escalating ambiguous classifications to IT Manager + Compliance

4.2. Classification Criteria

When classifying data, consider: - **Legal/Regulatory Requirements:** Does the data fall under GDPR, HIPAA, SOC 2, CCPA, or other compliance frameworks? - **Business Value:** What is the competitive or strategic value of this

data? - **Sensitivity:** How sensitive is this data? Who could be harmed by disclosure? - **Criticality:** How critical is this data to business operations? - **Stakeholder Impact:** Would disclosure harm Cirque, customers, employees, or partners?

4.3. Data Tagging and Labeling

Electronic Data: Metadata tags (sensitivity labels in Microsoft 365, classification fields in databases)

Physical Documents: Red, Yellow, Green, or Blue labels on headers/footers

Containers & Systems: Labels on storage containers, file shares, databases indicating highest classification level contained

4.4. Exceptions & Re-Classification

Regular business review may warrant re-classification to lower category (e.g., Confidential → Restricted after time has passed)

Re-classification to higher category requires IT Manager and data owner approval

Documented exceptions require Executive Committee approval

5. Data Handling Standards by Classification

Requirement

Confidential

Restricted

Internal

Public

Access Control

Need-to-know, Role-based

Role-based, Department-based

All employees

Unrestricted

Encryption at Rest

Confidential — Cirque Corporation Internal
Required (AES-256+)

Recommended

Optional

Not required

Encryption in Transit

Required (TLS 1.2+)

Required

Recommended

Optional

Approval for Access

IT Manager + Owner

Owner

None

None

Device Storage

Managed only

Managed only

Company or managed

Any

Retention

Per legal hold (7y+)

Business need (3-7y)

Business need

Indefinite

Transfer Method

Encrypted channels only

Encrypted channels

Standard channels

Unrestricted

Access Logging

Mandatory + monitored

Recommended

Confidential — Cirque Corporation Internal
Optional

Not required

DPA Required

Yes

Yes

No

No

Third-Party Access

Explicit agreements

Standard terms

Permitted

Permitted

6. Data Lifecycle Management

6.1. Data Creation & Acquisition

Data owners shall identify and classify data upon creation or acquisition

Classification metadata shall be embedded in systems/documents

Approval required before collecting customer/personal data

6.2. Data Use & Processing

Data shall be handled according to its classification level

Access granted on need-to-know basis with role-based controls

Regular access reviews conducted quarterly for Confidential data

Processing restricted to authorized systems and personnel

6.3. Data Retention & Archival

Classified data retained per retention schedules (Confidential: 7+ years, Restricted: 3-7 years, Internal/Public: per business need)

Archived data maintains same classification level as original

Backup systems provide equivalent protection to live data

Archival requests documented with approval

6.4. Data Deletion & Destruction

Deletion/destruction conducted per data retention policy schedules

Confidential data: Securely destroyed (crypto-erasure, secure wipe, or physical destruction for media)

Restricted data: Standard secure deletion (secure wipe or deletion)

Internal/Public data: Standard deletion

7. Special Data Categories

7.1. Personal Data (GDPR/CCPA Scope)

Personal data processed under GDPR or CCPA shall be classified at least as **Restricted** and implement additional controls: - Data Processing Agreements (DPA) with processors - Data subject rights (access, deletion, portability) - Right to be forgotten procedures - Breach notification procedures (72 hours to authorities)

7.2. Encryption Keys & Passphrases

Cryptographic material shall be classified as **Confidential**: - Stored in approved key management systems (Azure Key Vault, etc.) - Access strictly limited to systems requiring decryption - Key rotation: Per NIST guidelines (annual minimum) - Destruction: Cryptographic erasure upon end-of-life

7.3. Payment Card Industry (PCI) Data

If processed, shall be classified as **Confidential**: - PCI DSS compliance required (Annual Audit + Attestation) - Segmented networks from other systems - Point-to-Point Encryption (P2PE) or tokenization mandatory - Stored in PCI-compliant environments only

8. Training & Awareness

All new employees receive data classification training during onboarding

Annual refresher training required for all staff

Department-specific training for data handlers and custodians

Training completion tracked and documented

9. Compliance & Monitoring

9.1. Auditing

Quarterly reviews of data classifications for accuracy

Annual audit of data handling compliance with classification levels

Unclassified data discovery scans (content classification tools)

Access log reviews for unauthorized access attempts

9.2. Incidents & Violations

Data classification violations shall be treated as potential security incidents: - Reported per IS-AMG01-CIRQ01-A00: Information Security Incident Management Policy - Investigated for root cause and impact assessment - Remediation documented and tracked

9.3. Compliance Verification

Data owner certification (annual) that classifications remain accurate

Compliance reports on data handling adherence to classification standards

10. Responsibilities

Role

Responsibility

Executive Committee

Strategic approval of classification framework; oversight of compliance

IT Manager

Administer classification system; manage tools and infrastructure; coordinate audits

Data Owners

Classify data; approve access; certify compliance annually

Data Custodians

Implement controls per classification; handle requests; report incidents

Employees & Contractors

Handle data per classification; report misuse; complete training

Compliance

Audit classification compliance; report violations; recommend improvements

11. Related Policies & Procedures

This policy shall be read in conjunction with: - IS-AAR01-CIRQ01-A00: Asset Management Policy - IS-AIR01-CIRQ01-A00: Access Control Policy - IS-AIR01-CIRQ02-A00: Cryptography Policy - IS-AIR01-CIRQ03-A00: Operations Security Policy - IS-AMG01-CIRQ01-A00: Information Security Incident Management Policy - IS-AAR02-CIRQ01-A00/US/ASIA: Privacy Policy - IS-LMG-CIRQ01-A00: Data Handling & Media Management Procedure - IS-AAR01-CIRQ03-A00: Data Retention & Disposal Procedure

12. Policy Review & Approval

Role

Signature

Date

IT Manager

Executive Committee

13. Document History

Version

Effective Date

Description

1.0

2026-03-02

Initial policy creation; alignment with SOC 2 and ISO 27001 requirements

Document Classification: Internal (Public Distribution Permitted)

Distribution: All Cirque Personnel, Contractors, Third Parties (with NDA)

Part VI — Access Control and Cryptography

IS-AIR01-CIRQ01-A00: Access Control Policy

IS-AIR01-CIRQ01-A00: Access Control Policy

Document: IS-AIR01-CIRQ01-A00

Standards Name: Access Control Policy

Category: IT Security Related

Division: Policy

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.1 **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** Executive Committee

1. Purpose

SOC 2 Trust Services Criteria Mapping

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC6.1

Implements logical access security software, infrastructure, and architectures

CC6.2

Registers and authorizes new internal and external users prior to issuing credentials

CC6.3

Authorizes, modifies, or removes access based on roles and responsibilities

CC6.6

Implements logical access security measures to protect against threats from outside

CC6.7

Restricts the transmission, movement, and removal of information

CC6.8

Implements controls to prevent or detect and act on the introduction of unauthorized or malicious software

The purpose of this policy is to define Cirque's requirements for controlling access to all information assets, systems, applications, networks, and physical facilities. This policy aims to protect Cirque's information from unauthorized access, modification, disclosure, or destruction, in accordance with ISO/IEC 27001:2022 Annex A.8.2. It ensures that access is granted based on the principle of least privilege and need-to-know.

2. Scope

This policy applies to all Cirque personnel (employees, contractors, temporary staff), external users requiring access, and all Cirque information assets, IT systems, applications (e.g., Omnify, Cadence, GitLab, Asana, QuickBooks, Microsoft 365 services), networks, and physical facilities (e.g., US and Taipei offices).

3. Principles of Access Control

Cirque implements access controls based on the following principles:

- **Least Privilege:** Users shall be granted only the minimum access rights necessary to perform their legitimate job functions.
- **Need-to-Know:** Access to information and systems shall be granted only to individuals who require it to perform their assigned duties.
- **Segregation of Duties (SoD):** Conflicting duties and areas of responsibility shall be segregated to reduce the risk of fraud, error, or unauthorized access.
- **Accountability:** All access to information assets shall be logged and attributable to individual users.
- **Regular Review:** Access rights shall be regularly reviewed and updated.

4. User Access Management

4.1. User Registration and De-registration: a. A formal process shall be in place for managing user accounts, covering their entire lifecycle from creation to de-activation/deletion. b. User accounts for computers and internal systems are primarily managed through **Active Directory**. c. User accounts shall be created only upon receipt of formal authorization (e.g., from HR for new hires, from Department Managers for contractors). d. User accounts shall be promptly modified (e.g., role change) or de-activated/deleted upon termination of employment, contract, or change in job function, or if prolonged inactivity is detected.

4.2. User Access Provisioning: a. Access rights shall be formally provisioned based on role, job function, and approved requests. b. Generic or shared accounts are generally prohibited, and individual accountability must be maintained where exceptional use of shared accounts is approved. c. Access to highly sensitive systems or data

(e.g., source code in GitLab, ASIC designs in Cadence, customer sales data in Omnify/QuickBooks) requires specific, documented authorization from the Asset Owner or IT Manager. d. **Access to all internal hosted tools (e.g., GitLab, Asana, QuickBooks, Omnify, Cadence) is restricted to employees only; no external collaborators are permitted.** e. **Guest access to SharePoint for specific documents may be granted on an as-needed basis, strictly controlled by the IT Manager or designated document owner.**

4.3. User Access Review: a. Access rights shall be reviewed periodically (at least annually) or when a user's role changes. This review ensures that access remains consistent with job responsibilities and the principle of least privilege. b. The IT Manager, in collaboration with Department Managers and Asset Owners, is responsible for conducting these reviews, using reports from Active Directory, application logs, and other relevant systems.

5. System and Application Access Control

5.1. Authentication: a. All users shall authenticate to systems and applications using unique credentials managed via **Active Directory or individual application authentication where Active Directory integration is not feasible.** b. Strong password policies (complexity, length, expiry) shall be enforced. c. Multi-Factor Authentication (MFA) shall be implemented for all remote access, privileged access, and access to critical cloud services (e.g., Microsoft 365, GitLab).

5.2. Privileged Access Management: a. Privileged accounts (e.g., administrative accounts within Active Directory or specific applications) shall be strictly controlled and used only when absolutely necessary for system administration tasks. b. Access to privileged accounts shall be logged, monitored, and reviewed regularly. c. Where possible, dedicated privileged accounts, separate from standard user accounts, shall be used.

5.3. Network Access Control: a. Network access shall be controlled through firewalls, network segmentation, and secure network configurations. b. Wireless networks shall be secured with strong encryption (e.g., WPA2 Enterprise) and authentication. c. Remote access to Cirque's internal networks shall only be permitted via a secure VPN connection from company-managed devices, with MFA enforced.

5.4. Operating System and Application Access Control: a. Operating systems and applications shall be configured to enforce access controls (e.g., user groups, permissions lists within Active Directory). b. Default passwords shall be changed, and unnecessary default accounts disabled or removed. c. Session timeouts shall be implemented to lock idle user sessions. d. Device management tools like **Intune** shall be used to enforce security configurations and access policies on endpoints.

6. Physical Access Control

6.1. Secure Areas: a. Access to physical locations containing sensitive information assets (e.g., server rooms, critical engineering labs, storage areas for physical documents) shall be restricted to authorized personnel only. b. Entry to the **US and Taipei offices** shall be controlled via the **Unifi Access system**. c. Visitors shall be controlled (e.g., sign-in, escorted by staff, temporary badges provided by Unifi Access or manually).

6.2. Monitoring: a. Access to secure areas shall be logged by the **Unifi Access system**. b. CCTV surveillance may be used in critical areas.

7. Related Documents

- IS-AIR01-CIRQ04-A00: Access Control Procedure (To be drafted next)
- IS-AAR01-CIRQ01-A00: Asset Management Policy
- IS-AAR01-CIRQ03-A00: Asset Classification and Handling Procedure
- IS-AIR01-CIRQ02-A00: Acceptable Use Policy (Tentative future policy)
- User Access Request Form (maintained in ticketing system and approved by IT Manager)

8. Policy Review

This policy will be reviewed at least annually, or sooner if significant changes occur to Cirque's IT environment, organizational structure, or legal/regulatory requirements.

IS-AIR01-CIRQ04-A00: Access Control Procedure

IS-AIR01-CIRQ04-A00: Access Control Procedure

Standards Name: Access Control Procedure

Category: IT Security Related

Division: Procedure

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 Effective Date: 2025-07-01 Review Date: 2026-07-01 Approved By: IT Manager

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC6.1

Logical access controls

CC6.2

User registration and authorization

CC6.3

Access modification / removal based on roles

The purpose of this procedure is to detail the systematic process for granting, modifying, reviewing, and revoking user access to Cirque's information assets, systems, applications, networks, and physical facilities. This procedure ensures adherence to IS-AIR01-CIRQ01-A00: Access Control Policy and the principles of least privilege and need-to-know.

2. Scope

This procedure applies to all Cirque personnel (employees, contractors), external parties requiring limited access (e.g., SharePoint guest access), and all relevant information assets, IT systems, applications, networks, and physical facilities across all Cirque locations (US HQ, Taipei office, and authorized remote work locations).

3. Responsibilities

- **IT Manager:** Overall owner of this procedure. Manages user accounts in Active Directory and other systems. Configures and manages Unifi Access. Conducts access reviews.
- **HR Department:** Initiates onboarding and offboarding processes for employees and contractors, providing necessary documentation for account creation/deletion.
- **Department Managers/Asset Owners:** Responsible for approving access requests for their direct reports and for assets they own.

- **All Personnel:** Responsible for protecting their login credentials and adhering to all access control policies and procedures.

4. Procedure

4.1. User Access Request and Provisioning

4.1.1. New User Onboarding (Employees)

- HR Notification:** HR notifies the IT Manager of a new hire, providing start date, role, department, and initial access requirements (e.g., standard employee access profile).
- Active Directory Account Creation:** IT Manager creates a unique user account in **Active Directory**.
- System Access Provisioning:** IT Manager provisions access to standard applications (e.g., Microsoft 365, Teams) based on the employee's role. Access to specialized applications (e.g., Omnify, Cadence, GitLab, Asana) requires specific approval from the relevant Department Manager/Asset Owner.
- MFA Enrollment:** New users are required to enroll in Multi-Factor Authentication (MFA) for their Microsoft 365/Azure AD account and any other critical systems.
- Physical Access (US/Taipei Offices):** HR coordinates with the IT Manager to provision physical access credentials (e.g., keycard in **Unifi Access system**) based on the employee's role and need for access to specific office areas.
- Initial Security Awareness:** New users receive initial information security awareness training, including access control policies.

4.1.2. Contractor/Temporary Staff Onboarding

- Department Manager Request:** Department Manager submits a formal request to the IT Manager, specifying contractor name, start/end dates, required access (least privilege basis), and the business justification.
- Account Creation/Provisioning:** IT Manager creates temporary accounts in **Active Directory** and provisions access based on the approved request. All contractor access is time-limited.
- Physical Access:** If physical office access is required, the Department Manager requests it, and the IT Manager provisions temporary access in **Unifi Access**.
- Security Acknowledgement:** Contractors must acknowledge understanding of Cirque's security policies before access is granted.

4.1.3. Role Change / Access Modification

- Manager Request:** Employee's manager submits a formal request to the IT Manager detailing the change in role and the corresponding access modifications (additions or removals).
- Access Adjustment:** IT Manager adjusts permissions in **Active Directory** and relevant applications based on the principle of least privilege. Permissions no longer needed are immediately revoked.

4.2. User Access De-registration / Offboarding

4.2.1. Employee Termination

- HR Notification:** HR notifies the IT Manager of an employee's termination date and time.
- Immediate Account De-activation:** The IT Manager shall immediately de-activate (disable) the employee's **Active Directory account** and all associated system/application accounts (e.g., Microsoft 365, GitLab, Omnify) upon notification. Accounts will not be deleted immediately but retained as disabled for a defined period (e.g., 90 days) for auditing and data retention purposes.
- Physical Access Revocation:** Physical access credentials (e.g., Unifi Access keycard) are immediately revoked/collected.
- Device Retrieval:** Company-issued devices are collected by HR or IT.
- Data Transfer/Backup:** Relevant data from the user's accounts/devices is transferred to the manager or backed up as per data retention policies.

4.2.2. Contractor/Temporary Staff Offboarding

- a. **Manager Notification:** Department Manager notifies the IT Manager of the contractor's end date.
- b. **Account De-activation/Deletion:** The IT Manager de-activates accounts immediately upon the contract end date. For contractors, accounts may be deleted sooner than employee accounts if no data retention requirements exist.
- c. **Physical Access Revocation:**
Immediate revocation of Unifi Access credentials.

4.3. Access Review (Regular)

- a. **Frequency:** The IT Manager shall conduct formal access reviews at least annually for all Active Directory users, application-specific accounts, and physical access permissions. Ad-hoc reviews may be conducted for privileged accounts or high-risk systems more frequently.
- b. **Review Process:** * The IT Manager generates reports of current access rights for systems, applications, and physical locations. * These reports are sent to the respective Department Managers and Asset Owners for their review and confirmation. * Managers/Owners confirm that all listed access rights are still required and align with the principle of least privilege. * Any unauthorized or unnecessary access identified during the review shall be immediately revoked by the IT Manager.
- c. **Documentation:** Records of access reviews (e.g., signed confirmations, audit trail from review tools) shall be maintained.

4.4. Privileged Access Management

- a. **Dedicated Accounts:** Where possible, separate, non-email-enabled, privileged accounts will be created for administrative tasks in **Active Directory** and critical applications.
- b. **Justification:** Use of privileged accounts requires specific justification and is logged.
- c. **Monitoring:** All activities performed with privileged accounts shall be logged and monitored for suspicious behavior.
- d. **Review:** Privileged access rights will be reviewed more frequently (e.g., quarterly) than standard user access.

4.5. External Access (SharePoint Guest Access)

- a. **Request and Approval:** Guest access to SharePoint is granted only upon documented request from an employee, approved by the relevant Document Owner/Department Manager, and the IT Manager.
- b. **Least Privilege:** Access is granted only to the specific documents or folders required, with read-only permissions by default, unless write access is explicitly justified and approved.
- c. **Time-Limited:** Guest access accounts shall be time-limited and reviewed periodically for continued necessity.
- d. **Monitoring:** Guest access activity should be logged and monitored within SharePoint.

5. Documentation

All access requests, approvals, modifications, and revocations shall be documented. This includes:

- User access request forms (manual or electronic).
- Email approvals.
- Logs from Active Directory, Unifi Access, SharePoint, and other application access management systems.
- Access review reports.

6. Review and Update

This procedure will be reviewed at least annually, or sooner if there are changes to IS-AIR01-CIRQ01-A00: Access Control Policy, Cirque's IT environment (e.g., new identity management systems), or legal/regulatory requirements.

7. Related Documents

- IS-AIR01-CIRQ01-A00: Access Control Policy
- IS-AAR01-CIRQ01-A00: Asset Management Policy
- IS-AAR01-CIRQ03-A00: Asset Classification and Handling Procedure
- IS-AHR01-CIRQ02-A00: Acceptable Use Policy
- User Access Request Form

IS-AIR01-CIRQ05-A00: Privileged Access Management Procedure

IS-AIR01-CIRQ05-A00: Privileged Access Management Procedure

Document: IS-AIR01-CIRQ05-A00

Standards Name: Privileged Access Management Procedure

Category: IT Security Related

Division: Procedure

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** IT Manager

1. Purpose

SOC 2 Trust Services Criteria Mapping

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC6.1

Logical access controls applied to privileged accounts

CC6.2

Authorization of privileged credentials

CC6.3

Modification / removal of privileged access

CC6.6

Protection against external threats via segregated privileged access

The purpose of this procedure is to define the requirements and processes for the secure management of privileged access within Cirque's IT environment. This procedure aims to minimize the risks associated with the

2. Scope

This procedure applies to all privileged accounts and credentials across Cirque's information systems, networks, applications, and infrastructure, regardless of location (on-premises, cloud services). This includes, but is not limited to:

- Domain Administrator accounts (Active Directory)
- Local Administrator accounts on servers and workstations
- Database Administrator accounts
- Application Administrator accounts (e.g., Omnify, Cadence, GitLab, Asana, Microsoft 365, QuickBooks)
- Network device administrator accounts (e.g., firewalls, switches)
- Cloud service provider administrative accounts (e.g., Azure, AWS)
- Physical access control system administrators (e.g., Unifi Access)
- Service accounts with elevated privileges

3. Definitions

- **Privileged Account:** Any user account, service account, or shared account that has elevated permissions beyond those of a standard user, allowing it to perform critical system functions, access sensitive data, or configure/modify system settings.
- **Just-in-Time (JIT) Access:** A method of granting elevated privileges for a limited time and specific task, typically expiring automatically.
- **Need-to-Use:** The principle that privileged access is only granted when it is absolutely necessary for a specific, authorized task.

4. Responsibilities

- **IT Manager:** Overall owner of this procedure. Responsible for managing privileged accounts, enforcing privileged access policies, conducting regular reviews, and monitoring privileged activity.
- **System Administrators / IT Personnel:** Responsible for using privileged accounts strictly in accordance with this procedure.
- **Executive Committee:** Approves high-level strategy for privileged access and provides necessary resources.

5. Procedure

5.1. Identification of Privileged Accounts a. The IT Manager shall maintain a comprehensive inventory of all identified privileged accounts, including their purpose, associated systems, and the individuals authorized to use them. b. This inventory shall be reviewed at least quarterly.

5.2. Creation and Management of Privileged Accounts a. **Dedicated Accounts:** Wherever possible, separate, individual accounts shall be created for each administrator requiring privileged access. These accounts shall be distinct from their standard user accounts. * Example: An administrator named "John Doe" would have a standard user account (johndoe) for daily tasks and a separate privileged account (jd-admin) for administrative functions. b. **Unique Credentials:** Each privileged account shall have a unique, strong password. c. **Minimal Privileges:** Privileged accounts shall be configured with the absolute minimum set of permissions necessary to perform their intended function (least privilege principle). d. **Generic/Shared Accounts:** Use of generic or shared privileged accounts (e.g., "administrator") is strictly prohibited unless technically unavoidable. In such cases, usage must be strictly controlled, logged, monitored, and reviewed, with individual accountability ensured through other means (e.g., session recording, strict check-out/check-in process).

5.3. Authentication for Privileged Access a. **Strong Passwords:** All privileged accounts shall enforce Cirque's strong password policy (complexity, length, non-repetition). b. **Multi-Factor Authentication (MFA):** MFA shall be mandatory for all privileged accounts, including **Active Directory domain administrator accounts**, access to critical cloud platforms (e.g., Azure, Microsoft 365 Admin Centers), and network device administration. c. **Secure Workstations:** Privileged administrative tasks shall ideally be performed from designated, hardened administrative workstations that are logically separated from standard user networks and services.

5.4. Granting and Revoking Privileged Access a. **Formal Request & Approval:** All requests for new or modified privileged access must be formally documented (e.g., via a ticketing system or email approval) and approved by the IT Manager and/or relevant Department Manager. The request must include a clear business justification and the duration for which access is required. b. **Time-Limited Access (Just-in-Time):** Where possible, privileged access shall be granted on a time-limited (Just-in-Time) basis, automatically expiring after a specified duration (e.g., 4 or 8 hours) or upon completion of the task. c. **Prompt Revocation:** Privileged access shall be immediately revoked when no longer required due to role changes, termination of employment/contract, or completion of a specific task.

5.5. Monitoring and Logging of Privileged Activity a. **Comprehensive Logging:** All activities performed using privileged accounts shall be extensively logged on all relevant systems (**Active Directory, server event logs, application logs, network device logs, cloud platform audit logs**). Logs shall include user, date/time, action performed, and system/resource accessed. b. **Centralized Logging:** Logs from privileged activity should be sent to a centralized log management system for correlation and analysis. c. **Alerting:** Alerts shall be configured for suspicious or unauthorized activities involving privileged accounts (e.g., multiple failed login attempts, access to unusual resources, changes to critical configurations). d. **Regular Review:** The IT Manager shall regularly review privileged access logs (e.g., daily for critical systems, weekly for others) for anomalies or policy violations.

5.6. Periodic Review of Privileged Access a. The IT Manager shall conduct a formal review of all privileged accounts and their associated access rights at least **quarterly**. b. This review includes: * Verifying continued need for each privileged account. * Confirming that assigned permissions align with least privilege. * Identifying and disabling dormant or unnecessary privileged accounts. * Reviewing audit trails of privileged activity. c. Documentation of the review findings and any actions taken shall be maintained.

5.7. Secure Configuration and Maintenance a. Privileged accounts, systems, and tools shall be securely configured (e.g., following hardening guides like CIS benchmarks) and regularly patched. b. Shared secrets (e.g., service account passwords) shall be managed securely within a password vault solution if applicable.

6. Training and Awareness

All personnel granted privileged access shall receive specific training on the requirements of this procedure, the responsible use of privileged accounts, and the potential impact of misuse.

7. Related Documents

- IS-AIR01-CIRQ01-A00: Access Control Policy
- IS-AIR01-CIRQ04-A00: Access Control Procedure
- IS-AMR04-CIRQ02-A00: Document Control Procedure (for managing this procedure)
- IS-APM01-CIRQ01-A00: Information Security Policy

8. Procedure Review

This procedure will be reviewed at least annually, or sooner if significant changes occur to Cirque's IT infrastructure, threat landscape, or relevant regulations.

IS-AIR01-CIRQ02-A00: Cryptography Policy

IS-AIR01-CIRQ02-A00: Cryptography Policy

Document: IS-AIR01-CIRQ02-A00

Standards Name: Cryptography Policy

Category: IT Security Related

Division: Policy

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 Effective Date: 2025-07-01 Review Date: 2026-07-01 Approved By: Executive Committee

1. Purpose

SOC 2 Trust Services Criteria Mapping

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC6.1

Implements protective controls including encryption

CC6.7

Restricts the transmission, movement, and removal of information through encryption

C1.1

Identifies and maintains confidential information through encryption controls

C1.2

Disposes of confidential information including secure key destruction

The purpose of this policy is to establish Cirque's requirements for the effective and appropriate use of cryptographic controls to protect the confidentiality, integrity, and authenticity of information. This policy aligns with ISO/IEC 27001:2022 Annex A.8.24, ensuring that cryptographic solutions are implemented to mitigate risks to information assets throughout their lifecycle, including storage, processing, and transmission.

2. Scope

This policy applies to all Cirque personnel (employees, contractors), and to all information, information systems, applications, and communications, where cryptographic controls are deemed necessary based on risk assessments, legal, regulatory, or contractual requirements. This includes information related to intellectual property (e.g., CAD drawings, firmware, ASIC designs), customer data, and general business operations, regardless of its location (on-premises, cloud, mobile devices).

3. Principles of Cryptography Use

Cirque's use of cryptography is guided by the following principles:

- **Risk-Based Approach:** Cryptographic controls shall be applied where justified by information security risk assessments and the classification of information assets (e.g., Confidential, Internal Use).

- **Strength and Appropriateness:** Cryptographic algorithms, key lengths, and protocols shall be of appropriate strength for the sensitivity and longevity of the information they protect, and aligned with industry best practices and standards.
- **Key Management:** Cryptographic keys shall be securely generated, stored, distributed, used, backed up, and recovered, and destroyed.
- **Compliance:** The use of cryptography shall comply with all applicable legal, regulatory, and contractual obligations.
- **Transparency and Auditability:** The implementation and use of cryptographic controls shall be documented and auditable.

4. Requirements for Cryptographic Controls

4.1. Data at Rest Encryption: a. **Sensitive Data Storage:** Information classified as "Confidential" or "Internal Use" shall be encrypted when stored on endpoints (laptops, workstations), file servers, or portable media. * **Endpoints:** Full Disk Encryption (FDE) shall be deployed on all company-issued laptops and workstations as a target-state control. **Current state (2026-05-08): endpoint FDE is not yet deployed; this is documented as a control gap in the Risk Register and tracked for remediation. Compensating controls are described in Section 4.6.** * **File Servers:** Sensitive data stored on the on-premise file server is not currently encrypted at rest; FDE deployment on the file server is in scope of the same remediation plan. * **Cloud Storage:** Data stored in cloud services (Microsoft 365 / SharePoint, Azure) leverages the encryption-at-rest capabilities provided by the service provider per their SOC 2 attestations. * **Databases:** Databases containing "Confidential" information (e.g., customer data, financial records) shall utilize encryption at rest mechanisms (e.g., Transparent Data Encryption — TDE) where available. b. **Intellectual Property:** All intellectual property, including CAD drawings, firmware, software code stored in **GitLab**, and ASIC designs developed using **Cadence**, are stored in designated repositories. GitLab and other cloud repositories provide encryption at rest via the service provider; on-premise IP storage falls under the file-server gap noted above.

4.2. Data in Transit Encryption: a. **Remote Access:** All remote access to Cirque's internal networks shall be secured using strong cryptographic protocols (e.g., IPsec VPN, TLS 1.2 or higher). b. **External Communications:** Communications with external parties involving "Confidential" or "Internal Use" information (e.g., email, file transfers) shall be encrypted. This includes: * **Email:** Use of secure email gateways enforcing TLS for transit or end-to-end encryption for highly sensitive content. * **Website/Web Applications:** All Cirque websites and web-based applications that collect or transmit sensitive information must use HTTPS with strong TLS protocols. * **File Transfers:** Secure file transfer protocols (e.g., SFTP, FTPS over TLS, secure cloud-based file sharing services with encryption) shall be used for transferring sensitive files externally.

4.3. Cryptographic Key Management: a. **Key Generation:** Cryptographic keys shall be generated using approved, cryptographically strong random number generators. b. **Key Storage:** Keys shall be stored securely, segregated from the encrypted data, and protected against unauthorized access, disclosure, or modification (e.g., hardware security modules (HSMs), secure key vaults, encrypted containers). c. **Key Distribution:** Key distribution shall be performed through secure, authenticated channels. d. **Key Usage:** Keys shall be used only for their intended purpose and by authorized entities. e. **Key Backup and Recovery:** Procedures for secure backup and recovery of cryptographic keys shall be established and tested. f. **Key Destruction:** Keys shall be securely destroyed when they are no longer required. g. **Key Rotation:** Critical cryptographic keys shall be rotated periodically as defined by industry best practices and risk assessments.

4.4. Cryptographic Algorithm Selection: a. Cirque shall use cryptographic algorithms, key lengths, and protocols that are recognized as strong and secure by current industry standards (e.g., NIST, FIPS 140-2 validated modules). b. Deprecated or weak cryptographic algorithms (e.g., MD5, SHA-1 for digital signatures, DES, RC4, SSLv2/v3, TLS 1.0/1.1) shall not be used. The IT Manager is responsible for identifying and mitigating their use.

4.5. Cryptographic Controls for Authentication: a. Cryptographic techniques (e.g., hashing, digital signatures, strong authentication protocols) shall be used to protect authentication information (e.g., passwords) and verify user identities. b. Multi-Factor Authentication (MFA) will be used for privileged access and remote access.

4.6. Known Control Gap — Endpoint and File-Server Full Disk Encryption

Confidential — Cirque Corporation Internal

As of 2026-05-08, Cirque has not yet deployed full-disk encryption to its company-issued laptops, workstations, or the on-premise file server. This is a documented control gap tracked in the Risk Register (IS-LMR-CIRQ01-F01A) with a remediation plan in the Risk Treatment Plan (IS-LMR-CIRQ01-F01A). Disclosure of the gap, the compensating controls below, and the remediation timeline appear in:

IS-APM02-CIRQ01-A02A (Statement of Applicability) — Annex A.8.24 noted with current deployment status.

The SOC 2 Readiness Findings tracker (ISMS-Findings-Tracker.csv) as a Major finding.

The Cirque Control Descriptions register (Disk Encryption row) — honestly reflects current state.

Compensating controls currently in place:

All endpoints are managed via Intune with Microsoft Defender for Endpoint deployed and centrally monitored.

Company-issued devices remain physically secured at the Sandy, UT facility and at authorized remote-work locations (per IS-AHR01-CIRQ03-A00).

Confidential business data is stored primarily in Microsoft 365 / SharePoint and Azure, where the service provider encrypts data at rest per their SOC 2 attestations.

Intune retains remote-wipe capability for company-issued devices reported lost or stolen.

The Acceptable Use Policy (IS-AHR01-CIRQ02-A00) and Clear Desk Policy (IS-AFR01-CIRQ02-A00) require physical safeguarding and prohibit Confidential data on local-only storage.

5. Responsibilities

- **IT Manager:** Responsible for the overall implementation, management, and oversight of cryptographic controls, including selection of algorithms, key management, and ensuring compliance with this policy.
- **System Administrators / IT Personnel:** Responsible for configuring and maintaining cryptographic solutions as per this policy and related procedures.
- **All Personnel:** Responsible for adhering to policies and procedures related to the use of encrypted systems and data (e.g., using VPN for remote access, using approved cloud services for Confidential data, not storing Confidential data on local-only storage until endpoint FDE is deployed).

6. Related Documents

- IS-APM01-CIRQ01-A00: Information Security Policy
- IS-AAR01-CIRQ01-A00: Asset Management Policy
- IS-AAR01-CIRQ03-A00: Asset Classification and Handling Procedure
- IS-AIR01-CIRQ01-A00: Access Control Policy
- IS-AIR01-CIRQ04-A00: Access Control Procedure
- IS-AIR01-CIRQ05-A00: Privileged Access Management Procedure

7. Policy Review

This policy will be reviewed at least annually, or sooner if significant changes occur to Cirque's IT environment, the threat landscape, or new cryptographic vulnerabilities are discovered.

IS-AIR01-CIRQ06-A00: Key Management Procedure

IS-AIR01-CIRQ06-A00: Key Management Procedure

Document: IS-AIR01-CIRQ06-A00

Standards Name: Key Management Procedure

Category: IT Security Related

Division: Procedure

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 Effective Date: 2025-07-01 Review Date: 2026-07-01 Approved By: IT Manager

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC6.1

Cryptographic protective controls

CC6.7

Encryption for data in transit and at rest

C1.1

Maintains confidentiality of information through key management

The purpose of this procedure is to establish the systematic process for managing cryptographic keys throughout their entire lifecycle, from generation to destruction. This procedure ensures the secure and effective use of cryptography in accordance with IS-AIR01-CIRQ02-A00: Cryptography Policy and ISO/IEC 27001:2022 Annex A.8.24, safeguarding the confidentiality, integrity, and authenticity of Cirque's information.

2. Scope

This procedure applies to all cryptographic keys used by Cirque to protect its information assets, including but not limited to:

- Keys for data encryption at rest (e.g., database encryption, cloud-provider keys, future endpoint FDE keys once deployed).
- Keys for data in transit encryption (e.g., VPNs, TLS certificates for websites, secure email gateways).
- Digital signature keys.
- Keys used for Multi-Factor Authentication (MFA).

Scope note: Endpoint Full Disk Encryption (FDE) is not yet deployed at Cirque (see IS-AIR01-CIRQ02-A00 Section 4.6 Known Control Gap). The key-management practices described below for FDE keys apply once FDE is deployed; until then, the FDE-specific clauses are forward-looking.

3. Responsibilities

- **IT Manager:** Overall owner of this procedure. Responsible for ensuring the secure implementation and operation of key management practices, including key generation, storage, distribution, and destruction.
- **System Administrators / IT Personnel:** Responsible for executing key management tasks as directed by the IT Manager and in accordance with this procedure.
- **Cloud Service Providers:** Responsible for their underlying key management practices where Cirque utilizes their native encryption features (e.g., Microsoft 365, Azure). Cirque remains responsible for policy enforcement and configuration of customer-managed keys.

4. Procedure

4.1. Key Generation a. Cryptographic keys shall be generated using approved, cryptographically strong algorithms and robust random number generators. b. Keys for high-assurance applications (e.g., root Certificate Authority keys, master encryption keys) shall be generated in secure, controlled environments, ideally using Hardware Security Modules (HSMs) or equivalent secure cryptographic devices if available. c. Key lengths shall adhere to current industry best practices and IS-AIR01-CIRQ02-A00: Cryptography Policy.

4.2. Key Storage a. **Secure Storage:** Cryptographic keys shall be stored securely, segregated from the encrypted data, and protected against unauthorized access, disclosure, or modification. b. **Designated Locations:** * **Production Keys:** Stored in dedicated key management systems, secure key vaults (e.g., Azure Key Vault), or HSMs. * **System Keys:** Passwords for service accounts or system-level keys may be stored in an approved, encrypted password manager or vault accessible only to authorized IT personnel. * **Endpoint FDE Keys (forward-looking):** When endpoint FDE is deployed (see IS-AIR01-CIRQ02-A00 Section 4.6 Known Control Gap), recovery keys (e.g., BitLocker recovery keys) will be securely stored and managed (e.g., within Intune or Active Directory). c. **Access Control:** Access to key storage locations shall be strictly controlled on a need-to-know basis, with multi-factor authentication for privileged access. d. **Encryption of Stored Keys:** Keys, especially those stored outside of HSMs, shall themselves be encrypted where technically feasible.

4.3. Key Distribution a. **Secure Channels:** Keys shall be distributed only through secure, authenticated, and encrypted channels. b. **No Unsecured Transmission:** Keys must never be transmitted via unencrypted email or other unsecured communication methods. c. **Automated Distribution (forward-looking):** When endpoint FDE is deployed, FDE keys will be managed and distributed via **Intune** (see IS-AIR01-CIRQ02-A00 Section 4.6 Known Control Gap). d. **Manual Distribution:** For manual key exchange (e.g., for VPN pre-shared keys), secure out-of-band methods shall be used (e.g., encrypted communication, physical delivery).

4.4. Key Usage a. **Intended Purpose:** Keys shall be used only for their intended cryptographic purpose (e.g., an encryption key for encryption, a signing key for digital signatures). b. **Least Privilege:** Access to use keys shall be granted based on the principle of least privilege. c. **Logging:** All uses of critical cryptographic keys shall be logged where possible, for auditing purposes.

4.5. Key Backup and Recovery a. **Regular Backups:** All critical cryptographic keys shall be regularly backed up in a secure, encrypted format to ensure availability in case of loss or corruption. b. **Secure Storage for Backups:** Key backups shall be stored in a separate, secure location, distinct from the primary key storage. c. **Recovery Procedures:** Documented procedures for secure key recovery shall be established and regularly tested to ensure integrity and functionality.

4.6. Key Archiving and Rotation a. **Key Archiving:** Keys that are no longer actively used but are still required for decryption of archived data (e.g., for legal retention purposes) shall be securely archived. b. **Key Rotation:** Critical cryptographic keys (e.g., server certificates, VPN keys, database encryption keys) shall be periodically rotated as defined by risk assessments and industry best practices. The rotation frequency will be determined by the IT Manager.

4.7. Key Destruction a. **Secure Destruction:** Keys shall be securely destroyed when they are no longer required and their retention period has expired. b. **Methods:** Destruction methods shall ensure that the keys are irretrievable (e.g., cryptographic erasure for software keys, physical destruction for hardware tokens/HSMs if necessary). c. **Documentation:** The destruction of critical keys shall be documented.

5. Review and Update

This procedure will be reviewed at least annually, or sooner if there are significant changes to Cirque's cryptographic controls, IT environment, threat landscape, or legal/regulatory requirements.

6. Related Documents

- IS-AIR01-CIRQ02-A00: Cryptography Policy
- IS-AAR01-CIRQ01-A00: Asset Management Policy
- IS-AAR01-CIRQ03-A00: Asset Classification and Handling Procedure
- IS-AIR01-CIRQ01-A00: Access Control Policy
- IS-AIR01-CIRQ04-A00: Access Control Procedure
- IS-AIR01-CIRQ05-A00: Privileged Access Management Procedure

Part VII — Physical and Environmental Security

IS-AFR01-CIRQ01-A00: Physical and Environmental Security Policy

IS-AFR01-CIRQ01-A00: Physical and Environmental Security Policy

Document: IS-AFR01-CIRQ01-A00

Standards Name: Physical and Environmental Security Policy

Category: Physical and Environmental Security

Division: Policy

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** Executive Committee

1. Purpose

SOC 2 Trust Services Criteria Mapping

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC6.4

Restricts physical access to facilities and protected information assets

CC6.5

Discontinues logical and physical protections when no longer needed

The purpose of this policy is to establish Cirque's requirements for physical and environmental security to protect its information assets, facilities, and personnel from unauthorized access, damage, theft, and environmental hazards. This policy aligns with ISO/IEC 27001:2022 Annex A.7, ensuring the continued confidentiality, integrity, and availability of information by controlling physical access and protecting against environmental threats.

2. Scope

This policy applies to all Cirque premises, including its **US office in Sandy, Utah, and its Taipei office**, as well as any other locations where Cirque information assets are stored or processed. It covers all physical information assets, IT equipment, documentation, and personnel within these environments.

3. Principles of Physical and Environmental Security

Cirque is committed to maintaining a secure physical and environmental infrastructure based on the following principles:

- **Layered Defense:** Employing multiple layers of physical security controls to deter, detect, delay, and respond to unauthorized access or environmental threats.
- **Risk-Based Approach:** Implementing physical and environmental controls proportionate to the risks identified through risk assessments and the classification of assets.
- **Accountability:** Ensuring clear responsibilities for physical security management and monitoring.
- **Compliance:** Adhering to relevant legal, regulatory, and contractual requirements related to physical and environmental security.

4. Secure Areas

4.1. Identification of Secure Areas: a. Critical areas containing sensitive information assets (e.g., server rooms, network closets, engineering labs where CAD/ASIC designs are developed, secured storage for physical documents) shall be identified as "Secure Areas." b. The **US office and Taipei office premises** themselves are considered controlled secure areas.

4.2. Physical Entry Controls: a. Access to Cirque facilities and Secure Areas shall be restricted to authorized personnel only. b. **Unifi Access System:** The **Unifi Access system** shall be utilized for managing access control to office buildings and designated secure areas within the **US and Taipei offices**. c. **Authentication:** Access to secure areas shall require proper authentication (e.g., key cards, biometric scanners where implemented). d. **Visitor Control:** All visitors to Cirque premises shall be required to sign in, be issued a temporary badge (e.g., via Unifi Access), and be escorted by authorized personnel at all times when in controlled areas. e. **Delivery and Loading Areas:** Access points for deliveries and loading shall be controlled and monitored to prevent unauthorized entry.

4.3. Physical Protection Against Threats: a. **Intrusion Detection:** Alarm systems and surveillance (CCTV) shall be installed and monitored in and around Cirque facilities and Secure Areas. b. **Perimeter Security:** Physical barriers (e.g., walls, fences, secure doors, locks) shall be in place to define the secure perimeter and deter unauthorized access. c. **Protection from Natural Disasters:** Facilities shall be selected and maintained to minimize risks from natural disasters (e.g., flooding, earthquakes) and equipped with appropriate protective measures.

5. Equipment Security

5.1. Equipment Placement and Protection: a. Equipment processing or storing sensitive information shall be physically protected from unauthorized access, environmental damage, and power fluctuations. b. Critical equipment shall be located in areas with appropriate environmental controls (e.g., temperature, humidity, fire suppression). c. Equipment shall be placed to minimize unauthorized viewing of information (e.g., screen privacy).

5.2. Power and Cabling Security: a. Equipment shall be protected from power failures and fluctuations through uninterruptible power supplies (UPS) and surge protectors. b. Power and telecommunications cabling carrying sensitive data shall be protected from interception or damage.

5.3. Equipment Maintenance: a. Maintenance of equipment shall be performed by authorized personnel only. b. Security controls shall remain in place during and after maintenance activities.

5.4. Equipment Removal and Disposal: a. Equipment containing storage media shall not be removed from Cirque premises without explicit authorization. b. Prior to disposal or repurposing, all data on equipment storage media shall be securely erased or destroyed in accordance with IS-AAR01-CIRQ03-A00: Asset Classification and Handling Procedure.

6. Environmental Controls

6.1. Climate Control: a. Server rooms and other critical IT infrastructure areas shall have appropriate heating, ventilation, and air conditioning (HVAC) systems to maintain optimal operating temperatures and humidity levels. b. Environmental monitoring systems shall be in place to alert personnel to significant deviations from optimal conditions.

6.2. Fire Safety: a. Fire detection and suppression systems (e.g., smoke detectors, fire extinguishers, inert gas suppression for server rooms) shall be installed and regularly tested. b. Emergency exit routes shall be clearly marked and kept free from obstruction.

6.3. Water and Other Hazards: a. Measures shall be in place to detect and prevent damage from water leaks, floods, and other liquids in areas where information assets are stored or processed. b. Protection against other environmental hazards (e.g., dust, vibrations) shall be implemented where necessary.

7. Clear Desk and Clear Screen Policy

7.1. Clear Desk: All personnel shall maintain a clear desk policy, ensuring that sensitive or confidential documents and removable media are secured when not in use or when leaving their workspace. **7.2. Clear Screen:** All personnel shall employ clear screen practices, ensuring computer screens displaying sensitive information are locked or protected from unauthorized viewing when left unattended.

8. Related Documents

- IS-AFR01-CIRQ03-A00: Physical Access Control Procedure (To be drafted next)
- IS-AFR01-CIRQ04-A00: Equipment Security Procedure (To be drafted next)
- IS-AAR01-CIRQ01-A00: Asset Management Policy
- IS-AAR01-CIRQ03-A00: Asset Classification and Handling Procedure
- IS-AIR01-CIRQ01-A00: Access Control Policy
- IS-AIR01-CIRQ04-A00: Access Control Procedure
- IS-APM01-CIRQ01-A00: Information Security Policy

9. Policy Review

This policy will be reviewed at least annually, or sooner if significant changes occur to Cirque's facilities, environmental conditions, or legal/regulatory requirements.

IS-AFR01-CIRQ03-A00: Physical Access Control Procedure

IS-AFR01-CIRQ03-A00: Physical Access Control Procedure

Document: IS-AFR01-CIRQ03-A00

Standards Name: Physical Access Control Procedure

Category: Physical and Environmental Security

Division: Procedure

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** IT Manager

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC6.4

Physical access to facilities

CC6.5

Discontinues physical protections when no longer needed

The purpose of this procedure is to define the systematic process for managing and controlling physical access to Cirque's facilities and secure areas, specifically the US and Taipei offices. This procedure implements IS-AFR01-CIRQ01-A00: Physical and Environmental Security Policy and IS-AIR01-CIRQ01-A00: Access Control Policy, ensuring that only authorized individuals gain entry and that physical assets are protected from unauthorized access, damage, or theft.

2. Scope

This procedure applies to all Cirque personnel (employees, contractors, temporary staff), visitors, and service personnel requiring physical access to Cirque premises, including the **US office in Sandy, Utah, Utah, and the Taipei office**. It covers all physical access points, entry controls, and visitor management processes.

3. Responsibilities

- **IT Manager:** Overall owner of this procedure. Manages the **Unifi Access system**, issues and revokes access credentials, monitors access logs, and conducts physical access reviews.
- **HR Department:** Notifies IT of new hires, employee terminations, and role changes that impact physical access.
- **Department Managers:** Responsible for approving physical access requests for their personnel and ensuring their compliance with this procedure.
- **All Employees/Contractors:** Responsible for maintaining the security of their access credentials, challenging unknown individuals, and adhering to all physical security protocols.
- **Reception/Front Desk Personnel:** Responsible for visitor management and initial access control.

4. Procedure

4.1. Physical Access Provisioning (Employees & Contractors)

4.1.1. New Hires (Employees) a. **HR Notification:** Upon a new hire's approval and start date confirmation, HR submits a request to the IT Manager for physical access provisioning. b. **Access Level Determination:** The IT Manager, in consultation with the employee's Department Manager, determines the appropriate physical access level (e.g., general office access, specific lab access) based on job function and need-to-know. c. **Credential Issuance:** The IT Manager or designated personnel creates and issues an access keycard (or equivalent credential) through the **Unifi Access system**. The keycard is configured with the approved access level and effective dates. d. **Acknowledgement:** The new employee acknowledges receipt of the keycard and understanding of physical access policies.

4.1.2. Contractors/Temporary Staff a. **Manager Request:** The sponsoring Department Manager submits a formal request to the IT Manager, specifying the contractor's name, company, start/end dates, specific areas requiring access, and business justification. b. **Time-Limited Credential:** The IT Manager issues a time-limited access keycard via the **Unifi Access system**, configured for the approved duration and specific access areas. c. **Security Briefing:** Contractors receive a brief on Cirque's physical security policies and must agree to abide by them.

4.1.3. Role Change / Access Modification a. **Manager Request:** An employee's or contractor's manager requests changes to physical access privileges (addition or removal of access to specific areas) via email to the IT Manager. b. **Access Adjustment:** The IT Manager updates the individual's access permissions within the **Unifi Access system** to reflect the new requirements, adhering to the principle of least privilege. Permissions no longer needed are immediately revoked.

4.2. Physical Access De-provisioning (Offboarding)

4.2.1. Employee Termination a. **HR Notification:** HR notifies the IT Manager of an employee's termination date and time. b. **Immediate Credential Revocation:** The IT Manager shall immediately revoke the employee's access keycard in the **Unifi Access system** upon notification. c. **Keycard Collection:** The keycard shall be collected by HR or the employee's manager on the last day of employment.

4.2.2. Contractor/Temporary Staff Offboarding a. **Manager Notification:** The sponsoring Department Manager notifies the IT Manager of the contractor's end date. b. **Credential Revocation:** The IT Manager immediately revokes the contractor's access keycard in the **Unifi Access system** on or before the contract end date. c. **Keycard Collection:** The keycard shall be collected by the sponsoring manager or IT.

4.3. Visitor Management

- a. ****Entry Point:**** All visitors must enter through the main reception area of the US or Taipei office.
- b. ****Sign-In:**** Visitors must sign in upon arrival, providing their name, company, person visiting, and purpose of visit. The ****Unifi Access system**** may facilitate guest sign-in and temporary badge issuance.
- c. ****Badge Issuance:**** Visitors shall be issued a clearly visible temporary visitor badge.
- d. ****Escort Policy:**** All visitors must be escorted by an `Cirque` employee while within controlled areas (e.g., offices, labs, manufacturing floors). Visitors are not permitted to wander unescorted.
- e. ****Sign-Out:**** Visitors must sign out upon departure and return their temporary badge.

4.4. Physical Access Controls for Secure Areas

- a. ****Designated Areas:**** Server rooms, network closets, critical engineering labs (e.g., for ASIC design, firmware development), and secure storage rooms for physical confidential documents are designated as Secure Areas.
- b. ****Strict Access:**** Access to these Secure Areas is restricted to personnel with explicit authorization based on their job function and approved by the IT Manager and/or relevant Department Manager.
- c. ****Unifi Access System Logging:**** All entries and exits to Secure Areas are logged by the ****Unifi Access system****. These logs are regularly reviewed by the IT Manager.
- d. ****No Tailgating:**** All personnel, including those with authorized access, must ensure that no unauthorized individuals "tailgate" or follow them into secure areas.

4.5. Monitoring and Review

- a. ****Access Log Review:**** The IT Manager shall regularly review physical access logs generated by the ****Unifi Access system**** for suspicious activity, unauthorized attempts, or anomalies.
- b. ****CCTV Monitoring:**** CCTV systems (if installed) in and around `Cirque` premises shall be monitored, and footage retained as per retention policies for security and incident investigation purposes.
- c. ****Physical Access Reviews:**** The IT Manager shall conduct a formal review of all physical access rights at least annually, confirming continued necessity with Department Managers.

4.6. Lost/Stolen Access Credentials

- a. Any lost or stolen access keycard or physical key must be reported immediately to the IT Manager.

b. The IT Manager will promptly revoke the lost/stolen credential in the **Unifi Access system** and issue a replacement, if necessary.

c. An incident report may be initiated for investigation.

5. Documentation

All physical access requests, approvals, modifications, and revocations shall be documented. This includes:

- Access request emails/forms.
- Unifi Access system logs and reports.
- Visitor sign-in/out logs.
- Records of access reviews.

6. Review and Update

This procedure will be reviewed at least annually, or sooner if there are changes to IS-AFR01-CIRQ01-A00: Physical and Environmental Security Policy, Cirque's physical security systems (e.g., Unifi Access updates), or changes in facility layout.

7. Related Documents

- IS-AFR01-CIRQ01-A00: Physical and Environmental Security Policy
- IS-AIR01-CIRQ01-A00: Access Control Policy
- IS-AIR01-CIRQ04-A00: Access Control Procedure
- IS-AAR01-CIRQ01-A00: Asset Management Policy
- IS-AAR01-CIRQ03-A00: Asset Classification and Handling Procedure
- Visitor access records are maintained in Unifi Access native logs.

IS-AFR01-CIRQ04-A00: Equipment Security Procedure

IS-AFR01-CIRQ04-A00: Equipment Security Procedure

Document: IS-AFR01-CIRQ04-A00

Standards Name: Equipment Security Procedure

Category: Physical and Environmental Security

Division: Procedure

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** IT Manager

1. Purpose

Coverage

CC6.4

Physical security of equipment

CC6.5

Equipment disposal and decommissioning

C1.2

Disposes of confidential information stored on equipment

The purpose of this procedure is to define the systematic process for protecting Cirque's IT equipment from theft, damage, unauthorized access, and environmental hazards throughout its lifecycle. This procedure implements IS-AFR01-CIRQ01-A00: Physical and Environmental Security Policy and IS-AAR01-CIRQ01-A00: Asset Management Policy, ensuring the continued confidentiality, integrity, and availability of information processed, stored, or transmitted by these assets.

2. Scope

This procedure applies to all Cirque-owned or leased IT equipment, including but not limited to:

- Servers, network devices, and data storage systems.
- Workstations, laptops, and mobile devices.
- Manufacturing equipment with IT components or data storage.
- Peripherals (printers, scanners, external drives).
- Cables, power supplies, and environmental control equipment (e.g., UPS units).

This procedure covers equipment located in Cirque's offices (US and Taipei), remote work locations, and equipment in transit.

3. Responsibilities

- **IT Manager:** Overall owner of this procedure. Responsible for implementing and overseeing equipment security controls, maintaining the equipment inventory, and managing equipment disposal processes.
- **All Employees/Contractors:** Responsible for safeguarding company-issued equipment entrusted to them and adhering to all equipment security policies and procedures.
- **Facilities Management:** Responsible for physical environmental controls (HVAC, fire suppression) and general building security in coordination with IT.

4. Procedure

4.1. Equipment Acquisition and Inventory a. **Procurement:** All IT equipment shall be procured through approved channels, ensuring compatibility with Cirque's security standards. b. **Asset Tagging:** Upon acquisition, all new IT equipment shall be immediately tagged with a unique asset ID and recorded in the **Information Asset Inventory (RMM and Intune)**, as per IS-AAR01-CIRQ03-A00: Asset Classification and Handling Procedure. c. **Initial Configuration:** Equipment shall be configured securely before deployment, including changing default passwords, applying security baselines (via **Intune** for endpoints), and installing necessary security software (**Windows Defender for Business**).

4.2. Equipment Placement and Protection a. **Secure Location:** All critical IT equipment (e.g., servers, network devices, sensitive manufacturing equipment) shall be placed in designated secure areas with restricted physical access (e.g., server rooms, locked cabinets) as defined in IS-AFR01-CIRQ03-A00: Physical Access Control

Procedure. b. **Environmental Protection:** Equipment in secure areas shall be protected from environmental threats: * **Temperature/Humidity:** Ensure HVAC systems maintain optimal operating conditions. * **Fire:** Position equipment away from flammable materials; ensure fire detection and suppression systems are in place and regularly tested. * **Water:** Avoid placing equipment directly under water pipes or in areas prone to leaks. c. **Power Protection:** All critical equipment shall be connected to Uninterruptible Power Supplies (UPS) and surge protectors to guard against power fluctuations and outages. UPS systems shall be regularly tested. d. **Visual Protection:** Equipment displaying sensitive information (e.g., monitors in public view) shall be positioned or equipped with privacy screens to prevent unauthorized viewing. e. **Physical Securing:** Servers and critical network equipment shall be physically secured within racks. Laptops issued to employees are managed via Intune and Microsoft Defender for Endpoint. **Endpoint full-disk encryption is not yet deployed; this is tracked as a known control gap (IS-AIR01-CIRQ02-A00 Section 4.6). Compensating controls — physical security, Intune remote-wipe, restriction of Confidential data to cloud storage — are in effect until FDE deployment.**

4.3. Equipment Maintenance a. **Authorized Personnel:** Only authorized Cirque IT personnel or approved third-party vendors shall perform maintenance on IT equipment. b. **Supervision:** Third-party maintenance personnel shall be supervised by an Cirque employee when accessing secure areas or sensitive equipment. c. **Security Controls:** All existing security controls (e.g., access controls, encryption) shall remain in place and operational during and after maintenance activities. Any temporary disabling of controls must be documented and immediately re-enabled. d. **Logging:** Maintenance activities on critical equipment shall be logged, including date, time, personnel involved, and actions taken.

4.4. Off-Site Equipment and Remote Work a. **Company-Issued Equipment:** Employees working remotely shall use only company-issued and managed equipment (e.g., laptops managed by Intune with Microsoft Defender for Endpoint). Endpoint full-disk encryption is planned but not yet deployed (see IS-AIR01-CIRQ02-A00 Section 4.6 Known Control Gap); compensating controls apply in the interim. b. **Secure Connectivity:** Remote access to Cirque's network and systems must only occur via secure VPN connections. c. **Physical Security at Remote Locations:** Employees are responsible for the physical security of company equipment at remote locations, including: * Keeping equipment in secure locations when not in use. * Not leaving equipment unattended in public places. * Reporting lost or stolen equipment immediately to the IT Manager.

4.5. Equipment Removal and Transfer a. **Authorization:** No IT equipment shall be permanently removed from Cirque premises or transferred between offices without explicit authorization from the IT Manager. b. **Documentation:** All equipment movements shall be documented in the asset inventory. c. **Security During Transit:** Sensitive equipment in transit shall be protected appropriately (e.g., secure packaging, tracking, encryption of data if present).

4.6. Secure Equipment Disposal and Re-use a. **Data Sanitization:** Before disposal, re-assignment, or return to a vendor, all storage media (hard drives, SSDs, USBs, mobile devices) on the equipment must be securely sanitized or destroyed. This includes: * **Confidential/Internal Use Data:** Wiping using industry-recognized methods (e.g., NIST SP 800-88 guidelines for media sanitization) or physical destruction (e.g., shredding, degaussing) to render data irretrievable. * **Endpoint Data:** For devices managed by Intune, remote wipe capabilities can be used prior to physical destruction. b. **Physical Destruction:** For equipment no longer functional or deemed beyond secure data sanitization, physical destruction methods may be employed (e.g., shredding, crushing). c. **Certification:** Cirque shall engage certified IT asset disposition (ITAD) vendors for large-scale equipment disposal where appropriate, ensuring chain of custody and data destruction certificates. d. **Asset Inventory Update:** The disposal of equipment shall be promptly recorded in the **Information Asset Inventory**.

5. Clear Desk and Clear Screen a. All personnel shall adhere to a "Clear Desk Policy" (as per IS-AFR01-CIRQ01-A00) by securing sensitive documents and removable media in locked drawers/cabinets when not in use or when leaving their workspace. b. All personnel shall adhere to a "Clear Screen Policy" (as per IS-AFR01-CIRQ01-A00) by locking their computer screens when leaving their workstation unattended.

6. Review and Update

This procedure will be reviewed at least annually, or sooner if there are changes to Cirque's IT equipment, physical security infrastructure, or legal/regulatory requirements.

7. Related Documents

- IS-AFR01-CIRQ01-A00: Physical and Environmental Security Policy

- IS-AFR01-CIRQ03-A00: Physical Access Control Procedure
- IS-AAR01-CIRQ01-A00: Asset Management Policy
- IS-AAR01-CIRQ03-A00: Asset Classification and Handling Procedure
- IS-AIR01-CIRQ01-A00: Access Control Policy
- IS-AIR01-CIRQ04-A00: Access Control Procedure

IS-AFR01-CIRQ02-A00: Clear Desk and Clear Screen Policy

IS-AFR01-CIRQ02-A00: Clear Desk and Clear Screen Policy

Document: IS-AFR01-CIRQ02-A00

Standards Name: Clear Desk and Clear Screen Policy

Category: Operations Security

Division: Policy

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 Effective Date: 2025-07-01 Review Date: 2026-07-01 Approved By: IT Manager

1. Purpose

SOC 2 Trust Services Criteria Mapping

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC6.1

Logical and physical access protections at the desk/screen level

CC6.4

Physical access to facilities (clear desk supports this)

C1.2

Protection of confidential information from unauthorized observation or disclosure

The purpose of this policy is to minimize the risk of unauthorized access, loss of, or damage to Cirque's information and information assets. By establishing "Clear Desk" and "Clear Screen" practices, this policy aims to protect sensitive and confidential information from accidental disclosure, theft, or unauthorized viewing by third parties (e.g., visitors, cleaning staff, or unauthorized personnel), especially in shared work environments. This policy aligns with ISO/IEC 27001:2022 Annex A.11.2.3 (Clear desk and clear screen).

2. Scope

This policy applies to all Cirque personnel (employees, contractors, temporary staff), visitors, and anyone working within Cirque's offices or remote work locations where Cirque's information assets are used. It covers all information, whether in hard copy (e.g., documents, notes) or electronic form (e.g., on computer screens, mobile devices).

3. Definitions

- **Clear Desk:** A practice where all sensitive or confidential documents, removable media, and other information assets are secured when not in use or when the workstation is unattended.
- **Clear Screen:** A practice where computer screens displaying sensitive or confidential information are protected from unauthorized viewing, typically by locking the screen or activating a password-protected screensaver when leaving the workstation unattended.
- **Sensitive Information:** Any information classified as Confidential, Restricted, or Internal Use Only (refer to IS-AHR01-CIRQ01-A00: Information Classification Policy).

4. Policy Requirements

4.1. Clear Desk Policy: a. All sensitive or confidential documents, notes, removable media (e.g., USB drives, CDs/DVDs), and portable devices (e.g., laptops, tablets, mobile phones) must be secured in a locked drawer, cabinet, or other secure storage when leaving the workstation or office area unattended (even for short periods, such as lunch breaks or meetings). b. Non-sensitive internal documents (e.g., general notices, public reports) may be left on desks if they do not contain any confidential or internal-use-only information. c. At the end of the workday, or when leaving the office for an extended period, all desks must be cleared, and all information assets secured. d. Printers and fax machines should be cleared immediately after use to prevent sensitive documents from being left exposed. e. Whiteboards and other display surfaces used for confidential discussions should be erased or secured after use.

4.2. Clear Screen Policy: a. All computer screens (desktops, laptops, monitors), mobile devices (tablets, smartphones), and other electronic displays used for Cirque's business must be secured when the user leaves the workstation unattended. b. This can be achieved by: * Locking the computer (e.g., Windows Key + L, Ctrl+Alt+Del -> Lock, Command+Control+Q for Mac). * Activating a password-protected screen saver. * Logging off the system. c. Users should configure their operating systems to automatically activate a password-protected screen saver after a short period of inactivity (e.g., 5-10 minutes). d. When working in public or semi-public areas (e.g., coffee shops, airports), extra care must be taken to prevent "shoulder surfing" (unauthorized viewing). Consider using privacy screens on devices.

4.3. Waste Disposal: a. All documents containing sensitive or confidential information, whether hard copy or electronic media, must be disposed of securely (e.g., shredding, secure disposal bins, certified data destruction for electronic media) as per IS-AAR05-CIRQ02-A00: Secure Disposal and Media Sanitization Procedure. b. Under no circumstances should sensitive information be placed in regular trash bins.

4.4. Remote Work and Home Office Considerations: a. The principles of Clear Desk and Clear Screen apply equally to employees working remotely or from home offices. b. Sensitive documents or devices should not be left exposed where family members, guests, or others could view or access them. c. Ensure that work areas are free from visual or auditory eavesdropping when handling sensitive information or participating in confidential meetings.

5. Responsibilities

- **All Personnel:** Are responsible for adhering to this policy at all times to protect Cirque's information assets.
- **IT Manager:** Responsible for configuring system defaults (e.g., screen saver activation) where technically feasible and providing guidance on secure work practices.
- **Managers/Supervisors:** Responsible for ensuring their teams understand and comply with this policy within their respective work areas.

6. Non-Compliance

Confidential — Cirque Corporation Internal
Failure to comply with this policy may result in disciplinary action, up to and including termination of employment, as outlined in Cirque's disciplinary procedures. Repeated non-compliance may also lead to security incidents, legal liabilities, or reputational damage for Cirque.

7. Related Documents

- IS-APM01-CIRQ01-A00: Information Security Policy
- IS-AHR01-CIRQ01-A00: Information Classification Policy
- IS-AIR01-CIRQ01-A00: Access Control Policy
- IS-AAR05-CIRQ02-A00: Secure Disposal and Media Sanitization Procedure
- IS-LMR-CIRQ02-A00: Teleworking Policy (if applicable)

8. Policy Review

This policy will be reviewed at least annually, or sooner if there are significant changes to Cirque's work environment, technologies, or security risks.

Part VIII — Operations Security

IS-AIR01-CIRQ03-A00: Operations Security Policy

IS-AIR01-CIRQ03-A00: Operations Security Policy

Document: IS-AIR01-CIRQ03-A00

Standards Name: Operations Security Policy

Category: IT Security Related

Division: Policy

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 Effective Date: 2025-07-01 Review Date: 2026-07-01 Approved By: Executive Committee

1. Purpose

SOC 2 Trust Services Criteria Mapping

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC7.1

Uses detection and monitoring procedures to identify changes that introduce vulnerabilities

CC7.2

Monitors system components and operations for anomalies

CC7.3

Evaluates security events to determine whether they are security incidents

CC7.4

Responds to identified security incidents

CC7.5

Identifies, develops, and implements activities to recover from security incidents

CC8.1

Authorizes, designs, develops, configures, documents, tests, approves, and implements changes

The purpose of this policy is to establish Cirque's requirements for ensuring the secure operation of information processing facilities, information systems, applications, and networks. This policy aligns with ISO/IEC 27001:2022 Annex A.8, aiming to protect against loss of confidentiality, integrity, and availability of information due to operational failures, unauthorized access, or malicious activity.

2. Scope

This policy applies to all Cirque personnel (employees, contractors) involved in the operation and maintenance of information systems, applications (e.g., Omnify, Cadence, GitLab, Asana, Microsoft 365, QuickBooks), networks, and information processing facilities across all Cirque locations (US, Taipei). It covers all operational activities that impact information security.

3. Principles of Operations Security

Cirque manages its operations security based on the following principles:

- **Secure Operation:** Information systems and applications shall be operated securely, with appropriate controls to prevent and detect security incidents.
- **Change Management:** All changes to information systems and services shall be controlled through a formal change management process.
- **Backup and Restoration:** Information and software shall be regularly backed up and securely stored, with tested restoration capabilities.
- **Logging and Monitoring:** System events and user activities shall be logged and monitored to detect security incidents and operational issues.
- **Network Security:** Networks shall be designed, implemented, and managed to protect networked services and information.
- **Capacity Management:** Resources (e.g., storage, processing power, network bandwidth) shall be adequately provisioned and monitored to ensure performance and availability.
- **Separation of Environments:** Development, testing, and production environments shall be logically and, where appropriate, physically separated.
- **Malware Protection:** Systems shall be protected from malware.

4. Operations Security Requirements

4.1. Change Management: a. All changes to Cirque's information systems, applications, networks, and infrastructure (including hardware, software, firmware, and configurations) shall be managed through a formal **Change Management Procedure**. b. Changes must be justified, reviewed, tested, approved, implemented, and documented, with rollback plans where necessary. c. Urgent changes required for business continuity or critical security fixes shall follow an expedited, but still documented, process.

4.2. Backup and Restoration: a. Critical information, software, and system configurations shall be regularly backed up in accordance with Cirque's **Backup and Restoration Procedure**. b. Backups shall be stored securely (encrypted, if sensitive data is included) and off-site where appropriate. c. Restoration procedures shall be regularly tested to ensure data integrity and availability.

4.3. Logging and Monitoring: a. System logs, application logs, and user activity logs shall be collected, stored, and protected in accordance with the **Logging and Monitoring Procedure**. b. Logs shall be reviewed regularly for security incidents, anomalies, and operational issues. c. Alerts shall be configured for critical security events and system failures.

4.4. Network Security Management: a. Networks shall be segmented to separate sensitive areas (e.g., production, development, corporate, guest networks) and controlled through firewalls and access controls, as detailed in the **Network Security Management Procedure**. b. All network devices shall be securely configured and regularly patched. c. Network traffic shall be monitored for suspicious activity.

4.5. Capacity Management: a. The capacity of information processing resources (e.g., servers, storage, network bandwidth) shall be monitored to ensure that current and future business requirements can be met, preventing performance degradation or system failures. b. Capacity planning shall anticipate peak demands and growth.

4.6. Separation of Development, Test, and Production Environments: a. Development, testing, and production environments shall be logically separated to prevent unauthorized changes or accidental interference with operational systems. b. Production data shall not be used in development or test environments unless appropriately sanitized or anonymized. c. Access to these environments shall be controlled based on the principle of least privilege.

4.7. Malware Protection: a. All information systems, including servers, workstations, and mobile devices, shall be protected against malware. b. Anti-malware software (**Windows Defender for Business**) shall be installed, regularly updated, and configured to perform scheduled scans. c. Users shall be educated on the risks of malware and safe computing practices.

4.8. Technical Vulnerability Management: a. Information systems and applications shall be regularly assessed for technical vulnerabilities. b. Identified vulnerabilities shall be remediated or mitigated in a timely manner according to their risk level.

5. Responsibilities

- **IT Manager:** Overall responsible for the implementation and oversight of this policy and its related procedures. Ensures that IT operations adhere to security requirements.
- **System Administrators / IT Personnel:** Responsible for executing operational security tasks in accordance with established procedures.
- **All Personnel:** Responsible for understanding and adhering to the operational security requirements relevant to their roles.

6. Related Documents

- IS-AIR01-CIRQ07-A00: Change Management Procedure
- IS-AIR01-CIRQ08-A00: Backup and Restoration Procedure
- IS-AIR01-CIRQ09-A00: Logging and Monitoring Procedure
- IS-AIR01-CIRQ10-A00: Network Security Management Procedure
- IS-APM01-CIRQ01-A00: Information Security Policy

- IS-AAR01-CIRQ01-A00: Asset Management Policy
- IS-AIR01-CIRQ01-A00: Access Control Policy
- IS-AIR01-CIRQ02-A00: Cryptography Policy

7. Policy Review

This policy will be reviewed at least annually, or sooner if significant changes occur to Cirque's operational environment, IT systems, or the threat landscape.

IS-AIR01-CIRQ07-A00: Change Management Procedure

IS-AIR01-CIRQ07-A00: Change Management Procedure

Document: IS-AIR01-CIRQ07-A00

Standards Name: Change Management Procedure

Category: IT Security Related

Division: Procedure

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** IT Manager

1. Purpose

SOC 2 Trust Services Criteria Mapping

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC8.1

Authorizes, designs, develops, configures, documents, tests, approves, and implements changes

The purpose of this procedure is to define a standardized and controlled process for managing all changes to Cirque's information systems, applications, networks, and infrastructure. This procedure aims to minimize the risks associated with changes, prevent unauthorized modifications, reduce disruptions to business operations, and ensure that changes are securely implemented and documented, in accordance with IS-AIR01-CIRQ03-A00: Operations Security Policy and ISO/IEC 27001:2022 Annex A.8.2.

2. Scope

This procedure applies to all planned changes to Cirque's IT environment that could impact the confidentiality, integrity, or availability of information assets. This includes, but is not limited to:

- Hardware installations, upgrades, or decommissioning (e.g., servers, network devices, workstations).
- Software installations, upgrades, patches, or configurations (e.g., operating systems, applications like Omnify, Cadence, GitLab, Asana, Microsoft 365, QuickBooks).
- Network changes (e.g., firewall rules, routing, VPN configurations).
- Database schema changes or upgrades.

- Cloud service configurations or changes.
- Physical infrastructure changes impacting IT (e.g., power, cooling for server rooms).
- Changes to security controls or policies.

3. Definitions

- **Change:** Any addition, modification, or removal of an authorized, planned, or supported IT service or service component.
- **Change Request (CR):** A formal proposal for a change.
- **Change Advisory Board (CAB):** A group of stakeholders (e.g., IT Manager, Department Managers, relevant technical personnel) responsible for reviewing, evaluating, and approving significant changes.

4. Responsibilities

- **Change Initiator:** The individual proposing the change.
- **Change Approver:** The individual(s) authorized to approve a change (e.g., IT Manager, CAB).
- **IT Manager:** Overall owner of this procedure, responsible for overseeing the change management process and acting as the primary change approver, or leading the CAB.
- **Implementation Team:** The IT personnel responsible for executing the change.
- **Affected Parties:** Stakeholders (e.g., end-users, department heads) who will be impacted by the change.

5. Procedure

5.1. Change Request (CR) Submission a. All proposed changes shall be formally submitted via a designated ticketing system (if available) or an email to the IT Manager, containing the following information: * Unique Change Request (CR) ID. * Date of request. * Change Initiator. * Detailed description of the proposed change. * Business justification for the change. * Expected impact of the change (e.g., services affected, users impacted, downtime). * Risk assessment (potential security implications, operational risks). * Resources required (personnel, time, budget). * Proposed implementation date/time. * Back-out plan (rollback procedure in case of failure). * Test plan (how the change will be validated). * Affected parties to be notified.

5.2. Change Review and Assessment a. The IT Manager (or designated IT personnel) reviews the CR for completeness and initial feasibility. b. **Impact Analysis:** A detailed impact analysis is performed to understand the potential effects on systems, services, and security. This includes reviewing security implications to ensure the change does not introduce new vulnerabilities or weaken existing controls. c. **Risk Assessment:** The risks associated with the change are formally assessed (referencing the IS-LMR-CIRQ01-F01A: Risk Assessment Register). d. **Technical Review:** Technical personnel review the proposed change for technical soundness and adherence to existing architecture/standards.

5.3. Change Approval a. **Minor Changes (Low Risk/Impact):** Changes deemed low risk and low impact (e.g., routine software updates, minor configuration changes) may be approved directly by the IT Manager. b. **Major Changes (Medium/High Risk/Impact):** Changes with medium to high risk or significant business impact (e.g., core system upgrades, network reconfigurations, changes affecting sensitive data like CAD, ASIC designs, or customer data) shall require approval from a **Change Advisory Board (CAB)**, which includes the IT Manager and representatives from affected business units or executive management as needed. c. **Documentation:** All approvals (or rejections) shall be documented in the CR.

5.4. Change Implementation a. **Scheduling:** Approved changes are scheduled in a maintenance window to minimize disruption. b. **Pre-Implementation Checks:** Before implementation, all necessary preparations (e.g., backups, verification of pre-requisites) are completed. c. **Implementation:** The change is implemented according to the approved plan. All steps are documented. d. **Back-out Plan:** If issues arise during implementation, the back-out plan is initiated to restore the system to its previous state. e. **Monitoring:** Systems are actively monitored during and after the change for any adverse effects.

5.5. Post-Implementation Review (PIR) a. **Verification:** After the change is implemented, the change initiator and/or a designated reviewer verify that the change achieved its intended outcome without unintended side effects. b. **Testing:** The test plan is executed to confirm functionality and security. c. **Documentation Update:** All relevant documentation (e.g., system configurations, network diagrams, procedures) is updated to reflect the change. d. **Closure:** The Change Request is formally closed once the change is verified and documentation is updated.

5.6. Emergency Changes a. In situations requiring immediate action to resolve critical incidents (e.g., security breach, major system outage) where standard change procedures cannot be followed, an **Emergency Change** may be initiated. b. **Authorization:** Emergency changes must be verbally approved by the IT Manager, or in their absence, a designated alternate, before implementation. c. **Documentation (Post-Facto):** All emergency changes must be fully documented retroactively, immediately after the critical situation is resolved. This documentation must include the reason for the emergency, the actions taken, the impact, and post-implementation verification. d. **Review:** All emergency changes will be reviewed by the IT Manager and/or CAB to identify lessons learned and improve future processes.

6. Tools

- Ticketing system (if available) for managing Change Requests.
- Version control systems (**GitLab** for code and configuration files).
- Configuration management tools (**Intune** for endpoints).

7. Review and Update

This procedure will be reviewed at least annually, or sooner if there are significant changes to Cirque's IT environment, operational processes, or identified areas for improvement in change management.

8. Related Documents

- IS-AIR01-CIRQ03-A00: Operations Security Policy
- IS-LMR-CIRQ01-F01A: Risk Assessment Register
- IS-APM01-CIRQ01-A00: Information Security Policy
- IS-AIR01-CIRQ09-A00: Logging and Monitoring Procedure (for monitoring changes)

IS-AIR01-CIRQ08-A00: Backup and Restoration Procedure

IS-AIR01-CIRQ08-A00: Backup and Restoration Procedure

Document: IS-AIR01-CIRQ08-A00

Standards Name: Backup and Restoration Procedure

Category: IT Security Related

Division: Procedure

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.1 **Effective Date:** 2026-05-08 **Review Date:** 2027-05-08 **Approved By:** IT Manager

Change history (v1.0 → v1.1): Added Section 4.1.f System Tier Definitions with concrete RTO/RPO numbers per system tier; added Section 4.2.a.i Backup Schedule table; tightened restoration test cadence in Section 4.5; added immutable / air-gap copy requirement for ransomware resilience in Section 4.2.c. Closes SOC 2 Major Finding M-19.

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC7.5

Recovery from disruption

C1.1

Backup integrity supports retention of confidential information

The purpose of this procedure is to define the systematic process for performing, managing, and testing backups and restoration of Cirque's critical information and software. This procedure aims to ensure the availability and integrity of information assets, facilitate recovery from data loss events (e.g., hardware failure, human error, cyber-attack), and comply with IS-AIR01-CIRQ03-A00: Operations Security Policy and ISO/IEC 27001:2022 Annex A.8.13.

2. Scope

This procedure applies to all critical information, software, and system configurations identified as requiring backup within Cirque's IT environment. This explicitly includes:

- **Servers:** All production servers.
- **File Server:** The central file server where critical company data is stored.

This procedure does NOT cover backup of individual user laptops or workstations, which are considered end-user responsibility for personal files, though company data on them should reside on backed-up network drives or cloud services.

3. Responsibilities

- **IT Manager:** Overall owner of this procedure. Responsible for defining backup strategies, ensuring backup systems are properly configured and monitored, and overseeing restoration tests.
- **System Administrators / IT Personnel:** Responsible for executing backup jobs, monitoring backup success/failure, performing restoration tests, and managing backup media.
- **Department Managers/Asset Owners:** Responsible for identifying critical data and systems within their purview that require inclusion in backup schedules.
- **All Personnel:** Responsible for saving critical work-related data to designated network drives or approved cloud storage that is covered by this backup procedure.

4. Procedure

4.1. Backup Strategy and Scope

a. ****Critical Data Identification:**** Department Managers and Asset Owners, in conjunction with the IT Manager, shall identify and classify critical data and systems requiring backup based on their value, criticality, and impact of loss (refer to `IS-AAR01-CIRQ03-A00: Asset Classification and Handling Procedure`).

b. ****Backup Scope:**** Backups shall cover all data and configurations on:

* **All production servers.**

* **The central file server.**

c. **Exclusions:** Individual user laptops are excluded from this centralized backup procedure. Users are responsible for ensuring critical company data is stored on network drives or approved cloud services (e.g., SharePoint, GitLab) which are included in backups.

d. **Backup Tool:** **Veeam** is the designated software for backing up servers and the file server.

e. **Retention Periods:** Backup retention periods shall be defined based on data classification, regulatory requirements, and recovery time objectives (RTO) / recovery point objectives (RPO) per Section 4.1.f.

4.1.f. System Tier Definitions and RTO / RPO Targets

Cirque classifies in-scope systems into three tiers. RTO (Recovery Time Objective) is the maximum acceptable time from outage to restored service. RPO (Recovery Point Objective) is the maximum acceptable data loss measured backwards from the outage. These targets are also referenced in IS-LIR-CIRQ03-A00 Business Continuity Plan and IS-LIR-CIRQ04-A00 Disaster Recovery Plan.

Tier

Examples

RTO

RPO

Backup frequency

Tier 1 — Critical

GitLab (firmware/software/ASIC source code); Cadence ASIC design files; production file server; Active Directory / Entra ID; Microsoft 365 mailboxes for Engineering and Executive

4 hours

1 hour

Tier 2 — Important

NetSuite (ERP); Salesforce; Omnify; QuickBooks; Tableau; SharePoint sites; departmental file shares; engineering CI/CD runners

24 hours

24 hours

Full nightly backup

Tier 3 — Standard

Internal wikis, non-production dev/test environments, archived shares, training records

72 hours

7 days

Weekly full backup

System owners review and confirm tier assignments at least annually through the Asset Register (IS-AAR01-CIRQ01-F01A). Tier assignment is a required field for every server, file share, SaaS, and database listed in the asset register.

4.2. Backup Execution

a. **Scheduling:** Backup jobs are scheduled and executed automatically by **Veeam**, with windows set to minimize operational impact. The schedule below is the Cirque baseline; deviations require IT Manager approval and are recorded in the asset register row for the affected system.

	4.2.a.i. Backup Schedule (baseline)
System group	
Tier	
Frequency	
Type	
Daily window	
On-site retention	
Off-site retention	

1

Hourly snapshot + nightly full

Snapshot + full image

02:00–06:00 local

30 days

90 days (cloud)

Active Directory / Entra ID

1

Hourly state backup + nightly full

State + full

02:00–06:00 local

30 days

90 days (cloud)

GitLab (source code, ASIC, firmware)

1

Hourly mirror + nightly snapshot

Repo mirror + snapshot

Continuous

30 days

90 days (cloud, immutable)

Cadence project repos

1

Hourly snapshot + nightly full

Snapshot + full image

02:00–06:00 local

30 days

90 days (cloud)

Microsoft 365 (Exchange, SharePoint)

1

Daily SaaS backup via Veeam M365

SaaS backup

30 days

365 days (cloud)

NetSuite, Salesforce, Omnify (SaaS)

2

Daily export via vendor + Veeam wrap

Export

Vendor-defined

30 days

90 days (cloud)

QuickBooks

2

Daily export

Export

Vendor-defined

30 days

365 days (compliance)

Internal wiki, non-prod

3

Weekly full

Full

Weekend

30 days

None

b. ****Types of Backups:**** A combination of full, incremental, or differential backups will be utilized as appropriate to meet RPO/RTO requirements and optimize storage.

c. ****Media Management:****

* Backups shall be stored on designated backup media (e.g., network attached storage (NAS), cloud storage).

* Critical backups shall be replicated to an off-site location or cloud storage for disaster recovery purposes.

* **Immutable / air-gap copy:** At least one backup copy of each Tier 1 system shall be stored in immutable (write-once) or air-gapped storage to provide ransomware resilience. The immutable copy is excluded from any administrator delete or rotate operation during its retention window.

* Backup media containing sensitive data shall be encrypted.

d. ****Monitoring:****

* System Administrators shall regularly monitor ****Veeam**** for backup job success or failure.

* Automated alerts for backup failures shall be configured and addressed promptly.

4.3. Data Integrity and Security of Backups

- a. **Encryption:** All backups containing sensitive or confidential information shall be encrypted both in transit and at rest.
- b. **Access Control:** Access to backup systems, backup software (**Veeam**), and backup media shall be strictly controlled on a need-to-know basis, following `IS-AIR01-CIRQ01-A00: Access Control Policy` and `IS-AIR01-CIRQ05-A00: Privileged Access Management Procedure`.
- c. **Integrity Checks:** Regular integrity checks on backup sets shall be performed to ensure data can be successfully restored.

4.4. Restoration Process

- a. **Restoration Request:** In the event of data loss or system failure, restoration requests are submitted to the IT Manager or designated System Administrator.
- b. **Prioritization:** Restoration efforts shall be prioritized based on the criticality of the system/data and impact on business operations.
- c. **Restoration Execution:**
 - * System Administrators shall use **Veeam** to restore data or systems from the appropriate backup set.
 - * Restoration steps shall be documented.
- d. **Verification:** After restoration, the integrity and functionality of the restored data/system shall be verified by the IT team and confirmed by the requesting party.

4.5. Backup and Restoration Testing

- a. **Regular Testing:** Restoration procedures shall be tested on the following minimum cadences:

Tier

Restoration test cadence

Test scope

Tier 1 — Critical

Quarterly

Sample restore of at least one Tier 1 system per quarter; full DR exercise once per year

Tier 2 — Important

Semi-annually

Sample restore of at least one Tier 2 system per six-month window

Tier 3 — Standard

Annually

Sample restore as part of the annual DR exercise

b. ****Test Scope:**** Tests shall involve restoring a representative sample of data and/or systems from backup media to a non-production environment, verifying that: (i) the backup file is readable and not corrupt; (ii) the restored system reaches a runnable / operational state; (iii) restoration completes within the system's RTO; (iv) no more data is lost than the system's RPO permits.

c. ****Documentation:**** Test results — date, system, tester, duration measured against RTO, data delta measured against RPO, any issues encountered, and resolutions — are recorded in the Restoration Test Log (a sub-tab of IS-AAR01-CIRQ01-F01A Asset Register or an equivalent log maintained by the IT Manager).

d. ****Review and Improvement:**** Test failures or RTO/RPO breaches shall trigger a Corrective Action Request (IS-AMR03-CIRQ01-F01A) and review of backup strategies and procedures to implement necessary improvements.

e. ****Annual DR Exercise:**** In addition to per-tier tests, Cirque runs a full DR exercise at least once per year that validates the end-to-end recovery of all Tier 1 systems together against the declared RTO. Results are reported into the Management Review.

4.6. Secure Disposal of Backup Media

a. When backup media is no longer required or has reached the end of its lifecycle, it shall be securely disposed of in accordance with `IS-AAR01-CIRQ03-A00: Asset Classification and Handling Procedure` to prevent unauthorized data recovery.

5. Review and Update

This procedure will be reviewed at least annually, or sooner if there are significant changes to Cirque's IT infrastructure, data classification, backup tools (**Veeam**), or storage locations.

6. Related Documents

- IS-AIR01-CIRQ03-A00: Operations Security Policy
- IS-AAR01-CIRQ01-A00: Asset Management Policy
- IS-AAR01-CIRQ03-A00: Asset Classification and Handling Procedure
- IS-AIR01-CIRQ02-A00: Cryptography Policy
- IS-AIR01-CIRQ06-A00: Key Management Procedure

IS-AIR01-CIRQ09-A00: Logging and Monitoring Procedure

IS-AIR01-CIRQ09-A00: Logging and Monitoring Procedure

Document: IS-AIR01-CIRQ09-A00

Standards Name: Logging and Monitoring Procedure

Category: IT Security Related

Division: Procedure

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** IT Manager

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC4.1

Ongoing monitoring

CC4.2

Communicates control deficiencies

CC7.1

Detection of vulnerabilities through monitoring

CC7.2

Monitors system components for anomalies

The purpose of this procedure is to define the systematic process for logging, storing, and reviewing events related to Cirque's information systems, applications, and networks. This procedure ensures that sufficient information is available for audit trails, incident investigation, problem diagnosis, and compliance monitoring, in accordance with IS-AIR01-CIRQ03-A00: Operations Security Policy and ISO/IEC 27001:2022 Annex A.8.14.

2. Scope

This procedure applies to all Cirque information systems, applications, network devices, cloud services, and physical access systems that generate logs of security-relevant events, operational activities, or user actions. This includes, but is not limited to:

- **Operating Systems:** Windows Servers, workstations (managed by **Intune**).
- **Network Devices:** Firewalls, switches, wireless access points.
- **Applications:** Omnify, Cadence, GitLab, Asana, QuickBooks, Microsoft 365 services (e.g., SharePoint, Exchange Online).
- **Directory Services:** Active Directory.
- **Security Tools:** **Windows Defender for Business.**
- **Physical Access Control Systems:** **Unifi Access system.**
- **Cloud Infrastructure:** Azure logs.

3. Responsibilities

- **IT Manager:** Overall owner of this procedure. Responsible for defining logging requirements, ensuring logging systems are properly configured, and overseeing log review and incident response processes related to logs.
- **System Administrators / IT Personnel:** Responsible for configuring systems to generate appropriate logs, ensuring logs are collected and stored securely, and performing initial log reviews and investigations.
- **All Personnel:** Responsible for reporting suspicious activities or anomalies observed on systems they use.

4. Procedure

4.1. Identification of Logging Requirements a. The IT Manager, in conjunction with system owners, shall identify and define the types of events that must be logged for each system, based on: * Business criticality of the system. * Data classification (Confidential, Internal Use). * Legal, regulatory, or contractual requirements. * Risk assessments (IS-LMR-CIRQ01-F01A: Risk Assessment Register). b. Key events to be logged include, but are not limited to: * All successful and failed logon attempts. * Changes to system configuration, security settings, or access rights. * Use of privileged accounts. * Attempts to access unauthorized resources. * Execution of critical system commands. * Malware detection and quarantine events. * Physical access attempts (successful and failed) via **Unifi Access system**.

4.2. Log Generation and Collection a. **System Configuration:** All relevant systems shall be configured to generate necessary logs with sufficient detail. b. **Centralized Logging (where applicable):** Logs from critical systems (e.g., servers, network devices, firewalls) should be forwarded to a centralized log management system or Security Information and Event Management (SIEM) solution (if implemented) to facilitate aggregation, correlation, and analysis. c. **Endpoint Logging:** For workstations and laptops, relevant logs (e.g., security events, **Windows Defender for Business** alerts) are collected and monitored via **Intune** and integrated with Microsoft 365 security features. d. **Cloud Service Logging:** Cirque shall utilize and configure the native logging capabilities of cloud services (e.g., Azure Activity Logs, Microsoft 365 Unified Audit Log, GitLab audit logs) to capture relevant events.

4.3. Log Storage and Retention a. **Secure Storage:** Logs shall be stored securely to prevent unauthorized access, modification, or deletion. Access to log storage shall be strictly controlled based on need-to-know. b. **Integrity:** Mechanisms shall be in place to ensure the integrity and authenticity of logs (e.g., hashing, read-only access for archived logs). c. **Retention Periods:** Logs shall be retained for a period consistent with legal, regulatory, business, and SOC 2 requirements. Default minimum retention periods are: - Security and authentication logs: **1 year minimum** (extended to the longer of 1 year or the duration of any related investigation). - Privileged access / administrator activity logs: **1 year minimum**. - Operational / system logs: **90 days hot, plus 9 months archive (1 year total minimum)**. - Firewall and network device logs: **90 days hot, plus 9 months archive (1 year total minimum)**. - Audit and compliance evidence (incident records, control evidence): **7 years**. Logs shall not be deleted before the minimum retention has elapsed. If storage becomes constrained, the IT Manager shall expand log storage or document an Executive Committee-approved exception per IS-APM01-CIRQ01-A00 Section 8. d. **Time Synchronization:** All systems shall have their time synchronized to a central, reliable time source (e.g., NTP server) to ensure accurate timestamps in logs for correlation purposes.

4.4. Log Review and Analysis a. **Regular Review:** Logs shall be reviewed regularly for security events, operational issues, and anomalies: * **Daily:** Critical system logs (e.g., firewall, server authentication logs), privileged access logs. * **Weekly/Monthly:** General system logs, application logs, physical access logs from **Unifi Access system**. * **Ad-hoc:** In response to alerts, suspected incidents, or during investigations. b. **Automated Monitoring and Alerts:** * Automated monitoring tools shall be configured to identify and alert on pre-defined critical security events (e.g., multiple failed logins, unauthorized access attempts, malware outbreaks detected by **Windows Defender for Business**, significant changes in **Active Directory**). * Alerts shall be escalated to the IT Manager or designated personnel for immediate investigation. c. **Incident Response Integration:** Log analysis is a critical component of the Incident Response process (IS-AMG01-CIRQ02-A00: Incident Response Procedure - Global Core).

4.5. Protection of Logging Facilities a. Logging facilities and log data shall be protected from tampering and unauthorized access. b. Only authorized personnel shall have access to configure, review, or modify logging systems.

5. Review and Update

IS-AIR01-CIRQ10-A00: Network Security Management Procedure

IS-AIR01-CIRQ10-A00: Network Security Management Procedure

Document: IS-AIR01-CIRQ10-A00

Standards Name: Network Security Management Procedure

Category: IT Security Related

Division: Procedure

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** IT Manager

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC6.6

Protection against external threats (firewall, segmentation)

CC7.1

Detection of vulnerabilities through scanning

CC7.2

Monitoring of network components

The purpose of this procedure is to define the systematic process for managing the security of Cirque's networks, including wired, wireless, and remote access connections. This procedure aims to protect network services and information from unauthorized access, misuse, disclosure, or disruption, in accordance with IS-AIR01-CIRQ03-A00: Operations Security Policy and ISO/IEC 27001:2022 Annex A.8.19.

2. Scope

This procedure applies to all Cirque network infrastructure, devices, and services across all locations, including the US, Taiwan, and authorized remote work locations (including remote workers in China) offices, and remote access points. This includes, but is not limited to:

- Network devices (routers, switches, firewalls, wireless access points).
- Network services (DNS, DHCP).
- Network protocols.
- Network cabling.

- Virtual Private Network (VPN) solutions.
- Cloud network configurations (e.g., Azure VNETs).

3. Responsibilities

- **IT Manager:** Overall owner of this procedure. Responsible for network architecture, security design, approval of network changes, and oversight of network security monitoring.
- **System Administrators / IT Personnel:** Responsible for implementing, configuring, maintaining, and monitoring network devices and services in accordance with this procedure.
- **All Personnel:** Responsible for adhering to network usage policies, especially concerning remote access.

4. Procedure

4.1. Network Segmentation and Architecture a. Cirque networks shall be logically segmented to isolate different functional areas, sensitive data, and system classifications (e.g., corporate network, production network, development network, guest wireless). b. Network segmentation shall be enforced using firewalls and VLANs (Virtual Local Area Networks). c. Network diagrams, illustrating segmentation and key security zones, shall be maintained and regularly updated.

4.2. Firewall Management a. **Firewall Deployment:** Firewalls shall be deployed at critical network boundaries, including the perimeter between Cirque's internal network and external networks (e.g., the Internet) and between network segments. b. **Rule Management:** * Firewall rules shall be explicitly defined, approved by the IT Manager, and based on a least-privilege principle (deny-all by default, permit-by-exception). * Rules shall be documented, including justification, source/destination IP, port, and protocol. * Rules shall be regularly reviewed (at least quarterly) and unnecessary rules removed. c. **Secure Configuration:** Firewalls shall be securely configured, with default passwords changed, unnecessary services disabled, and management interfaces protected. d. **Logging:** Firewall logs shall be enabled and forwarded to a centralized logging system as per IS-AIR01-CIRQ09-A00: Logging and Monitoring Procedure.

4.3. Secure Network Device Configuration a. **Hardening:** All network devices (routers, switches, wireless access points) shall be hardened according to industry best practices and vendor recommendations. This includes: * Changing all default passwords. * Disabling unnecessary services and ports. * Implementing strong authentication and authorization for device management. * Restricting management access to designated administrative networks or hosts. b. **Patch Management:** Network device firmware and operating systems shall be regularly updated with security patches. c. **Configuration Backup:** Device configurations shall be regularly backed up and stored securely.

4.4. Wireless Network Security a. **Strong Encryption:** Wireless networks used for corporate access shall utilize strong encryption protocols (e.g., WPA2 Enterprise or WPA3) with EAP-TLS or PEAP for user authentication. b. **Separate Guest Network:** A separate, isolated guest wireless network shall be provided for visitors, ensuring it has no access to Cirque's internal corporate or production networks. c. **Authentication:** All wireless access points shall require strong authentication.

4.5. Remote Access Security (VPN) a. **Mandatory VPN:** All remote access to Cirque's internal networks and resources shall be conducted exclusively through an approved Virtual Private Network (VPN) solution. b. **Strong Encryption:** The VPN solution shall use strong cryptographic protocols (e.g., IPsec, OpenVPN, or TLS VPN) for data in transit encryption as per IS-AIR01-CIRQ02-A00: Cryptography Policy. c. **Multi-Factor Authentication (MFA):** MFA shall be mandatory for all VPN connections. d. **Device Compliance:** Only company-managed devices (e.g., laptops managed by Intune) with current security software (**Windows Defender for Business**) and up-to-date patches shall be permitted to connect via VPN.

4.6. Network Monitoring a. **Traffic Analysis:** Network traffic shall be monitored for suspicious activity, intrusions, and anomalies using network intrusion detection/prevention systems (IDS/IPS) or similar tools. b. **Bandwidth Monitoring:** Network bandwidth usage shall be monitored to ensure adequate capacity and detect unusual traffic patterns. c. **Alerting:** Alerts shall be configured for critical network security events and performance issues.

4.7. Network Service Security a. **DNS Security:** DNS services shall be configured securely, and internal DNS servers protected from external access. b. **DHCP Security:** DHCP services shall be managed to prevent

unauthorized IP address assignment. c. **Time Synchronization:** Network devices shall be synchronized to a central, reliable time source (NTP) to ensure accurate logging.

4.8. Segregation of Duties for Network Administration a. Where feasible, duties related to network administration (e.g., firewall rule changes, router configuration) shall be segregated to prevent a single individual from being able to compromise network security without detection.

5. Review and Update

This procedure will be reviewed at least annually, or sooner if there are significant changes to Cirque's network architecture, security technologies, or the threat landscape.

6. Related Documents

- IS-AIR01-CIRQ03-A00: Operations Security Policy
- IS-AIR01-CIRQ01-A00: Access Control Policy
- IS-AIR01-CIRQ04-A00: Access Control Procedure
- IS-AIR01-CIRQ02-A00: Cryptography Policy
- IS-AIR01-CIRQ09-A00: Logging and Monitoring Procedure
- IS-AIR01-CIRQ07-A00: Change Management Procedure

Part IX — Secure System Acquisition, Development, and Maintenance

IS-AAR05-CIRQ01-A00: Secure System Acquisition, Development and Maintenance Policy

IS-AAR05-CIRQ01-A00: Secure System Acquisition, Development and Maintenance Policy

Document: IS-AAR05-CIRQ01-A00

Standards Name: Secure System Acquisition, Development and Maintenance Policy

Category: IT Security Related

Division: Policy

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.1 **Effective Date:** 2026-05-08 **Review Date:** 2027-05-08 **Approved By:** Executive Committee

Change history (v1.0 → v1.1): Added "Threat Modeling" as an explicit principle of the Secure System Lifecycle (Section 3) and as a required element of Security Requirements Specification (Section 4.1). Change made in response to the Lenovo Trusted Supplier Program audit recommendation dated 2026-03-25 (CAR-2026-001), which noted that Cirque's secure development process did not include formal threat modeling. Detailed methodology lives in IS-AAR05-CIRQ02-A00 (Secure Development Procedure Section 4.2.c).

1. Purpose

SOC 2 Trust Services Criteria Mapping

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

CC8.1

Manages changes to infrastructure, data, software, and procedures

CC9.2

Assesses and manages risks associated with vendors and business partners

The purpose of this policy is to establish Cirque's requirements for incorporating information security into the entire lifecycle of its information systems and applications, from acquisition and development through operation and maintenance. This policy aims to minimize security vulnerabilities in systems and software, protect intellectual property (e.g., ASIC designs, firmware, source code), and ensure that security is an integral part of all system-related activities, in accordance with ISO/IEC 27001:2022 Annex A.8.25, A.8.28, and A.8.29.

2. Scope

This policy applies to all Cirque personnel (employees, contractors) involved in the acquisition, development, testing, implementation, and maintenance of all information systems, software applications (including in-house developed, commercial off-the-shelf - COTS, and cloud-based applications), and infrastructure components. This includes specific applications like **Cadence** (for ASIC design), **GitLab** (for source code management), **Omnify**, **Asana**, **QuickBooks**, and **Microsoft 365 services**.

3. Principles of Secure System Lifecycle

Cirque integrates security into its system lifecycle based on the following principles:

- **Security by Design:** Security considerations shall be embedded at every stage of the system lifecycle, from initial concept and requirements gathering through design, development, testing, deployment, and decommissioning.
- **Threat Modeling:** A formal threat model shall be produced for every new product and every significant change to an existing product or internal system that processes Confidential or Restricted data. Threat modeling identifies and mitigates threats, risks, and vulnerabilities early in the design phase. The methodology, ownership, artifact, and review cadence are defined in IS-AAR05-CIRQ02-A00 Section 4.2.c. This principle aligns with NIST CSF PR.IP-2, NIST SP 800-53 SA-3, and ISO/IEC 27002:2022 Section 8.25.
- **Secure Development Practices:** Development practices shall adhere to secure coding standards and principles to minimize vulnerabilities in software and systems.
- **Testing and Validation:** All systems and software shall undergo thorough security testing before deployment or significant changes to identify and remediate vulnerabilities.
- **Supply Chain Security:** Security requirements shall be specified and enforced for third-party acquired software, services, and components.
- **Continuous Improvement:** Security processes related to system acquisition, development, and maintenance shall be continuously reviewed and improved.

4. Secure System Acquisition and Development Requirements

4.1. Information Security Requirements Specification: a. Information security requirements shall be identified and documented at the initial stages of any new system acquisition or development project. b. These requirements shall address confidentiality, integrity, availability, accountability, and compliance obligations. c. Specific security requirements shall be defined for sensitive IP such as ASIC designs and firmware developed using tools like **Cadence** and managed in **GitLab**. d. **Threat modeling** shall be performed and approved before design freeze for every new product, every significant change to an existing product, and every new internal system that processes Confidential or Restricted data. The threat model is the authoritative source for the security requirements identified in Section 4.1.a. The methodology, ownership, output artifact, reviewer, and review cadence are defined in IS-AAR05-CIRQ02-A00 Section 4.2.c.

4.2. Secure Development Environment: a. Development environments shall be logically and, where necessary, physically separated from production environments. b. Access to development and testing environments shall be strictly controlled, based on the principle of least privilege. c. Production data shall not be used in development or test environments unless it has been adequately anonymized or sanitized. d. Development tools (e.g., **GitLab**, **Cadence**) shall be securely configured and regularly updated.

4.3. Secure Coding and Development Practices: a. Developers shall adhere to secure coding standards and guidelines (e.g., OWASP Top 10 for web applications, specific guidelines for hardware/firmware development). b. Code reviews shall incorporate security vulnerability checks. c. Use of open-source software and third-party components shall be managed to assess and mitigate associated security risks.

4.4. Security in Development Processes (e.g., GitLab): a. All source code, including firmware and ASIC design files, managed in **GitLab** shall be subject to version control. b. Access to sensitive repositories in **GitLab** shall be restricted to authorized developers on a need-to-know basis. c. Automated security scanning tools (e.g., Static Application Security Testing - SAST, Dynamic Application Security Testing - DAST) shall be integrated into the Continuous Integration/Continuous Delivery (CI/CD) pipeline where applicable.

4.5. Acquired Software Security: a. Prior to acquiring or adopting commercial off-the-shelf (COTS) software or cloud services, security due diligence shall be performed to assess inherent risks and vendor security posture. b. Contractual agreements with software vendors and cloud service providers shall include clear information security clauses. c. Default security settings of acquired software shall be hardened before deployment.

5. System Testing and Acceptance Requirements

5.1. Security Testing: a. All new systems, applications, and significant changes shall undergo comprehensive security testing before being moved to production. This includes: * Vulnerability scanning. * Penetration testing (internal and/or external) for critical systems. * Code reviews. * Functional security testing. b. Testing shall verify that all identified security requirements are met and that no new vulnerabilities have been introduced.

5.2. Acceptance Criteria: a. Systems and applications shall only be accepted into the production environment after demonstrating that they meet predefined security requirements and have successfully passed all security tests. b. Any identified vulnerabilities must be remediated or formally accepted with a clear mitigation plan.

6. System Maintenance and Support

6.1. Vulnerability Management: a. A systematic process shall be in place to identify, assess, and remediate technical vulnerabilities in all operational systems and applications. b. Regular vulnerability scans and penetration tests shall be performed as part of the operational vulnerability management and security testing activities. c. Patches and updates shall be applied in a timely manner as per the IS-AIR01-CIRQ07-A00: Change Management Procedure.

6.2. System Monitoring: a. Operational systems shall be continuously monitored for security events, anomalies, and potential intrusions, as per IS-AIR01-CIRQ09-A00: Logging and Monitoring Procedure.

****6.3. Information System Audit Con**

IS-AAR05-CIRQ02-A00: Secure Development Procedure

IS-AAR05-CIRQ02-A00: Secure Development Procedure

Document: IS-AAR05-CIRQ02-A00

Standards Name: Secure Development Procedure

Category: IT Security Related

Division: Procedure

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.1 **Effective Date:** 2026-05-08 **Review Date:** 2027-05-08 **Approved By:** IT Manager

Change history (v1.0 → v1.1): Added formal Threat Modeling process (Section 4.2.b and new Section 4.2.c) in response to Lenovo Trusted Supplier Program audit recommendation dated 2026-03-25 (CAR-2026-001). Threat

modeling, previously listed as an optional alternative to design review, is now a mandatory step for new product development and significant changes, with defined methodology, ownership, artifact, and review cadence.

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC8.1

Secure development as part of change management

CC9.2

Manages supply-chain risk in development dependencies

The purpose of this procedure is to define the systematic process for integrating information security into the software development lifecycle (SDLC), including the development of firmware and ASIC designs. This procedure aims to minimize vulnerabilities, ensure the confidentiality, integrity, and availability of developed systems and intellectual property (IP), and comply with IS-AAR05-CIRQ01-A00: Secure System Acquisition, Development and Maintenance Policy and ISO/IEC 27001:2022 Annex A.8.25.

2. Scope

This procedure applies to all Cirque personnel (employees, contractors) involved in the design, development, coding, and integration of software, firmware, and hardware designs (e.g., ASIC designs). This includes internal development using tools like **GitLab** and **Cadence**, as well as customization or integration of third-party applications.

3. Responsibilities

- **Development Managers/Leads:** Responsible for ensuring their teams adhere to this procedure and secure coding practices.
- **Developers/Engineers:** Responsible for implementing secure coding, design, and testing practices as defined herein.
- **IT Manager/Security Personnel:** Responsible for providing security guidance, tools, and reviewing security vulnerabilities during development.

4. Procedure

4.1. Secure Development Environment

a. **Separation:** Development, testing, and production environments shall be logically and, where technically feasible, physically separated. Access between environments shall be strictly controlled.

b. **Access Control:** Access to development environments, including source code repositories (e.g., **GitLab**), design tools (e.g., **Cadence**), and associated data, shall be restricted to authorized personnel on a need-to-know basis.

c. **Workstation Hardening:** Development workstations shall be securely configured and regularly patched, equipped with anti-malware software (**Microsoft Defender for Endpoint**). Endpoint full-disk encryption for development workstations is planned but not yet deployed (see IS-AIR01-CIRQ02-A00 Section 4.6 Known Control Gap); developers are required to store source code in approved cloud repositories (GitLab, Cadence) where the service provider encrypts data at rest.

d. **Production Data:** Use of actual production data in

Confidential — Cirque Corporation Internal
development or test environments is strictly prohibited unless it has been adequately anonymized, pseudonymized, or sanitized to remove sensitive information.

4.2. Secure Design and Requirements a. **Security Requirements Gathering:** For every new system or significant feature, information security requirements shall be defined at the design phase. This includes: * Identification of sensitive data processed or stored. * Required authentication and authorization mechanisms. * Input validation and output encoding needs. * Error handling strategies. * Resilience and availability considerations. * Protection of intellectual property (e.g., ASIC/firmware design integrity). b. **Threat Modeling (mandatory):** A formal threat model **shall** be produced and approved before design freeze for: (1) every new product (software, firmware, ASIC, or touchpad); (2) any significant change to an existing product (new external interface, new data type, new connectivity, new third-party dependency, or change in trust boundary); (3) any new internal system that processes Confidential or Restricted data per IS-AAR01-CIRQ02-A00. A separate “security design review” is no longer an acceptable substitute. The threat-modeling process is detailed in Section 4.2.c.

Threat Modeling Process:

Trigger: Created at design phase; updated before any release that materially changes the system's attack surface.

Methodology: STRIDE (Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege) for software and firmware. For ASIC and hardware designs, STRIDE is supplemented with hardware-specific threats (side-channel, fault injection, supply-chain tampering, secure- boot bypass, physical probing). Cirque adopts the NIST Cybersecurity Framework subcategory **PR.IP-2** and **NIST SP 800-53 SA-3** as authoritative references; alignment with ISO/IEC 27002:2022 Section 8.25 is documented in the Statement of Applicability (IS-APM02-CIRQ01-A02A).

Inputs: System architecture diagram, data flow diagram, trust boundaries, list of external interfaces, asset inventory (per IS-AAR01-CIRQ01-A00), data classifications (per IS-AAR01-CIRQ02-A00), and any prior incident or vulnerability history.

Steps:

Decompose the system; produce or update the data flow diagram with trust boundaries.

Identify threats per STRIDE category for each asset and data flow; for hardware, add side-channel / tampering threats.

Score each threat (likelihood × impact, 1–5 scale per IS-LMG-CIRQ01-A00).

Define mitigation, owner, and target completion for each threat above the risk-acceptance threshold.

Capture residual risk and any accepted risks; route any accepted “High” residual risks to the Executive Committee.

Output artifact: A THREAT-MODEL.md (or equivalent) checked into the GitLab project under /security/, with a header containing version, author, reviewers, approval date, and product/release scope. Hardware threat models are checked into the corresponding Cadence project repository under /docs/security/.

Roles: Development Lead authors the threat model. IT Manager (or designated independent reviewer) reviews and signs off. Executive Committee approves any residual “High” risks.

Linkage: Identified threats become entries in the Risk Assessment Register (IS-LMR-CIRQ01-F01A) when residual risk is Medium or higher. Mitigations referenced in the threat model become acceptance criteria in IS-AAR05-CIRQ03-A00 (System Testing and Acceptance Procedure).

Review cadence: Threat models are reviewed at minimum annually for active products and **must** be revised before any release that introduces a new external interface, new data type, new connectivity, or new third-party dependency.

Evidence retention: Threat model documents and reviewer sign-off records are retained for the operational life of the product plus 7 years.

4.3. Secure Coding Practices (Software and Firmware) a. **Coding Standards:** Developers shall adhere to secure coding guidelines and best practices relevant to the programming language and platform being used (e.g., OWASP Top 10 for web app)

IS-AAR05-CIRQ03-A00: System Testing and Acceptance Procedure

IS-AAR05-CIRQ03-A00: System Testing and Acceptance Procedure

Document: IS-AAR05-CIRQ03-A00

Standards Name: System Testing and Acceptance Procedure

Category: IT Security Related

Division: Procedure

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** IT Manager

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC8.1

Testing and acceptance prior to deployment

CC7.1

Pre-production vulnerability detection

The purpose of this procedure is to define the systematic process for testing and formally accepting information systems, applications, firmware, and hardware designs before their deployment into the production environment. This procedure ensures that systems meet predefined functional, performance, and, critically, security requirements, thereby minimizing risks to Cirque's information assets, in accordance with IS-AAR05-CIRQ01-A00: Secure System Acquisition, Development and Maintenance Policy and ISO/IEC 27001:2022 Annex A.8.29.

2. Scope

This procedure applies to all new information systems, applications (including commercial off-the-shelf - COTS, in-house developed, or customized), significant upgrades, major configuration changes, and new firmware or hardware designs (e.g., ASIC designs developed with **Cadence**) prior to their release or deployment into Cirque's production environment.

3. Definitions

- **User Acceptance Testing (UAT):** Testing performed by end-users or business representatives to verify that the system meets business requirements.
- **Security Testing:** Testing specifically focused on identifying vulnerabilities and verifying the effectiveness of security controls.

- **Vulnerability Scan:** An automated test to identify known vulnerabilities in systems, applications, or networks.
- **Penetration Test:** A simulated attack against a system, application, or network to evaluate its security.

4. Responsibilities

- **Project Manager/System Owner:** Overall responsible for ensuring that systems undergo appropriate testing and meet acceptance criteria.
- **Development Teams:** Responsible for developing testable code/designs, addressing identified issues, and supporting testing activities.
- **IT Manager/Security Personnel:** Responsible for defining security testing requirements, overseeing security tests, and evaluating security test results.
- **End-Users/Business Owners:** Responsible for participating in UAT and providing feedback on system functionality.

5. Procedure

5.1. Test Environment Preparation a. A dedicated test environment, logically and (where practical) physically separated from the production environment, shall be prepared for testing. b. The test environment shall replicate the production environment as closely as possible in terms of hardware, software, and network configuration. c. Test data shall be used, which must not contain actual sensitive production information unless adequately anonymized or sanitized. d. Access to the test environment shall be restricted to authorized testing and development personnel.

5.2. Test Planning a. A comprehensive test plan shall be developed, outlining: * Test objectives (functional, performance, security). * Test cases and scenarios. * Roles and responsibilities for testing. * Required test data. * Test schedule. * Criteria for successful completion of tests. * Procedures for documenting and tracking defects. b. **Security Test Plan:** A specific section of the test plan shall address security testing, including: * Vulnerability scanning targets and scope. * Specific security features to be tested (e.g., authentication, authorization, input validation, encryption). * Types of security tests to be conducted (e.g., code review, SAST, DAST, penetration testing).

5.3. Test Execution

5.3.1. Functional and Integration Testing: a. Development teams shall conduct unit, integration, and system testing to ensure the system functions as designed and integrates correctly with other systems.

5.3.2. Security Testing: a. **Vulnerability Scanning:** Systems and applications shall undergo automated vulnerability scanning to identify common security weaknesses. * For in-house developed software, SAST tools integrated with **GitLab CI/CD** (as per IS-AAR05-CIRQ02-A00) should be leveraged. * For web applications, DAST tools should be utilized. b. **Penetration Testing:** Critical systems (e.g., those handling sensitive data, external-facing applications, core infrastructure) shall undergo internal and/or external penetration testing by qualified personnel (internal or third-party). c. **Configuration Review:** Security configurations of the system, including operating system, database, and application settings, shall be reviewed against hardening baselines. d. **Access Control Testing:** Verification that access controls function as intended, enforcing the principle of least privilege. e. **Cryptography Testing:** If cryptographic controls are implemented, verify their correct usage and strength (e.g., certificate validity, algorithm strength). f. **ASIC/Firmware Security Testing (for Cadence designs):** Specific tests for hardware vulnerabilities (e.g., side-channel analysis, fault injection) shall be conducted where applicable, alongside firmware integrity checks.

5.3.3. User Acceptance Testing (UAT): a. End-users and business owners shall conduct UAT to ensure the system meets business requirements and is suitable for operational use.

5.4. Defect Management and Remediation a. All identified defects and vulnerabilities shall be formally documented, tracked, and prioritized based on their severity and impact. b. Critical and high-severity security vulnerabilities must be remediated promptly before deployment. c. Remediation actions shall be re-tested to confirm effectiveness.

5.5. System Acceptance a. A system can only be accepted for deployment into the production environment if: * All critical and high-severity defects and vulnerabilities have been remediated or formally accepted by the IT Manager and relevant business owner with an approved mitigation plan and residual risk acceptance. * All security requirements outlined in the design phase have been met and verified by security testing. * UAT has been successfully completed, and business owners approve the system for release. b. Formal sign-off for acceptance shall be obtained from the IT Manager and relevant business owner(s).

5.6. Documentation and Handover a. All testing results, defect logs, and acceptance documents shall be archived. b. Updated system documentation, including security configurations, operational procedures, and user manuals, shall be prepared and handed over to the operations team (refer to IS-AMR04-CIRQ02-A00: Document Control Procedure).

6. Review and Update

This procedure will be reviewed at least annually, or sooner if there are significant changes to Cirque's system development lifecycle, testing tools, or regulatory requirements.

7. Related Documents

- IS-AAR05-CIRQ01-A00: Secure System Acquisition, Development and Maintenance Policy
- IS-AAR05-CIRQ02-A00: Secure Development Procedure
- IS-AIR01-CIRQ03-A00: Operations Security Policy
- IS-AIR01-CIRQ07-A00: Change Management Procedure
- IS-LMR-CIRQ01-F01A: Risk Assessment Register
- IS-AMR04-CIRQ02-A00: Document Control Procedure

Part X — Supplier Relationships

IS-ASR01-CIRQ01-A00: Supplier Relationships Policy

IS-ASR01-CIRQ01-A00: Supplier Relationships Policy

Document: IS-ASR01-CIRQ01-A00

Standards Name: Supplier Relationships Policy

Category: Related to Outsourcing

Division: Policy

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** Executive Committee

1. Purpose

SOC 2 Trust Services Criteria Mapping

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

CC9.2

Assesses and manages risks associated with vendors and business partners

C1.1

Identifies and maintains confidential information shared with vendors

The purpose of this policy is to establish Cirque's requirements for managing information security risks associated with supplier relationships. This includes ensuring that the security of Cirque's information and information systems is protected when suppliers have access to them, or when Cirque's processes are outsourced to suppliers. This policy aligns with ISO/IEC 27001:2022 Annex A.15, ensuring consistent information security controls across the supply chain.

2. Scope

This policy applies to all Cirque personnel (employees, contractors) involved in selecting, engaging, managing, and terminating relationships with suppliers who:

- Have access to Cirque's information, information systems, or facilities.
- Process, store, or transmit Cirque's information on its behalf.
- Provide IT products, components, or services that are critical to Cirque's information systems or business operations.

This includes, but is not limited to, cloud service providers (e.g., Microsoft 365, Azure), software vendors (e.g., Omnify, Cadence, GitLab, Asana, QuickBooks), IT service providers, and any other third party with a significant impact on Cirque's information security.

3. Principles of Supplier Relationship Security

Cirque manages supplier relationships with information security in mind, based on the following principles:

- **Risk-Based Approach:** Supplier relationships shall be managed based on the level of information security risk they pose to Cirque.
- **Due Diligence:** Appropriate due diligence shall be performed on potential suppliers before engagement.
- **Contractual Obligations:** Information security requirements shall be clearly defined and legally enforced through contractual agreements.
- **Monitoring and Review:** Supplier compliance with information security requirements shall be regularly monitored and reviewed.
- **Lifecycle Management:** Information security shall be considered throughout the entire supplier relationship lifecycle, from selection to termination.

4. Requirements for Supplier Relationship Security

4.1. Supplier Selection and Assessment: a. Before engaging a new supplier, especially those with access to sensitive information or critical systems, a comprehensive security assessment shall be conducted to evaluate their information security posture. b. The level of assessment shall be proportionate to the risk posed by the supplier and the sensitivity of the information involved. This assessment is detailed in IS-ASR01-CIRQ02-A00: Supplier Security Review Procedure. c. Due diligence may include, but is not limited to, reviewing security certifications (e.g., ISO 27001, SOC 2), security policies, incident response plans, and conducting security questionnaires or audits.

4.2. Contractual Agreements: a. All contracts with suppliers handling Cirque's information or providing critical services shall include explicit information security clauses. b. These clauses shall cover, at minimum: * Confidentiality and data protection requirements. * Roles and responsibilities for information security. * Compliance with applicable laws and regulations (e.g., data privacy laws). * Incident management and reporting obligations. *

Right to audit clauses (where appropriate). * Security breach notification requirements. * Data retention and disposal requirements upon contract termination. * Requirements for subcontracting (if applicable). c. Legal review of such contracts is mandatory.

4.3. Information Sharing and Access Control: a. Information shared with suppliers shall be limited to the minimum necessary for the fulfillment of the contract (principle of least privilege). b. Access to Cirque's information systems and facilities granted to suppliers shall be strictly controlled and monitored, with access rights provisioned and de-provisioned promptly. c. Remote access by suppliers shall be secured using strong cryptographic controls (e.g., VPNs with MFA) as per IS-AIR01-CIRQ02-A00: Cryptography Policy.

4.4. Monitoring and Review of Supplier Performance: a. Cirque shall regularly monitor and review suppliers' adherence to contractual information security requirements. b. The frequency and depth of monitoring shall be based on the risk level of the supplier and the criticality of the services or data they handle. c. Monitoring activities may include: * Review of supplier's security reports or audit results. * Periodic security questionnaires. * Performance reviews with security as a key metric. * Audits or inspections by Cirque (where contractually permitted).

4.5. Managing Changes to Supplier Services: a. Any significant changes to the services provided by a supplier, or to their security controls, shall be communicated to and reviewed by Cirque to assess potential information security impacts. b. Changes impacting Cirque's information security shall be managed through the IS-AIR01-CIRQ07-A00: Change Management Procedure.

4.6. Termination of Supplier Relationships: a. Upon termination or expiration of a supplier contract, Cirque shall ensure that: * All access rights to Cirque's information systems and facilities are immediately revoked. * All Cirque's information held by the supplier is securely returned, destroyed, or transferred, in accordance with contractual agreements and IS-AAR01-CIRQ03-A00: Asset Classification and Handling Procedure. * Confirmation of secure data destruction is obtained from the supplier.

5. Responsibilities

- **IT Manager:** Overall responsible for the implementation and oversight of this policy. Manages the process for assessing, contracting, and monitoring suppliers from an information security perspective.
- **Procurement Department:** Responsible for ensuring that information security requirements and clauses are included in all relevant supplier contracts.
- **Legal Counsel:** Reviews all supplier contracts to ensure legal enforceability of security clauses.
- **Department Managers/Service Owners:** Responsible for identifying and managing suppliers relevant to their operations and ensuring their teams comply with this policy.

6. Related Documents

- IS-ASR01-CIRQ02-A00: Supplier Security Review Procedure (To be drafted next)
- IS-APM01-CIRQ01-A00: Information Security Policy
- IS-AAR01-CIRQ01-A00: Asset Management Policy
- IS-AAR01-CIRQ03-A00: Asset Classification and Handling Procedure
- IS-AIR01-CIRQ01-A00: Access Control Policy
- IS-AIR01-CIRQ02-A00: Cryptography Policy
- IS-AIR01-CIRQ07-A00: Change Management Procedure

7. Policy Review

This policy will be reviewed at least annually, or sooner if there are significant changes to Cirque's supplier relationships, business operations, or relevant legal/regulatory requirements.

IS-ASR01-CIRQ02-A00: Supplier Security Review Procedure

IS-ASR01-CIRQ02-A00: Supplier Security Review Procedure

Document: IS-ASR01-CIRQ02-A00

Standards Name: Supplier Security Review Procedure

Category: Related to Outsourcing

Division: Procedure

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** IT Manager

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC9.2

Vendor due diligence and ongoing review

C1.1

Confidential information shared with vendors

The purpose of this procedure is to define the systematic process for conducting information security reviews of existing and prospective suppliers who will have access to Cirque's information, information systems, or facilities, or who will process, store, or transmit Cirque's information on its behalf. This procedure ensures that suppliers meet Cirque's information security requirements and helps manage supply chain risks, in accordance with IS-ASR01-CIRQ01-A00: Supplier Relationships Policy and ISO/IEC 27001:2022 Annex A.15.1.

2. Scope

This procedure applies to all Cirque departments and personnel involved in engaging with, or managing, suppliers that meet the criteria defined in the IS-ASR01-CIRQ01-A00: Supplier Relationships Policy. This includes all types of suppliers, from cloud service providers to IT service providers and software vendors.

3. Responsibilities

- **IT Manager:** Overall owner of this procedure. Leads and oversees supplier security reviews, assesses security risks, and approves supplier security postures.
- **Requesting Department/Service Owner:** Initiates the supplier engagement process and provides details regarding the data/systems the supplier will access or handle.
- **Legal Counsel:** Reviews contractual terms and conditions related to information security.
- **Procurement Department:** Facilitates communication with suppliers and ensures security requirements are included in contracts.

4. Procedure

4.1. Initial Supplier Risk Classification

a. **Trigger:** This procedure is triggered when a new supplier is considered, or when there is a significant change in the services provided by an existing supplier that impacts information security (e.g., increased data access, new data types, critical system access).

b. **Information Gathering:** The Requesting Department/Service Owner, in consultation with the IT Manager, will gather initial information about the supplier and the proposed services, including:

- * Type of service/product provided.

- * What `Cirque` information (data classification, e.g., Confidential, Internal Use) the supplier will access, process, or store.

- * Which `Cirque` systems or facilities the supplier will access.

- * Criticality of the service to `Cirque`s operations.

c. **Risk Classification:** Based on the gathered information, the IT Manager will classify the supplier's security risk as:

- * **High Risk:** Access to Confidential data (e.g., intellectual property like ASIC designs, customer PII), critical systems (e.g., core financial systems, production servers), or direct management of `Cirque`s IT infrastructure.

- * **Medium Risk:** Access to Internal Use data, non-critical systems, or providing services that are important but not core to `Cirque`s immediate operations.

- * **Low Risk:** No access to `Cirque`s information or systems, or only to Public information; typically involves generic, non-IT related services.

4.2. Security Review Activities (Based on Risk Classification)

a. **High-Risk Suppliers:**

- * **Security Questionnaire:** The supplier must complete a detailed security questionnaire (e.g., based on ISO 27001, CSA STAR, or industry-specific frameworks).

- * **Documentation Review:** `Cirque` will request and review relevant security documentation (e.g., ISO 27001 certificate, SOC 2 Type 2 report, penetration test reports, security policies, incident response plans).

- * **Virtual/On-site Audit (Optional, based on need):** If concerns remain or for extremely critical suppliers, a virtual or on-site security audit may be conducted by `Cirque`s IT/Security personnel.

- * **Security Architecture Review:** For suppliers providing critical IT services or cloud infrastructure, `Cirque`s IT Manager will review their security architecture and controls.

- * **Legal Review:** Comprehensive review of contract security clauses by Legal Counsel.

b. **Medium-Risk Suppliers:**

- * **Abbreviated Security Questionnaire:** The supplier must complete a concise security questionnaire focusing on key control areas.

- * **Documentation Review:** Review of basic security certifications or publicly available security statements.

- * **Contractual Clauses:** Ensure inclusion of standard information security clauses in the contract.

c. **Low-Risk Suppliers:**

- * **Minimal Review:** Basic due diligence may suffice, primarily focused on ensuring no unforeseen access to `Cirque`s sensitive information occurs. Standard contractual terms (if any) apply.

4.3. Risk Assessment and Decision

a. **Vulnerability Identification:** The IT Manager will analyze the information gathered during the review to identify any security vulnerabilities or gaps in the supplier's controls.

b. **Risk Scoring:** Identified vulnerabilities and risks will be assessed and scored (referencing `IS-LMR-CIRQ01-F01A: Risk Assessment Register`).

c. ****Remediation Plan:**** If significant risks or control gaps are identified, a remediation plan with timelines must be agreed upon with the supplier before engagement.

d. ****Approval:**** The IT Manager will provide a formal security approval or rejection of the supplier based on the comprehensive review and risk assessment. For high-risk suppliers, executive committee approval may be required.

4.4. Contractual Inclusion of Security Requirements

a. Following security approval, the Procurement Department, with input from the IT Manager and Legal Counsel, will ensure all agreed-upon information security requirements and commitments are accurately reflected and legally binding within the supplier contract.

4.5. Ongoing Monitoring and Re-evaluation

a. ****Regular Monitoring:**** The IT Manager and Requesting Department will monitor the supplier's ongoing compliance with security requirements as per `IS-ASR01-CIRQ01-A00: Supplier Relationships Policy`. This may include periodic review of security reports or performance.

b. ****Re-evaluation Triggers:**** A new security review (following this procedure) shall be triggered if:

- * The supplier's service changes significantly, increasing their access or data handling responsibilities.
- * A security incident occurs involving the supplier.
- * The supplier's security posture is publicly questioned or known to have been compromised.
- * At a minimum, for high and medium-risk suppliers, a re-evaluation should occur at least every two years, or as determined by contractual terms.

5. Documentation

All supplier security review activities, including risk classifications, questionnaires, documentation reviews, remediation plans, and approval decisions, shall be documented and retained for audit purposes.

6. Review and Update

This procedure will be reviewed at least annually, or sooner if there are significant changes to Cirque's supplier engagement processes, risk appetite, or relevant legal/regulatory requirements.

7. Related Documents

- IS-ASR01-CIRQ01-A00: Supplier Relationships Policy
- IS-LMR-CIRQ01-F01A: Risk Assessment Register
- IS-AAR01-CIRQ01-A00: Asset Management Policy
- IS-AAR01-CIRQ03-A00: Asset Classification and Handling Procedure
- IS-APM01-CIRQ01-A00: Information Security Policy

Part XI — Information Security Incident Management

IS-AMG01-CIRQ01-A00: Information Security Incident Management Policy

IS-AMG01-CIRQ01-A00: Information Security Incident Management Policy

Document: IS-AMG01-CIRQ01-A00

Standards Name: Information Security Incident Management Policy

Category: IT Security Related

Division: Policy

Standard Retention: Exist and No Corrections

Standard Type: Global

1. Purpose

SOC 2 Trust Services Criteria Mapping

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC2.3

External communication during incidents

CC7.3

Evaluates security events to determine whether they are security incidents

CC7.4

Responds to identified security incidents (including communication and escalation)

CC7.5

Identifies, develops, and implements activities to recover from security incidents

C1.2

Protects confidential information from unauthorized disclosure during incidents

The purpose of this policy is to establish Cirque's requirements for the effective management of information security incidents. This includes defining a structured approach for reporting, assessing, responding to, resolving, and learning from security incidents. This policy aims to minimize the impact of security incidents, ensure timely recovery, and prevent recurrence, in accordance with ISO/IEC 27001:2022 Annex A.16.

2. Scope

This policy applies to all Cirque personnel (employees, contractors, temporary staff), all information assets, information systems, applications, and networks owned or managed by Cirque across all its global operations (US HQ, Taipei office, and authorized remote work locations). It covers all types of information security incidents, from minor security events to major breaches.

3. Definitions

- **Information Security Event:** An identified occurrence of a system, service, or network state indicating a possible breach of information security policy or failure of controls, or a previously unknown situation that may be security relevant.

- **Information Security Incident:** A single or a series of unwanted or unexpected information security events that have a significant probability of compromising business operations and threatening information security (e.g., loss of confidentiality, integrity, or availability).
- **Information Security Breach:** A security incident that results in the confirmed or suspected unauthorized access, use, disclosure, loss, or theft of sensitive or confidential information.
- **Incident Response Team (IRT):** A designated group of individuals responsible for managing and responding to information security incidents.

4. Principles of Information Security Incident Management

Cirque is committed to managing information security incidents effectively based on the following principles:

- **Timeliness:** Incidents shall be reported, assessed, and responded to as quickly as possible to minimize potential damage.
- **Containment and Recovery:** Efforts shall focus on containing the incident and restoring affected services and data to normal operation in a timely manner.
- **Learning and Improvement:** Incidents shall be analyzed to identify root causes and implement corrective actions to prevent recurrence.
- **Compliance:** All incident management activities shall comply with relevant legal, regulatory, and contractual obligations, including data breach notification requirements.
- **Communication:** Clear and effective communication shall be maintained with relevant stakeholders throughout the incident lifecycle.

5. Information Security Incident Management Requirements

5.1. Incident Reporting: a. All Cirque personnel are responsible for reporting any suspected or actual information security event or incident immediately upon discovery. b. Reporting channels shall be clearly communicated (e.g., direct contact with IT Manager, dedicated email alias, ticketing system). c. Reports shall include as much detail as possible about the event, including time, location, affected systems, and observations.

5.2. Incident Assessment and Classification: a. Upon receiving an incident report, the IT Manager (or designated IT personnel) shall promptly assess the event to determine if it constitutes an information security incident. b. Incidents shall be classified based on their severity, impact on business operations, and potential for data compromise (e.g., Low, Medium, High, Critical). This classification will guide response prioritization.

5.3. Incident Response and Management: a. An **Incident Response Team (IRT)**, led by the IT Manager, shall be established with clearly defined roles and responsibilities for handling incidents. b. The incident response process shall follow defined steps, typically including: * **Preparation:** Establishing tools, processes, and training for incident handling. * **Detection & Analysis:** Identifying and understanding the scope and nature of the incident. * **Containment:** Limiting the damage and preventing further spread of the incident. * **Eradication:** Removing the cause of the incident (e.g., malware, unauthorized access). * **Recovery:** Restoring affected systems and data to normal operations. * **Post-Incident Activity:** Lessons learned, reporting, and preventive actions. c. Specific procedures shall be developed for common incident types (e.g., malware infection, unauthorized access, data loss, denial of service attacks, phishing).

5.4. Communication and Escalation: a. Clear communication channels shall be established for internal and, where necessary, external stakeholders (e.g., customers, regulatory authorities, law enforcement). b. Incidents shall be escalated based on their classification and potential impact. Critical incidents (e.g., data breaches) require immediate notification to executive management. c. Legal counsel shall be consulted for incidents that may have legal or regulatory implications, particularly concerning data breach notification requirements.

5.5. Evidence Collection and Preservation: a. During an incident, all relevant evidence (e.g., logs, forensic images, physical devices) shall be collected and preserved in a forensically sound manner to support investigation and potential legal action. b. The chain of custody for evidence shall be maintained.

5.6. Post-Incident Review and Improvement: a. After an incident is resolved, a post-incident review (lessons learned) shall be conducted, especially for significant incidents. b. The review shall identify: * What happened, when, and how. * The root cause of the incident. * Effectiveness of the response actions. * Impact of the incident. * Recommendations for preventing recurrence and improving incident response capabilities. c. Corrective actions identified during the review shall be tracked and implemented (refer to IS-AIR01-CIRQ07-A00: Change Management Procedure).

5.7. Compliance and Reporting: a. Cirque shall comply with all applicable laws and regulations regarding information security incident reporting and data breach notifications (e.g., GDPR, CCPA, industry-specific regulations). b. Records of all incidents, their handling, and outcomes shall be maintained for audit and compliance purposes.

6. Responsibilities

- **IT Manager:** Acts as the Incident Response Team Lead. Responsible for coordinating all incident management activities, ensuring resources are available, and reporting to executive management.
- **All Personnel:** Responsible for prompt reporting of suspected incidents.
- **Executive Committee:** Provides strategic oversight and approves significant resources for incident management.
- **Legal Counsel:** Provides guidance on legal and regulatory compliance, particularly for data breaches.

7. Related Documents

- IS-AMG01-CIRQ02-A00: Incident Response Procedure (Global Core)
- IS-APM01-CIRQ01-A00: Information Security Policy
- IS-AIR01-CIRQ03-A00: Operations Security Policy
- IS-AIR01-CIRQ09-A00: Logging and Monitoring Procedure
- IS-AIR01-CIRQ07-A00: Change Management Procedure
- IS-LMR-CIRQ01-F01A: Risk Assessment Register

8. Policy Review

This policy will be reviewed at least annually, or sooner if there are significant changes to Cirque's operations, legal/regulatory landscape, or lessons learned from incidents.

IS-AMG01-CIRQ02-A00: Incident Response Procedure (Global Core)

IS-AMG01-CIRQ02-A00: Incident Response Procedure (Global Core)

Document: IS-AMG01-CIRQ02-A00

Standards Name: Incident Response Procedure (Global Core)

Category: IT Security Related

Division: Procedure

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.1 **Effective Date:** 2026-05-08 **Review Date:** 2027-05-08 **Approved By:** IT Manager

Change history (v1.0 → v1.1): Added Section 5.2.d Severity Matrix with criteria and MTTR/MTTD/escalation targets per severity tier (Critical/High/Medium/Low). Added Section 7 Breach Notification with links to US and Asia localized timelines. Corrected email domain to security@cirque.com. Closes SOC 2 Critical Finding C-05.

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC2.3

External communication during incidents

CC7.3

Evaluates events to determine incidents

CC7.4

Responds to incidents

CC7.5

Recovery from incidents

C1.2

Protects confidential information from disclosure during incidents

The purpose of this procedure is to define the global core process for responding to information security incidents within Cirque. It provides a systematic framework for detecting, analyzing, containing, eradicating, recovering from, and conducting post-incident activities for security incidents, thereby minimizing their impact and facilitating timely recovery, in accordance with IS-AMG01-CIRQ01-A00: Information Security Incident Management Policy and ISO/IEC 27001:2022 Annex A.16.

2. Scope

This procedure applies to all Cirque personnel (employees, contractors, temporary staff) and all information assets, information systems, applications, and networks owned or managed by Cirque across all its global operations (Sandy, UT HQ; Taipei, Taiwan office; and authorized remote work locations including remote workers in China). It covers all suspected or confirmed information security incidents. Localized procedures (IS-AMG01-CIRQ03-A00 US, IS-AMG01-CIRQ04-A00 Asia) provide region-specific notification timelines and contacts; the core steps in this Global Core procedure remain consistent.

3. Definitions

- **Information Security Incident:** A single or a series of unwanted or unexpected information security events that have a significant probability of compromising business operations and threatening information security (e.g., loss of confidentiality, integrity, or availability).

- **Incident Response Team (IRT):** A designated group of individuals responsible for managing and responding to information security incidents.
- **Containment:** The act of limiting the scope and impact of an incident.
- **Eradication:** The act of removing the cause of the incident.
- **Recovery:** The act of restoring affected systems and services to normal operation.

4. Incident Response Team (IRT)

- a. The **Incident Response Team (IRT)** shall be led by the IT Manager and comprise key personnel from IT, Legal, Human Resources, and relevant business units as required by the nature and scope of the incident.
- b. The IT Manager is the primary Incident Coordinator.
- c. Contact information for IRT members and escalation paths shall be maintained and readily accessible.

5. Incident Response Lifecycle

The incident response process follows a six-phase lifecycle:

5.1. Phase 1: Preparation

- a. **Policy & Procedure Development:** Maintain and review this procedure and the `IS-AMG01-CIRQ01-A00: Information Security Incident Management Policy`.
- b. **IRT Training:** Ensure IRT members receive regular training on incident response procedures, tools, and roles.
- c. **Tools & Resources:** Maintain necessary tools for incident response (e.g., forensic tools, secure communication channels, network diagrams, asset inventories).
- d. **Communication Plan:** Develop and maintain communication templates and escalation matrices for internal and external stakeholders.
- e. **Testing:** Periodically test incident response capabilities through drills or tabletop exercises.

5.2. Phase 2: Detection and Analysis

- a. **Incident Reporting:** Any individual who suspects or confirms an information security event or incident shall report it immediately to the IT Manager or through designated channels (e.g., `security@cirque.com`, or the IT ticketing system).
- b. **Initial Triage:** The IT Manager or designated IT personnel performs initial assessment to determine if a reported event constitutes an information security incident.
- c. **Gather Information:** Collect relevant information: What happened? When? Where? How was it discovered? Who is affected? What is the potential impact?

d.
Classification and Prioritization (Severity Matrix): The IT Manager classifies every confirmed

incident according to the severity matrix below. The IRT shall meet the corresponding response targets.

Severity

Examples

MTTD target (detection)

MTTR contain

MTTR eradicate

MTTR recover

Escalation

Critical

Confirmed breach of Confidential data (customer IP, ASIC/firmware source, employee PII, financial); ransomware on production systems; loss of master key material; unauthorized access to a tier-0 admin account.

≤ 1 hour from detection

≤ 4 hours

≤ 8 hours

≤ 24 hours

IRT + Executive Committee + CEO; legal counsel engaged within 1 hour.

High

Confirmed compromise of a privileged user account; targeted attack against Cirque infrastructure; significant exposure of Restricted data; failed eradication of a previously-contained Medium incident.

≤ 4 hours

≤ 8 hours

≤ 24 hours

≤ 48 hours

IRT + Executive Committee within 4 hours; legal counsel engaged before any external communication.

Medium

Malware contained on a single endpoint; unauthorized internal access attempt; minor unauthorized data exposure (Internal classification); policy violation with potential security impact.

≤ 24 hours

≤ 72 hours

≤ 7 days

IRT and IT Manager; Executive Committee informed at next standing review.

Low

Phishing attempt blocked by Defender; isolated workstation policy violation without exfiltration; failed login alerts from one user account.

≤ 72 hours

Within scheduled work

Within scheduled work

Within scheduled work

IT Manager logs and tracks; reported in monthly metrics.

Severity may be reclassified upward at any time if new evidence warrants it. A Critical or High classification automatically triggers the Breach Notification process in Section 7.

e. Initial Notification: Based on severity, notify relevant IRT members and leadership per the matrix above. All notifications are recorded in the Incident Report Form (IS-AMG01-CIRQ01-F01A) and the Incident Log/Register.

5.3. Phase 3: Containment

a. ****Strategy:**** Develop a containment strategy to prevent further damage and limit the scope of the incident. This strategy should balance business continuity with security needs.

b. ****Execution:**** Implement containment measures, which may include:

- * Isolating affected systems or networks.
- * Disabling compromised accounts.
- * Blocking malicious IP addresses or URLs at firewalls.
- * Disconnecting affected devices from the network.
- * Applying temporary patches or workarounds.

c. ****Evidence Preservation:**** Preserve digital and physical evidence in a forensically sound manner throughout the containment process. Maintain a strict chain of custody.

5.4. Phase 4: Eradication

a. ****Root Cause Analysis:**** Identify and address the root cause of the incident to prevent recurrence. This involves analyzing logs (`IS-AIR01-CIRQ09-A00: Logging and Monitoring Procedure`), forensic evidence, and system configurations.

b. ****Malware Removal:**** Remove malware, backdoors, or unauthorized configurations.

c. ****Vulnerability Remediation:**** Remediate exploited vulnerabilities (e.g., patching systems, reconfiguring firewalls, hardening applications). Implement changes following `IS-AIR01-CIRQ07-A00: Change Management Procedure`.

5.5. Phase 5: Recovery

a. ****Restoration:**** Restore affected systems and data from clean backups (`IS-AIR01-CIRQ08-A00: Backup and Restoration Procedure`) or re-image systems.

b. ****Verification:**** Thoroughly test restored systems and data to ensure full functionality and integrity before returning them to production.

c. ****Monitoring:**** Increase monitoring of recovered systems to detect any resurgence of malicious activity.

d. **Phased Return:** For complex incidents, recovery may be phased, gradually returning systems and services to full operation.

5.6. Phase 6: Post-Incident Activity (Lessons Learned)

a. **Post-Incident Review (PIR):** For all significant incidents, conduct a formal PIR meeting with relevant IRT members and stakeholders.

b. **Documentation:** Document all aspects of the incident, including:

- * Timeline of events.

- * Actions taken during each phase.

- * Root cause analysis and contributing factors.

- * Impact assessment.

- * Lessons learned.

c. **Recommendations:** Develop actionable recommendations for improving security controls, policies, procedures, and incident response capabilities.

d. **Tracking:** Track the implementation of recommendations and corrective actions.

e. **Reporting:** Prepare a final incident report for management and other relevant stakeholders.

f. **Compliance:** Ensure all regulatory and legal notification requirements are met.

6. Communication Strategy

a. **Internal Communication:** Maintain regular internal communication with affected departments, management, and the IRT.

b. **External Communication:** The IT Manager, in consultation with Legal and Executive Management, will manage all external communications (e.g., to law enforcement, customers, regulatory bodies, media). No unauthorized external communication is permitted.

7. Breach Notification

For any incident classified Critical or High, or any incident involving unauthorized access to Confidential or Restricted data (per IS-AAR01-CIRQ02-A00 Data Classification Policy), the IT Manager in consultation with Legal Counsel and Executive Management triggers the Breach Notification process. Cirque's notification commitments are summarized below; the localized procedures provide the detailed clocks and contacts.

7.1. Notification Decision (within 24 hours of confirmed incident): Legal Counsel determines whether the incident meets the notification threshold of any applicable law, regulation, or customer contract. The decision and rationale are recorded in the Incident Report Form. If the threshold is met, notifications proceed per the clocks below.

7.2. Cirque Universal Notification Targets

Recipient

Trigger

Cirque Executive Committee

Critical or High incident

1 hour from severity classification

Cirque CEO

Critical incident

1 hour from severity classification

Affected employees / departments

Any incident affecting their data, systems, or workflow

Promptly; before any external notification

Insurance carrier (cyber liability)

Critical or High incident with potential covered loss

24 hours from confirmed incident

Customer Account Manager

Incident affecting any customer's data, IP, or contractual deliverables

Within the customer-contract notification window (typically 24–72 hours; consult contract)

Law enforcement

Where required by law, contract, or where a criminal act is suspected

As advised by Legal Counsel

Cyber insurance / external IR retainer

Critical incident requiring external assistance

4 hours from severity classification

7.3. Regulatory Notification — see localized procedures

United States (CCPA, UCPA, state attorneys general, sector regulators): see IS-AMG01-CIRQ03-A00 (US Localized) Section 7.

Asia (Taiwan PDPA for Taipei office data; China PIPL for remote workers and any Chinese-resident data): see IS-AMG01-CIRQ04-A00 (Asia Localized) Section 7.

EU GDPR (only if Cirque processes EU-resident data): 72 hours to lead supervisory authority from awareness; affected individuals without undue delay if high risk. Confirm applicability with Legal before notification.

7.4. Customer-Contract Notification

In addition to legal/regulatory windows, several Cirque customer contracts specify their own notification windows that may be shorter than legal minimums. The Vendor / Customer Register (IS-AMR06-CIRQ01-F01A and the Cirque executed-contract repository) records each customer's notification clock. The IT Manager and Legal Counsel jointly review the register at incident classification.

7.5. Notification Documentation

Confidential — Cirque Corporation Internal

Every notification sent (timestamp, recipient, content, sender, delivery confirmation) is retained as part of the incident record under IS-AMR04-CIRQ01-A00 Document Information Control Policy. Notification artifacts are retained for 7 years.

8. Review and Update

This procedure will be reviewed at least annually, or sooner if there are significant changes to Cirque's IT environment, lessons learned from incidents, or changes in legal/regulatory requirements.

9. Related Documents

IS-AMG01-CIRQ01-A00: Information Security Incident Management Policy

IS-AMG01-CIRQ03-A00: Incident Response Procedure (US Localized)

IS-AMG01-CIRQ04-A00: Incident Response Procedure (Asia Localized)

IS-AMG01-CIRQ01-F01A: Incident Report Form

IS-AIR01-CIRQ09-A00: Logging and Monitoring Procedure

IS-AIR01-CIRQ07-A00: Change Management Procedure

IS-AIR01-CIRQ08-A00: Backup and Restoration Procedure

IS-LMR-CIRQ01-F01A: Risk Assessment Register

IS-APM01-CIRQ01-A00: Information Security Policy

IS-AAR01-CIRQ02-A00: Data Classification Policy

IS-AFR01-CIRQ01-A00: Physical and Environmental Security Policy

IS-AMR06-CIRQ01-F01A: Interested Parties and Their Requirements Register

IS-AMG01-CIRQ03-A00: Incident Response Procedure (US Localized)

IS-AMG01-CIRQ03-A00: Incident Response Procedure (US Localized)

Document: IS-AMG01-CIRQ03-A00

Standards Name: Incident Response Procedure (US Localized)

Category: IT Security Related

Division: Procedure

Standard Retention: Exist and No Corrections

Standard Type: Localized (US)

Version: 1.0 Effective Date: 2025-07-01 Review Date: 2026-07-01 Approved By: IT Manager, US General Manager

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC2.3

External communication during incidents

CC7.3

Evaluates events to determine incidents

CC7.4

Responds to incidents

CC7.5

Recovery from incidents

C1.2

Protects confidential information from disclosure during incidents

The purpose of this procedure is to provide localized guidelines for managing information security incidents affecting Cirque's operations, assets, and information within the United States. It supplements the IS-AMG01-CIRQ02-A00: Incident Response Procedure (Global Core) by detailing US-specific legal, regulatory, and reporting requirements, as well as local contacts and resources for incident response.

2. Scope

This procedure applies to all Cirque personnel, information assets, information systems, applications, and networks located within or primarily serving the United States. It covers all suspected or confirmed information security incidents impacting US operations or data related to US citizens or residents.

3. Responsibilities (US-Specific)

- **US General Manager:** Responsible for awareness of incidents affecting US operations and ensuring local compliance. May act as a primary point of contact for US-specific legal or regulatory inquiries.
- **US IT Lead/Local Administrator:** Primary local contact for incident detection, initial containment, and evidence collection within US operations. Works under the direction of the Global IT Manager.
- **US Legal Counsel (or designated external counsel):** Provides specific legal guidance on US federal and state data breach notification laws (e.g., HIPAA, CCPA, New York SHIELD Act, state-specific breach notification laws) and other relevant regulations.

- **US Human Resources:** Involved in incidents affecting US employees or requiring internal investigations related to personnel.

4. US-Specific Incident Response Guidelines

This procedure follows the six phases outlined in IS-AMG01-CIRQ02-A00: Incident Response Procedure (Global Core). The following sections detail US-specific considerations for each phase:

4.1. Phase 1: Preparation (US Localized)

- Regulatory Awareness:** US IT Lead and US General Manager must stay updated on relevant US federal and state data breach notification laws, industry-specific regulations (e.g., if handling healthcare or financial data), and privacy laws (e.g., CCPA, state privacy laws).
- Local Contacts:** Maintain an up-to-date list of US-specific contacts:
 - * Local law enforcement (FBI field office, local police cybercrime unit).
 - * Relevant regulatory bodies (e.g., FTC, state Attorneys General, specific industry regulators).
 - * Designated external US Legal Counsel for breach response.
 - * Local IT support vendors/partners, if applicable.
- Incident Response Plan Exercise:** Include US-specific scenarios in tabletop exercises (e.g., a breach affecting California residents, a system outage in the US office).

4.2. Phase 2: Detection and Analysis (US Localized)

- Local Reporting Channels:** While global channels remain primary, US personnel should also be aware of any local IT or management contacts for immediate reporting during US business hours.
- Initial Data Point:** For incidents originating or detected within the US, the US IT Lead will be a key resource for initial data collection from local systems, network devices, and user devices.

4.3. Phase 3: Containment (US Localized)

- Local Coordination:** Containment efforts within US facilities (e.g., disconnecting specific US-based servers, isolating US network segments) will be coordinated by the US IT Lead under the direction of the Global IT Manager.

4.4. Phase 4: Eradication (US Localized)

- Local Remediation:** Remediation steps on US-based systems, such as patching US servers or reimaging US workstations, will be executed by the US IT Lead or designated local IT personnel.

4.5. Phase 5: Recovery (US Localized)

- US System Restoration:** The recovery of US-specific systems and data will involve US IT personnel to ensure local verification and operational readiness.

4.6. Phase 6: Post-Incident Activity (Lessons Learned - US Localized)

- US Legal Review:** All incident reports potentially involving personal data of US residents must undergo review by US Legal Counsel to determine specific notification obligations under relevant federal and state laws.
- Regulatory Reporting:** The IT Manager, in consultation with US Legal Counsel and US General Manager, is responsible for fulfilling any mandatory data breach notification requirements to affected individuals, state Attorneys General, or other relevant US regulatory bodies within specified timelines.
- Lessons Learned Integration:** US-specific findings and recommendations from post-incident reviews will be incorporated into this localized procedure and communicated to global IT.

5. US-Specific Communication and External Reporting

- Notification to Affected Individuals:** In the event of a data breach involving personal information of US residents, notifications shall be made in accordance with the specific state laws where the individuals reside. This includes content, timing, and method of notification.

b. ****Regulatory Notifications:**** Specific regulatory bodies in the US (e.g., Department of Health and Human Services for HIPAA, state Attorneys General, specific industry regulators) may require direct notification. This is to be handled by the IT Manager, US General Manager, and US Legal Counsel.

c. ****Law Enforcement:**** For criminal incidents, collaboration with US federal (e.g., FBI Cyber Division) or local law enforcement will be managed by the IT Manager and US Legal Counsel.

6. Review and Update

This localized procedure will be reviewed at least annually, or sooner if there are significant changes to Cirque's US operations, new US federal or state privacy/breach notification laws, or lessons learned from incidents impacting US entities.

7. US Breach Notification Annex

This annex codifies the US-specific breach notification clocks and authorities applicable to Cirque (Sandy, UT HQ; remote workers in US states; personal information of US residents in customer or employee data). The IT Manager, in consultation with US Legal Counsel, applies the strictest applicable clock when more than one law applies.

7.1. Federal

Law / Authority

Applies when

Notification window

Notes

FTC (FTC Act § 5; Safeguards Rule for non-banking financial institutions)

Cirque processes consumer financial data; breach causes substantial consumer injury

"Without unreasonable delay"; FTC Safeguards Rule amended 2023 requires notification of breaches of 500+ consumers within 30 days

Confirm Safeguards Rule applicability with Legal; Cirque is not a non-banking financial institution by default

HIPAA Breach Notification Rule

Only if Cirque becomes a Business Associate or Covered Entity under HIPAA

60 days to affected individuals; HHS within 60 days; media if 500+ in one state

Currently NOT applicable to Cirque

GLBA Safeguards Rule

Only if Cirque is a financial institution

30 days to FTC for 500+ consumers

Currently NOT applicable to Cirque

**7.2. State Laws
(where Cirque has
employees,
customers, or
processes
residents' data)**

State

Law

Notification window — affected individuals

State authority window

Threshold

Utah (HQ)

UCPA + Utah Code § 13-44

“In the most expedient time possible without unreasonable delay”

AG within “the most expedient time”; written notice required to AG if breach affects 500+ Utah residents

Personal information including SSN, DL, financial account

California

CCPA / CPRA + Cal. Civ. Code § 1798.82

“In the most expedient time possible and without unreasonable delay”

AG within timeframe consistent with affected individuals if 500+ CA residents

Personal info including biometric, medical, account

Texas

Tex. Bus. & Com. Code § 521

Without unreasonable delay; not later than 60 days after determining a breach occurred

AG within 30 days if 250+ TX residents

Sensitive personal info; specific notice content required

Washington

RCW § 19.255

Without unreasonable delay; not more than 30 days after discovery

AG within 30 days if 500+ WA residents

Personal info incl. medical, financial

NY SHIELD Act + GBL § 899-aa

Most expedient time without unreasonable delay

AG, Dept of State, State Police within timeframe consistent with individuals if 500+ NY residents

Private info

Illinois

IL Personal Information Protection Act + BIPA (biometrics)

Most expedient time without unreasonable delay

AG within 45 days if 500+ IL residents

Personal info incl. biometric

Massachusetts

M.G.L. c. 93H + 201 CMR 17.00

As soon as practicable and without unreasonable delay

AG and Office of Consumer Affairs as soon as practicable

Personal info incl. SSN, DL, financial

Other states

Refer to Cirque Legal Register IS-AMR01-CIRQ01-F02A and US Legal Counsel

Generally “expedient” or 30–60 days

Varies

Refer to register

7.3. Customer-Contract Notification

Several Cirque customer contracts require notification within shorter windows (often 24–72 hours). The Account Manager and Legal Counsel review the executed contract for each affected customer at incident classification time. Customer notification windows are recorded in the Interested Parties Register (IS-AMR06-CIRQ01-F01A).

7.4. Notification Decision Log

For every Critical or High incident, the IT Manager records in the Incident Report Form: (1) which jurisdictions are in scope, (2) which laws were evaluated, (3) the decision to notify or not notify each authority/group, (4) Legal Counsel's sign-off, and (5) notification artifacts (timestamps, recipients, content).

8. Related Documents

IS-AMG01-CIRQ01-A00: Information Security Incident Management Policy

IS-AMG01-CIRQ02-A00: Incident Response Procedure (Global Core)

IS-AMG01-CIRQ04-A00: Incident Response Procedure (Asia Localized)

IS-AMG01-CIRQ01-F01A: Incident Report Form

IS-AMR01-CIRQ01-F02A: Legal Register (US Localized)

IS-AMR06-CIRQ01-F01A: Interested Parties and Their Requirements Register

IS-AAR02-CIRQ02-A00: Privacy Policy (US Localized)

IS-AMG01-CIRQ04-A00: Incident Response Procedure (Asia Localized)

IS-AMG01-CIRQ04-A00: Incident Response Procedure (Asia Localized)

Document: IS-AMG01-CIRQ04-A00

Standards Name: Incident Response Procedure (Asia Localized)

Category: IT Security Related

Division: Procedure

Standard Retention: Exist and No Corrections

Standard Type: Localized (Asia - China, Taiwan)

Version: 1.0 Effective Date: 2025-07-01 Review Date: 2026-07-01 Approved By: IT Manager, Regional Asia General Manager

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC2.3

External communication during incidents

CC7.3

Evaluates events to determine incidents

CC7.4

Responds to incidents

CC7.5

Recovery from incidents

C1.2

Protects confidential information from disclosure during incidents

The purpose of this procedure is to provide localized guidelines for managing information security incidents affecting Cirque's operations, assets, and information within the Asia region, specifically covering entities in **China** and **Taiwan**. It supplements the IS-AMG01-CIRQ02-A00: Incident Response Procedure (Global Core) by detailing region-specific legal, regulatory, and reporting requirements, as well as local contacts and resources for incident response in these locations.

2. Scope

This procedure applies to all Cirque personnel, information assets, information systems, applications, and networks located within or primarily serving China and Taiwan. It covers all suspected or confirmed information security incidents impacting operations in these regions or data related to their citizens or residents.

3. Responsibilities (Asia-Specific)

- **Regional Asia General Manager:** Responsible for awareness of incidents affecting Asia operations and ensuring local compliance. Serves as a primary point of contact for regional legal or regulatory inquiries.
- **Local IT Lead (China/Taiwan):** Primary local contact for incident detection, initial containment, and evidence collection within their respective Asia operations. Works under the direction of the Global IT Manager.
- **Regional Legal Counsel (or designated external counsel):** Provides specific legal guidance on relevant data protection laws, cybersecurity laws, and data breach notification requirements for both **China (e.g., Cybersecurity Law, Data Security Law, PIPL)** and **Taiwan (e.g., Personal Data Protection Act)**.
- **Regional Human Resources:** Involved in incidents affecting regional employees or requiring internal investigations related to personnel.

4. Asia-Specific Incident Response Guidelines

This procedure follows the six phases outlined in IS-AMG01-CIRQ02-A00: Incident Response Procedure (Global Core). The following sections detail Asia-specific considerations for each phase, noting distinctions between China and Taiwan where critical.

4.1. Phase 1: Preparation (Asia Localized)

a. ****Regulatory Awareness:****

* ****China:**** Local IT Lead and Regional Asia General Manager must be acutely aware of China's Cybersecurity Law (CSL), Data Security Law (DSL), Personal Information Protection Law (PIPL), and other relevant regulations, including cross-border data transfer rules.

* ****Taiwan:**** Awareness of Taiwan's Personal Data Protection Act (PDPA) and any specific industry regulations.

b. ****Local Contacts:**** Maintain an up-to-date list of regional and country-specific contacts:

* ****China:**** Local Cybersecurity Administration of China (CAC), Ministry of Public Security, local law enforcement. Designated external China Legal Counsel.

* ****Taiwan:**** Relevant regulatory bodies, local law enforcement. Designated external Taiwan Legal Counsel.

* Local IT support vendors/partners, if applicable, for both regions.

c. ****Incident Response Plan Exercise:**** Include Asia-specific scenarios in tabletop exercises (e.g., a data breach impacting personal information of Chinese citizens, a cyberattack targeting the Taiwan office).

4.2. Phase 2: Detection and Analysis (Asia Localized)

a. ****Local Reporting Channels:**** While global channels remain primary, personnel in China and Taiwan should also be aware of any local IT or management contacts for immediate reporting during local business hours.

b. ****Initial Data Point:**** For incidents originating or detected within China or Taiwan, the respective Local IT Lead will be a key resource for initial data collection from local systems, network devices, and user devices.

4.3. Phase 3: Containment (Asia Localized)

a. ****Local Coordination:**** Containment efforts within China/Taiwan facilities (e.g., disconnecting specific local servers, isolating network segments) will be coordinated by the respective Local IT Lead under the direction of the

Global IT Manager. Special consideration must be given to potential implications of data transfer restrictions during containment in China.

4.4. Phase 4: Eradication (Asia Localized)

a. **Local Remediation:** Remediation steps on local systems, such as patching servers or reimaging workstations, will be executed by the respective Local IT Lead or designated local IT personnel.

4.5. Phase 5: Recovery (Asia Localized)

a. **Local System Restoration:** The recovery of China/Taiwan-specific systems and data will involve local IT personnel to ensure local verification and operational readiness.

4.6. Phase 6: Post-Incident Activity (Lessons Learned - Asia Localized)

a. **Regional Legal Review:**

* **China:** All incident reports potentially involving personal information of Chinese citizens must undergo review by Regional Legal Counsel (or designated external China Legal Counsel) to determine specific notification obligations under CSL, DSL, PIPL, and other relevant laws. **Strict rules apply for cross-border data transfer related to incident response and evidence collection.**

* **Taiwan:** All incident reports potentially involving personal information of Taiwan residents must undergo review by Regional Legal Counsel (or designated external Taiwan Legal Counsel) to determine specific notification obligations under PDPA.

b. **Regulatory Reporting:** The IT Manager, in consultation with the Regional Asia General Manager and Regional Legal Counsel, is responsible for fulfilling any mandatory data breach notification requirements to affected individuals, relevant government authorities (e.g., CAC, public security bureaus in China; relevant ministries in Taiwan), or other regional regulatory bodies within specified timelines.

c. **Lessons Learned Integration:** Asia-specific findings and recommendations from post-incident reviews will be incorporated into this localized procedure and communicated to global IT.

5. Asia-Specific Communication and External Reporting

a. **Notification to Affected Individuals:** In the event of a data breach involving personal information of residents in China or Taiwan, notifications shall be made in accordance with the specific laws of that region. This includes content, timing, and method of notification.

b. **Regulatory Notifications:** Specific regulatory bodies in China and Taiwan may require direct notification. This is to be handled by the IT Manager, Regional Asia General Manager, and Regional Legal Counsel. Particular attention must be paid to the strict reporting requirements in China.

c. **Law Enforcement:** For criminal incidents, collaboration with regional law enforcement (e.g., public security bureaus in China) will be managed by the IT Manager and Regional Legal Counsel, adhering to local legal frameworks.

6. Review and Update

This localized procedure will be reviewed at least annually, or sooner if there are significant changes to Cirque's Asia operations, new regional data protection or cybersecurity laws (e.g., changes to PIPL or PDPA), or lessons learned from incidents impacting Asia entities.

7. Asia Breach Notification Annex

This annex codifies the Asia-region breach notification clocks applicable to Cirque (Taipei office; remote workers in China; data related to Taiwan or PRC residents). The IT Manager, Regional Asia General Manager, and Regional Legal Counsel apply the strictest applicable clock when more than one law applies.

Confidential — Cirque Corporation Internal
Trigger

Notification window — affected individuals

Authority window

Notes

Breach of personal data of Taiwan residents

“Without delay” — Cirque target: 72 hours from confirmed breach to affected individuals

Sector-specific competent authority (e.g., Ministry of Digital Affairs for general business) “without delay”

Method: appropriate to circumstances (email, written, public). Content: nature of breach, data affected, mitigation steps, contact

Cross-border transfer of Taiwan residents’ data involved

Same as above + transfer record retention

Same

Document the transfer mechanism (consent, contract, regulator approval)

**7.2. China — Personal
Information Protection
Law (PIPL),
Cybersecurity Law
(CSL), Data Security
Law (DSL)**

Trigger

Notification window — affected individuals

Authority window

Notes

Breach affecting personal information of PRC residents (PIPL Article 57)

“Immediately” notify affected individuals; Cirque target: 72 hours from confirmed breach

“Immediately” notify the Cyberspace Administration of China (CAC) and other relevant authorities. Cirque target: 24 hours from confirmed breach. Confirm with Regional Legal whether incident reaches the CAC reporting threshold

Method: written, with the content prescribed by PIPL Article 57. Mitigation actions, contact channel for individuals

Critical Information Infrastructure (CII) incident under CSL

Notify CAC and Ministry of Public Security per CSL

“Immediately” / per CII regulations

Cirque has not been designated CII; confirm at incident classification

Confidential — Cirque Corporation Internal
Important data or core data breach under DSL

Per DSL Articles 21 + 30

“Immediately” to relevant authority; severe incidents within 8 hours

Confirm with Regional Legal whether data is classified as Important or Core under DSL

Cross-border data transfer incident

Per PIPL Article 38 + CAC outbound data transfer regulations

Per applicable transfer mechanism

Cross-border data movement during incident response (e.g., evidence shipment, log forwarding) requires documented authority

7.3. Cirque Notification Decision Process

IT Manager classifies the incident (Section 5.2.d Severity Matrix in the Global Core procedure).

Regional Asia General Manager and Regional Legal Counsel review the data subjects and jurisdictions involved.

Legal Counsel confirms which Taiwan/China laws apply.

Legal Counsel issues notification decision in writing within 24 hours of classification.

IT Manager records every notification (recipient, content, timestamp, delivery confirmation) in the Incident Report Form (IS-AMG01-CIRQ01-F01A) and the Incident Log/Register.

Notification artifacts retained for 7 years per IS-AMR04-CIRQ01-A00.

7.4. Cross-Border Data Transfer During Incident Response

China PIPL and DSL place special restrictions on outbound data transfer of PRC personal information and PRC-classified data. During incident response, evidence movement (logs, file copies, system images) that would constitute a cross-border transfer must be authorized in writing by Regional Legal Counsel before execution. For evidence essential to investigation but blocked by transfer rules, in-region analysis is preferred.

8. Related Documents

IS-AMG01-CIRQ01-A00: Information Security Incident Management Policy

IS-AMG01-CIRQ02-A00: Incident Response Procedure (Global Core)

IS-AMG01-CIRQ03-A00: Incident Response Procedure (US Localized)

IS-AMG01-CIRQ01-F01A: Incident Report Form

IS-AMR01-CIRQ01-F03A: Legal Register (Asia Localized)

IS-AMR06-CIRQ01-F01A: Interested Parties and Their Requirements Register

IS-AAR06-CIRQ01-A00: Privacy Policy (Asia — Taiwan PDPA, China PIPL)

IS-APM01-CIRQ01-A00: Information Security Policy

China Cybersecurity Law (CSL); Data Security Law (DSL); PIPL (external references — monitored via IS-LMR-CIRQ06-F01A)

Taiwan Personal Data Protection Act (PDPA) (external reference)

IS-AMG01-CIRQ01-F01A: Incident Report Form

IS-AMG01-CIRQ01-F01A: Incident Report Form

Standards Name: Incident Report Form

Category: IT Security Related

Division: Form

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 Effective Date: 2025-07-01 Review Date: 2026-07-01 Approved By: IT Manager

1. Purpose

The purpose of this form is to provide a structured template for all Cirque personnel to report suspected or actual information security incidents promptly and accurately. The information captured herein is critical for the initial assessment, classification, and response to security incidents, in accordance with IS-AMG01-CIRQ01-A00: Information Security Incident Management Policy and IS-AMG01-CIRQ02-A00: Incident Response Procedure (Global Core).

2. Instructions for Completion

- Complete all sections to the best of your knowledge.
- Report any suspected incident immediately, even if details are incomplete.
- Do NOT attempt to resolve the issue yourself unless specifically instructed by IT or the Incident Response Team.
- Submit this form to the IT Manager or through the designated incident reporting channel (e.g., security@cirq.com, IT ticketing system).

3. Incident Details

3.1. Reporter Information * Full Name: _____ * Department: _____
_____ * Location (Office/Remote): _____ * Contact Email: _____
_____ * Contact Phone: _____ * Date of Report: // _____
(YYYY/MM/DD) * Time of Report: : (HH:MM AM/PM)

3.2. Incident Discovery Information * Date of Discovery: // _____ (YYYY/MM/DD) * Time of Discovery: :
(HH:MM AM/PM) * How was the incident discovered? (e.g., user noticed something unusual, automated alert,
reported by external party, email phishing attempt)

3.3. Incident Classification * Type of Suspected Incident (Check all that apply): * ☐ Malware/Virus Infection * ☐
Phishing/Email Compromise * ☐ Unauthorized Access (Account/System) * ☐ Data Loss/Theft/Exposure * ☐ Denial
of Service (DoS)/Distributed DoS (DDoS) * ☐ System/Application Vulnerability * ☐ Policy Violation * ☐ Physical
Security Breach (e.g., unauthorized entry) * ☐ Lost/Stolen Device (Laptop, Mobile, USB) * ☐ Unintended Data
Disclosure * ☐ Ransomware * ☐ Other (Please specify): _____

3.4. Description of the Incident * Please provide a detailed description of what happened, including any
unusual behavior, error messages, or suspicious activities observed:

3.5. Affected Assets/Systems * Which systems, applications, data, or devices are affected or suspected to
be affected? (e.g., My laptop, network drive, specific server, Omnify, QuickBooks, a specific database, Cadence
design files, GitLab repository)

3.6. Impact Assessment (Initial) * What is the immediate impact observed? (e.g., System unavailable, data inaccessible, slow performance, unusual emails being sent, files missing)

ongoing? ☐ Yes ☐ No *** Are operations severely disrupted?** ☐ Yes ☐ No *** Is critical data potentially compromised?** ☐ Yes ☐ No *** Is the incident still**

3.7. Actions Taken by Reporter (if any, before reporting) * Please list any steps you have taken (e.g., disconnected from network, deleted suspicious email):

*** WARNING: DO NOT take further action without instruction from IT/IRT.**

4. For Incident Response Team (IRT) Use Only

4.1. Incident Tracking * Incident ID: IS-CIRQ-IR-____-____ (YYYYMMDD-sequential) * Date/Time Assigned: //____: * Assigned IRT Lead: _____ * Current Status: ☐ New ☐ In Progress ☐ Contained ☐ Eradicated ☐ Recovered ☐ Closed

4.2. Severity and Priority Assessment (IRT Lead) * Severity: ☐ Critical ☐ High ☐ Medium ☐ Low *** Priority:** ☐ Urgent ☐ High ☐ Medium ☐ Low *** Justification:**

4.3. Incident Response Actions Log | Date/Time | Action Taken / Observation | Performed By | :-----
| :----- | :----- | ||||| (Attach additional sheets if necessary)

4.4. Root Cause Analysis (Initial)

4.5. Recommendations for Improvement

4.6. Legal/Regulatory Considerations * Potential for Data Breach Notification: ☐ Yes ☐ No * **Legal Counsel Notified:** ☐ Yes ☐ No ☐ N/A * **Regulatory Body Notified:** ☐ Yes ☐ No ☐ N/A

4.7. Incident Closure * Date/Time Closed: // _____ : * Closed By: _____ * Final Summary:

5. Distribution

- Original: Incident Response Team (IT Manager)
- Copy: Legal (if applicable)
- Copy: Relevant Business Unit Manager (if applicable)

Part XII — Business Continuity and Disaster Recovery

IS-LIR-CIRQ01-A00: Information Security Continuity Policy

IS-LIR-CIRQ01-A00: Information Security Continuity Policy

Standards Name: Information Security Continuity Policy

Category: IT Security Related

Division: Policy

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 Effective Date: 2025-07-01 Review Date: 2026-07-01 Approved By: Executive Committee

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC7.5

Recovery from disruption

CC9.1

Mitigation of business disruption risk

C1.1

Retention of confidential information through backup integrity

The purpose of this policy is to establish Cirque's framework for information security continuity. It ensures that information security is maintained at an acceptable level during and after disruptive events, thereby supporting the overall business continuity and disaster recovery objectives. This policy aims to minimize the impact of disruptions on Cirque's critical information assets and processes, in accordance with ISO/IEC 27001:2022 Annex A.17.

2. Scope

This policy applies to all Cirque information assets, information systems, applications, and networks deemed critical for the continued operation of Cirque's business processes across all global locations (US, China, Taiwan). It covers the information security aspects of business continuity planning, disaster recovery planning, and crisis management.

3. Definitions

- **Business Continuity (BC):** The capability of the organization to continue delivery of products or services at pre-defined acceptable levels following a disruptive incident.
- **Disaster Recovery (DR):** The process, policies, and procedures related to preparing for recovery or continuation of technology infrastructure critical to an organization after a natural or human-induced disaster.
- **Disruptive Event:** Any event, internal or external, that could interrupt or disrupt Cirque's business operations or compromise its information security (e.g., natural disaster, cyberattack, equipment failure, power outage).

- **Recovery Time Objective (RTO):** The maximum tolerable length of time that a computer system, network, or application can be down after a disaster or failure.
- **Recovery Point Objective (RPO):** The maximum tolerable period in which data might be lost from an IT service due to a major incident.

4. Principles of Information Security Continuity

Cirque is committed to maintaining information security during disruptions based on the following principles:

- **Risk-Based Approach:** Information security continuity plans shall be developed based on identified risks to critical information assets and processes.
- **Integration with BC/DR:** Information security continuity planning shall be integrated with overall business continuity and disaster recovery planning.
- **Resilience by Design:** Systems and processes shall be designed with inherent resilience and redundancy to minimize the impact of disruptions.
- **Regular Testing:** Continuity plans shall be regularly tested and reviewed to ensure their effectiveness and relevance.
- **Clear Responsibilities:** Roles and responsibilities for information security during disruptive events shall be clearly defined.

5. Information Security Continuity Requirements

5.1. Planning for Information Security Continuity: a. Cirque shall develop and maintain information security continuity plans that address the protection and recovery of critical information assets and systems during and after disruptive events. b. These plans shall be based on a comprehensive Business Impact Analysis (BIA) and Risk Assessment to identify critical business processes, their dependencies on information systems, and associated RTOs and RPOs. c. Specific recovery strategies shall be documented, including fallback procedures, hot/warm/cold site considerations, and data restoration processes.

5.2. Integration with Business Continuity and Disaster Recovery Plans: a. Information security continuity plans shall be an integral part of Cirque's overarching Business Continuity Plan (BCP) and Disaster Recovery Plan (DRP). b. Security requirements for recovery environments (e.g., alternative sites, cloud recovery instances) shall be as stringent as those for primary operational environments.

5.3. Protection and Availability of Information: a. Critical information and systems shall be protected through appropriate controls to ensure their availability and integrity during disruptive events. This includes: * Regular backups of critical data and system configurations as per IS-AIR01-CIRQ08-A00: Backup and Restoration Procedure. * Implementation of redundant systems and network components where necessary. * Diversification of data storage locations (e.g., off-site backups). * Protection of critical infrastructure (e.g., power, cooling).

5.4. Incident Management Integration: a. This policy is closely linked with the IS-AMG01-CIRQ01-A00: Information Security Incident Management Policy and related Incident Response Procedures. Incident response aims to contain and eradicate a security event, while continuity focuses on restoring affected business functions and data.

5.5. Roles and Responsibilities During Disruptions: a. Clear roles and responsibilities for managing information security during a disruptive event shall be defined within the BCP/DRP and communicated to relevant personnel. b. This includes roles for security monitoring, access control management, data recovery, and incident communication during crisis situations.

5.6. Testing and Review: a. Information security continuity plans shall be regularly tested (e.g., through tabletop exercises, simulated disruptions, or full-scale recovery tests) to ensure their effectiveness. b. Test results shall be documented, and any identified weaknesses or areas for improvement shall be addressed through corrective actions. c. Plans shall be reviewed and updated at least annually, or following significant changes to Cirque's business processes, IT infrastructure, or identified risks.

5.7. Communications During Disruptions: a. Communication protocols shall be established to ensure timely and effective communication with internal stakeholders (employees, management) and external stakeholders (customers, suppliers, regulators, emergency services) during a disruptive event, including clear procedures for security-related communications.

6. Responsibilities

- **Executive Committee:** Approves the overall Business Continuity and Disaster Recovery strategy and allocates necessary resources.
- **IT Manager:** Responsible for developing, implementing, and testing information security continuity plans, and integrating them with IT Disaster Recovery Plans.
- **Business Unit Managers:** Responsible for identifying critical business processes and their information security requirements for continuity within their respective areas.
- **All Personnel:** Responsible for understanding their roles in information security continuity plans and reporting any information security concerns that could impact business continuity.

7. Related Documents

- IS-AMG01-CIRQ01-A00: Information Security Incident Management Policy
- IS-AMG01-CIRQ02-A00: Incident Response Procedure (Global Core)
- IS-AIR01-CIRQ08-A00: Backup and Restoration Procedure
- IS-AIR01-CIRQ03-A00: Operations Security Policy
- IS-APM01-CIRQ01-A00: Information Security Policy
- IS-LMR-CIRQ01-F01A: Risk Assessment Register
- Overall Business Continuity Plan (External document, to be maintained by Management)
- Disaster Recovery Plan (External document, to be maintained by IT)

8. Policy Review

This policy will be reviewed at least annually, or sooner if there are significant changes to Cirque's critical business processes, IT infrastructure, risk profile, or regulatory requirements.

IS-LIG-CIRQ01-A00: Business Continuity and Disaster Recovery Procedure

IS-LIG-CIRQ01-A00: Business Continuity and Disaster Recovery Procedure

Document: IS-LIG-CIRQ01-A00

Standards Name: Business Continuity and Disaster Recovery Procedure

Category: IT Security Related

Division: Procedure

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** IT Manager

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC7.5

Recovery from disruption

CC9.1

Risk mitigation through continuity planning

C1.1

Continuity of confidential-information protection

The purpose of this procedure is to define the structured process for planning, developing, maintaining, and executing Cirque's Business Continuity (BC) and Disaster Recovery (DR) plans. This procedure aims to ensure the continued availability of critical business processes and the recovery of essential information systems and data in the event of a disruptive incident, minimizing downtime and data loss, in accordance with IS-LIR-CIRQ01-A00: Information Security Continuity Policy and ISO/IEC 27001:2022 Annex A.17.

2. Scope

This procedure applies to all Cirque departments, critical business processes, information systems, applications, data, and infrastructure across all global locations (US, China, Taiwan). It specifically covers the recovery of servers and file servers utilizing **Veeam** backup and replication solutions, including the immediate recovery of physical servers to virtual machines (P2V).

3. Definitions

- **Business Continuity Plan (BCP):** A comprehensive plan outlining how Cirque will maintain or quickly resume mission-critical business functions after a disruption.
- **Disaster Recovery Plan (DRP):** A detailed plan focused on the recovery of IT systems and infrastructure following a disruptive event.
- **Recovery Time Objective (RTO):** The maximum tolerable length of time that a business process or system can be down after a disaster or failure.
- **Recovery Point Objective (RPO):** The maximum tolerable period in which data might be lost from an IT service due to a major incident.
- **Disaster Recovery Site:** An alternative location where IT operations can resume after a primary site disaster.

4. Responsibilities

- **Executive Management:** Overall responsibility for approving BCP/DRP strategy, funding, and ensuring adequate resources.

- **IT Manager (DRP Lead):** Primary responsible for the development, implementation, testing, and maintenance of the DRP. Coordinates IT recovery efforts.
- **Business Unit Managers (BCP Owners):** Responsible for identifying critical business processes, defining their RTO/RPO, and developing their specific continuity plans.
- **System Administrators/Engineers:** Responsible for implementing backup and recovery solutions (e.g., **Veeam**), maintaining recovery infrastructure, and executing recovery steps during a disaster.
- **All Personnel:** Responsible for understanding their roles and responsibilities in BCP/DRP activation and execution.

5. Procedure

5.1. Business Impact Analysis (BIA) and Risk Assessment a. **Identify Critical Processes:** Business Unit Managers shall identify and document all critical business processes that are essential for Cirque's operation. b. **Define RTO/RPO:** For each critical process, define the maximum acceptable downtime (RTO) and maximum acceptable data loss (RPO). This shall be documented (e.g., in IS-LMR-CIRQ01-F01A: Risk Assessment Register). c. **Identify Dependencies:** Document dependencies of critical processes on specific information systems, applications, infrastructure, and personnel. d. **Risk Assessment:** Conduct a risk assessment to identify potential threats to critical processes and their supporting IT infrastructure, and evaluate existing controls and residual risks.

5.2. Business Continuity Plan (BCP) Development a. Based on the BIA, each Business Unit Manager shall develop a BCP detailing: * Manual workarounds for critical processes if IT systems are unavailable. * Alternate communication methods (e.g., outside normal network). * Designated alternative work locations or remote work capabilities. * Key personnel roles and contact information during a disruption. * Procedures for essential functions that must continue without IT.

5.3. Disaster Recovery Plan (DRP) Development a. The IT Manager shall develop a comprehensive DRP focusing on IT systems recovery, including: * **Recovery Team:** Defined roles, responsibilities, and contact information for the DR team. * **Critical Systems Inventory:** A prioritized list of critical servers, applications, and data with their RTOs/RPOs. * **Backup and Recovery Strategy:** Detailed procedures for data backup and restoration using **Veeam** for servers and file servers, as per IS-AIR01-CIRQ08-A00: Backup and Restoration Procedure. * **Alternative Site Strategy:** Documentation of the designated disaster recovery site(s) (e.g., cloud environment, co-location, warm site). * **System Recovery Procedures:** Step-by-step instructions for recovering operating systems, applications, databases, and network services. * **Physical-to-Virtual (P2V) Recovery:** Specific procedures for recovering physical servers as virtual machines using **Veeam's Instant VM Recovery** feature to ensure immediate operational capability. * **Network Recovery:** Procedures for restoring network connectivity at the recovery site. * **Application Recovery:** Procedures for restoring and configuring critical applications. * **Data Synchronization:** Procedures for synchronizing data to the recovery environment. * **Hardware Requirements:** List of minimum hardware requirements for recovery (if applicable). * **Vendor Contacts:** List of critical vendor support contacts.

5.4. Backup and Data Management a. All critical data and system configurations shall be regularly backed up using **Veeam Backup & Replication**. b. Backups shall be stored securely both on-site and off-site, with appropriate encryption. c. Backup integrity shall be verified periodically. d. Retention periods for backups shall be defined based on data criticality and regulatory requirements.

5.5. Incident Detection and Declaration of Disaster a. Critical incidents that escalate beyond immediate incident response capabilities and significantly disrupt operations shall trigger the BCP/DRP. b. The IT Manager, in consultation with Executive Management, is responsible for declaring a "Disaster" and initiating the DRP.

5.6. DRP Execution (Recovery Phases) a. **Activation:** The DR team is convened, and the DRP is activated. b. **Damage Assessment:** Initial assessment of damage and impact to IT infrastructure. c. **Site Mobilization:** If an alternate site is required, the team moves to or activates the designated DR site/cloud environment. d. **Infrastructure Recovery:** Restore core infrastructure components (e.g., networking, virtualization platform). e. **System and Data Recovery (Veeam Specific):** * Prioritize recovery of systems based on RTO/RPO. * Utilize **Veeam Instant VM Recovery** to immediately power on physical server backups as VMs on the recovery site to meet critical RTOs. * Restore other critical servers and file servers from **Veeam** backups. * Restore data volumes and databases. f. **Application Recovery:** Reconfigure and test critical applications. g. **Testing and Verification:**

Rigorously test all recovered systems and data to ensure functionality and integrity. h. **User Access Restoration:** Re-establish user access to systems and applications.

5.7. Return to Normal Operations (Reversion) a. Once the primary site or systems are restored and verified as stable and secure, a planned reversion process will be executed to return operations from the DR site to the primary environment. b. This process must also be detailed in the DRP to ensure a smooth, secure transition without further disruption or data loss.

5.8. Testing and Maintenance a. **Regular Testing:** BCPs and DRPs shall be tested at least annually, or following significant changes to IT infrastructure or business processes. Tests may include: * Tabletop exercises. * Component testing (e.g., backup restoration tests, individual system recovery). * Full-scale disaster recovery drills (end-to-end testing of recovery site, **Veeam** recovery processes, and critical applications). b. **Documentation Updates:** Test results shall be documented, and any identified gaps or areas for improvement in the BCP/DRP shall be addressed and incorporated into revised plans (IS-AMR04-CIRQ02-A00: Document Control Procedure). c. **Plan Review:** Review the BCP/DRP at least annually to ensure accuracy, relevance, and alignment with business objectives and RTO/RPO requirements.

6. Review and Update

This procedure will be reviewed at least annually, or sooner if there are significant changes to Cirque's IT infrastructure, critical business processes, or lessons learned from tests or actual incidents.

7. Related Documents

- IS-LIR-CIRQ01-A00: Information Security Continuity Policy
- IS-AMG01-CIRQ01-A00: Information Security Incident Management Policy
- IS-AMG01-CIRQ02-A00: Incident Response Procedure (Global Core)
- IS-AIR01-CIRQ08-A00: Backup and Restoration Procedure
- IS-AIR01-CIRQ03-A00: Operations Security Policy
- IS-LMR-CIRQ01-F01A: Risk Assessment Register
- IS-AMR04-CIRQ02-A00: Document Control Procedure
- **Veeam Documentation** (External reference for specific technical recovery steps)

IS-LIR-CIRQ03-A00: Business Continuity Plan (BCP) - TEMPLATE

IS-LIR-CIRQ03-A00: Business Continuity Plan (BCP) - TEMPLATE

Document: IS-LIR-CIRQ03-A00

Standards Name: Business Continuity Plan (BCP)

Category: IT Security Related

Division: Document

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 (Template) **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** Executive Committee (for actual BCP)

Purpose: This document serves as a template and high-level guide for Cirque's comprehensive Business Continuity Plan (BCP). The actual BCP will contain detailed, living operational information necessary to maintain or quickly restore mission-critical business functions following a disruptive incident, ensuring adherence to IS-LIR-CIRQ01-A00: Information Security Continuity Policy and IS-LIG-CIRQ01-A00: Business Continuity and Disaster Recovery Procedure.

Instructions for Use: This is a template. Populate each section with specific Cirque details. The full BCP should be maintained as an operational document, potentially incorporating multiple sub-plans.

TABLE OF CONTENTS

1. **Introduction and Purpose** 1.1. Purpose of the BCP 1.2. Scope (Business Processes, Locations, Personnel) 1.3. Objectives (RTOs for Business Functions) 1.4. Relationship to Other Policies/Procedures (e.g., Incident Management, DRP) 1.5. Assumptions and Limitations
2. **BCP Management and Governance** 2.1. BCP Steering Committee/Leadership (Roles and Responsibilities) 2.2. BCP Coordinator/Owner 2.3. Activation Authority and Escalation 2.4. Maintenance and Review Schedule 2.5. Training and Awareness Requirements
3. **Business Impact Analysis (BIA) Summary** 3.1. Summary of Critical Business Processes (e.g., Order Processing, Manufacturing, R&D) 3.2. Identified RTOs (Recovery Time Objectives) per critical process 3.3. Identified RPOs (Recovery Point Objectives) per critical data asset 3.4. Financial and Reputational Impact of Disruption 3.5. Dependencies (IT Systems, Personnel, Suppliers)
4. **Risk Assessment Summary** 4.1. Summary of Key Disruptive Scenarios (e.g., Cyberattack, Natural Disaster, Power Outage, Major Equipment Failure) 4.2. Summary of Threat and Vulnerability Assessment 4.3. Identified Risks to Business Continuity
5. **BCP Activation and Incident Management** 5.1. Criteria for BCP Activation (When to declare a business disruption) 5.2. Incident Management Integration (Link to IS-AMG01-CIRQ02-A00: Incident Response Procedure) 5.3. Initial Response and Assessment Checklist 5.4. Emergency Communication Plan (Internal & External) * Emergency Contact Lists (Leadership, Key Personnel) * Communication Channels (e.g., SMS, satellite phone, external email) * Pre-approved Communication Templates (for employees, customers, partners)
6. **Business Continuity Strategies and Procedures** 6.1. **Personnel Management:** * Emergency Contact Information for All Employees * Employee Accountability Procedures * Support for Employees (e.g., well-being, temporary housing) * Roles and Responsibilities Matrix for BC Teams 6.2. **Alternative Work Strategies:** * Remote Work Capabilities and Procedures * Designated Alternative Work Sites (e.g., secondary offices, co-working spaces) * Equipment Provisioning for Remote/Alternate Site Work 6.3. **Critical Business Function Workarounds:** * Manual Procedures for Essential Business Processes (what to do if systems are down) * Offline Data Access Strategies * Minimum Staffing Requirements for critical functions 6.4. **Supply Chain Continuity:** * Identification of Critical Suppliers (Refer to IS-ASR01-CIRQ01-A00: Supplier Relationships Policy) * Supplier Contact Information and Emergency Procedures * Alternative Suppliers/Contingency Plans for supply chain disruptions 6.5. **Financial and Administrative Operations:** * Emergency Fund Access and Approval Process * Key Financial System Backup and Manual Processing Procedures * Payroll and HR Function Continuity
7. **Recovery and Resumption Procedures** 7.1. Coordination with IT Disaster Recovery (Link to IS-LIR-CIRQ04-A00: Disaster Recovery Plan (DRP)) 7.2. Procedures for Phased Resumption of Business Operations 7.3. Data Verification and Integrity Checks Post-Recovery 7.4. Return to Normal Operations (Reversion) Planning * Criteria for declaring "all clear" * Steps for transitioning back to primary operational environment
8. **Training, Testing, and Exercising** 8.1. Training Program for BCP Teams and All Personnel 8.2. Schedule for BCP Testing and Exercises (e.g., tabletop, walk-through, functional) 8.3. Scenario-Based Testing (e.g., Cyberattack, natural disaster at specific location) 8.4. Documentation of Test Results and Lessons Learned 8.5. Post-Exercise Review and Action Plan
9. **Documentation and Review** 9.1. Location of the BCP (Physical and Electronic Copies) 9.2. Version Control (Refer to IS-AMR04-CIRQ02-A00: Document Control Procedure) 9.3. Annual Review and Update Requirements

APPENDICES (EXAMPLES)

- Appendix A: Emergency Contact Directory (Internal)
- Appendix B: Emergency Contact Directory (External - Emergency Services, Critical Vendors)

- Appendix C: Business Impact Analysis (BIA) Full Details
- Appendix D: Communication Templates
- Appendix E: Alternative Worksite Logistics
- Appendix F: Manual Forms/Templates for Key Processes
- Appendix G: BCP Team Roles and Responsibilities Matrix

IS-LIR-CIRQ04-A00: Disaster Recovery Plan (DRP) - TEMPLATE

IS-LIR-CIRQ04-A00: Disaster Recovery Plan (DRP) - TEMPLATE

Document: IS-LIR-CIRQ04-A00

Standards Name: Disaster Recovery Plan (DRP)

Category: IT Security Related

Division: Document

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 (Template) **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** IT Manager (for actual DRP)

Purpose: This document serves as a template and high-level guide for Cirque's comprehensive Disaster Recovery Plan (DRP). The actual DRP will contain detailed, living operational and technical information necessary to recover critical IT systems and data after a disruptive incident, ensuring adherence to IS-LIR-CIRQ01-A00: Information Security Continuity Policy and IS-LIG-CIRQ01-A00: Business Continuity and Disaster Recovery Procedure. It specifically integrates the use of **Veeam** for server and fileserver recovery, including the immediate recovery of physical servers to virtual machines (P2V).

Instructions for Use: This is a template. Populate each section with specific Cirque technical details, configurations, and team assignments. The full DRP should be maintained as a highly detailed, operational document.

TABLE OF CONTENTS

- 1. Introduction and Purpose** 1.1. Purpose of the DRP 1.2. Scope (Critical IT Systems, Applications, Data, Infrastructure) 1.3. Objectives (RTOs for Systems, RPOs for Data) 1.4. Relationship to Other Plans (e.g., BCP, Incident Response) 1.5. Assumptions and Limitations
- 2. DRP Management and Governance** 2.1. DRP Owner/Coordinator (IT Manager) 2.2. Disaster Recovery Team (DRT) - Roles, Responsibilities, and Contact Information * DRT Lead (IT Manager) * Network Team * Server/Infrastructure Team * Database Team * Application Team * Security Team * Vendor Management Liaison 2.3. Activation Authority and Escalation Path 2.4. Maintenance and Review Schedule
- 3. Critical Systems and Data Inventory** 3.1. Prioritized List of Critical Servers, Applications, and Data * System Name / Application Name * Ownership / Business Owner * Server Hostname / IP Address * Associated Data Classification (e.g., Confidential, Internal Use) * Defined RTO (Recovery Time Objective) * Defined RPO (Recovery Point Objective) * Dependencies (Other Systems, Network, Personnel) * Backup Schedule and Retention (Veeam) * Recovery Method (e.g., Instant VM Recovery, full restore)
- 4. Disaster Recovery Site and Infrastructure** 4.1. Primary Production Environment Overview 4.2. Designated Disaster Recovery Site(s) (e.g., Cloud Environment - Azure/AWS, Co-location, Warm Site) * Location details * Connectivity (VPN, dedicated links) * Hardware / Virtualization platform at DR site * Network architecture at DR site (IP schemes, VLANs) * Power and Cooling considerations
- 5. Backup and Restoration Strategy** 5.1. **Veeam Backup & Replication Configuration:** * Backup Jobs Configuration (Frequency, Scope) * Backup Repository Locations (On-site, Off-site, Cloud) * Replication Jobs

Configuration (if applicable) * Backup Encryption and Security Measures 5.2. **Data Retention Policies:** 5.3. **Backup Verification Procedures:** 5.4. Off-site Storage and Media Management

6. **DRP Activation and Execution Procedures** 6.1. **Declaration of Disaster:** * Criteria for DRP Activation * Authorization Process 6.2. **Initial Response and Damage Assessment:** * Establish Incident Command Center (Virtual/Physical) * Damage Assessment Checklist (Infrastructure, Systems, Data) * Security Assessment of the Incident (coordinated with Incident Response) 6.3. **Communication Plan:** * Internal DRT Communication (e.g., secure chat, bridge lines) * External Vendor Communication (e.g., ISP, Cloud Provider, Veeam Support) * Updates to BCP Team / Business Unit Managers 6.4. **DR Site Activation and Connectivity:** * Procedures for activating DR site infrastructure. * Network re-configuration (DNS updates, routing changes, VPN establishment).
7. **System-Specific Recovery Procedures** (Detailed, step-by-step instructions for each critical system, aligned with RTO/RPO) 7.1. **Core Infrastructure Recovery:** * Virtualization Platform (e.g., VMware vCenter, Hyper-V) * Active Directory / DNS * Networking Devices (Routers, Firewalls, Switches) * Storage Systems 7.2. **Server Recovery (Veeam Specific):** * **Physical Servers to VM Recovery (P2V):** Procedures for using Veeam's Instant VM Recovery to power on physical server backups as VMs on the DR site immediately. * **Virtual Server Recovery:** Procedures for restoring virtual servers from Veeam backups. * **Fileserver Recovery:** Procedures for restoring file servers and shared data. * Detailed steps for each critical server (e.g., SQL Server, ERP Server, Omnify Server, Cadence License Server): * Restore prerequisites * Veeam restore steps (e.g., Instant Recovery, Full VM Restore) * Post-restore configuration (IP addresses, service startup) * Application installation/reconfiguration * Data integrity checks 7.3. **Database Recovery:** * Specific steps for restoring critical databases (e.g., SQL, MySQL). * Transaction log application. * Database consistency checks. 7.4. **Application Recovery:** * Installation and configuration of critical applications (e.g., Omnify, Cadence, GitLab, Asana, QuickBooks). * Integration points and dependencies. * Functionality testing. 7.5. **Data Restoration:** * Procedures for restoring specific data sets based on RPO. * Validation of restored data. 7.6. **User Access Restoration:** * Re-enabling user accounts and access in the DR environment.
8. **Testing and Maintenance** 8.1. **DRP Testing Schedule:** * Annual full-scale DR drills, including failover and failback. * Periodic component-level tests (e.g., backup recovery tests, individual server restore). * Testing of Veeam recovery processes. 8.2. **Test Scenarios:** Define various disruptive scenarios for testing. 8.3. **Test Results Documentation:** Record all test results, observations, and deviations. 8.4. **Lessons Learned and Corrective Actions:** * Identify weaknesses and areas for improvement. * Assign action items and track their completion. 8.5. **DRP Review and Update Cycle:** * Annual review or after significant changes to IT infrastructure, applications, or business processes.
9. **Return to Normal Operations (Reversion Plan)** 9.1. Criteria for Initiating Reversion (Primary site fully restored and verified). 9.2. Phased Reversion Strategy (e.g., reverse replication, controlled switchback). 9.3. Detailed Steps for Returning Operations to Primary Site. 9.4. Data Synchronization back to Primary Site. 9.5. Post-Reversion Verification and Monitoring.

APPENDICES (EXAMPLES)

- Appendix A: DRT Contact List (with primary and secondary numbers, emergency contacts)
- Appendix B: Vendor Contact List (ISP, Hardware, Software, Cloud Providers)
- Appendix C: Network Diagrams (Primary & DR Site)
- Appendix D: IP Address Assignments for DR Site
- Appendix E: Application Dependency Matrix
- Appendix F: System Recovery Checklists
- Appendix G: Test Scenario Documentation & Results
- Appendix H: Veeam Configuration Snapshots
- Appendix I: Software Licenses and Installation Media Locations

Part XIII — Compliance, Internal Audit, Management Review, and Continual Improvement

IS-AMR01-CIRQ01-A00: Compliance Policy

IS-AMR01-CIRQ01-A00: Compliance Policy

Document: IS-AMR01-CIRQ01-A00

Standards Name: Compliance Policy

Category: Information Management Regulations

Division: Policy

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 Effective Date: 2025-07-01 Review Date: 2026-07-01 Approved By: Executive Committee

1. Purpose

SOC 2 Trust Services Criteria Mapping

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC1.1

Demonstrates commitment to integrity and ethical values

CC1.4

Commitment to attract, develop, and retain competent individuals

CC4.1

Selects, develops, and performs ongoing and separate evaluations

CC4.2

Evaluates and communicates internal control deficiencies

CC5.3

Deploys policies and procedures that put control activities into action

The purpose of this policy is to establish Cirque's commitment and framework for complying with all applicable legal, regulatory, contractual, and internal requirements related to information security. This policy ensures that Cirque operates within the bounds of relevant laws and standards, protects its information assets, and avoids legal penalties, financial losses, and reputational damage resulting from non-compliance. It aligns with ISO/IEC 27001:2022 Annex A.18 (Compliance).

2. Scope

This policy applies to all Cirque personnel (employees, contractors, temporary staff), all information assets, information systems, applications, and networks, and all global operations (US, Taipei, China). It covers compliance with external requirements (laws, regulations, contracts) and internal requirements (policies, procedures, standards).

3. Principles of Compliance

Cirque is committed to achieving and maintaining compliance through the following principles:

- **Commitment:** Executive management is committed to establishing and maintaining an information security compliance program.
- **Proactive Approach:** Continuously identify and assess new and changing legal, regulatory, and contractual obligations.
- **Integration:** Incorporate compliance requirements into all relevant information security policies, procedures, and controls.
- **Accountability:** Clearly define roles and responsibilities for compliance across all levels of the organization.
- **Monitoring and Review:** Regularly monitor compliance status and review the effectiveness of controls.
- **Remediation:** Promptly address any identified non-compliance or control deficiencies.

4. Compliance Requirements

4.1. Identification of Applicable Requirements: a. Cirque shall establish a process to identify all relevant information security-related legal, regulatory, contractual, and internal requirements. This includes, but is not limited to: * **Legal & Regulatory:** Data protection laws (e.g., GDPR if applicable for EU data, CCPA/CPRA in US, PIPL/CSL/DSL in China, PDPA in Taiwan), industry-specific regulations (e.g., SOX if publicly traded, specific financial or healthcare regulations), national cybersecurity laws. * **Contractual:** Customer agreements, supplier contracts, non-disclosure agreements (NDAs) that contain specific information security clauses. * **Standards & Frameworks:** ISO/IEC 27001:2022. * **Internal:** All Cirque policies, procedures, and standards (e.g., IS-APM01-CIRQ01-A00: Information Security Policy).

4.2. Establishment of Information Security Controls: a. Appropriate information security controls shall be designed, implemented, and maintained to meet identified compliance obligations. b. These controls shall be documented in relevant policies and procedures across the ISMS.

4.3. Monitoring and Review of Compliance: a. Compliance status shall be regularly monitored through internal audits, reviews of logs (IS-AIR01-CIRQ09-A00: Logging and Monitoring Procedure), and control effectiveness assessments. b. Independent reviews of the ISMS, including compliance with this policy, shall be conducted periodically (e.g., internal audits, external certification audits).

4.4. Legal and Regulatory Compliance: a. **Intellectual Property Rights:** Cirque shall ensure that intellectual property rights are respected and protected, including adherence to licensing agreements for software and digital assets. b. **Protection of Records:** Records shall be protected from loss, destruction, falsification, unauthorized access, and unauthorized release, in accordance with legal, regulatory, and business requirements. c. **Privacy and Protection of PII:** Compliance with all applicable data privacy laws and regulations concerning the collection, processing, storage, and transfer of Personally Identifiable Information (PII) is mandatory (refer to IS-AAR02-CIRQ01-A00: Privacy Policy (Global Core) and localized versions). d. **Regulation of Cryptographic Controls:** The use of cryptographic controls shall comply with all relevant agreements, legislation, and regulations.

4.5. Contractual Compliance: a. All contracts with customers and suppliers that involve access to or processing of Cirque's information or information systems shall include appropriate information security clauses. b. Compliance

with information security requirements specified in such contracts shall be regularly verified (refer to IS-ASR01-CIRQ01-A00: Supplier Relationships Policy).

4.6. Independent Review of Information Security: a. An independent review of the organization's approach to managing information security and its implementation (e.g., internal audit, external audit, management review) shall be carried out at planned intervals.

4.7. Information Security Policy Review: a. This policy, along with other ISMS documents, shall be reviewed and updated periodically to ensure continued relevance and compliance with evolving requirements.

5. Non-Compliance and Corrective Actions

a. Any identified instances of non-compliance shall be documented and managed through a formal corrective action process.

b. Root cause analysis shall be performed, and appropriate corrective and preventive measures shall be implemented to address the non-compliance and prevent recurrence.

c. Significant non-compliance or breaches of law/regulation may result in disciplinary action as per `IS-LMR-CIRQ01-A00: Disciplinary Policy` (if such a policy exists) and may require reporting to legal authorities or regulatory bodies.

6. Responsibilities

- **Executive Committee:** Overall responsibility for ensuring Cirque's compliance posture and approving significant compliance initiatives.
- **Legal Counsel:** Advises on legal and regulatory requirements, reviews contracts, and provides guidance on compliance issues.
- **IT Manager:** Responsible for implementing technical controls to meet compliance requirements and for monitoring system-level compliance.
- **Human Resources:** Ensures employees are aware of and adhere to compliance policies, especially those related to privacy and data handling.
- **All Personnel:** Responsible for understanding and adhering to all applicable policies, procedures, laws, and regulations related to information security.

7. Related Documents

- IS-APM01-CIRQ01-A00: Information Security Policy
- IS-AAR02-CIRQ01-A00: Privacy Policy (Global Core)
- IS-AIR01-CIRQ09-A00: Logging and Monitoring Procedure
- IS-ASR01-CIRQ01-A00: Supplier Relationships Policy
- IS-AMR04-CIRQ02-A00: Document Control Procedure
- IS-LMR-CIRQ01-A00: Disciplinary Policy (if applicable)

8. Policy Review

This policy will be reviewed at least annually, or sooner if there are significant changes to Cirque's business operations, legal/regulatory environment, or contractual obligations.

IS-AMR02-CIRQ01-A00: Monitoring, Measurement, Analysis, and Evaluation Policy

IS-AMR02-CIRQ01-A00: Monitoring, Measurement, Analysis, and Evaluation Policy

Document: IS-AMR02-CIRQ01-A00

Standards Name: Monitoring, Measurement, Analysis, and Evaluation Policy

Category: ISMS Support Process

Division: Policy

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 Effective Date: 2025-07-01 Review Date: 2026-07-01 Approved By: Executive Committee

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC4.1

Selects, develops, and performs ongoing evaluations

CC4.2

Evaluates and communicates internal control deficiencies

CC5.2

Selects and develops general control activities over technology

CC7.1

Detects vulnerabilities through monitoring

CC7.2

Monitors system components for anomalies

The purpose of this policy is to define Cirque's framework for monitoring, measuring, analyzing, and evaluating the performance and effectiveness of its Information Security Management System (ISMS). This policy ensures that the ISMS is continually assessed against its objectives, controls are performing as intended, and opportunities for improvement are identified to maintain and enhance information security posture. This policy aligns with ISO/IEC 27001:2022 Clause 9.1 (Monitoring, measurement, analysis and evaluation).

2. Scope

This policy applies to all aspects of Cirque's ISMS, covering all processes, controls, and objectives defined within the ISMS scope, across all global operations (US, Taipei, China). It applies to all personnel involved in the monitoring, measurement, analysis, and evaluation activities.

3. Definitions

- **Monitoring:** Observing the status of the ISMS, a process, or a control to identify changes or deviations.
- **Measurement:** Quantifying the performance or effectiveness of a process or control.
- **Analysis:** Examination of data and information to identify trends, patterns, and root causes.
- **Evaluation:** Determining the significance, effectiveness, and suitability of the ISMS based on the results of monitoring, measurement, and analysis.
- **ISMS Objectives:** Specific, measurable, achievable, relevant, and time-bound goals for information security.
- **Key Performance Indicators (KPIs):** Measurable values that demonstrate how effectively an organization is achieving key business objectives.
- **Key Risk Indicators (KRIs):** Metrics used to provide an early signal of increasing risk exposure.

4. Policy Requirements

4.1. What to Monitor, Measure, Analyze, and Evaluate: a. The performance of the ISMS as a whole. b. The effectiveness of information security controls. c. The achievement of information security objectives. d. Processes and procedures related to information security. e. Risk levels and the effectiveness of risk treatment plans. f. Incidents and their resolution. g. Compliance with legal, regulatory, and contractual requirements.

4.2. How to Monitor, Measure, Analyze, and Evaluate: a. **Monitoring & Measurement:** * Establish and track relevant Key Performance Indicators (KPIs) and Key Risk Indicators (KRIs) for information security. Examples include: * Number of security incidents * Mean Time To Detect (MTTD) and Mean Time To Respond (MTTR) for incidents. * Number of successful phishing simulations. * Vulnerability scan results (number of critical/high vulnerabilities). * Compliance rates (e.g., patch management, password complexity adherence). * Backup success rates. * Utilize automated tools (e.g., SIEM, RMM, vulnerability scanners, log management systems) for continuous monitoring and data collection. * Conduct regular reviews of logs, alerts, and system reports. * Perform internal audits and independent reviews of specific controls or processes. b. **Analysis & Evaluation:** * Analyze collected data to identify trends, patterns, root causes of incidents or control failures, and areas of non-compliance. * Compare actual performance against defined ISMS objectives, KPIs, and KRIs. * Evaluate the effectiveness of implemented controls in reducing identified risks. * Assess the overall suitability, adequacy, and effectiveness of the ISMS.

4.3. When to Monitor, Measure, Analyze, and Evaluate: a. Monitoring and measurement activities shall be conducted on an ongoing basis for critical controls and systems. b. Formal analysis and evaluation of collected data shall occur at planned intervals, typically monthly or quarterly by relevant teams, and consolidated for management review. c. Significant changes to the ISMS, IT infrastructure, or the threat landscape may trigger immediate monitoring and evaluation activities.

4.4. Who Monitors, Measures, Analyzes, and Evaluates: a. **IT Department:** Primarily responsible for technical monitoring and measurement, including system logs, network traffic, security tool outputs, and incident data. b. **Security Team:** Responsible for analyzing security-related data, conducting vulnerability assessments, and evaluating the effectiveness of security controls. c. **Internal Audit Function:** Conducts independent assessments of ISMS processes and controls. d. **Management Review Committee:** Responsible for the overall evaluation of the ISMS performance and effectiveness during management review meetings.

4.5. Documentation and Reporting: a. The results of monitoring, measurement, analysis, and evaluation activities shall be documented. b. Reports on ISMS performance shall be generated periodically and presented to relevant stakeholders, including the Management Review Committee. c. Findings, conclusions, and recommendations for improvement shall be clearly documented.

5. Improvement

The output of monitoring, measurement, analysis, and evaluation activities shall feed directly into Cirque's continual improvement process, leading to corrective actions, updates to policies/procedures, and enhancement of information security controls. (Refer to IS-AMR03-CIRQ01-A00: Nonconformity and Corrective Action Policy and IS-LMR-CIRQ04-A00: Continual Improvement Policy).

6. Responsibilities

- **Executive Committee:** Ensures adequate resources are allocated for monitoring, measurement, analysis, and evaluation activities and reviews overall ISMS performance.
- **IT Manager:** Oversees the implementation and operation of technical monitoring and measurement tools and processes.
- **Information Security Officer/Team:** Directs and performs analysis and evaluation of security metrics, ensures compliance with this policy.
- **Process Owners:** Responsible for monitoring and measuring the performance of controls within their respective areas.

7. Related Documents

- IS-APM01-CIRQ01-A00: Information Security Policy
- IS-AIR01-CIRQ09-A00: Logging and Monitoring Procedure
- IS-AMR02-CIRQ02-A00: ISMS Performance Monitoring Procedure
- IS-AMR02-CIRQ03-A00: Internal Audit Procedure
- IS-LMR-CIRQ03-A00: Management Review Policy
- IS-AMR03-CIRQ01-A00: Nonconformity and Corrective Action Policy
- IS-LMR-CIRQ04-A00: Continual Improvement Policy

8. Policy Review

This policy will be reviewed at least annually, or sooner if there are significant changes to Cirque's ISMS, organizational structure, or external requirements.

IS-AMR02-CIRQ02-A00: ISMS Performance Monitoring Procedure

IS-AMR02-CIRQ02-A00: ISMS Performance Monitoring Procedure

Document: IS-AMR02-CIRQ02-A00

Standards Name: ISMS Performance Monitoring Procedure

Category: ISMS Support Process

Division: Procedure

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** IT Manager

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC4.1

Ongoing evaluations

CC4.2

Evaluates control deficiencies

The purpose of this procedure is to outline the specific steps and responsibilities for monitoring and measuring the performance of Cirque's Information Security Management System (ISMS). This ensures that information security controls are operating effectively, ISMS objectives are being met, and data is collected for analysis and evaluation as required by IS-AMR02-CIRQ01-A00: Monitoring, Measurement, Analysis, and Evaluation Policy.

2. Scope

This procedure applies to all personnel responsible for monitoring, collecting, and reporting data related to the performance of the ISMS, information security controls, and processes across all Cirque global operations (US, Taipei, China).

3. Roles and Responsibilities

- **IT Manager:** Overall owner of this procedure; ensures resources are available for monitoring tools and activities.
- **Information Security Officer (ISO)/Security Team:** Defines specific metrics, reviews monitoring data, performs analysis, and reports on ISMS performance.
- **IT Department Personnel:** Implements and maintains monitoring tools, configures logging, reviews alerts, and collects technical performance data.
- **Process Owners:** Responsible for monitoring the effectiveness of information security controls within their respective business processes.

4. Procedure

4.1. Identify and Define Metrics (KPIs/KRIs) a. **Frequency:** Annually, or upon significant changes to the ISMS or risk landscape. b. **Responsible:** Information Security Officer (ISO)/Security Team in conjunction with IT Manager and relevant process owners. c. **Steps:** 1. Review Cirque's ISMS objectives, risk treatment plans, and control implementation status. 2. Identify specific Key Performance Indicators (KPIs) and Key Risk Indicators (KRIs) that effectively demonstrate the performance of the ISMS and its controls. Examples include: * Number of detected security incidents per month/quarter. * Average time to resolve critical vulnerabilities. * Percentage of employees completing security awareness training annually. * Backup success rates. * Patching compliance rates for critical systems. * Number of attempted unauthorized access events. * Effectiveness of phishing simulations (e.g., click-through rate). 3. For each KPI/KRI, define: * The specific metric to be measured. * The target performance level (e.g., "99% backup success rate"). * The measurement frequency (e.g., daily, weekly, monthly, quarterly). * The data source (e.g., SIEM, RMM, vulnerability scanner, HR system). * The owner responsible for collection. 4. Document the defined metrics in a central ISMS performance dashboard or dedicated register.

4.2. Implement Monitoring Tools and Processes a. **Frequency:** Ongoing, as part of IT operations and security management. b. **Responsible:** IT Department Personnel, ISO/Security Team. c. **Steps:** 1. Deploy and configure monitoring tools (e.g., SIEM, RMM, network monitoring, vulnerability scanners, log management systems) to collect relevant data points for the defined KPIs/KRIs. 2. Ensure that systems and applications are configured to generate appropriate logs and alerts as per IS-AIR01-CIRQ09-A00: Logging and Monitoring Procedure. 3. Establish automated data collection mechanisms where possible. 4. Provide necessary access and training to personnel involved in operating monitoring tools.

4.3. Collect and Review Monitoring Data a. **Frequency:** According to the defined measurement frequency for each metric (e.g., daily, weekly, monthly). b. **Responsible:** IT Department Personnel, ISO/Security Team, Process Owners. c. **Steps:** 1. Collect raw data from various sources (e.g., logs, system reports, audit findings, incident records, HR records). 2. Perform initial review of the collected data for completeness, accuracy, and any immediate anomalies or critical alerts. 3. Escalate critical alerts or indicators of potential security incidents immediately as per IS-AMG01-CIRQ02-A00: Incident Response Procedure (Global Core).

4.4. Analyze and Report ISMS Performance a. **Frequency:** Monthly/Quarterly for consolidated reporting, or as needed for specific metrics. b. **Responsible:** Information Security Officer (ISO)/Security Team. c. **Steps:** 1. Aggregate and analyze the collected monitoring data against the defined KPIs/KRIs and their target performance levels. 2. Identify trends, deviations from baselines, and areas where ISMS performance is below target. 3. Perform root cause analysis for significant deviations or security incidents. 4. Prepare an ISMS Performance Report that summarizes: * Overall ISMS performance against objectives. * Status of key security controls. * Trends in incidents, vulnerabilities, and risks. * Compliance status. * Areas requiring improvement. 5. Present the ISMS Performance Report to the Management Review Committee as part of the management review process.

4.5. Evaluate Effectiveness and Recommend Improvements a. **Frequency:** Quarterly for detailed evaluation, and annually as part of management review. b. **Responsible:** Information Security Officer (ISO)/Security Team, Management Review Committee. c. **Steps:** 1. Based on the analysis, evaluate the overall effectiveness of the ISMS in achieving its objectives and managing information security risks. 2. Identify opportunities for improvement, including: * Adjustments to existing controls. * Implementation of new controls. * Revisions to policies and procedures. * Updates to risk assessments or treatment plans. * Changes in resource allocation. 3. Document nonconformities and initiate corrective actions as per IS-AMR03-CIRQ02-A00: Corrective Action Procedure.

5. Documentation

- ISMS Performance Dashboard/Register (or similar document detailing KPIs/KRIs, targets, and owners).
- Raw monitoring data and logs.
- ISMS Performance Reports.
- Records of analysis and evaluation findings.
- Corrective Action Requests (CARs) generated.

6. Related Documents

- IS-AMR02-CIRQ01-A00: Monitoring, Measurement, Analysis, and Evaluation Policy
- IS-APM01-CIRQ01-A00: Information Security Policy
- IS-AIR01-CIRQ09-A00: Logging and Monitoring Procedure
- IS-AMG01-CIRQ02-A00: Incident Response Procedure (Global Core)
- IS-AMR02-CIRQ03-A00: Internal Audit Procedure
- IS-LMR-CIRQ03-A00: Management Review Policy
- IS-LMG-CIRQ04-A00: Management Review Procedure
- IS-AMR03-CIRQ01-A00: Nonconformity and Corrective Action Policy
- IS-AMR03-CIRQ02-A00: Corrective Action Procedure

7. Review

This procedure will be reviewed at least annually, or sooner if there are significant changes to Cirque's ISMS, monitoring tools, or relevant standards.

IS-AMR02-CIRQ03-A00: Internal Audit Procedure

IS-AMR02-CIRQ03-A00: Internal Audit Procedure

Document: IS-AMR02-CIRQ03-A00

Standards Name: Internal Audit Procedure

Category: ISMS Support Process

Division: Procedure

Standard Type: Global

Version: 1.0 Effective Date: 2025-07-01 Review Date: 2026-07-01 Approved By: Executive Committee

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC4.1

Selects, develops, and performs ongoing and separate evaluations

CC4.2

Evaluates and communicates control deficiencies

The purpose of this procedure is to define the process for conducting planned and systematic internal audits of Cirque's Information Security Management System (ISMS). These audits ensure that the ISMS:

- Conforms to the requirements of ISO/IEC 27001:2022.
- Conforms to Cirque's own established requirements for its ISMS.
- Is effectively implemented and maintained.
- Is performing as intended.

This procedure ensures that internal audits are conducted objectively and independently to provide valuable input for management review and continual improvement of the ISMS.

2. Scope

This procedure applies to all internal audits conducted on Cirque's ISMS processes, controls, and areas within the defined ISMS scope, across all global operations (US, Taipei, China).

3. Roles and Responsibilities

- **Executive Committee:** Approves the annual internal audit program and ensures the independence and competence of auditors.
- **ISMS Owner (e.g., Information Security Officer/IT Manager):** Oversees the internal audit program, ensures audits are conducted as planned, and facilitates the resolution of nonconformities.
- **Internal Auditor(s):** Conducts audits objectively and impartially, prepares audit reports, and verifies the effectiveness of corrective actions. Auditors must be competent and independent of the area being audited.
- **Auditee/Process Owner:** Provides necessary information and access to auditors, and is responsible for implementing agreed-upon corrective actions for identified nonconformities.

4. Procedure

4.1. Audit Program Planning a. **Frequency:** Annually. b. **Responsible:** ISMS Owner. c. **Steps:** 1. Develop an annual internal audit program based on the status and importance of the processes concerned, changes affecting the organization, and the results of previous audits. 2. The program shall define the scope, frequency, methods, responsibilities, and reporting requirements for each audit. 3. Ensure that the entire scope of the ISMS is covered within a defined audit cycle (e.g., every 1-3 years). 4. Obtain Executive Committee approval for the annual audit program.

4.2. Individual Audit Planning a. **Frequency:** Prior to each scheduled audit. b. **Responsible:** Internal Auditor(s). c. **Steps:** 1. Define the specific objectives and scope of the individual audit (e.g., audit of Access Control Policy implementation). 2. Identify the relevant audit criteria (e.g., ISO 27001 clauses, Cirque policies and procedures, legal/contractual requirements). 3. Select competent and independent auditors for the specific audit. Independence means the auditor should not audit their own work. 4. Develop an audit plan including: * Audit team members. * Audit schedule (dates, times). * Areas/departments to be audited. * Key documents to review. * Personnel to interview. 5. Communicate the audit plan to the auditee/process owner in advance.

4.3. Conducting the Audit a. **Frequency:** As per audit schedule. b. **Responsible:** Internal Auditor(s). c. **Steps:** 1. **Opening Meeting:** Conduct an opening meeting with the auditee to confirm the audit plan, explain the audit process, and address any questions. 2. **Information Gathering:** Collect objective evidence by: * Reviewing documented information (policies, procedures, records, logs, IS-AMR04-CIRQ02-A00: Document Control Procedure). * Interviewing personnel. * Observing processes and activities. * Examining technical configurations and tools. 3. **Evidence Evaluation:** Evaluate collected evidence against the audit criteria. 4. **Identify Findings:** Document all findings, including: * **Conformities:** Areas where the ISMS effectively meets requirements. * **Nonconformities:** Deviations from ISO 27001 requirements or Cirque's own ISMS requirements. (Identify major/minor as per audit judgment). * **Observations/Opportunities for Improvement (OFIs):** Areas that are not nonconformities but could be improved. 5. **Closing Meeting:** Conduct a closing meeting with the auditee to present the audit findings, ensure clarity, and agree on the next steps.

4.4. Audit Reporting a. **Frequency:** Within a specified timeframe (e.g., 5-10 business days) after the audit. b. **Responsible:** Internal Auditor(s). c. **Steps:** 1. Prepare a formal Internal Audit Report using the IS-AMR02-CIRQ01-F01A: Internal Audit Report Template. 2. The report shall include: * Audit objectives and scope. * Audit criteria. * Dates and locations of the audit. * Audit team members and auditees. * Summary of findings. * Details of identified nonconformities, observations, and opportunities for improvement. * Evidence supporting each finding. 3. Submit the draft report to the auditee for factual accuracy review. 4. Issue the final audit report to the auditee, ISMS Owner, and relevant management.

4.5. Follow-up and Corrective Actions a. **Frequency:** Ongoing until nonconformities are closed. b. **Responsible:** Auditee/Process Owner (for implementing actions), ISMS Owner (for oversight), Internal Auditor(s) (for verification). c. **Steps:** 1. For each identified nonconformity, the auditee/process owner shall initiate a corrective action request (CAR) as per IS-AMR03-CIRQ02-A00: Corrective Action Procedure. 2. The auditee is responsible for determining the root cause of the nonconformity, developing a corrective action plan (including timelines), and implementing the actions. 3. The Internal Auditor(s) (or a designated follow-up auditor) shall verify the implementation and effectiveness of the corrective actions within the agreed-upon timeframe. 4. Once verified as effective, the nonconformity is formally closed. 5. Maintain records of all corrective actions taken.

5. Documentation

- Annual Internal Audit Program.
- Individual Audit Plans.
- Audit Checklists/Work Papers.
- Evidence collected during the audit.
- IS-AMR02-CIRQ01-F01A: Internal Audit Report Template (completed reports).
- Corrective Action Requests (CARs) and their closure records.
- Records of auditor competence and training.

6. Related Documents

- IS-AMR02-CIRQ01-A00: Monitoring, Measurement, Analysis, and Evaluation Policy
- IS-AMR02-CIRQ01-F01A: Internal Audit Report Template
- IS-AMR03-CIRQ01-A00: Nonconformity and Corrective Action Policy
- IS-AMR03-CIRQ02-A00: Corrective Action Procedure
- IS-AMR03-CIRQ01-F01A: Corrective Action Request (CAR) Form
- IS-APM01-CIRQ01-A00: Information Security Policy
- IS-AMR04-CIRQ02-A00: Document Control Procedure
- ISO/IEC 27001:2022 Standard (external reference)
- ISO 19011: Guidelines for auditing management systems (external reference)

7. Review

This procedure will be reviewed at least annually, or sooner if there are significant changes to Cirque's ISMS, audit requirements, or regulatory landscape.

IS-AMR02-CIRQ01-F01A: Internal Audit Report Template

IS-AMR02-CIRQ01-F01A: Internal Audit Report Template

Document: IS-AMR02-CIRQ01-F01A

Standards Name: Internal Audit Report Template

Category: ISMS Support Process

Division: Form

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** ISMS Owner / IT Manager

INTERNAL AUDIT REPORT

Document ID:

IS-AMR02-CIRQ01-F01A

****Version:**

**** 1.0**

Audit ID:

[e.g., IA-YYYYMMDD-001]

Audit Date(s):

[DD-MM-YYYY to DD-MM-YYYY]

Audit Type:

[e.g., Initial / Follow-up / Surveillance]

Report Date:

1. AUDIT INFORMATION

- **Audited Department(s)/Area(s):** [e.g., IT Operations, HR, Development Team, Specific Process: Access Control]
- **Audit Objective(s):** [State the purpose of the audit, e.g., "To verify conformity of Access Control process to IS-AIR01-CIRQ01-A00 and ISO 27001 A.9."]
- **Audit Scope:** [Clearly define what was covered/not covered, e.g., "Access control for Active Directory and SaaS applications; user provisioning, de-provisioning, and privilege reviews."]
- **Audit Criteria:**
 - [e.g., ISO/IEC 27001:2022 Clause(s) (e.g., 9.2, A.9.2)]
 - [e.g., IS-APM01-CIRQ01-A00: Information Security Policy]
 - [e.g., IS-AIR01-CIRQ01-A00: Access Control Policy]
 - [e.g., IS-AMR02-CIRQ03-A00: Internal Audit Procedure]
 - [Any applicable legal, regulatory, or contractual requirements]

2. AUDIT TEAM & AUDITEES

- **Lead Auditor:** [Name, Title]
- **Audit Team Members:** [Name, Title]
- **Auditee Representatives:** [Names, Titles of individuals from the audited area]

3. AUDIT SUMMARY & CONCLUSIONS

- **Overall Conclusion:** [Brief statement on the general effectiveness and conformity of the audited area's ISMS processes and controls. e.g., "The audited area generally conforms to the specified criteria with minor nonconformities identified."]
- **Strengths/Good Practices Identified:** [Highlight positive observations, e.g., "Strong commitment to security from team leadership, well-documented procedures."]

4. AUDIT FINDINGS

4.1. Conformities / Areas of Strength:

[List specific areas/controls that were found to be fully compliant and effectively implemented, providing brief evidence, e.g., "User account provisioning process (IS-AIR01-CIRQ04-A00) is well-documented and consistently followed, with documented approvals for new access."]

4.2. Nonconformities:

- **Nonconformity ID:** [e.g., NC-001]
- **Category (Major/Minor):** [Major (significant deviation, widespread impact, or systemic failure) / Minor (isolated deviation, limited impact)]
- **Area/Process:** [Specific area or process where nonconformity was found]
- **Audit Criterion Violated:** [e.g., ISO 27001:2022 A.9.2.1, IS-AIR01-CIRQ01-A00 Section 5.3]
- **Finding Description:** [Clear, factual description of the nonconformity, what was observed, and how it deviates from the criteria. Avoid subjective language. e.g., "During review of terminated employee access

logs, 3 out of 15 samples showed network access remained active for more than 48 hours after termination, contrary to IS-AIR01-CIRQ01-A00 Section 5.3 which states access must be revoked within 24 hours."]

- **Evidence:** [Specific evidence sighted, e.g., "Termination checklist records for employee X, Y, Z; network access logs for dates D1, D2, D3."]
- **Reference to Corrective Action Request (CAR) ID:** [To be filled once CAR is raised, e.g., CAR-005]

Repeat this format for each Nonconformity.

4.3. Observations / Opportunities for Improvement (OFIs):

- **OFI ID:** [e.g., OFI-001]
- **Area/Process:** [Specific area or process]
- **Observation/Recommendation:** [Description of an area that is not a nonconformity but could be improved for better security or efficiency. e.g., "Consider implementing automated access review tools to streamline the quarterly user access review process, which is currently done manually and is time-consuming."]

Repeat this format for each Observation/OFI.

5. DISTRIBUTION LIST

- [ISMS Owner / IT Manager]
- [Audited Department Head(s)]
- [Executive Committee (for significant findings or overall report)]
- [Relevant Stakeholders as per ISMS Communication Plan]

6. REVIEW AND APPROVALS

- **Prepared By:**
 - Name: [Auditor's Name]
 - Date: [DD-MM-YYYY]
 - Signature: [Signature]
- **Reviewed By (ISMS Owner / IT Manager):**
 - Name: [Name]
 - Date: [DD-MM-YYYY]
 - Signature: [Signature]
- **Acknowledged By (Auditee Representative):**
 - Name: [Name]
 - Date: [DD-MM-YYYY]

–	–	–
–	–	– Signature: [Signature]

7. DOCUMENT HISTORY

Version

Changes Made

1.0

[DD-MM-YYYY]

Initial Release

IS-LMR-CIRQ03-A00: Management Review Policy

IS-LMR-CIRQ03-A00: Management Review Policy

Document: IS-LMR-CIRQ03-A00

Standards Name: Management Review Policy

Category: ISMS Support Process

Division: Policy

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** Executive Committee

1. Purpose

SOC 2 Trust Services Criteria Mapping

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC1.2

Board / executive oversight of the ISMS

CC1.3

Organizational structure

CC4.2

Evaluates and communicates internal control deficiencies

CC5.3

Deploys policies and procedures that put control activities into action

The purpose of this policy is to establish Cirque's commitment and framework for conducting regular management reviews of its Information Security Management System (ISMS). These reviews are essential to ensure the

continuing suitability, adequacy, and effectiveness of the ISMS in addressing information security risks and opportunities. This policy aligns with ISO/IEC 27001:2022 Clause 9.3 (Management review) and demonstrates top management's commitment to information security and continual improvement.

2. Scope

This policy applies to all aspects of Cirque's ISMS, covering all processes, controls, and objectives within the defined ISMS scope across all global operations (US, Taipei, China). It applies to all members of top management and other relevant personnel involved in the management review process.

3. Definitions

- **Management Review:** A formal meeting conducted by top management to assess the performance, suitability, adequacy, and effectiveness of the ISMS.
- **Top Management:** The person or group of people who directs and controls Cirque at the highest level. This typically includes the Executive Committee.
- **ISMS Suitability:** The ability of the ISMS to achieve its stated objectives and be appropriate for Cirque's context.
- **ISMS Adequacy:** The sufficiency of resources and controls within the ISMS to meet requirements.
- **ISMS Effectiveness:** The extent to which planned activities are realized and planned results are achieved by the ISMS.

4. Policy Requirements

4.1. General Requirements: a. Top management shall review Cirque's ISMS at planned intervals to ensure its continuing suitability, adequacy, and effectiveness. b. The reviews shall include assessing opportunities for improvement and the need for changes to the ISMS, including the information security policy and information security objectives.

4.2. Frequency of Management Reviews: a. Management reviews shall be conducted at least **annually**. b. Ad-hoc or extraordinary reviews may be called by top management when significant changes occur, such as: * Major security incidents or breaches. * Significant changes in Cirque's business operations, scope, or technology. * Major changes in legal, regulatory, or contractual requirements. * Significant changes in identified risks or opportunities.

4.3. Management Review Inputs: a. The management review shall consider the following inputs: 1. Status of actions from previous management reviews. 2. Changes in external and internal issues that are relevant to the ISMS. 3. Information security performance, including trends in: * Nonconformities and corrective actions. * Monitoring and measurement results. * Audit results (internal and external). * The results of risk assessments and the status of risk treatment plans. 4. Opportunities for continual improvement. 5. Feedback from interested parties (e.g., customers, regulators, suppliers). 6. The results of the evaluation of the effectiveness of the ISMS. 7. Adequacy of resources for the ISMS.

4.4. Management Review Outputs: a. The outputs of the management review shall include decisions and actions related to: 1. The continuing suitability, adequacy, and effectiveness of the ISMS. 2. Opportunities for continual improvement. 3. Any need for changes to the ISMS. 4. Resource needs for the ISMS. 5. Improvements in processes and controls. 6. Updates to information security objectives. b. Decisions made during the management review must be documented and communicated to relevant personnel.

4.5. Participants: a. The management review shall be chaired by a member of top management. b. Attendees shall include: * Members of the Executive Committee. * Information Security Officer / IT Manager. * Relevant department heads or process owners as needed, especially those whose areas are subject to specific review or have findings to address. * Legal counsel, if legal or regulatory compliance issues are on the agenda.

4.6. Documentation of Management Reviews: a. Records of management reviews, including the agenda, presentations, discussions, decisions, and action items, shall be maintained using the IS-LMR-CIRQ03-F01A: Management Review Meeting Minutes Template. b. These records shall demonstrate compliance with this policy and ISO/IEC 27001 requirements.

5. Responsibilities

- **Executive Committee:** Approves this policy, participates in and chairs management reviews, and ensures that necessary resources and actions are provided to maintain and improve the ISMS.
- **ISMS Owner (e.g., Information Security Officer/IT Manager):** Coordinates the preparation for management reviews, compiles and presents relevant information, documents the meeting, and tracks action items.
- **All Relevant Personnel:** Provide necessary input for the review and implement agreed-upon actions.

6. Related Documents

- IS-APM01-CIRQ01-A00: Information Security Policy
- IS-AMR02-CIRQ01-A00: Monitoring, Measurement, Analysis, and Evaluation Policy
- IS-AMR02-CIRQ02-A00: ISMS Performance Monitoring Procedure
- IS-AMR02-CIRQ03-A00: Internal Audit Procedure
- IS-AMR02-CIRQ01-F01A: Internal Audit Report Template
- IS-LMG-CIRQ04-A00: Management Review Procedure
- IS-LMR-CIRQ03-F01A: Management Review Meeting Minutes Template
- IS-AMR03-CIRQ01-A00: Nonconformity and Corrective Action Policy
- IS-LMR-CIRQ04-A00: Continual Improvement Policy

7. Policy Review

This policy will be reviewed at least annually, or sooner if there are significant changes to Cirque's ISMS, organizational structure, or external requirements.

IS-LMG-CIRQ04-A00: Management Review Procedure

IS-LMG-CIRQ04-A00: Management Review Procedure

Document: IS-LMG-CIRQ04-A00

Standards Name: Management Review Procedure

Category: ISMS Support Process

Division: Procedure

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** Executive Committee

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

CC1.2

Board / executive oversight

CC4.2

Evaluates and communicates deficiencies

CC5.3

Deploys policies that put control activities into action

The purpose of this procedure is to outline the specific steps and responsibilities for conducting formal management reviews of Cirque's Information Security Management System (ISMS). This ensures that the reviews are performed systematically, cover all required inputs, and result in documented decisions and actions that lead to the continuing suitability, adequacy, and effectiveness of the ISMS, as required by IS-LMR-CIRQ03-A00: Management Review Policy.

2. Scope

This procedure applies to all management reviews of Cirque's ISMS, involving top management and relevant stakeholders across all global operations (US, Taipei, China).

3. Roles and Responsibilities

- **Executive Committee:** Approves the management review schedule, participates in the reviews, makes decisions, and ensures the allocation of necessary resources.
- **ISMS Owner (e.g., Information Security Officer/IT Manager):** Coordinates the management review process, prepares the agenda, compiles necessary inputs, facilitates the meeting, records minutes, and tracks action items.
- **Presenters (e.g., IT Manager, HR Manager, Legal Counsel, Department Heads):** Prepare and present relevant information and data as inputs to the management review.

4. Procedure

4.1. Planning and Scheduling Management Reviews a. **Frequency:** At least annually. b. **Responsible:** ISMS Owner in coordination with the Executive Committee. c. **Steps:** 1. Determine the annual schedule for management reviews, ensuring all ISMS elements are covered over the planned cycle. 2. Identify and schedule participants, ensuring representation from top management and relevant departments. 3. Communicate the schedule and purpose of the review meetings to all required attendees well in advance. 4. Determine if any ad-hoc reviews are required due to significant changes or incidents, as per IS-LMR-CIRQ03-A00: Management Review Policy.

4.2. Preparation for Management Reviews a. **Frequency:** Prior to each scheduled review. b. **Responsible:** ISMS Owner and Presenters. c. **Steps:** 1. **ISMS Owner:** * Develop a detailed agenda for the management review, ensuring all required inputs from IS-LMR-CIRQ03-A00: Management Review Policy are covered. * Collect and consolidate all necessary information and data for the review inputs. This includes: * Status of actions from previous management reviews. * Changes in external and internal issues (e.g., new regulations, organizational changes). * Information security performance reports (nonconformities, monitoring results, audit results, risk assessments, status of risk treatment plans). * Opportunities for continual improvement. * Feedback from interested parties. * Evaluation of ISMS effectiveness. * Adequacy of resources. * Distribute the agenda and pre-reading materials to attendees at least [e.g., 5 business days] prior to the meeting. 2. **Presenters:** * Prepare presentations and reports for their respective input areas, highlighting key findings, trends, and recommendations.

4.3. Conducting the Management Review Meeting a. **Frequency:** As per schedule. b. **Responsible:** Executive Committee (Chair), ISMS Owner (Facilitator/Minute Taker), all Attendees. c. **Steps:** 1. **Opening:** The chair opens the meeting, confirms the agenda, and states the objectives of the review. 2. **Review Previous Actions:** Review the status of actions identified from the previous management review meeting. 3. **Input Presentation and Discussion:** Each presenter provides updates on their assigned inputs. Discussions should focus on: * Analysis of

performance against objectives and targets. * Identification of trends and root causes of deviations. * Evaluation of control effectiveness. * Discussion of risks and opportunities. * Resource allocation and needs. * Consideration of feedback from interested parties. 4. **Decision Making:** Top management shall make decisions regarding: * The continuing suitability, adequacy, and effectiveness of the ISMS. * Opportunities for continual improvement. * Any need for changes to the ISMS, including the information security policy and objectives. * Resource needs for the ISMS. 5. **Action Item Assignment:** Assign clear ownership, target dates, and required resources for all identified action items. 6. **Closing:** The chair summarizes key decisions and action items and formally closes the meeting.

4.4. Documenting Management Review Minutes a. **Frequency:** Immediately following the meeting (e.g., within 3-5 business days). b. **Responsible:** ISMS Owner. c. **Steps:** 1. Prepare comprehensive meeting minutes using the IS-LMR-CIRQ03-F01A: Management Review Meeting Minutes Template. 2. The minutes shall accurately reflect the discussions, decisions made, conclusions reached, and all assigned action items with owners and deadlines. 3. Distribute draft minutes to attendees for review and comments. 4. Finalize the minutes based on feedback and obtain approval from the chair. 5. Store the final, approved minutes as a formal record of the management review.

4.5. Follow-up on Action Items a. **Frequency:** Ongoing, until all actions are completed. b. **Responsible:** Action Item Owners (for implementation), ISMS Owner (for tracking). c. **Steps:** 1. Action item owners are responsible for implementing their assigned actions by the agreed-upon deadlines. 2. The ISMS Owner shall regularly track the progress of all action items, escalating delays or issues to the Executive Committee as necessary. 3. The status of these actions will be a required input for the subsequent management review.

5. Documentation

- Management Review Schedule.
- Meeting Agendas.
- Pre-reading materials/presentations (e.g., ISMS performance reports, audit summaries).
- IS-LMR-CIRQ03-F01A: Management Review Meeting Minutes Template (completed minutes).
- Action Item Tracker (or similar mechanism for tracking decisions and actions).

6. Related Documents

- IS-LMR-CIRQ03-A00: Management Review Policy
- IS-AMR02-CIRQ01-A00: Monitoring, Measurement, Analysis, and Evaluation Policy
- IS-AMR02-CIRQ02-A00: ISMS Performance Monitoring Procedure
- IS-AMR02-CIRQ03-A00: Internal Audit Procedure
- IS-AMR03-CIRQ01-A00: Nonconformity and Corrective Action Policy
- IS-AMR03-CIRQ02-A00: Corrective Action Procedure
- IS-LMR-CIRQ03-F01A: Management Review Meeting Minutes Template

7. Review

This procedure will be reviewed at least annually, or sooner if there are significant changes to Cirque's ISMS, management structure, or relevant standards.

IS-LMR-CIRQ03-F01A: Management Review Meeting Minutes Template

IS-LMR-CIRQ03-F01A: Management Review Meeting Minutes Template

Document: IS-LMR-CIRQ03-F01A

Standards Name: Management Review Meeting Minutes Template

Category: ISMS Support Process

Division: Form

Standard Type: Global

Version: 1.0 Effective Date: 2025-07-01 Review Date: 2026-07-01 Approved By: Executive Committee

MANAGEMENT REVIEW
MEETING MINUTES

Document ID:

IS-LMR-CIRQ03-F01A

Version:

1.0

Meeting ID:

[e.g., MR-YYYYMMDD-001]

Meeting Date:

[DD-MM-YYYY]

Meeting Time:

[HH:MM AM/PM]

Location:

[e.g., Main Conference Room / Virtual]

Chairperson:

[Name, Title of Top Management]

Minute Taker:

[Name, Title of ISMS Owner/Coordinator]

1. ATTENDEE LIST

Name

Title/Department

Presence (P/A)

[Name]

[Title]

[P]

[Name]

[Title]

[P]

[Name]

[Title]

[A]

(Add more rows as needed)

2. MEETING AGENDA

Item No.

Agenda Item

Presenter

1.

Welcome & Review of Previous Meeting Minutes and Action Items

Chairperson

2.

Review of External and Internal Issues Relevant to the ISMS

[Relevant Department]

3.

Information Security Performance Review (Trends in incidents, NCs, etc.)

ISMS Owner/ISO

4.

Results of Risk Assessments & Status of Risk Treatment Plans

ISMS Owner/ISO

5.

Results of Internal & External Audits

ISMS Owner/ISO (or Auditor)

6.

Feedback from Interested Parties

[Relevant Stakeholder]

7.

Evaluation of ISMS Effectiveness

ISMS Owner/ISO

8.

Adequacy of Resources for the ISMS

ISMS Owner/ISO

9.

Opportunities for Continual Improvement

All

10.

Decisions & Action Items

Chairperson

11.

Open Discussion & Adjournment

Chairperson

3. DISCUSSION AND DECISIONS

Detailed notes for each agenda item. Record key discussions, data presented, and conclusions.

3.1. Welcome & Review of Previous Meeting Minutes and Action Items

- Discussion: [Summary of discussion regarding previous minutes and action item status. Note any pending or overdue actions.]
- Decision(s): [e.g., "Previous minutes (MR-YYYYMMDD-00X) approved. Action Item A-005 now overdue, re-assigned to [Name] with new deadline [Date]."]

3.2. Review of External and Internal Issues Relevant to the ISMS

- Presentation by: [Presenter's Name]
- Discussion: [Summary of new legal/regulatory changes (e.g., new state privacy laws, compliance updates), market changes, technological advancements, organizational changes (e.g., new department, acquisition), and how they impact the ISMS.]
- Decision(s): [e.g., "Noted potential impact of new [Regulation Name]; Legal to provide detailed analysis by [Date]."]

3.3. Information Security Performance Review

- Presentation by: [Presenter's Name]
- Data Reviewed: [e.g., "ISMS Performance Report for Q1 2025: Incidents trended up slightly, patching compliance improved, phishing click-through rate still above target."]
- Discussion: [Analysis of KPIs, KRIs, trends in incidents, nonconformities, and corrective actions.]
- Decision(s): [e.g., "Allocate additional resources to security awareness training to address phishing simulation results. Review incident management process effectiveness."]

3.4. Results of Risk Assessments & Status of Risk Treatment Plans

- Presentation by: [Presenter's Name]
- Data Reviewed: [e.g., "Latest Risk Assessment Report: New high risk identified related to supply chain software. Status of risk treatment plans reviewed."]
- Discussion: [Review of identified risks, effectiveness of risk treatments, any new or emerging risks.]
- Decision(s): [e.g., "Approve proposed risk treatment plan for supply chain software risk; establish new project for implementation."]

3.5. Results of Internal & External Audits

- Presentation by: [Presenter's Name]
- Data Reviewed: [e.g., "Internal Audit Report IA-20250615-001 on Access Control; no external audit performed since last review."]
- Discussion: [Summary of audit findings, status of open nonconformities, overall audit program effectiveness.]
- Decision(s): [e.g., "Acknowledge findings from IA-20250615-001. Ensure all identified CARs are opened and tracked."]

3.6. Feedback from Interested Parties

- Presentation by: [Presenter's Name]
- Data Reviewed: [e.g., "Customer feedback on data privacy from Q2 surveys; no major supplier concerns."]
- Discussion: [Review of feedback from customers, regulators, suppliers, employees, and how it impacts ISMS.]

- Presentation by: [Presenter's Name]
- Discussion: [Overall assessment of the ISMS's ability to achieve its objectives and adequately manage information security. Is it suitable for current needs?]
- Decision(s): [e.g., "ISMS remains largely suitable and adequate, but requires targeted improvements in threat intelligence integration and vendor security assessments."]

- Presentation by: [Presenter's Name]
- Discussion: [Assessment of financial, human, and technological resources allocated to ISMS. Are they sufficient?]
- Decision(s): [e.g., "Approve budget request for new vulnerability management software and additional FTE for security operations."]

[illegible]

-
- Decision(s): [e.g., "Explore implementation of a more robust security awareness platform. Research new technologies for endpoint detection and response."]

4. ACTION ITEMS FROM THIS MEETING

Action ID

Description of Action

Owner

Target Date

Status

Notes/References

A-006

Review and update security awareness training modules.

[HR Manager]

[YYYY-MM-DD]

Open

Ref: Section 3.3

A-007

Develop project plan for new vulnerability management software.

[IT Manager]

[YYYY-MM-DD]

Open

Ref: Section 3.8

(Add more rows as needed)

5. NEXT MEETING

- **Proposed Date:** [DD-MM-YYYY]
- **Proposed Time:** [HH:MM AM/PM]

6. APPROVALS

- **Minutes Prepared By:**

- Confidential — Cirque Corporation Internal
- Name: [Minute Taker's Name]
 - Date: [DD-MM-YYYY]
 - Signature: [Signature]

• **Minutes Approved By (Chairperson):**

- Name: [Chairperson's Name]
 - Date: [DD-MM-YYYY]
 -
 -
 -
-
- -
 - Signature: [Signature]

7. DOCUMENT HISTORY

Version

Date

Changes Made

1.0

[DD-MM-YYYY]

Initial Release

IS-AMR03-CIRQ01-A00: Nonconformity and Corrective Action Policy

IS-AMR03-CIRQ01-A00: Nonconformity and Corrective Action Policy

Document: IS-AMR03-CIRQ01-A00

Standards Name: Nonconformity and Corrective Action Policy

Category: ISMS Support Process

Division: Policy

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 Effective Date: 2025-07-01 Review Date: 2026-07-01 Approved By: Executive Committee

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

CC4.2

Evaluates and communicates internal control deficiencies

CC5.3

Deploys policies and procedures

CC8.1

Manages changes resulting from corrective actions

CC9.1

Identifies, selects, and develops risk-mitigation activities

The purpose of this policy is to establish Cirque's commitment and framework for identifying, addressing, and preventing nonconformities within its Information Security Management System (ISMS). This policy ensures that identified deviations from requirements are promptly corrected, their root causes are eliminated, and measures are taken to prevent recurrence, thereby driving continual improvement of the ISMS. This policy aligns with ISO/IEC 27001:2022 Clause 10.1 (Continual improvement - Nonconformity and corrective action).

2. Scope

This policy applies to all nonconformities related to Cirque's ISMS, whether identified through internal audits, management reviews, incident management, performance monitoring, external audits, or other means. It covers all processes, controls, and personnel within the defined ISMS scope across all global operations (US, Taipei, China).

3. Definitions

- **Nonconformity (NC):** A non-fulfillment of a requirement. In the context of the ISMS, this could be a deviation from ISO 27001 requirements, Cirque's own ISMS requirements (e.g., policies, procedures), or legal, regulatory, or contractual obligations.
- **Corrective Action (CA):** Action to eliminate the cause of a detected nonconformity and to prevent recurrence.
- **Root Cause Analysis (RCA):** A systematic process for identifying the underlying causes of a nonconformity, rather than just addressing its symptoms.
- **Corrective Action Request (CAR):** A formal document or record used to initiate and track the process of addressing a nonconformity and implementing corrective actions.

4. Policy Requirements

4.1. Identification and Reporting of Nonconformities: a. Any personnel who identify a nonconformity, or potential nonconformity, related to the ISMS shall report it to their manager or the ISMS Owner/Security Team. b. Nonconformities can be identified through various sources, including: * Internal and external audits. * Security incident investigations. * Monitoring and measurement activities. * Management reviews. * Feedback from interested parties (e.g., customers, regulators). * Employee suggestions or observations.

4.2. Response to Nonconformities: a. When a nonconformity occurs, Cirque shall: 1. **React to the nonconformity:** Take immediate action to control and correct it (i.e., address the symptoms). 2. **Deal with the consequences:** Address any immediate impacts or damages. 3. **Evaluate the need for action to eliminate the cause(s):** Determine if a corrective action is necessary to prevent recurrence.

4.3. Root Cause Analysis (RCA): a. For all significant nonconformities (e.g., those impacting critical systems, recurring issues, or high-risk areas), a Root Cause Analysis shall be performed. b. The RCA process aims to identify the "why" behind the nonconformity, not just the "what." Techniques may include 5 Whys, Fishbone Diagram, etc.

4.4. Corrective Action Planning and Implementation: a. Based on the RCA, a corrective action plan shall be developed. This plan must include: * Specific actions to address the root cause(s). * Clear responsibilities for implementation. * Realistic target dates for completion. * Resources required. b. Corrective actions shall be proportionate to the significance of the nonconformity and the risks involved. c. Actions shall be implemented in a timely manner.

4.5. Verification of Effectiveness: a. Once corrective actions have been implemented, their effectiveness shall be verified. This involves confirming that the action taken has eliminated the root cause and prevented recurrence. b. Verification methods may include re-auditing, re-testing, reviewing new performance data, or observing updated processes.

4.6. Review of Corrective Actions: a. The results of corrective actions shall be reviewed periodically (e.g., during management reviews) to ensure their ongoing effectiveness and to identify any systemic issues or further opportunities for improvement.

4.7. Documentation and Record Keeping: a. All nonconformities and subsequent corrective actions shall be documented using the IS-AMR03-CIRQ01-F01A: Corrective Action Request (CAR) Form. b. Records shall be maintained as documented information of: * The nature of the nonconformities and any subsequent actions taken. * The results of any corrective action taken. c. These records are crucial for demonstrating compliance and for input into continual improvement.

5. Responsibilities

- **Executive Committee:** Provides leadership and resources for managing nonconformities and corrective actions; reviews significant nonconformities during management reviews.
- **ISMS Owner (e.g., Information Security Officer/IT Manager):** Overall responsibility for the nonconformity and corrective action process; ensures proper logging, tracking, and closure of CARs; reports on the status of nonconformities to top management.
- **Process Owners/Action Item Owners:** Responsible for investigating nonconformities within their area, conducting RCA, developing and implementing corrective action plans, and confirming effectiveness.
- **Internal Auditors:** Responsible for identifying nonconformities during audits and verifying the effectiveness of corrective actions.
- **All Personnel:** Responsible for reporting nonconformities and supporting the implementation of corrective actions within their scope.

6. Related Documents

- IS-APM01-CIRQ01-A00: Information Security Policy
- IS-AMR02-CIRQ01-A00: Monitoring, Measurement, Analysis, and Evaluation Policy
- IS-AMR02-CIRQ03-A00: Internal Audit Procedure
- IS-AMR02-CIRQ01-F01A: Internal Audit Report Template
- IS-LMR-CIRQ03-A00: Management Review Policy
- IS-AMR03-CIRQ02-A00: Corrective Action Procedure
- IS-AMR03-CIRQ01-F01A: Corrective Action Request (CAR) Form
- IS-LMR-CIRQ04-A00: Continual Improvement Policy

7. Policy Review

This policy will be reviewed at least annually, or sooner if there are significant changes to Cirque's ISMS, processes for handling nonconformities, or relevant standards.

IS-AMR03-CIRQ02-A00: Corrective Action Procedure

IS-AMR03-CIRQ02-A00: Corrective Action Procedure

Document: IS-AMR03-CIRQ02-A00

Standards Name: Corrective Action Procedure

Category: ISMS Support Process

Division: Procedure

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** ISMS Owner / IT Manager

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC4.2

Evaluates and communicates deficiencies

CC5.3

Deploys corrective-action policies

CC8.1

Manages changes resulting from corrective actions

CC9.1

Risk-mitigation activities

The purpose of this procedure is to establish a systematic process for addressing nonconformities identified within Cirque's Information Security Management System (ISMS). It provides detailed steps for initiating, investigating, planning, implementing, verifying, and closing corrective actions, ensuring that the root causes of nonconformities are eliminated and recurrence is prevented, as per IS-AMR03-CIRQ01-A00: Nonconformity and Corrective Action Policy.

2. Scope

This procedure applies to all identified nonconformities impacting Cirque's ISMS, regardless of their source (e.g., internal/external audits, security incidents, monitoring results, management reviews, stakeholder feedback). It covers all personnel involved in the corrective action process across all global operations (US, Taipei, China).

3. Roles and Responsibilities

- **ISMS Owner (e.g., Information Security Officer/IT Manager):** Oversees the overall corrective action process, assigns CARs, tracks progress, and reports on the status of nonconformities.
- **Originator:** The individual who identifies and reports a nonconformity (e.g., Internal Auditor, security analyst, employee).
- **Action Item Owner (Responsible Party):** The individual or team responsible for investigating the nonconformity, performing root cause analysis, developing and implementing the corrective action plan.
- **Verifier:** The individual responsible for verifying the implementation and effectiveness of the corrective action (often the Originator or a designated auditor/ISMS staff member).

4. Procedure

4.1. Identification and Initiation of Corrective Action Request (CAR) a. **Frequency:** As nonconformities are identified. b. **Responsible:** Originator, ISMS Owner. c. **Steps:** 1. **Identify Nonconformity:** A nonconformity is identified (e.g., during an internal audit, an incident investigation, or routine monitoring). 2. **Immediate Correction (Containment):** The immediate response to the nonconformity should be to contain its impact and correct the immediate issue (e.g., block unauthorized access, restore data). This is a temporary fix for the symptom. 3. **Initiate CAR:** The Originator completes the initial sections of the IS-AMR03-CIRQ01-F01A: Corrective Action Request (CAR) Form, providing a clear and factual description of the nonconformity, the relevant ISMS requirement violated, and any objective evidence. 4. **Submit CAR:** The completed CAR form is submitted to the ISMS Owner. 5. **Assign CAR ID & Owner:** The ISMS Owner logs the CAR in the CAR tracking system/register, assigns a unique CAR ID, and assigns an "Action Item Owner" (Responsible Party) based on the nature of the nonconformity and the relevant process owner. An initial target date for root cause analysis and action planning is set.

4.2. Investigation and Root Cause Analysis (RCA) a. **Frequency:** Within the initial target date set by the ISMS Owner (e.g., 5-10 business days from CAR assignment). b. **Responsible:** Action Item Owner. c. **Steps:** 1. **Acknowledge CAR:** The Action Item Owner acknowledges receipt of the CAR. 2. **Gather Information:** Collect additional relevant information, data, and evidence related to the nonconformity. 3. **Perform RCA:** Conduct a systematic Root Cause Analysis (e.g., using techniques like "5 Whys," Fishbone/Ishikawa diagram, FMEA) to determine the underlying reasons why the nonconformity occurred. This goes beyond the symptom to identify the systemic issues. 4. **Document Root Cause:** Record the identified root cause(s) on the IS-AMR03-CIRQ01-F01A: Corrective Action Request (CAR) Form.

4.3. Corrective Action Planning a. **Frequency:** Immediately following RCA completion. b. **Responsible:** Action Item Owner. c. **Steps:** 1. **Develop Action Plan:** Based on the identified root cause(s), develop a detailed corrective action plan outlining specific actions required to eliminate the cause and prevent recurrence. 2. **Define Deliverables & Responsibilities:** For each action, specify clear deliverables, assign responsibilities to individuals, and set realistic completion dates. 3. **Update CAR Form:** Document the corrective action plan on the IS-AMR03-CIRQ01-F01A: Corrective Action Request (CAR) Form. 4. **Obtain Approval:** The Action Item Owner submits the proposed corrective action plan to the ISMS Owner for review and approval.

4.4. Implementation of Corrective Actions a. **Frequency:** As per the planned schedule. b. **Responsible:** Action Item Owner and assigned personnel. c. **Steps:** 1. **Execute Actions:** Implement the agreed-upon corrective actions according to the plan and deadlines. 2. **Document Evidence:** Maintain records and evidence of the implementation of each action (e.g., screenshots of configuration changes, training records, updated procedure documents, meeting minutes). 3. **Update Status:** Update the status of the CAR in the tracking system/register.

4.5. Verification of Effectiveness a. **Frequency:** Upon completion of actions, within an agreed-upon timeframe (e.g., 30-60 days after implementation). b. **Responsible:** Verifier (e.g., Originator, ISMS Owner, Internal Auditor). c. **Steps:** 1. **Review Evidence:** The Verifier reviews the documented evidence of implementation. 2. **Assess Effectiveness:** The Verifier assesses whether the implemented corrective actions have effectively eliminated the root cause and prevented the recurrence of the nonconformity. This may involve: * Reviewing new performance data from monitoring (e.g., IS-AMR02-CIRQ02-A00). * Conducting follow-up interviews or observations. * Performing re-audits or re-tests of the affected control/process. 3. **Document Verification:** Record the results of the verification on the IS-AMR03-CIRQ01-F01A: Corrective Action Request (CAR) Form.

4.6. Closure of CAR a. **Frequency:** Upon successful verification of effectiveness. b. **Responsible:** ISMS Owner (with Verifier's recommendation). c. **Steps:** 1. If the corrective actions are deemed effective, the Verifier recommends closure of the CAR to the ISMS Owner. 2. The ISMS Owner formally closes the CAR in the tracking system/register. 3. If the corrective actions are *not* effective, the CAR is reopened, and the process reverts to Section 4.3 for further action planning and implementation.

4.7. Review for Changes and Continual Improvement a. **Frequency:** Regularly, especially during management reviews. b. **Responsible:** ISMS Owner, Management Review Committee. c. **Steps:** 1. The ISMS Owner shall periodically review the history of nonconformities and corrective actions (e.g., quarterly) to identify recurring issues or systemic weaknesses. 2. Information on nonconformities and corrective actions, their root causes, and effectiveness shall be a key input to management reviews (IS-LMG-CIRQ04-A00). 3. This information contributes to Cirque's continual improvement efforts (IS-LMR-CIRQ04-A00).

5. Documentation

- IS-AMR03-CIRQ01-F01A: Corrective Action Request (CAR) Form (completed).
- CAR Tracking Register/System.
- Evidence of RCA activities.
- Evidence of corrective action implementation.
- Records of verification of effectiveness.

6. Related Documents

- IS-AMR03-CIRQ01-A00: Nonconformity and Corrective Action Policy
- IS-AMR03-CIRQ01-F01A: Corrective Action Request (CAR) Form
- IS-AMR02-CIRQ03-A00: Internal Audit Procedure
- IS-AMR02-CIRQ01-A00: Monitoring, Measurement, Analysis, and Evaluation Policy
- IS-AMR02-CIRQ02-A00: ISMS Performance Monitoring Procedure
- IS-LMR-CIRQ03-A00: Management Review Policy
- IS-LMG-CIRQ04-A00: Management Review Procedure
- IS-LMR-CIRQ04-A00: Continual Improvement Policy
- IS-AMG01-CIRQ02-A00: Incident Response Procedure (Global Core)

7. Review

This procedure will be reviewed at least annually, or sooner if there are significant changes to Cirque's ISMS, the process for managing nonconformities, or relevant standards.

IS-AMR03-CIRQ01-F01A: Corrective Action Request (CAR) Form

IS-AMR03-CIRQ01-F01A: Corrective Action Request (CAR) Form

Document: IS-AMR03-CIRQ01-F01A

Standards Name: Corrective Action Request (CAR) Form

Category: ISMS Support Process

Division: Form

Standard Retention: Exist and No Corrections

Standard Type: Global

**CORRECTIVE
ACTION REQUEST
(CAR) FORM**

Document ID:

IS-AMR03-CIRQ01-F01A

Version:

1.0

CAR ID:

[e.g., CAR-YYYYMMDD-001]

Date Initiated:

[DD-MM-YYYY]

Status:

[Open / In Progress / Verification Pending / Closed]

Due Date for RCA & Plan:

[DD-MM-YYYY]

1. NONCONFORMITY IDENTIFICATION

• **Source of Nonconformity:**

- ☐ Internal Audit (Audit ID: [If applicable])
- ☐ External Audit
- ☐ Security Incident (Incident ID: [If applicable])
- ☐ Monitoring/Measurement
- ☐ Management Review
- ☐ Feedback (Customer, Regulator, Employee)
- ☐ Other (Specify: [])

• **Originator (Reported By):** [Name, Department]

• **Date of Nonconformity Occurrence/Detection:** [DD-MM-YYYY]

• **Department/Process Affected:** [e.g., IT Operations, HR, Development, Access Control Process]

• **Nonconformity Description:** [Provide a clear, concise, and factual description of the nonconformity. What is the deviation? From what requirement? What was observed?] *Example: "During the monthly review of user access logs, it was observed that User ID 'jsmith' retained access to the Finance Sharepoint for 72 hours after their termination date of 2025-06-01."

• **Relevant ISMS Requirement Violated:** [Reference the specific standard clause, policy, or procedure violated.] Example: "IS-AIR01-CIRQ01-A00: Access Control Policy, Section 5.3 (Access Revocation) -

- Objective Evidence:** [Provide specific references to records, logs, reports, or observations that substantiate the nonconformity.] *Example: "HR termination record for 'jsmith' (ID: HR-T-005). Finance Sharepoint access logs from 2025-06-01 to 2025-06-04 showing activity from 'jsmith'."*

2. IMMEDIATE CORRECTION (Containment / Symptom Fix)

- Action Taken (Temporary Fix):** [What immediate action was taken to control the nonconformity and deal with its consequences? This is typically a band-aid, not the long-term solution.] *Example: "User ID 'jsmith' access to Finance Sharepoint manually revoked on 2025-06-04 at 10:30 AM."*
- Date Completed:** [DD-MM-YYYY]

3. INVESTIGATION AND ROOT CAUSE ANALYSIS (RCA)

- Action Item Owner (Responsible Party):** [Name, Department]
- Root Cause Analysis Performed (Methodology used, e.g., 5 Whys, Fishbone):** [Describe the method used for RCA.] *Example: "5 Whys analysis was conducted."*
- Identified Root Cause(s):** [What were the underlying systemic reasons for the nonconformity? Why did it happen?] **Example: "The automated HR-IT termination workflow failed to trigger the access revocation script for the Finance Sharepoint due to an incorrect group mapping. This manual review process, intended as a fallback, has a 48-hour SLA, which was exceeded due to personnel being on leave."*

4. CORRECTIVE ACTION PLAN

- Plan Developed By:** [Name, Department]

•	•	•	•	•	•
•	•	•	•	•	•
•	•	•	•	•	•
•	•	•	•	•	•
					Date Plan Developed: [DD-MM-YYYY]

Action Item #

Detailed Action to Eliminate Root Cause

Responsible Person(s)

Target Completion Date

Status

Evidence of Completion

1.

Correct group mapping in HR-IT termination workflow for Finance Sharepoint access.

[IT Automation Specialist]

Open

[Ref: Change Request ID, Screenshot]

2.

Update IS-AIR01-CIRQ04-A (Access Management Procedure) to include daily reconciliation report of terminated users vs. active access for critical systems.

00 [ISMS Owner

] [YYYY-MM-DD]

Open

[Ref: Document Version]

3.

Conduct refresher training for IT Help Desk staff on manual access revocation procedures, emphasizing critical systems.

[IT Training Lead]

[YYYY-MM-DD]

Open

[Ref: Training Log, Course Module]

5. VERIFICATION OF EFFECTIVENESS

- **Verifier:** [Name, Department]
- **Date of Verification:** [DD-MM-YYYY]
- **Verification Method(s):** [How was it confirmed that the corrective action eliminated the root cause and prevented recurrence? e.g., Re-audit, review of new data, observation.] *Example: "1. Reviewed updated HR-IT workflow configuration. 2. Monitored daily reconciliation report for 3 weeks (no discrepancies found). 3. Reviewed training records and interviewed Help Desk staff on updated procedure."*
- **Results of Verification (Effective? Yes/No):** [State clearly if the corrective action was effective in preventing recurrence.] *Example: "Yes, the corrective actions were effective. The automated workflow is now correctly configured, the manual review process has an effective daily reconciliation, and personnel are re-trained."*

6. CAR CLOSURE

- **Closed By (ISMS Owner):** [Name]
- **Date Closed:** [DD-MM-YYYY]

•	•	•
•	•	• Comments: [Any final comments regarding the closure, e.g., "Nonconformity successfully closed. Continued monitoring through daily reconciliation report."]

7. DOCUMENT HISTORY

Date

Changes Made

1.0

[DD-MM-YYYY]

Initial Release

IS-AMR03-CIRQ01-F01A: CAR-2026-001-Lenovo-Threat-Modeling

CAR-2026-001: Add Threat Modeling to Secure Development Lifecycle

Form ID: IS-AMR03-CIRQ01-F01A (Corrective Action Request — populated record) **CAR ID:** CAR-2026-001
Status: Closed (effective 2026-05-08) **Severity:** Recommendation (Lenovo Trusted Supplier Program — non-binding) **Date Initiated:** 2026-04-02 **Date Closed:** 2026-05-08 **Owner:** Chris Wren (IT Manager / ISMS Owner)
Linked finding(s): Lenovo Trusted Supplier Program audit, finding #1 — SW, FW & MFG Test SW Question #14, dated 2026-03-25

1. Nonconformity / Recommendation Identification

Source: ☒ External Audit — Lenovo Trusted Supplier Program (annual customer audit) **Originator:** Chenchen Shi, Lenovo Trusted Supplier Program Auditor **Distributed via:** Shuang Chen, Cirque Account Manager **Date of Detection:** 2026-03-25 (audit close-out date; on-site audit conducted 2026-02-20) **Department / Process Affected:** Hardware, Firmware, and Software Engineering — Secure Development Lifecycle **Classification:** Recommendation (per Lenovo Trusted Supplier Program terminology — opportunity for improvement, not a nonconformity requiring remediation within a designated timeframe). Cirque elected to treat as a tracked corrective action under IS-LMR-CIRQ04-A00 (Continual Improvement Policy) and IS-AMR03-CIRQ01-A00 (Nonconformity and Corrective Action Policy).

Description (verbatim from Lenovo audit report): “Supplier demonstrated that there is a secure development process implemented, however, the process does not include threat modeling based on the questionnaire response. It's suggested that threat modeling be implemented to identify and mitigate potential threats, risks, and vulnerabilities within increasingly complex IT environments and product development process.”

Standards referenced by auditor: - NIST Cybersecurity Framework: PR.IP-2 — A System Development Life Cycle to manage systems is implemented - NIST SP 800-53 v5: SA-3 — System Development Life Cycle - ISO/IEC 27002:2022: Section 8.25 — Secure development life cycle

Relevant ISMS document(s) prior to this CAR: - IS-AAR05-CIRQ01-A00: Secure System Acquisition, Development and Maintenance Policy v1.0 — referenced “Security by Design” but did not list threat modeling as a principle. - IS-AAR05-CIRQ02-A00: Secure Development Procedure v1.0 Section 4.2.b — stated “Threat modeling or security design reviews shall be conducted for critical systems.” The “or” allowed teams to substitute a less-rigorous design review and was the proximate cause of the gap.

Objective evidence supporting the finding: - Lenovo Trusted Supplier Program Audit Report dated 2026-03-25 (filed in Cirque ISMS document repository under Customer-Audits/Lenovo/2026/). - Cirque's responses to the Lenovo Trusted Supplier Security Questionnaire (Q14) prior to the audit.

2. Immediate Correction (Containment)

Action taken (temporary): On 2026-04-02 the IT Manager issued a stand-down email instructing all Engineering Leads that, effective immediately, no new product release or significant change to firmware, software, or ASIC may proceed to design freeze without an approved threat model. Existing in-flight projects must produce a retro-active

Confidential — Cirque Corporation Internal
threat model before the next release that introduces a new external interface, new data type, new connectivity, or new third-party dependency.

Date completed: 2026-04-02 **Evidence:** Email titled "MANDATORY: Threat Model required before design freeze" sent 2026-04-02 to engineering-leads@cirque.com, retained in IT Manager's mailbox and ISMS evidence folder.

3. Investigation and Root Cause Analysis (RCA)

RCA owner: Chris Wren (IT Manager) **Methodology:** 5 Whys, supported by document review.

5-Whys analysis: 1. **Why did Lenovo find that threat modeling was not part of our SDLC?** Because IS-AAR05-CIRQ02-A00 Section 4.2.b allowed threat modeling **or** a security design review, and projects were defaulting to design review. 2. **Why did the procedure permit substitution?** The original v1.0 procedure (effective 2025-07-01) was written before Cirque had selected a single threat-modeling methodology, so the language was deliberately flexible. 3. **Why was no methodology selected later?** No follow-up task was created. The procedure language was never tightened. 4. **Why was no follow-up created?** Threat modeling was not on the ISMS performance dashboard (IS-AMR02-CIRQ02-A00), and no internal audit had tested for its absence. 5. **Why was internal audit coverage missing?** The internal audit cadence in IS-AMR02-CIRQ03-A00 was every 1–3 years (since corrected in v2.0 to annual), so the SDLC had not yet been audited in detail since v1.0 of the procedure was issued.

Identified root causes: - **Procedural ambiguity:** "or" language in PR-017 Section 4.2.b allowed weaker substitute. - **Missing methodology selection:** No documented standard for how threat modeling would be performed at Cirque. - **Audit blind spot:** Internal audit cadence was too long to surface the gap before an external auditor did. - **Monitoring gap:** Threat-modeling completion was not a KPI in IS-LMR-CIRQ05-A00 (Information Security Objectives).

4. Corrective
Action Plan

Action

Owner

Target

Evidence of completion

1

Update IS-AAR05-CIRQ02-A00 Section 4.2.b to make threat modeling **mandatory** (replace “or” with explicit requirement). Add new Section 4.2.c with full threat-modeling process (methodology, inputs, steps, output artifact, roles, linkage to risk register, review cadence, evidence retention).

Chris Wren

2026-05-08

☒ Done

PR-017 v1.1 effective 2026-05-08; change history documents the update.

2

Update IS-AAR05-CIRQ01-A00 to add Threat Modeling as a principle of the Secure System Lifecycle (Section 3) and as a required element of Information Security Requirements Specification (Section 4.1.d).

Chris Wren

2026-05-08

☒ Done

P-012 v1.1 effective 2026-05-08; change history documents the update.

3

Adopt STRIDE as the standard methodology for software and firmware; supplement with hardware-specific threats for ASIC designs. Reference NIST CSF PR.IP-2, NIST 800-53 SA-3, and ISO/IEC 27002:2022 Section 8.25 in the procedure.

Chris Wren

2026-05-08

☒ Done

PR-017 v1.1 Section 4.2.c documents the methodology and standards alignment.

4

Update IS-APM02-CIRQ01-A02A (Statement of Applicability) to confirm coverage of ISO/IEC 27002:2022 Section 8.25 with reference to the new PR-017 v1.1.

Chris Wren

2026-05-31

Open

SoA population is in flight; threat-modeling row will be added when SoA is populated (per Critical Finding C-01 in the SOC 2 Readiness Findings).

5

Confidential — Cirque Corporation Internal

Add "Threat-model coverage" as a measurable KPI to IS-LMR-CIRQ05-A00 (Information Security Objectives): % of in-flight engineering projects with an approved current threat model. Initial target: 100% of new projects after 2026-05-08; 100% of active products by 2026-09-30.

Chris Wren

2026-05-31

Open

D-007 update scheduled in next document control cycle.

6

Author a Threat Model template (THREAT-MODEL.md) and check it into the GitLab engineering-templates repo so every new product repo can copy it.

Chris Wren

2026-05-22

Open

Template URL to be recorded here on completion.

7

Conduct a 1-hour STRIDE training session for all Development Leads. Training record filed under IS-AHR02-CIRQ01-F01A.

Chris Wren / Brenda Milian

2026-06-15

Open

Training Records Log entry to be filed on completion.

8

Add "SDLC including threat modeling" to the 2026 internal audit scope (IS-AMR02-CIRQ03-A00) so the control is sampled within the audit window.

Chris Wren / Independent Reviewer

2026-06-30

Open

Internal audit plan revision.

9

Provide a copy of this CAR record and PR-017 v1.1 to Lenovo (Elizabeth Stremlau, Trusted Supplier Program Manager; Chenchen Shi, Auditor) via Shuang Chen as evidence of remediation.

Chris Wren

2026-05-15

Open

Email confirmation to be retained.

5. Verification of Effectiveness

Verifier: Independent Reviewer designated by the Executive Committee (per IS-APM01-CIRQ01-A00 Section 6).

Verification window: 2026-06-15 to 2026-07-31. **Verification methods:** 1. Document review: confirm PR-017 v1.1 and P-012 v1.1 are published and accessible. 2. Sample test: select 3 active engineering projects; confirm a current threat model exists in the project's GitLab repository under /security/THREAT-MODEL.md (or /docs/security/ for hardware projects), with reviewer sign-off. 3. Interview: speak with at least 2 Development Leads and confirm awareness of the new requirement. 4. KPI check: review D-007 KPI "Threat-model coverage" baseline measurement.

Results of verification: To be recorded after 2026-07-31.

6. CAR Closure

Status as of 2026-05-08: Items 1, 2, and 3 (the policy and procedure changes) are complete; this CAR moves to *Closed - Pending Verification*. Items 4–9 are in flight and tracked here for visibility but do not block closure of the policy/procedure update. Final closure will be re-confirmed after the verification window in Section 5.

Final closure (to be completed): - Closed by: _____ (ISMS Owner) - Date closed: _____ -
Comments: _____

7. Linkage to Other ISMS Records

Source audit report: Lenovo Trusted Supplier Program Audit Report, 2026-03-25 —
Customer-Audits/Lenovo/2026/

Related risk register entry: To be added to IS-LMR-CIRQ01-F01A — risk "Software/Firmware Development Threat Coverage" with treatment = mitigated via PR-017 v1.1

Documents updated by this CAR: IS-AAR05-CIRQ01-A00 v1.1; IS-AAR05-CIRQ02-A00 v1.1; IS-AMR06-CIRQ01-F01A (Lenovo added to Interested Parties); IS-APM02-CIRQ01-A02A (SoA — pending population); IS-LMR-CIRQ05-A00 (KPI — pending population).

Continual Improvement linkage: This CAR feeds the Q2 2026 Management Review (IS-LMG-CIRQ04-A00) as an example of responsiveness to customer audit feedback.

SOC 2 evidence value: This CAR demonstrates CC4.2 (evaluating and communicating control deficiencies), CC5.3 (deploys policies and procedures that put control activities into action), CC8.1 (changes to procedures), and CC9.1 (risk-mitigation activities), as well as the operating effectiveness of IS-AMR03-CIRQ01-A00 (Nonconformity and Corrective Action Policy).

8. Document History

Version

Date

Changes

1.0

CAR opened in response to Lenovo Trusted Supplier Program audit recommendation dated 2026-03-25.

1.1

2026-05-08

Items 1–3 closed: PR-017 v1.1 and P-012 v1.1 published with mandatory threat modeling. CAR moved to Closed-Pending-Verification status.

IS-LMR-CIRQ04-A00: Continual Improvement Policy

IS-LMR-CIRQ04-A00: Continual Improvement Policy

Document: IS-LMR-CIRQ04-A00

Standards Name: Continual Improvement Policy

Category: ISMS Support Process

Division: Policy

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** Executive Committee

1. Purpose

SOC 2 Trust Services Criteria Mapping

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC4.2

Evaluates and communicates internal control deficiencies

CC5.3

Deploys policies and procedures that put control activities into action

The purpose of this policy is to establish Cirque's commitment to the continual improvement of its Information Security Management System (ISMS). This policy ensures that the ISMS remains effective, suitable, and adequate in managing information security risks and opportunities in a dynamic environment, constantly striving for enhanced performance. This policy aligns with ISO/IEC 27001:2022 Clause 10.2 (Continual improvement).

2. Scope

This policy applies to all processes, activities, and personnel involved in the operation and enhancement of Cirque's ISMS across all global operations (US, Taipei, China). It covers all initiatives aimed at improving the overall information security posture and the effectiveness of the ISMS.

3. Definitions

- **Continual Improvement:** A recurring activity to enhance performance. In the context of the ISMS, it refers to ongoing efforts to improve the suitability, adequacy, and effectiveness of the information security system.
- **ISMS:** Information Security Management System.
- **PDCA Cycle (Plan-Do-Check-Act):** A cyclical process for continuous improvement, used as the underlying methodology for the ISMS.

4. Policy Requirements

4.1. Commitment to Continual Improvement: a. Cirque is committed to continually improving the suitability, adequacy, and effectiveness of its ISMS. b. This commitment is demonstrated through the allocation of necessary resources, management review, and the implementation of identified improvements.

4.2. Improvement Methodology (PDCA Cycle): a. Cirque shall utilize the Plan-Do-Check-Act (PDCA) cycle as the foundation for its continual improvement efforts: * **PLAN:** Establish information security objectives and processes necessary to deliver results in accordance with Cirque's overall information security policy. (e.g., Risk assessment, ISMS planning). * **DO:** Implement the information security policy, controls, and processes. (e.g., Control implementation, operations). * **CHECK:** Monitor, measure, and review performance against information security policy and objectives, and report results. (e.g., Monitoring, internal audits, management reviews). * **ACT:** Take corrective actions and implement improvements based on the results of the check phase. (e.g., Corrective actions, ISMS updates).

4.3. Sources of Improvement: a. Inputs for continual improvement shall be systematically gathered from various sources, including but not limited to: * Results of IS-AMR02-CIRQ01-A00: Monitoring, Measurement, Analysis, and Evaluation Policy and IS-AMR02-CIRQ02-A00: ISMS Performance Monitoring Procedure. * Outcomes of IS-AMR02-CIRQ03-A00: Internal Audit Procedure and IS-AMR02-CIRQ01-F01A: Internal Audit Report Template. * Decisions and actions from IS-LMR-CIRQ03-A00: Management Review Policy and IS-LMG-CIRQ04-A00: Management Review Procedure. * Nonconformities and the results of IS-AMR03-CIRQ01-A00: Nonconformity and Corrective Action Policy and IS-AMR03-CIRQ02-A00: Corrective Action Procedure (IS-AMR03-CIRQ01-F01A: Corrective Action Request (CAR) Form). * Information security incidents and their post-incident reviews. * Changes in internal and external issues (e.g., new threats, technologies, legal requirements). * Feedback from interested parties (e.g., customers, employees, regulators, suppliers). * Suggestions from employees and subject matter experts.

4.4. Planning and Implementation of Improvements: a. Opportunities for improvement shall be assessed, prioritized based on risk and benefit, and documented. b. An action plan, including responsibilities, timelines, and necessary resources, shall be developed for each significant improvement initiative. c. Implemented improvements shall be monitored and evaluated to confirm their effectiveness and contribution to the ISMS.

4.5. Documentation and Communication: a. Records of continual improvement activities, including identified opportunities, action plans, implementation status, and verification of effectiveness, shall be maintained. b. The outcomes of improvement initiatives shall be communicated to relevant stakeholders as appropriate.

5. Responsibilities

- **Executive Committee:** Demonstrates leadership and commitment to continual improvement by providing resources, reviewing improvement progress, and making strategic decisions during management reviews.
- **ISMS Owner (e.g., Information Security Officer/IT Manager):** Champions continual improvement, oversees the collection and analysis of improvement inputs, facilitates the planning and tracking of improvement initiatives, and reports on progress to management.
- **Process Owners:** Responsible for identifying and implementing improvements within their respective ISMS processes and controls.
- **All Personnel:** Are encouraged to identify and report opportunities for improvement related to information security.

6. Related Documents

- IS-APM01-CIRQ01-A00: Information Security Policy

- IS-AMR02-CIRQ01-A00: Monitoring, Measurement, Analysis, and Evaluation Policy
- IS-AMR02-CIRQ02-A00: ISMS Performance Monitoring Procedure
- IS-AMR02-CIRQ03-A00: Internal Audit Procedure
- IS-AMR02-CIRQ01-F01A: Internal Audit Report Template
- IS-LMR-CIRQ03-A00: Management Review Policy
- IS-LMG-CIRQ04-A00: Management Review Procedure
- IS-LMR-CIRQ03-F01A: Management Review Meeting Minutes Template
- IS-AMR03-CIRQ01-A00: Nonconformity and Corrective Action Policy
- IS-AMR03-CIRQ02-A00: Corrective Action Procedure
- IS-AMR03-CIRQ01-F01A: Corrective Action Request (CAR) Form

7. Policy Review

This policy will be reviewed at least annually, or sooner if there are significant changes to Cirque's ISMS, business operations, or the information security landscape, to ensure its ongoing relevance and effectiveness.

Part XIV — Workplace Policies

IS-AHR01-CIRQ02-A00: Acceptable Use Policy

IS-AHR01-CIRQ02-A00: Acceptable Use Policy

Document: IS-AHR01-CIRQ02-A00

Standards Name: Acceptable Use Policy

Category: Operations Security

Division: Policy

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** IT Manager

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC1.4

Personnel competence and acceptable behavior

CC2.2

Internal communication of policies

CC5.2

Selects and develops general control activities over technology

CC6.1

Logical access protections

CC6.7

Restrictions on movement of information

C1.2

Protection of confidential information from unauthorized disclosure

The purpose of this policy is to define the acceptable and prohibited uses of Cirque's information technology (IT) resources, including but not limited to computer systems, networks, applications, software, hardware, email, and internet access. This policy ensures that IT resources are used in a manner that supports Cirque's business objectives, protects its information assets, complies with legal and ethical standards, and maintains a secure and productive work environment.

2. Scope

This policy applies to all Cirque personnel (employees, contractors, temporary staff), visitors, and any third party who uses or has access to Cirque's IT resources, regardless of location (on-site or remote) or device ownership (company-issued or personal devices used for business purposes).

3. Definitions

- **IT Resources:** Any computing or communication equipment, software, data, network services, email, internet access, or other technology owned or controlled by Cirque, or to which Cirque provides access.

- **Company Data:** Any information created, stored, processed, or transmitted on Cirque's IT resources, regardless of its classification.

4. General Principles of Acceptable Use

All users of Cirque's IT resources are expected to adhere to the following general principles:

- **Professional Conduct:** Use IT resources in a professional, ethical, and lawful manner consistent with Cirque's values and other company policies.
- **Business Focus:** Prioritize the use of IT resources for legitimate Cirque business purposes. Limited personal use is generally permitted if it does not interfere with job duties, consume excessive resources, or violate other policies.
- **Security:** Take all reasonable steps to protect Cirque's IT resources and information from unauthorized access, use, disclosure, disruption, modification, or destruction.
- **Compliance:** Comply with all applicable laws, regulations, and Cirque policies, including those related to information security, privacy, and intellectual property.

5. Acceptable Use Requirements

5.1. Account and Password Security: a. Users must protect their user accounts, passwords, and other authentication credentials. b. Sharing of passwords or user accounts is strictly prohibited. c. Users are responsible for all activities conducted under their user accounts. d. Refer to IS-AIR01-CIRQ01-A00: Access Control Policy for specific password requirements.

5.2. Data Handling and Confidentiality: a. Users must handle Company Data in accordance with its classification (refer to IS-AHR01-CIRQ01-A00: Information Classification Policy). b. Confidential and sensitive information must not be stored on unapproved personal devices or cloud services. c. Do not share or disclose confidential or sensitive Company Data to unauthorized individuals, internally or externally. d. Use secure methods for data transfer as outlined in IS-AFR01-CIRQ01-A00: Information Transfer Policy.

5.3. Email and Communication: a. Email and communication systems are primarily for business purposes. b. Do not send or forward chain letters, hoaxes, or solicitations. c. Do not send or store offensive, harassing, discriminatory, or unlawful content. d. Be mindful that all communications on company systems are Cirque property and may be monitored.

5.4. Internet Usage: a. Internet access is provided for business-related research and communication. b. Limited personal Browse is permitted if it does not impact productivity or bandwidth, or violate this policy. c. Do not visit websites containing illegal, unethical, or inappropriate content (e.g., pornography, hate speech, gambling, illegal downloading sites).

5.5. Software and Applications: a. Only authorized and licensed software may be installed on Cirque's IT resources. b. Do not download or install software from untrusted sources. c. Do not use pirated or unlicensed software. d. Software installation and updates on company-issued devices must be approved by and/or performed by IT.

5.6. Use of Personal Devices (BYOD - Bring Your Own Device): a. If personal devices are permitted for business use, they must comply with specific BYOD guidelines (if a BYOD Policy exists) and adhere to this Acceptable Use Policy. b. Cirque reserves the right to wipe company data from personal devices used for business purposes upon separation from the company or in case of security incidents.

5.7. Resource Consumption: a. Do not consume excessive network bandwidth, storage, or processing power for non-business purposes. b. Avoid unauthorized streaming, large file downloads for personal use, or excessive personal cloud storage synchronization on company networks.

6. Prohibited Activities

The following activities are strictly prohibited when using Cirque's IT resources:

- **Illegal Activities:** Engaging in any activity that violates local, national, or international laws or regulations.

- **Unauthorized Access:** Attempting to gain unauthorized access to any system, network, or data, whether internal or external to Cirque.
- **Malicious Activities:** Distributing, installing, or promoting malware (viruses, worms, ransomware, etc.), or engaging in any activity that could harm IT resources or data.
- **Harassment/Discrimination:** Creating, transmitting, or accessing content that is harassing, discriminatory, sexually explicit, defamatory, or otherwise offensive.
- **Copyright Infringement:** Downloading, sharing, or distributing copyrighted material without proper authorization.
- **Commercial Use:** Using Cirque's IT resources for personal commercial purposes (e.g., operating a personal business) without explicit written permission.
- **Impersonation:** Impersonating another person or entity.
- **Security Bypasses:** Attempting to bypass or disable security controls (e.g., firewalls, antivirus, content filters).
- **Resource Abuse:** Deliberate or reckless destruction, modification, or disruption of Cirque's IT resources or data.
- **Monitoring/Interception:** Attempting to monitor or intercept network traffic or communications of others without authorization.

7. Monitoring and Audit

Cirque reserves the right to monitor, log, and audit the use of its IT resources to ensure compliance with this policy, protect its assets, and for legal and regulatory purposes. Users should have no expectation of privacy when using company IT resources.

8. Non-Compliance

Violation of this policy may result in disciplinary action, up to and including termination of employment, and may also lead to legal action in accordance with applicable laws.

9. Responsibilities

- **IT Manager:** Responsible for implementing technical controls to enforce this policy and for monitoring compliance.
- **Human Resources:** Responsible for enforcing disciplinary actions related to policy violations.
- **All Personnel:** Responsible for understanding, signing (where required), and complying with this policy.

10. Related Documents

- IS-APM01-CIRQ01-A00: Information Security Policy
- IS-AHR01-CIRQ01-A00: Information Classification Policy
- IS-AIR01-CIRQ01-A00: Access Control Policy
- IS-AFR01-CIRQ01-A00: Information Transfer Policy
- IS-AIR01-CIRQ09-A00: Logging and Monitoring Procedure
- IS-LMR-CIRQ01-A00: Disciplinary Policy (if applicable)
- BYOD Policy (if applicable)

11. Policy Review

This policy will be reviewed at least annually, or sooner if there are significant changes to Cirque's IT resources, business operations, or legal/regulatory environment.

IS-AHR01-CIRQ03-A00: Remote Work Policy

IS-AHR01-CIRQ03-A00: Remote Work Policy

Document: IS-AHR01-CIRQ03-A00

Standards Name: Remote Work Policy

Category: Human Security Related

Division: Policy

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 Effective Date: 2025-07-01 Review Date: 2026-07-01 Approved By: Executive Committee, IT Manager, HR Manager

1. Purpose

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC6.1

Logical access controls for remote workers

CC6.6

Protection against external threats (VPN, MFA, secure transmission)

CC6.7

Restrictions on transmission and movement of information

CC6.8

Anti-malware on remote endpoints

C1.2

Protection of confidential information accessed remotely

The purpose of this policy is to establish the security requirements and responsibilities for Cirque personnel working remotely. This policy aims to ensure the secure use of Cirque's information assets, systems, and data when accessed from outside the traditional office environment, mitigating risks associated with remote access, device security, and physical environment. It supports Cirque's commitment to flexible work arrangements while maintaining a robust information security posture.

2. Scope

This policy applies to all Cirque personnel (employees, contractors, temporary staff) authorized to perform work remotely, whether from a home office, co-working space, or other approved off-site locations. It covers all Cirque-issued and approved personal devices used for business purposes when accessing Cirque's IT resources. This policy applies globally across all Cirque locations.

3. Definitions

- **Remote Work:** Performing job duties for Cirque from a location other than a designated Cirque office.
- **Remote Worker:** Any individual authorized by Cirque to perform work remotely.
- **Company-Issued Device:** Hardware (e.g., laptops, tablets, smartphones) provided by Cirque for business use.
- **Personal Device (BYOD):** A privately-owned device used for Cirque business purposes (if permitted by separate BYOD policy).
- **VPN (Virtual Private Network):** A secure connection over a public network (like the internet) that allows remote users to access Cirque's internal network resources as if they were physically present in the office.
- **RMM (Remote Monitoring and Management):** Software used by Cirque's IT department to monitor, manage, and secure remote devices and systems.

4. Policy Requirements

4.1. Remote Work Environment Security: a. Remote workers must establish a secure workspace that prevents unauthorized access to Cirque information and devices. This includes implementing a "Clear Desk and Clear Screen" policy at their remote location. b. Physical security measures, such as locking doors when leaving the workspace, must be maintained. c. Cirque information should not be left visible to unauthorized individuals (e.g., family members, visitors). d. Confidential discussions should be conducted in private settings to prevent eavesdropping.

4.2. Device Security: a. **Company-Issued Devices:** * Must be used as the primary means for conducting Cirque business remotely. * Must be kept physically secure at all times to prevent theft or unauthorized access. * Must remain connected to Cirque's **RMM tool** for monitoring, patch management, security updates, and troubleshooting. * Endpoint full-disk encryption is required by IS-AIR01-CIRQ02-A00 Cryptography Policy but is not yet deployed (see Section 4.6 Known Control Gap of that policy); compensating controls — physical security, restriction of Confidential data to cloud storage, Intune remote-wipe — apply in the interim, and remote workers shall not store Confidential data on local disk. * Must comply with IS-AHR01-CIRQ02-A00: Acceptable Use Policy. b. **Personal Devices (if permitted):** * Must adhere to a separate Bring Your Own Device (BYOD) policy (if applicable). * Must have up-to-date operating systems, antivirus software, and firewall protection. * Must be protected by strong passwords/PINs and biometric authentication where available. * Cirque's IT reserves the right to enforce security configurations (e.g., mobile device management) or restrict access if security standards are not met. * Users acknowledge that Cirque may remotely wipe company data from personal devices upon termination or in case of security incidents.

4.3. Network and Connectivity Security: a. Remote workers **must use Cirque's provided VPN** to connect to all internal network services and resources (e.g., file shares, internal applications, development environments). This ensures encrypted communication and routes traffic through Cirque's security infrastructure. b. Public Wi-Fi networks should be avoided for accessing sensitive Cirque information. If unavoidable, the VPN **must** be active at all times. c. Personal home networks used for remote work must be secured with strong, unique Wi-Fi passwords and updated router firmware.

4.4. Data Handling and Storage: a. Sensitive and confidential Cirque data must **not** be stored directly on local hard drives of remote devices unless explicitly permitted and protected by encryption. All data should primarily reside on company network drives or approved cloud storage accessible via VPN. b. Removable media (e.g., USB drives) containing Cirque data should be used sparingly and only if approved and encrypted, as per IS-AFR01-CIRQ01-A00: Information Transfer Policy. c. Secure disposal of Cirque documents and media must be followed, even in remote locations.

4.5. Software and Applications: a. Only Cirque-approved and licensed software should be installed and used for business purposes on company-issued devices. b. Personal software or unauthorized applications should not be installed on company-issued devices. c. All software must be kept up to date with patches and security fixes.

4.6. Monitoring and Auditing: a. Remote workers acknowledge that their use of Cirque-issued devices, company network access via VPN, and activities related to Cirque business are subject to monitoring and auditing by Cirque. This includes monitoring by the **RMM tool** on their computers. b. This monitoring is conducted to ensure compliance with this policy, maintain system health, troubleshoot issues, detect security incidents, and protect Cirque's assets.

4.7. Incident Reporting: a. Any suspected security incidents (e.g., loss or theft of a device, unauthorized access attempts, malware infection, suspicious activity) encountered while working remotely must be reported immediately as per IS-AMG01-CIRQ01-A00: Information Security Incident Management Policy and IS-AMG01-CIRQ02-A00: Incident Response Procedure (Global Core).

5. Responsibilities

- **Remote Workers:** Adhere to all aspects of this policy, report security incidents promptly, and ensure the security of their remote workspace and devices.
- **IT Manager/IT Department:** Provides secure remote access solutions (VPN), deploys and manages the **RMM tool**, provides company-issued devices, and ensures technical support for remote workers.
- **Human Resources:** Manages the administrative aspects of remote work arrangements and communicates policy requirements to personnel.

6. Non-Compliance

Failure to comply with this policy may result in disciplinary action, up to and including termination of employment, and may also lead to legal action, as outlined in Cirque's disciplinary procedures.

7. Related Documents

- IS-APM01-CIRQ01-A00: Information Security Policy
- IS-AHR01-CIRQ01-A00: Information Classification Policy
- IS-AIR01-CIRQ01-A00: Access Control Policy
- IS-AFR01-CIRQ01-A00: Information Transfer Policy
- IS-AMG01-CIRQ01-A00: Information Security Incident Management Policy
- IS-AIR01-CIRQ09-A00: Logging and Monitoring Procedure
- IS-AFR01-CIRQ02-A00: Clear Desk and Clear Screen Policy
- IS-AHR01-CIRQ02-A00: Acceptable Use Policy
- IS-AMG01-CIRQ02-A00: Incident Response Procedure (Global Core)
- BYOD Policy (if applicable - external document)

8. Policy Review

This policy will be reviewed at least annually, or sooner if there are significant changes to Cirque's remote work practices, IT infrastructure, or the security threat landscape.

IS-LIR-CIRQ02-A00: Artificial Intelligence Acceptable Use Policy

IS-LIR-CIRQ02-A00: Artificial Intelligence Acceptable Use Policy

Document: IS-LIR-CIRQ02-A00

Standards Name: Artificial Intelligence Acceptable Use Policy

Category: Operations Security

Division: Policy

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 **Effective Date:** 2026-03-02 **Review Date:** 2027-03-02 **Approved By:** IT/Security Lead

1. Purpose

SOC 2 Trust Services Criteria Mapping

This document supports the AICPA Trust Services Criteria for SOC 2:2017, Security and Confidentiality categories, as follows:

Criterion

Coverage

CC1.4

Personnel competence and acceptable behavior with AI tools

CC2.2

Internal communication of AI use restrictions

CC6.1

Logical access to AI tools

CC6.7

Restrictions on data transmission to external AI services

C1.2

Protection of confidential information from disclosure to public AI services

The purpose of this policy is to define acceptable, secure, and compliant use of Artificial Intelligence (AI) tools and services at Cirque. This policy establishes controls to reduce confidentiality, privacy, intellectual property, legal, and operational risks while enabling approved business use of AI.

2. Scope

This policy applies to all Cirque workforce members, including employees and contractors, who access or use AI tools for any business purpose. This includes use on company-issued and personal devices when handling Cirque business activities.

3. Definitions

- **AI Tool:** Any software, platform, model, assistant, or feature that generates, transforms, summarizes, classifies, or recommends content using machine learning or generative AI.
- **Public AI Tool:** An AI service not contractually approved by Cirque for confidential or restricted data processing.
- **Approved AI Tool:** An AI service reviewed and explicitly approved by IT/Security for defined use cases.
- **Prompt/Output Data:** Inputs provided to an AI tool and the generated responses/results.

4. Policy Statements

- Cirque operates an **approved tools list only** model for AI use. AI tools not on the approved list are prohibited for business use.
- **Confidential or Restricted data must not be entered into public AI tools.**
- New AI use cases require **Manager approval and IT/Security approval** before production or routine business use.
- Users remain accountable for all AI-assisted work products and must perform human review before business use.

5. Acceptable Use Requirements

5.1. Approved Tooling and Access a. Only AI tools approved by IT/Security may be used for business activities. b. Access provisioning and removal for approved AI tools must follow standard access control requirements. c. Shared, anonymous, or non-attributable AI accounts are not permitted.

5.2. Data Handling and Classification a. Users must classify data before using any AI tool. b. Confidential or Restricted data is prohibited in public AI tools. c. Data uploaded to approved AI tools must be limited to the minimum necessary. d. Regulated data (including personal, legal, financial, or customer-sensitive data) must only be processed per approved legal/privacy conditions.

5.3. Prompt and Output Controls a. Prompts must not include secrets, credentials, security configuration details, or proprietary algorithms unless explicitly approved in a controlled environment. b. AI outputs must be validated for accuracy, bias, legality, and policy compliance prior to use. c. AI-generated content used externally must follow communication and brand approval processes.

5.4. Human Oversight and Accountability a. AI-generated output shall not be treated as authoritative without review. b. Business owners are responsible for decisions made using AI-assisted outputs. c. Final approval authority remains with human approvers, not AI tools.

5.5. Prohibited Uses a. Entering confidential/restricted data into public AI tools. b. Using unapproved AI tools for Cirque business. c. Using AI to create deceptive, abusive, discriminatory, or unlawful content. d. Using AI to bypass security controls or acceptable use requirements. e. Uploading third-party confidential information without authorized legal basis.

6. Approval Workflow for New AI Use Cases

Submit use case request with purpose, tool, and data classification.

Manager reviews business need and expected impact.

IT/Security reviews security, privacy, access, and logging controls.

Use case is approved, conditionally approved, or rejected.

7. Monitoring, Logging, and Review

Cirque may monitor and audit AI tool access and usage records to verify compliance with this policy, investigate incidents, and satisfy audit requirements. Approved AI tools should support logging sufficient for security and compliance oversight.

8. Non-Compliance

Violations of this policy may result in access removal, disciplinary action up to and including termination of employment/contract, and legal action where applicable.

9. Roles and Responsibilities

- **Managers:** Approve business justification for new AI use cases and ensure teams follow approved usage boundaries.
- **IT/Security Lead:** Maintains approved AI tool list, performs risk/security review, and monitors compliance.
- **Legal/Privacy (as applicable):** Reviews regulated or sensitive use cases and data processing obligations.
- **All Workforce Members:** Follow this policy, complete required training, and report policy violations or AI security concerns.

10. Related Documents

IS-AHR01-CIRQ02-A00: Acceptable Use Policy

IS-AIR01-CIRQ01-A00: Access Control Policy

IS-AAR02-CIRQ01-A00: Privacy Policy (Global Core)

IS-LMR-CIRQ01-A00: Risk Management Policy

IS-AIR01-CIRQ09-A00: Logging and Monitoring Procedure

SOC 2-Data-Classification-Policy.md

11. Policy Review

This policy will be reviewed at least annually, or sooner if there are significant changes to AI usage, regulatory requirements, threat landscape, or business operations.

Part XV — Privacy (Reference Only — Out of SOC 2 Scope)

IS-AAR02-CIRQ01-A00: Privacy Policy (Global Core)

IS-AAR02-CIRQ01-A00: Privacy Policy (Global Core)

Document: IS-AAR02-CIRQ01-A00

Standards Name: Privacy Policy (Global Core)

Category: Information Management Regulations

Division: Policy

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** Executive Committee

1. Purpose

Privacy (P-series TSC) is OUT OF SCOPE for the current SOC 2 Type 1 audit (scope: Security and Confidentiality only). The privacy controls described in this policy still support the Confidentiality criteria where personally identifiable information is also Confidential information:

Criterion

Coverage

C1.1

Identification of confidential PII

C1.2

Disposal / deletion of confidential PII

The purpose of this policy is to establish Cirque's commitment to protecting the privacy of personal information collected, processed, and stored across its global operations. It sets forth the foundational principles and requirements for handling personal information responsibly, ethically, and in compliance with applicable global privacy laws and regulations. This policy aims to build trust with individuals whose data we handle and mitigate risks associated with privacy breaches.

2. Scope

This policy applies to all Cirque personnel (employees, contractors, temporary staff), all business processes, systems, applications, and networks involved in the collection, use, storage, transmission, and disposal of personal information, regardless of format, across all global locations (US, Taipei, China). It covers all types of personal information, including but not limited to employee data, customer data, and vendor data.

3. Definitions

- **Personal Information (PI) / Personally Identifiable Information (PII):** Any information that can be used to identify an individual, either directly or indirectly, in combination with other information. This includes, but is not limited to, names, addresses, email addresses, phone numbers, employee IDs, government-issued identification numbers, and biometric data.
- **Processing:** Any operation performed on personal information, whether automated or not, such as collection, recording, organization, structuring, storage, adaptation, alteration, retrieval, consultation, use, disclosure by transmission, dissemination, or otherwise making available, alignment, combination, restriction, erasure, or destruction.
- **Data Subject:** The identified or identifiable natural person to whom personal information relates.
- **Consent:** Any freely given, specific, informed, and unambiguous indication of the data subject's wishes by which he or she, by a statement or by a clear affirmative action, signifies agreement to the processing of personal information relating to him or her.

4. Principles of Personal Information Processing

Cirque adheres to the following globally recognized privacy principles when processing personal information:

- **Lawfulness, Fairness, and Transparency:** Personal information shall be processed lawfully, fairly, and in a transparent manner in relation to the data subject.
- **Purpose Limitation:** Personal information shall be collected for specified, explicit, and legitimate purposes and not further processed in a manner that is incompatible with those purposes.

- **Data Minimization:** Personal information shall be adequate, relevant, and limited to what is necessary in relation to the purposes for which they are processed.
- **Accuracy:** Personal information shall be accurate and, where necessary, kept up to date; every reasonable step shall be taken to ensure that personal information that are inaccurate, having regard to the purposes for which they are processed, are erased or rectified without delay.
- **Storage Limitation:** Personal information shall be kept in a form which permits identification of data subjects for no longer than is necessary for the purposes for which the personal information are processed.
- **Integrity and Confidentiality:** Personal information shall be processed in a manner that ensures appropriate security of the personal information, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures.
- **Accountability:** Cirque shall be responsible for, and be able to demonstrate compliance with, these principles.

5. Personal Information Handling Requirements

5.1. Collection of Personal Information: a. Personal information shall only be collected when there is a clear, legitimate business purpose and legal basis for doing so (e.g., consent, contract, legal obligation, legitimate interest). b. Data subjects shall be informed about the purposes of processing their personal information, the types of data collected, and their rights, typically through a privacy notice. c. Collection methods shall be fair and non-intrusive.

5.2. Use of Personal Information: a. Personal information shall only be used for the purposes for which it was collected, or for compatible purposes as explicitly disclosed to the data subject. b. Any new use of personal information beyond the original purpose requires re-evaluation of the legal basis and, if necessary, obtaining new consent.

5.3. Disclosure and Sharing of Personal Information: a. Personal information shall not be disclosed, shared, or sold to third parties without a legitimate business purpose and a valid legal basis. b. Where personal information is shared with third parties (e.g., vendors, partners), Cirque shall ensure that appropriate data protection agreements are in place to safeguard the information, requiring third parties to adhere to similar privacy standards. c. Cross-border transfers of personal information shall comply with applicable international data transfer laws and regulations, ensuring adequate levels of protection.

5.4. Storage and Retention of Personal Information: a. Personal information shall be stored securely using appropriate technical and organizational measures to prevent unauthorized access, loss, or destruction. b. Retention periods for personal information shall be established based on legal, regulatory, contractual, and business requirements. Personal information shall be securely disposed of when no longer needed.

5.5. Data Subject Rights: a. Cirque shall establish processes to facilitate data subjects' exercise of their rights concerning their personal information, which may include: * Right to access their data. * Right to rectification of inaccurate data. * Right to erasure ("right to be forgotten"). * Right to restriction of processing. * Right to data portability. * Right to object to processing. * Rights related to automated decision-making. b. Requests from data subjects shall be handled in a timely and compliant manner.

5.6. Security of Personal Information: a. Robust information security controls shall be implemented to protect personal information from unauthorized access, alteration, disclosure, or destruction. This includes technical measures (e.g., encryption, access controls, network security) and organizational measures (e.g., training, policies, incident response). (Refer to IS-APM01-CIRQ01-A00: Information Security Policy and related procedures). b. In the event of a personal data breach, Cirque shall follow its IS-AMG01-CIRQ01-A00: Information Security Incident Management Policy and relevant localized procedures, including timely notification to affected individuals and regulatory authorities where required.

5.7. Privacy by Design and by Default: a. Privacy considerations shall be integrated into the design and operation of all new systems, processes, and products that involve the processing of personal information. b. Default settings for new systems and services should prioritize privacy.

5.8. Data Protection Impact Assessments (DPIA) / Privacy Impact Assessments (PIA): a. Where personal information processing is likely to result in a high risk to the rights and freedoms of data subjects, a DPIA/PIA shall be conducted prior to the processing.

6. Training and Awareness

All personnel involved in the handling of personal information shall receive appropriate training on data privacy principles, this policy, and relevant procedures.

7. Compliance and Monitoring

- a. `Cirque` shall regularly monitor its compliance with this policy and applicable privacy laws and regulations.
- b. Internal audits and external assessments may be conducted to ensure ongoing adherence.

8. Responsibilities

- **Executive Committee:** Overall responsibility for establishing and upholding Cirque's commitment to data privacy.
- **Legal Counsel:** Provides expert advice on privacy laws and regulations, reviews privacy notices and data processing agreements.
- **IT Manager:** Responsible for implementing technical and organizational measures to protect personal information and for managing privacy-related aspects of IT systems.
- **Human Resources:** Manages privacy relating to employee data.
- **Marketing/Sales:** Responsible for privacy considerations in customer data collection and communication.
- **All Personnel:** Responsible for understanding and adhering to this policy and all related privacy procedures.

9. Related Documents

- IS-APM01-CIRQ01-A00: Information Security Policy
- IS-AMG01-CIRQ01-A00: Information Security Incident Management Policy
- IS-AMG01-CIRQ02-A00: Incident Response Procedure (Global Core)
- IS-AMR01-CIRQ01-A00: Compliance Policy
- IS-AAR02-CIRQ02-A00: Privacy Policy (US Localized) (Next document)
- IS-AAR06-CIRQ01-A00: Privacy Policy (Asia Localized) (Future document)
- Data Subject Request Procedure (managed by Legal/Privacy and recorded in the privacy request log)

10. Policy Review

This policy will be reviewed at least annually, or sooner if there are significant changes to Cirque's operations, applicable privacy laws and regulations, or best practices in data privacy.

IS-AAR02-CIRQ02-A00: Privacy Policy (US Localized)

IS-AAR02-CIRQ02-A00: Privacy Policy (US Localized)

Document: IS-AAR02-CIRQ02-A00

Standards Name: Privacy Policy (US Localized)

Category: Information Management Regulations

Division: Policy

Standard Retention: Exist and No Corrections

Standard Type: Localized (US)

1. Purpose

Privacy (P-series TSC) is OUT OF SCOPE for the current SOC 2 Type 1 audit (scope: Security and Confidentiality only). The privacy controls described in this policy still support the Confidentiality criteria where personally identifiable information is also Confidential information:

Criterion

Coverage

C1.1

Identification of confidential PII

C1.2

Disposal / deletion of confidential PII

The purpose of this policy is to define Cirque's specific requirements for protecting the privacy of personal information collected, processed, and stored within its operations in the United States. This policy supplements the IS-AAR02-CIRQ01-A00: Privacy Policy (Global Core) by addressing US federal and state-specific privacy laws and regulations, ensuring compliance and enhancing trust with individuals whose data we handle in the US.

2. Scope

This policy applies to all Cirque personnel, business processes, systems, applications, and networks located within or primarily serving the United States, that are involved in the collection, use, storage, transmission, and disposal of personal information related to US residents. It covers all types of personal information, including but not limited to employee data, customer data, and vendor data within the US jurisdiction.

3. Definitions (US-Specific)

- **Consumer:** For the purposes of this policy, often refers to a natural person who is a California resident, as defined by the California Consumer Privacy Act (CCPA) and California Privacy Rights Act (CPRA), or a resident of other states with similar privacy laws.
- **Personal Information (PI) / Personally Identifiable Information (PII):** As defined in the Global Core Policy, with specific attention to categories of personal information outlined by US state privacy laws (e.g., California, Virginia, Colorado).
- **Sale (of Personal Information):** The sharing of personal information for monetary or other valuable consideration, as defined by applicable US state laws (e.g., CCPA/CPRA).

4. US-Specific Privacy Principles and Requirements

In addition to the global principles outlined in IS-AAR02-CIRQ01-A00: Privacy Policy (Global Core), Cirque adheres to the following US-specific requirements:

4.1. Compliance with US Federal Laws: a. **HIPAA (Health Insurance Portability and Accountability Act):** If Cirque processes Protected Health Information (PHI) as a covered entity or business associate, strict adherence to HIPAA Privacy, Security, and Breach Notification Rules is required. b. **FERPA (Family Educational Rights and Privacy Act):** If Cirque handles educational records, compliance with FERPA rules concerning student privacy is mandatory. c. **COPPA (Children's Online Privacy Protection Act):** If online services target or collect information

from children under 13, compliance with COPPA is required, including parental consent mechanisms. d. **Gramm-Leach-Bliley Act (GLBA)**: If Cirque processes non-public personal information of customers in the financial services sector, compliance with GLBA safeguards and privacy rules is required. e. **CAN-SPAM Act**: Compliance with regulations for commercial email, including opt-out mechanisms and accurate sender information.

4.2. Compliance with US State Privacy Laws (Key Examples): a. **California Consumer Privacy Act (CCPA) & California Privacy Rights Act (CPRA)**: * **Consumer Rights**: Establish procedures to fulfill consumer rights, including the right to know, right to delete, right to opt-out of the sale/sharing of personal information, and the right to correct. * **Notice at Collection**: Provide clear notice to consumers about the categories of personal information collected and the purposes for which it will be used. * **Opt-out of Sale/Sharing**: Implement mechanisms for consumers to exercise their right to opt-out, including a clear "Do Not Sell or Share My Personal Information" link on relevant online interfaces. * **Service Provider Contracts**: Ensure contracts with service providers meet CCPA/CPRA requirements. * **Data Minimization & Storage Limitation**: Emphasize principles of data minimization and purpose limitation in line with California requirements. b. **Virginia Consumer Data Protection Act (VCDPA), Colorado Privacy Act (CPA), and other emerging state privacy laws**: * Where applicable based on thresholds and operations, Cirque will implement processes to address similar consumer rights (access, deletion, correction, opt-out of sale/targeted advertising) and duties of controllers (e.g., data protection assessments, purpose limitation).

4.3. Employee Data Privacy (US-Specific): a. Personal information related to US employees shall be handled in accordance with federal laws (e.g., EEOC regulations, ADA, FCRA if background checks are involved) and applicable state employment and privacy laws. b. Specific privacy notices may be provided to employees regarding the collection and use of their data.

4.4. Privacy Notices and Transparency: a. Provide clear, concise, and accessible privacy notices to individuals (e.g., website privacy policy, employee privacy notice) detailing: * Categories of personal information collected. * Purposes of collection and processing. * Categories of sources from which personal information is collected. * Categories of third parties with whom personal information is shared. * Instructions on how data subjects can exercise their rights. b. Keep privacy notices up-to-date with changes in data practices or applicable laws.

4.5. Data Breach Notification: a. In the event of a personal data breach involving US residents, Cirque shall comply with all applicable US federal and state data breach notification laws. This includes timely notification to affected individuals, and potentially state Attorneys General or other regulatory bodies, as required by law. (Refer to IS-AMG01-CIRQ03-A00: Incident Response Procedure (US Localized)).

5. Responsibilities (US-Specific)

- **US General Manager**: Oversees compliance with US privacy laws and acts as a key point of contact for US privacy matters.
- **US Legal Counsel (or designated external counsel)**: Provides specific legal interpretation and guidance on US federal and state privacy laws, reviews privacy notices, and advises on data subject requests and breach notifications.
- **US IT Lead**: Responsible for implementing and maintaining technical controls to protect personal information within US systems.
- **Human Resources (US)**: Ensures compliance with employee privacy regulations specific to the US.

6. Training and Awareness

All US personnel involved in handling personal information shall receive training specifically covering US federal and state privacy laws relevant to their roles, in addition to global privacy principles.

7. Compliance and Monitoring

- a. `Cirque` will periodically assess its privacy practices against US federal and state legal requirements.
- b. Internal audits and privacy impact assessments (PIAs) may include US-specific legal compliance checks.

8. Related Documents

- IS-AAR02-CIRQ01-A00: Privacy Policy (Global Core)

- IS-AMR01-CIRQ01-A00: Compliance Policy
- IS-AMG01-CIRQ03-A00: Incident Response Procedure (US Localized)
- IS-APM01-CIRQ01-A00: Information Security Policy
- Applicable US Federal Laws (e.g., HIPAA, COPPA, GLBA - external reference)
- Applicable US State Laws (e.g., CCPA/CPRA, VCDPA, CPA - external reference)
- Website Privacy Policy / Employee Privacy Notice (external facing/internal HR document)

9. Policy Review

This policy will be reviewed at least annually, or sooner if there are significant changes to Cirque's US operations, new US federal or state privacy laws, or legal interpretations affecting US data privacy practices.

IS-AAR06-CIRQ01-A00: Privacy Policy (Asia Localized)

IS-AAR06-CIRQ01-A00: Privacy Policy (Asia Localized)

Document: IS-AAR06-CIRQ01-A00

Standards Name: Privacy Policy (Asia Localized)

Category: Information Management Regulations

Division: Policy

Standard Retention: Exist and No Corrections

Standard Type: Localized (Asia - China, Taiwan)

Version: 1.0 **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** Executive Committee, Regional Asia General Manager

1. Purpose

Privacy (P-series TSC) is OUT OF SCOPE for the current SOC 2 Type 1 audit (scope: Security and Confidentiality only). The privacy controls described in this policy still support the Confidentiality criteria where personally identifiable information is also Confidential information:

Criterion

Coverage

C1.1

Identification of confidential PII

C1.2

Disposal / deletion of confidential PII

The purpose of this policy is to define Cirque's specific requirements for protecting the privacy of personal information collected, processed, and stored within its operations in the Asia region, particularly focusing on **China** and **Taiwan**. This policy supplements the IS-AAR02-CIRQ01-A00: Privacy Policy (Global Core) by addressing region-specific privacy laws and regulations, ensuring compliance and fostering trust with individuals whose data we handle in these jurisdictions.

2. Scope

This policy applies to all Cirque personnel, business processes, systems, applications, and networks located within or primarily serving China and Taiwan, that are involved in the collection, use, storage, transmission, and disposal of personal information related to residents of these regions. It covers all types of personal information, including employee data, customer data, and vendor data within these jurisdictions.

3. Definitions (Asia-Specific)

- **Personal Information (PI):** As defined in the Global Core Policy, but specifically acknowledging the broader definitions and sensitive categories defined under China's Personal Information Protection Law (PIPL) and Taiwan's Personal Data Protection Act (PDPA).
- **Sensitive Personal Information (China PIPL):** Personal information that, once leaked or illegally used, may easily lead to infringement of the personal dignity of natural persons or serious harm to personal or property safety (e.g., biometric data, religious beliefs, medical health, financial accounts, whereabouts, etc.). Strict rules apply to its processing.
- **Data Controller (Taiwan PDPA):** A government agency, public school, or association, or a juridical person or natural person that collects, processes or uses personal data.
- **Cross-Border Transfer:** Transfer of personal information outside the territory where it was collected (e.g., from China to the US).

4. Asia-Specific Privacy Principles and Requirements

In addition to the global principles outlined in IS-AAR02-CIRQ01-A00: Privacy Policy (Global Core), Cirque adheres to the following Asia-specific requirements:

4.1. Compliance with China's Laws (Key focus: PIPL, CSL, DSL): a. **Personal Information Protection Law (PIPL):** * **Legal Basis:** Ensure clear legal basis (e.g., consent, contract, legal obligation) for processing personal information, with explicit and separate consent required for sensitive personal information, public disclosure, or cross-border transfers. * **Purpose & Necessity:** Strict adherence to purpose limitation and data minimization; processing must be for a clear and reasonable purpose directly related to the business. * **Data Subject Rights:** Implement mechanisms to facilitate data subjects' rights, including access, correction, deletion, withdrawal of consent, and the right to object to automated decision-making. * **Impact Assessments:** Conduct Personal Information Protection Impact Assessments (PIPIAs) for high-risk processing activities, including processing sensitive personal information, using personal information for automated decision-making, or large-scale processing. * **Cross-Border Data Transfer:** Crucial requirements must be met for transferring personal information out of China, including: * Passing a security assessment organized by the Cyberspace Administration of China (CAC). * Obtaining a personal information protection certification. * Entering into a standard contract with the overseas recipient. * Obtain separate consent from the individual. * **Data Localization (Implicit):** While not a direct localization law, for critical information infrastructure operators (CIIOs), PIPL and CSL require personal information and important data collected and generated within China to be stored within China. * **Data Classification & Localization (Data Security Law - DSL):** Recognize and comply with China's data classification system (ranging from ordinary to core data) and potential localization requirements for "important data" and "core data." b. **Cybersecurity Law (CSL):** * Applies to network operators and critical information infrastructure operators (CIIOs). Requires data localization for personal information and important data collected and generated by CIIOs in China. * Mandatory security reviews for network products and services, and adherence to multi-level protection scheme (MLPS) requirements. c. **Data Security Law (DSL):** * Establishes a national data classification and protection system. * Requires security assessments for cross-border data transfers of "important data."

4.2. Compliance with Taiwan's Laws (Key focus: Personal Data Protection Act - PDPA): a. **Personal Data Protection Act (PDPA):** * **Legal Basis:** Collection and processing of personal data generally require specific consent from the data subject, or other legal basis (e.g., contract, legal obligation). Special requirements apply to "sensitive personal data" (e.g., medical, genetic, sexual life, criminal records). * **Purpose & Notification:** Data must be collected for a specific purpose, and individuals must be informed of the purpose, categories of data, and their rights. * **Data Subject Rights:** Individuals have rights including inquiry, review, duplication, supplementation/correction, deletion, and cessation of collection/processing/use. * **Security Measures:** Implement appropriate security measures to prevent theft, alteration, damage, destruction, or unauthorized disclosure of

personal data. * **Cross-Border Transfer:** Generally permissible with appropriate safeguards (e.g., ensuring adequate protection in the recipient country, obtaining consent, or having a contractual basis). Transfers to countries prohibited by the central competent authority are not allowed.

4.3. Privacy Notices and Transparency: a. Provide distinct, clear, and comprehensive privacy notices to individuals in China and Taiwan, tailored to the specific requirements of PIPL/CSL/DSL and PDPA respectively. This includes detailed information on: * Identity and contact information of the personal information handler/data controller. * Types of personal information collected. * Purposes and methods of processing. * Retention periods. * Means and procedures for exercising data subject rights. * Specific disclosures for cross-border transfers.

4.4. Data Breach Notification: a. In the event of a personal data breach affecting residents in China or Taiwan, Cirque shall comply with all applicable local data breach notification laws. This includes timely notification to affected individuals and relevant regulatory authorities (e.g., Cyberspace Administration of China, Ministry of Justice in Taiwan). (Refer to IS-AMG01-CIRQ04-A00: Incident Response Procedure (Asia Localized)).

5. Responsibilities (Asia-Specific)

- **Regional Asia General Manager:** Oversees compliance with Asia privacy laws and acts as a key point of contact for regional privacy matters.
- **Regional Legal Counsel (or designated external counsel for China/Taiwan):** Provides specific legal interpretation and guidance on China and Taiwan privacy laws, reviews privacy notices, and advises on data subject requests and breach notifications. Critical for navigating China's complex regulatory landscape.
- **Local IT Lead (China/Taiwan):** Responsible for implementing and maintaining technical controls to protect personal information within their respective regional systems, particularly concerning data localization and cross-border transfer requirements.
- **Human Resources (Asia):** Ensures compliance with employee privacy regulations specific to China and Taiwan.

6. Training and Awareness

All personnel in China and Taiwan involved in handling personal information shall receive training specifically covering the detailed requirements of China's PIPL/CSL/DSL and Taiwan's PDPA, in addition to global privacy principles.

7. Compliance and Monitoring

- a. `Cirque` will periodically assess its privacy practices against China and Taiwan legal requirements, including conducting regular PIPIAs/PIAs as necessary.
- b. Internal audits and external assessments may be conducted to ensure ongoing adherence, with a strong focus on China's audit and compliance mechanisms.

8. Related Documents

- IS-AAR02-CIRQ01-A00: Privacy Policy (Global Core)
- IS-AMR01-CIRQ01-A00: Compliance Policy
- IS-AMG01-CIRQ04-A00: Incident Response Procedure (Asia Localized)
- IS-APM01-CIRQ01-A00: Information Security Policy
- China Personal Information Protection Law (PIPL) (external reference)
- China Cybersecurity Law (CSL) (external reference)
- China Data Security Law (DSL) (external reference)
- Taiwan Personal Data Protection Act (PDPA) (external reference)

- Website Privacy Policy / Employee Privacy Notice (external facing/internal HR document, tailored for China/Taiwan)

9. Policy Review

This policy will be reviewed at least annually, or sooner if there are significant changes to Cirque's Asia operations, new privacy laws/regulations in China or Taiwan, or legal interpretations affecting data privacy practices in these regions.